Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет информационных технологий и компьютерной безопасности

Кафедра систем информационной безопасности

Направление подготовки (специальность) 10.05.03 «Информационная безопасность автоматизированных систем»

(код и наименование направления подготовки)

Профиль/программа/направленность Обеспечение информационной безопасности распределенных информационных систем

ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА

Дипломная работа

(вид выпускной квалификационной работы – бакалаврская работа, дипломная работа (проект), магистерская диссертация)

Козина Ксения Владимировна

(фамилия, имя, отчество обучающегося)

Тема: Сценарии реализации и меры противодействия атакам на средства машинного обучения: информационное и методическое обеспечение

Состав выпускной квалификационной работы:

Расчетно-пояснительная записка на 198 страницах

Графическая часть на _____ листах

Расчетно-пояснительная записка к выпускной квалификационной работе:

Заведующий кафедрой _____ (А.Г. Остапенко)

(подпись) (инициалы, фамилия)

Руководитель _____ (А.С. Пахомова)

(подпись) (инициалы, фамилия)

Консультанты:

по _____ ( )

(наименование раздела, подпись) (инициалы, фамилия)

по _____ ( )

(наименование раздела, подпись) (инициалы, фамилия)

по _____ ( )

(наименование раздела, подпись) (инициалы, фамилия)

по _____ ( )

(наименование раздела, подпись) (инициалы, фамилия)

по _____ ( )

(наименование раздела, подпись) (инициалы, фамилия)

Обучающийся _____ К.В. Козина

(подпись) (инициалы, фамилия)

«02.» 07 2025 г.

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет информационных технологий и компьютерной безопасности

Кафедра систем информационной безопасности

Направление подготовки/специальность 10.05.03 «Информационная безопасность автоматизированных систем»
(код, наименование)

Профиль/программа/направленность Обеспечение информационной безопасности распределенных информационных систем

Утверждаю _____
(дата)

Зав.кафедрой _____
(подпись)

ЗАДАНИЕ

ПО ПОДГОТОВКЕ ВЫПУСКНОЙ КВАЛИФИКАЦИОННОЙ РАБОТЫ

дипломная работа
дипломная работа (проект), бакалаврская работа, магистерская диссертация

Обучающемуся Козиной Ксении Владимировне
фамилия, имя, отчество

1. Тема: Сценарии реализации и меры противодействия атакам на средства машинного обучения: информационное и методическое обеспечение

ФГБОУ ВО «ВГТУ», ВГТУ
по заданию какой организации выполняется работа

приказ № 01-1-10/3-2979 от 25.06.2025
утверждена приказом по университету

2. Срок сдачи обучающимся выпускной квалификационной работы 02.07.25

3. Исходные данные

4. Краткое содержание выпускной квалификационной работы

Глава 1. Архитектурные особенности средств машинного обучения и классификация атак на них
перечень подлежащих разработке в выпускной квалификационной работе вопросов

Глава 2. Методическое обеспечение для формирования сценариев атак на средства машинного обучения и риск-анализ процессов их реализации

Глава 3. Организационно-правовое обеспечение противодействия атакам на средства машинного обучения

5. Перечень графического материала (с точным указанием обязательных чертежей по разделам

6. Консультанты (с указанием относящихся к ним разделов)

График выполнения выпускной квалификационной работы

№ п/п	Наименование разделов выпускной квалификационной работы	Срок выполнения этапов работы
1	Введение	22.03.25 – 22.05.25
2	Архитектурные особенности средств машинного обучения и классификация атак на них	22.03.25 – 22.05.25
3	Методическое обеспечение для формирования сценариев атак на средства машинного обучения и риск-анализ процессов их реализации	23.05.25 – 31.05.25
4	Организационно-правовое обеспечение противодействия атакам на средства машинного обучения	1.06.25 – 24.06.25
5	Заключение	25.06.25 – 02.07.25

Руководитель _____
(подпись)

Дата выдачи задания 22.03.25

Задание принял к исполнению 22.03.25
(дата)

Подпись обучающегося _____

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение
высшего образования
«Воронежский государственный технический университет»

АННОТАЦИЯ
выпускной квалификационной работы

Обучающегося Козиной Ксении Владимировны

Тема ВКР: Сценарии реализации и меры противодействия атакам на средства машинного обучения: информационное и методическое обеспечение

Характеристика выпускной квалификационной работы

Актуальность исследования

Исследование решает проблему необходимости анализа архитектурных особенностей средств машинного обучения и построения классификации атак на средства машинного обучения, разработки методики формирования сценариев атак на средства машинного обучения и проведения специализированного риск-анализа процессов их реализации, а также формирования организационно-правового обеспечения противодействия атакам на средства машинного обучения, в условиях активного внедрения решений, связанных с машинным обучением, в государственный и коммерческий сектор Российской Федерации.

Задачи, решаемые в ВКР

– проведение системного анализа существующих атак на средства машинного обучения, с последующей разработкой их детальной классификации;

– создание методики оценки рисков для информационных автоматизированных систем, включающих в себя средства машинного обучения;

– разработка методических рекомендаций по выявлению, анализу и устранению уязвимостей в системах машинного обучения, включая методику управления уязвимостями средств машинного обучения.

Структура ВКР

Введение – 7 страниц;

Раздел 1. Архитектурные особенности средств машинного обучения и классификация атак на них – 78 страниц;

Раздел 2. Методическое обеспечение для формирования сценариев атак на средства машинного обучения и риск-анализ процессов их реализации – 44 страницы;

Раздел 3. Организационно-правовое обеспечение противодействия атакам на средства машинного обучения – 34 страницы;

Заключение – 2 страницы;

Список литературы – 9 страниц;

Приложение А – 11 страниц.

Краткая характеристика полученных результатов

Выполнено исследование средств машинного обучения, включая рассмотрение этапов жизненного цикла и типовых архитектур средств машинного обучения, а также проведен анализ отечественных и зарубежных ресурсов, описывающих атаки на средства машинного обучения;

Разработано методическое обеспечение для формирования сценариев атак на средства машинного обучения и риск-анализа процессов их реализации;

Сформировано организационно-правовое обеспечение противодействия атакам на средства машинного обучения, включая разработку мер реагирования и ликвидации последствий для наиболее критичных сценариев атак на средства машинного обучения, а также предложено методическое обеспечение для управления уязвимостями информационных автоматизированных систем, включающих в себя средства машинного обучения.

Автор ВКР_____Козина Ксения Владимировна
(подпись)

СОДЕРЖАНИЕ

Введение 8
1 Архитектурные особенности средств машинного обучения и классификация атак на них 15
1.1 Исследование средств машинного обучения: этапы жизненного цикла и типовые архитектуры 15
1.1.1 Функциональная модель жизненного цикла средств машинного обучения 15
1.1.2 Монолитная архитектура средств машинного обучения 29
1.1.3 Микросервисная архитектура средств машинного обучения 34
1.1.4 «Pipeline» архитектура средств машинного обучения 39
1.1.5 Анализ и сравнительная характеристика архитектурных решений средств машинного обучения 44
1.2 Обзор отечественных и зарубежных ресурсов, описывающих атаки на средства машинного обучения 54
1.2.1 Анализ нормативно-правовой базы Российской Федерации в области обеспечения информационной безопасности средств машинного обучения 54
1.2.2 Обзор отечественных и зарубежных ресурсов, рассматривающих атаки на средства машинного обучения 69
1.3 Классификация атак на средства машинного обучения 82
2 Методическое обеспечение для формирования сценариев атак на средства машинного обучения и риск-анализ процессов их реализации 94
2.1 Построение множества сценариев атак на средства машинного обучения 94
2.2 Оценка риска реализации наиболее критичных сценариев атак по каждой выделенной группе сценариев 101
3 Организационно-правовое обеспечение противодействия атакам на средства машинного обучения 139
3.1 Меры реагирования и ликвидация последствий для наиболее критичных сценариев атак на средства машинного обучения 139

3.2 Методическое обеспечение для управления уязвимостями информационных автоматизированных систем (ИАС), включающих в себя средства машинного обучения 149
3.2.1 Модель процесса управления уязвимостями средств машинного обучения 149
3.2.2 Мониторинг уязвимостей и оценка их применимости в информационных автоматизированных системах (ИАС), включающих в себя средства машинного обучения 153
3.2.3 Оценка уязвимостей средств машинного обучения 156
3.2.4 Методика определения приоритетов устранения уязвимостей средств машинного обучения 159
3.2.5 Устранение уязвимостей средств машинного обучения 161
3.2.6 Проектирование и внедрение компенсирующих мер защиты для моделей машинного обучения 165
3.2.7 Контроль устранения уязвимостей средств машинного обучения 169
Заключение 174
Список литературы 177
Приложение А 187

ВВЕДЕНИЕ

Современное информационное пространство в условиях кибервойны отличается стремительным появлением новых угроз [1-9]. В первом квартале 2025 года российское киберпространство столкнулось с беспрецедентными вызовами информационной безопасности (ИБ), обусловленными экспоненциальным ростом внедрения технологий искусственного интеллекта (ИИ). Согласно данным Министерства цифрового развития [10], уровень проникновения ИИ-решений в коммерческом секторе достиг 54,3%, а в государственных учреждениях — 38,7%. При этом динамика роста продолжает ускоряться: если в 2021-2023 годах среднегодовой прирост составлял 7—9 процентных пунктов, то за первый квартал 2025 года показатель увеличился на 3,1 процентных пункта.

Государственный сектор демонстрирует особую активность в области внедрения ИИ-технологий. По данным Росстата [11], 49% федеральных органов исполнительной власти уже используют системы на основе машинного обучения (МО) для обработки документооборота, 28% — для аналитики больших данных, а 23% — для поддержки управленческих решений. В коммерческом секторе лидерами внедрения стали финансовые организации (52% внедрения), телекоммуникационные компании (33%) и ритейл (15%). Особенно показателен пример Сбербанка, где внедрение нейросетевых технологий обработки транзакций позволило сократить операционные расходы на 23% при росте чистой прибыли на 17% в годовом исчислении [12].

Однако бурное развитие ИИ-технологий сопровождается ростом связанных с ними киберугроз. Основной брешью становятся средства машинного обучения (СМО) — ключевого компонента современных ИИ-решений. Алгоритмы МО, работающие с большими данными и принимающие автономные решения, превратились в главную мишень для киберпреступников. Согласно исследованиям Positive Technologies [13-14] и Group-IB [15], в 2024 году количество атак на ИИ-системы увеличилось на 37% по сравнению с предыдущим годом, причем наиболее распространенными были атаки типа «adversarial examples» (27%), «data poisoning»

(23%) и «model inversion» (18%). В первом же квартале 2025 года тенденция роста атак увеличилась на 12% по сравнению с предыдущим кварталом.

При таком активном росте внедрения ИИ и МО, особую озабоченность вызывает отсутствие адекватной нормативно-правовой базы. Анализ показывает следующую картину, что Доктрина информационной безопасности Российской Федерации, утвержденная Указом Президента № 646 от 5 декабря 2016 года [16], не содержит прямых положений, посвященных МО. Хотя в документе упоминаются перспективные информационные технологии, включая ИИ, конкретные механизмы защиты СМО не прописаны.

Частичное регулирование вопросов, связанных с машинным обучением, можно найти в некоторых нормативных актах. Приказ ФСТЭК России № 21 от 14.03.2013 [17] регламентирует требования по защите информации в государственных информационных системах, но не учитывает специфику МО в данном вопросе. Указ Президента РФ № 124 от 15.02.2024 «О развитии искусственного интеллекта в Российской Федерации» [18] содержит общие принципы развития ИИ, однако не затрагивает вопросы обеспечения ИБ МО. Стратегия развития ИИ до 2030 года [19] делает акцент на технологическом развитии, но без детализации мер защиты от эксплуатации уязвимостей МО и ликвидации последствий инцидентов в данных системах.

Также, современные методические подходы к идентификации атак на технологии МО и реагированию на них остаются далекими от совершенства. Система MITRE ATLAS [20], разработанная для структурирования знаний о техниках и тактиках атак на системы МО, имеет существенные ограничения: неполноту охвата современных векторов атак, запаздывание с обновлением базы новых угроз в среднем на 4-6 месяцев, а также отсутствие детализированных рекомендаций по противодействию для конкретных платформ и фреймворков.

Критическим пробелом в современном регулировании является отсутствие единой базы учета уязвимостей МО. Существующие базы уязвимостей, такие как американская база данных NIST NVD (National Vulnerability Database) [21] и отечественная БДУ ФСТЭК [22], демонстрируют серьезные ограничения в контексте

МО. В указанных базах часто отсутствуют CPE (Common Platform Enumeration), представляющий из себя стандартизированный метод для описания и идентификации различных типов приложений, операционных систем и аппаратных устройств, что затрудняет их автоматизированное сопоставление и анализ компонентов систем МО. В БДУ ФСТЭК подобные идентификаторы отсутствуют вовсе, а в NIST NVD в последнее время значительно сократил частоту публикаций обновлений по уязвимостям ИИ-систем на 43%, начиная с 2024 года, в 78% записей уязвимостей отсутствует CPE. Кроме того, применяемая в БДУ ФСТЭК система паспортизации уязвимостей не учитывает специфику МО, например, нет полей для указания типа модели, фреймворка, версии обучающего набора, что делает ее малопригодной для эффективного управления соответствующими рисками.

16 апреля 2025 года произошло событие, оказавшее существенное влияние на международное сообщество в сфере информационной безопасности: власти США приняли решение о прекращении финансирования базы данных «Common Vulnerabilities and Exposures (CVE)». Данная система служит глобальным стандартом идентификации и документирования уязвимостей программного обеспечения и широко используется во всем мире, включая Россию.

По мнению ведущих экспертов в области кибербезопасности [23], приостановка обновлений CVE может спровоцировать активизацию деятельности хакерских сообществ и преступных группировок, поскольку нарушается единый механизм централизованного оповещения и классификации уязвимостей. Большинство современных систем обнаружения и управления угрозами (включая сканеры уязвимостей и системы мониторинга) критически зависят от данных CVE для автоматического обновления сигнатур и правил корреляции.

В российском контексте решение США затрагивает интересы ключевых регуляторов в сфере ИБ — Минцифры и ФСТЭК, которые ориентируются на CVE при формировании требований к безопасности программных и аппаратных средств, а также при разработке технических заданий.

Особую тревогу вызывает потенциальное влияние этого события на безопасность систем, использующих методы МО. Современные модели ИИ всё чаще

становятся целями атак. Без оперативной информации о новых векторах уязвимостей и их характеристиках, защита МО-средств становится крайне затруднительной. Отсутствие централизованной базы может привести к снижению эффективности обнаружения угроз, использующих модифицированные или плохо документированные уязвимости, что открывает новые горизонты для целевых атак на информационные системы. В связи с этим перед Российской Федерацией стоит задача разработки собственной национальной системы каталогизации уязвимостей, аналогичной CVE, с возможностью интеграции в существующие средства автоматизированного анализа безопасности.

Стоит отметить, что анализ современных исследований в области безопасности машинного обучения выявил существенные методологические пробелы, связанные с отсутствием комплексного подхода к защите МО-систем. Существующие исследования теории сетевых войн на данный момент демонстрируют фрагментарный характер, охватывая преимущественно узкие аспекты угроз без учета полного спектра рисков, характерных для ИАС, включающих в себя СМО. При этом современные методы паспортизации уязвимостей [24-38] остаются неприменимыми для формального описания специфических уязвимостей МО-моделей, включая зависимость от качества данных, архитектурные риски и угрозы «transfer learning». Особую проблему представляет отсутствие стандартизированных протоколов реагирования на инциденты [25-59], которые должны включать методики детектирования атак, критерии оценки ущерба и алгоритмы восстановления моделей. Ключевым системным недостатком является отсутствие единой методологической платформы, интегрирующей классификацию атак, систему паспортизации уязвимостей и процедуры реагирования в рамках целостной концепции защиты систем машинного обучения.

На основании всего вышеперечисленного, можно сказать, что в нормативно-правовой базе РФ пока не разработана классификация атак на средства машинного обучения, отсутствуют методы оценки рисков, связанных с компрометацией моделей МО, не стандартизированы меры противодействия и процедуры реагирования на инциденты. В условиях, когда более половины компаний уже используют ИИ, а

количество атак на МО-системы продолжает расти, такое отставание нормативной базы от технологических реалий создает серьезные угрозы информационной безопасности нашей страны.

Также, на фоне активного и повсеместного внедрения технологий искусственного интеллекта и машинного обучения глобальная инфраструктура информационной безопасности сталкивается с явными признаками дестабилизации. Потеря зарубежных ориентиров, таких как поддержка и развитие открытых платформ и баз знаний (включая CVE), сопровождается сокращением финансирования фундаментальных и прикладных исследований в области кибербезопасности. В то же время ключевые международные инициативы и системы, которые ранее служили основой для мониторинга угроз и разработки средств защиты, деградируют. Эти тенденции имеют фатальные последствия: без общедоступных и оперативно обновляемых источников информации об уязвимостях системные меры безопасности теряют свою эффективность. Технологии ИИ становятся особенно уязвимыми, что само по себе открывает новое измерение киберугроз. Атаки на системы машинного обучения, такие как заражение данных, введение инфицированных данных и манипуляции на этапе логического вывода, становятся все более изощренными и их трудно обнаружить, тем более при отсутствии каких-либо стандартов классификации.

В этих условиях потребность в формировании и развитии отечественной экосистемы кибербезопасности, независимой от внешних поставщиков данных и стандартов, становится особенно острой.

Объектом исследования являются информационные автоматизированные системы (ИАС), включающие в себя средства машинного обучения.

Предметом исследования выступает разработка информационно методического обеспечения оценки и регулирования рисков для информационных автоматизированных систем, включающих в себя средства машинного обучения.

Цель исследования заключается в повышении защищенности информационных автоматизированных систем, включающих в себя средства машинного обучения, за счёт оценки и регулирования рисков реализации компьютерных атак.

В основе перечисленных недостатков аналогов, лежат следующие противоречия между:

- возрастающим темпом внедрения СМО в коммерческий и государственный сектор Российской Федерации и отсутствием нормативно правовой базы, осуществляющей классификацию атак на машинное обучение;
- необходимостью системного управления рисками в ИАС, включающих в себя СМО, и отсутствием специализированной методики их оценки;
- потребностью в оперативном реагировании на инциденты в ИАС, включающих в себя СМО, и отсутствием методик и инструментов для своевременного выявления и устранения уязвимостей в системах МО.

Отсюда выделяются следующие задачи, решение которых необходимо для достижения цели:

- провести системный анализ существующих атак на СМО, с последующей разработкой их детальной классификации;
- создать методику оценки рисков для ИАС, включающих в себя СМО;
- разработать методические рекомендации по выявлению, анализу и устранению уязвимостей в системах МО, включая методику управления уязвимостями СМО.

Новизна результатов, полученных в работе, состоит в том, что:

- впервые разработана комплексная классификация атак на средства машинного обучения, учитывающая современные векторы угроз;
- разработана методика оценки рисков для ИАС, включающих в себя СМО;
- впервые предлагается методическое обеспечение для выявления и устранения уязвимостей в системах МО, включая политику управления уязвимостями СМО.

Практическая ценность результатов, полученных в работе, состоит в том, что:

- разработка комплексной классификации атак на средства машинного обучения позволяет структурировать процессы мониторинга и анализа инцидентов в ИАС, обеспечивает методологическую базу для создания специализированных средств защиты МО-компонентов, формирует основу для разработки отраслевых стандартов и нормативных документов;

- создание специализированной методики оценки рисков предоставляет инструментарий для комплексного аудита безопасности ИАС, позволяет автоматизировать процессы идентификации и каталогизации уязвимостей, формирует основу для создания систем поддержки принятия решений по управлению рисками;

- разработка методического обеспечения защиты СМО предоставляет готовые алгоритмы действий при выявлении уязвимостей, сокращает время реагирования на инциденты безопасности, позволяет тиражировать лучшие практики защиты в различных отраслях.

Теоретическая значимость полученных в работе результатов, заключается в том, что:

- разработка комплексной классификации атак на средства машинного обучения систематизирует и расширяет теоретические представления о спектре угроз безопасности для ИАС с компонентами МО, формализует таксономию атак с учетом особенностей архитектуры современных МО-систем, создает концептуальную основу для разработки новых моделей угроз в области ИИ-безопасности;

- создание специализированного инструментария оценки рисков разрабатывает новые методологические подходы к формализации описания уязвимостей СМО, создает теоретическую модель многофакторной оценки рисков для ИАС, расширяет научные представления о механизмах управления рисками в условиях применения МО;

- разработка методического обеспечения защиты МО-систем создает новые принципы построения систем защиты ИАС с МО-компонентами, развивает методологию оперативного реагирования на инциденты, формирует теоретические основы для разработки защитных механизмов нового поколения информационной безопасности.

1 Архитектурные особенности средств машинного обучения и классификация атак на них

1.1 Исследование средств машинного обучения: этапы жизненного цикла и типовые архитектуры

1.1.1 Функциональная модель жизненного цикла средств машинного обучения

Средства машинного обучения — это совокупность теоретических, программных и аппаратных компонентов, реализующих принципы и методы машинного обучения — ключевого раздела искусственного интеллекта, в рамках которого вычислительные системы приобретают способность обучаться, адаптироваться и формулировать логические ответы на основе анализа больших данных без явного задания алгоритма решения конкретной задачи. Основной целью функционирования подобных систем является автоматизация процесса построения, настройки и эксплуатации математических моделей, способных выявлять скрытые зависимости, закономерности и общие связи в многомерных выборках, а также выполнять прогнозирование, классификацию, кластеризацию и принимать решения в условиях фрагментарной или противоречивой информации.

Машинное обучение выступает фундаментом современной парадигмы ИИ, обеспечивая адаптивность и когнитивную гибкость систем, основанных на анализе данных. Однако по мере масштабного внедрения ИИ-решений в критически важные и социально значимые сферы деятельности человечества возрастает не только техническая сложность моделей, но и спектр рисков, связанных с их безопасностью. Особенность МО заключается в тесной зависимости качества функционирования модели от обучающей выборки, что делает её уязвимым звеном, потенциально подверженным внешнему вмешательству. Это создает предпосылки для возникновения новых направлений атак, таких как отравление данных, вмешательство в процесс обучения и атаки на этапы предсказания.

В отличие от классических информационных систем, в которых поведение определено логикой жёстко заданного кода, системы на основе машинного обучения обладают свойством изменчивости и адаптивности, что усложняет их защиту в

контексте информационной безопасности. Злоумышленники могут использовать это свойство для подмены или искажения знаний, заложенных в модель, с последующим нарушением целостности, доступности и конфиденциальности информации. Особенно тревожным моментом является тот факт, что во многих случаях компрометация модели не требует физического доступа к инфраструктуре, достаточно осуществлять манипулирование входными данными или взаимодействовать с моделью через её интерфейс.

На практике это означает, что при внедрении ИИ-систем организации могут учитывать общие киберриски, но не уделять должного внимания слабостям, возникающим именно на уровне механизмов машинного обучения. Подобная недооценка угроз формирует огромную брешь в стратегиях обеспечения информационной безопасности, особенно в условиях активной цифровизации, перехода к автономному принятию решений и растущей зависимости от интеллектуальных подсистем.

Следовательно, учитывая возрастающую зависимость от решений, основанных на машинном обучении, и широту возможных векторов воздействия, существует объективная необходимость в систематизированном исследовании архитектурных, концептуальных и эксплуатационных основ средств машинного обучения. Это позволит не только выявить и классифицировать потенциально уязвимые компоненты, но и разработать подходы к повышению устойчивости моделей к целенаправленным атакам, обеспечивая тем самым более высокий уровень доверия, надёжности и безопасности в условиях современных угроз ИБ. Для полноты раскрытия особенностей функционирования машинного обучения рассмотрим основные концепции и принципы МО, необходимые для определения объектов защиты ИАС, включающих в себя средства МО. Начнем с анализа жизненного цикла модели МО, параллельно исследуя, какие угрозы могут возникать на каждом этапе жизни модели.

Жизненный цикл модели машинного обучения представляет собой последовательность взаимосвязанных этапов, охватывающих весь процесс создания, внедрения, поддержки и вывода из эксплуатации интеллектуальной системы,

способной анализировать поступающую информацию, извлекать закономерности из данных и принимать решения на их основе. Понимание архитектуры жизненного цикла критически важно как для построения корректных и эффективных моделей, так и с точки зрения обеспечения информационной безопасности. Каждый этап характеризуется определёнными задачами, технологиями, используемыми средствами машинного обучения и потенциальными угрозами.

Рассмотрение жизненного цикла модели машинного обучения в контексте атак на средства машинного обучения необходимо по ряду причин, имеющих фундаментальное значение для разработки надёжных и устойчивых к внешним воздействиям ИАС, включающих в себя СМО. В отличие от традиционного программного обеспечения, где вектор атаки часто ограничивается использованием уязвимостей в исходном коде или архитектуре программной среды, модели машинного обучения обладают гораздо более широким и специфичным спектром потенциальных уязвимостей. Эти уязвимости могут возникать не только на этапе эксплуатации модели, но и при ее проектировании, обучении, тестировании, развертывании и последующем обслуживании. Таким образом, эффективная стратегия безопасности должна быть интегрирована на протяжении всего жизненного цикла модели, начиная с этапов сбора и подготовки данных и заканчивая мониторингом поведения модели в реальных условиях эксплуатации.

Ключевая особенность ИАС, содержащих компоненты МО, заключается в их зависимости от данных: от качества, достоверности и репрезентативности обучающей выборки напрямую зависит корректность поведения модели. Данная черта открывает возможность для атак, направленных на подмену, отравление или искажение данных, поступающих на этапе обучения, что может привести к созданию модели с преднамеренно внедрёнными ошибками или уязвимым поведением. Поскольку подобные атаки могут быть невидимыми на стадии тестирования и проявляться только в процессе эксплуатации, необходимо рассматривать и анализировать потенциальные угрозы уже на ранних этапах жизненного цикла, до начала непосредственного обучения модели.

Кроме того, архитектура современных моделей, особенно основанных на глубоком обучении, подразумевает высокую степень сложности и слабую интерпретируемость. Это затрудняет обнаружение и анализ аномального поведения, вызванного как внешними атаками, так и внутренними дефектами разработки. Анализ уязвимостей в привязке к жизненному циклу позволяет выстраивать систематизированный подход к аудиту безопасности, обеспечивая контроль за критически важными точками входа: например, каналами поступления данных, механизмами автоматического обучения, стратегиями обновления модели и логикой развёртывания в облачной или периферийной среде.

Наконец, важно учитывать, что вектор атак на системы машинного обучения носит не только технический, но и социотехнический характер. Атакующий может воздействовать не только на код и данные, но и на процессы взаимодействия человека с моделью. Например, через манипуляции в интерфейсе пользователя, подмену пользовательских запросов или эксплуатацию ошибок в логике принятия решений модели. Такие векторы атаки могут проявляться в разных точках жизненного цикла и, в особенности, на стыке этапов, где происходит передача артефактов разработки (данных, моделей, конфигураций) между командами и системами. Отслеживание и документирование этих процессов на всех стадиях жизненного цикла становится важным компонентом обеспечения сквозной безопасности системы.

На основании всего вышесказанного можно утверждать, что рассмотрение жизненного цикла модели машинного обучения с точки зрения потенциальных угроз и векторов атак является неотъемлемой частью современного научно-практического подхода к построению защищённых ИАС, включающих компоненты МО. Без анализа цикла невозможно разработать адекватные меры защиты, соответствующие как техническим, так и организационно-правовым особенностям реализации машинного обучения в реальных информационных системах. На рисунках 1 и 2 представлено обобщенное схематическое изображение ключевых этапов жизненного цикла модели МО.

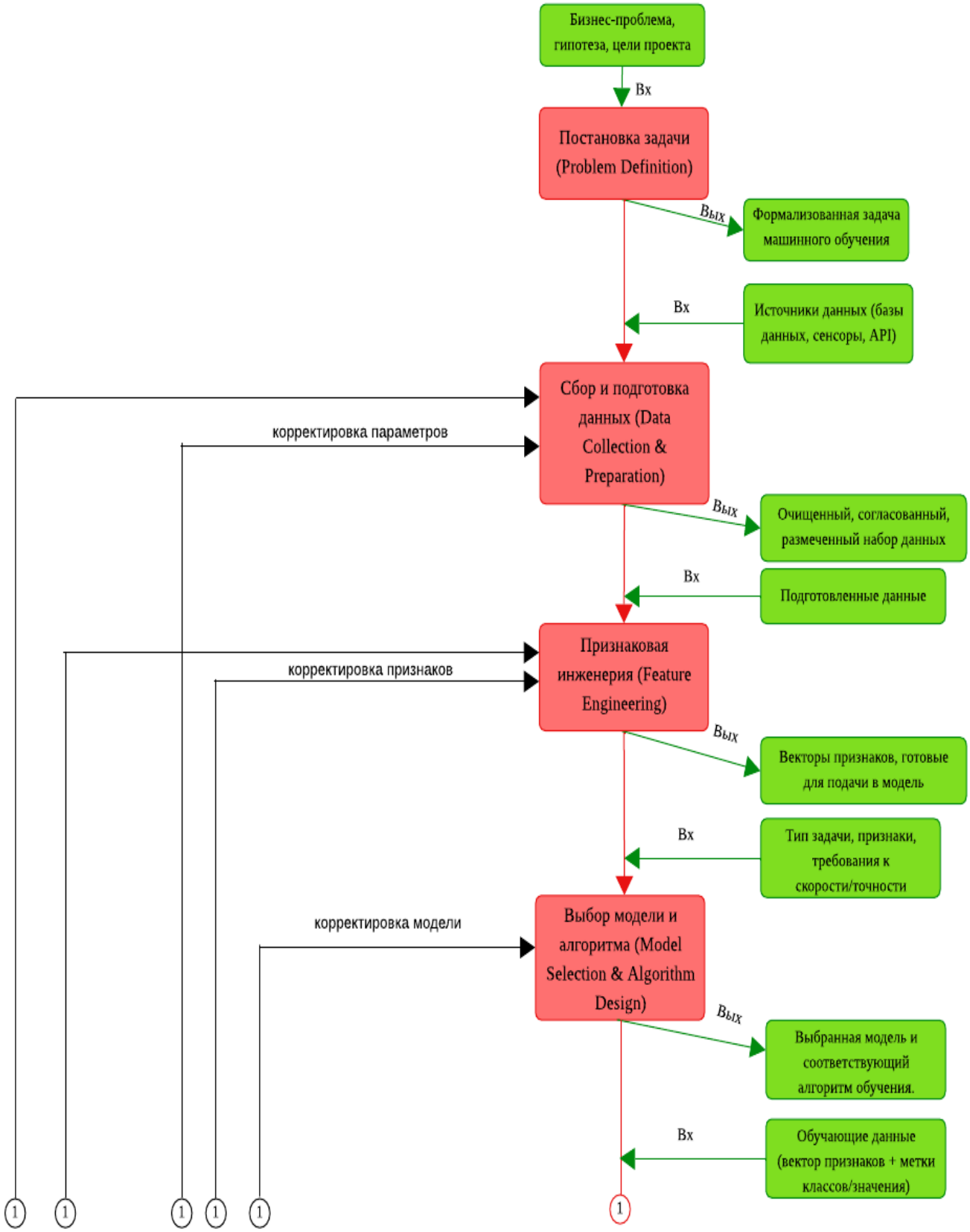


Рисунок 1 — Этапы жизненного цикла модели МО, часть 1

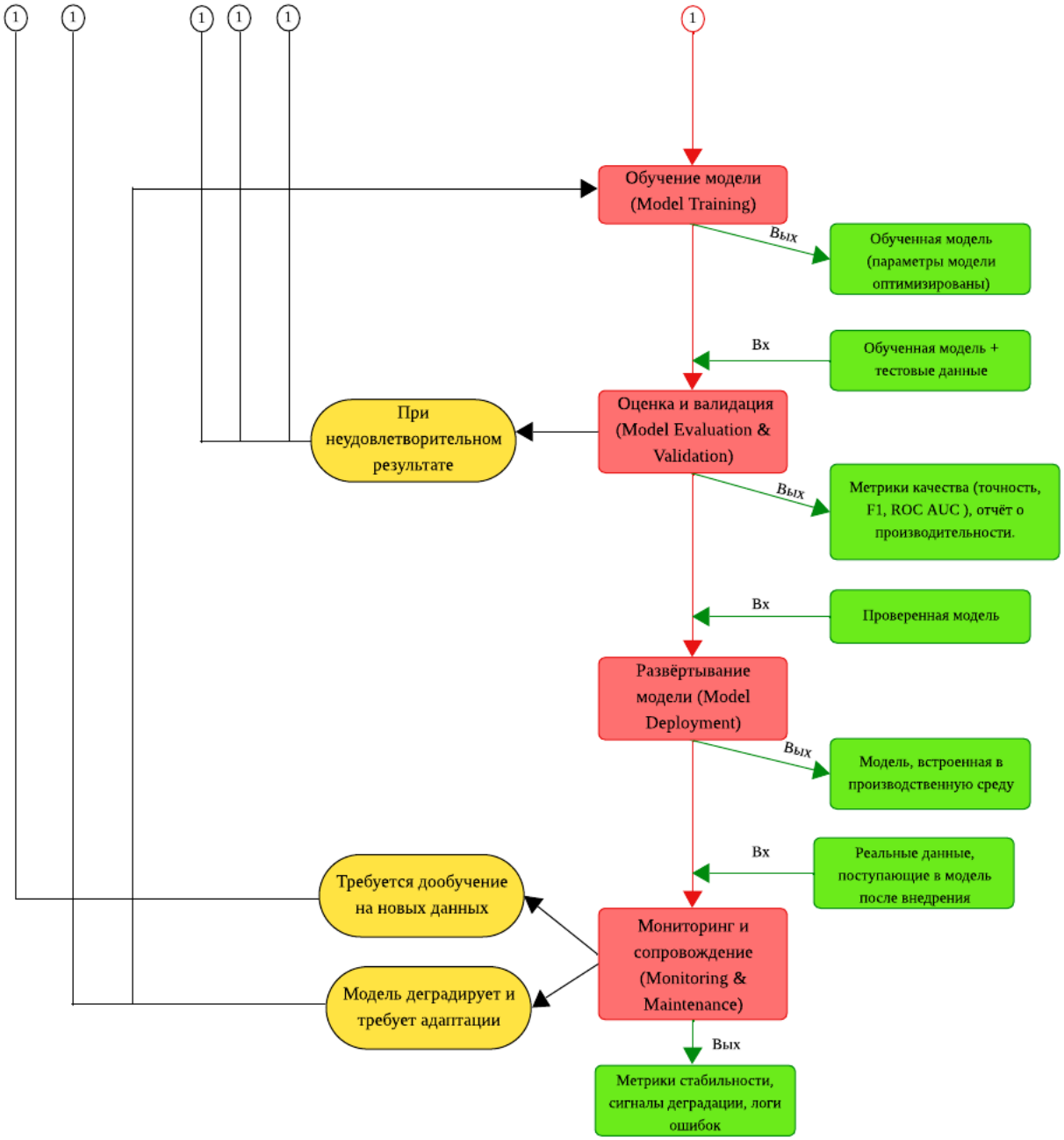


Рисунок 2 – Этапы жизненного цикла модели МО, часть 2

Постановка задачи (Problem Definition). Жизненный цикл модели машинного обучения начинается с постановки задачи, на этом этапе осуществляется переход от бизнес-проблемы к формализованной задаче машинного обучения. Входными данными выступают бизнес-контекст, гипотезы и цели проекта, которые анализируются с целью определения типа МО-задачи: классификация, регрессия, кластеризация и др. Результатом этапа является чёткая формулировка задачи, которую можно решить методами машинного обучения. На данном этапе возможны

атаки, связанные с манипуляцией требованиями или искажением первоначальных целей (например, атакующий может подменить гипотезу или изменить метрики), что приведёт к неправильной постановке задачи и, как следствие, к неэффективной или даже вредной модели. Злоумышленник на этом этапе может добиться саботажа модели, направив разработку по ложному пути.

Сбор и подготовка данных (Data Collection & Preparation). Следующий этап заключается в сборе, очистке, нормализации, агрегации и разметке данных. Входными данными являются источники информации: базы данных, сенсоры, API, веб-скрапинг. Результатом является согласованный и размеченный датасет, пригодный для дальнейшего анализа. На этом этапе уязвимости связаны с атаками на целостность и достоверность данных, включая «data poisoning» — преднамеренное включение вредоносных примеров в обучающую выборку. Вредоносный агент может внедрить ложные или искажённые данные, что приведёт к обучению модели на компрометирующей информации. Это может дать злоумышленнику возможность управлять поведением модели в реальном времени.

Признаковая инженерия (Feature Engineering). На этом этапе осуществляется трансформация подготовленных данных в числовое представление, являющееся вектором признаков, пригодных для подачи в алгоритмы обучения. Входом выступает размеченный и очищенный датасет, выходом — матрица признаков. Ошибки или уязвимости здесь могут возникнуть при выборе некорректных или избыточных признаков, а также при внедрении вредоносных признаков (feature poisoning). Злоумышленник может манипулировать распределением признаков таким образом, чтобы модель усвоила ложные корреляции, что сделает её уязвимой в производстве.

Выбор модели и алгоритма (Model Selection & Algorithm Design). После этапа признаковой инженерии следует выбор подходящей модели и алгоритма обучения. Учитываются тип задачи, структура признаков, ограничения по времени, ресурсам и требуемой точности. Входными данными служат тип задачи и характеристики признаков, на выходе получаем конкретную архитектуру модели и алгоритм её обучения. На данном этапе возможны атаки, направленные на «навязывание»

неподходящих моделей, что может снизить точность или повысить восприимчивость к атакам в дальнейшем. Например, злоумышленник может внести в рекомендательную систему или документацию предложения использовать модель, известную своей чувствительностью к «adversarial»-атакам.

Обучение модели («Model Training»). На этом шаге происходит процесс оптимизации параметров модели на обучающей выборке. Входными данными служат обучающие выборки и конфигурация модели, результатом является обученная модель с определёнными параметрами. Уязвимости на данном этапе включают модификацию данных во время обучения, вмешательство в процесс оптимизации (например, изменение функций потерь или гиперпараметров), а также извлечение информации из модели (например, «membership inference attacks»). Атаки во время обучения могут привести к созданию «backdoor»-моделей, которые ведут себя предсказуемо только при подаче определенных данных, известных только злоумышленнику, на входы модели.

Оценка и валидация («Model Evaluation & Validation»). Обученная модель проходит оценку на тестовых или валидационных данных для измерения её обобщающей способности. Входными данными являются обученная модель и отложенный набор данных, а выход — метрики качества (точность, полнота, F1, ROC AUC) и интерпретация результатов. Здесь возможны атаки на процедурную корректность. Например, подмена тестовых данных или манипуляция метриками может создать ложное впечатление о высоком качестве модели. Такой саботаж может привести к внедрению уязвимой модели в рабочую ИАС.

Развёртывание модели («Model Deployment»). Проверенная модель внедряется в функционирующую ИАС, где она начинает обрабатывать реальные входные данные. На вход этапа поступает валидационная модель, на выходе получается интегрированная модель в составе бизнес-системы. На этом этапе возможны атаки на окружение: подмена API, внедрение вредоносного ПО, атаки через уязвимости в контейнерах или зависимостях. Если злоумышленник получает доступ к развёрнутой модели, он может перехватывать запросы, изменять предсказания или осуществлять модельный эксфильтрационный канал.

Мониторинг и сопровождение («Monitoring & Maintenance»). Завершающий этап включает в себя постоянный мониторинг производительности модели на реальных данных, отслеживание деградации качества, логов ошибок, адаптацию под новые данные. Входом служат реальные запросы и метрики времени исполнения, а на выходе генерируются отчёты о стабильности и корректность работы модели. Здесь важны системы алертинга и автоматического обновления. Угрозы на данном этапе включают «adversarial drift» — постепенное изменение входных данных, которое незаметно снижает эффективность модели. Также возможна подмена логов или сокрытие ошибок, что мешает своевременному реагированию на деградацию модели. В результате злоумышленник может эксплуатировать слабости модели длительное время без обнаружения.

Также, на изображенном рисунке 2 не указан этап вывода модели МО из эксплуатации, так как этот этап по умолчанию присутствует в любом жизненном цикле, и в случае необходимости система выводится из эксплуатации ИАС, и в соответствии с политикой организации составляется акт вывода модели МО из эксплуатации.

Таким образом, понимание этапов жизненного цикла модели машинного обучения с точки зрения информационной безопасности является важнейшим аспектом при разработке, внедрении и эксплуатации интеллектуальных систем. Каждый этап жизненного цикла несет в себе уникальные векторы атак и потенциальные уязвимости, которые могут быть использованы злоумышленниками для нарушения корректной работы модели, компрометации данных или получения несанкционированного доступа к конфиденциальной информации.

Для углубления в тематику функционирования средств машинного обучения, целесообразно рассмотреть жизненный цикл средств машинного обучения (Рисунок 3), так как в определенных аспектах он отличается от моделей МО.

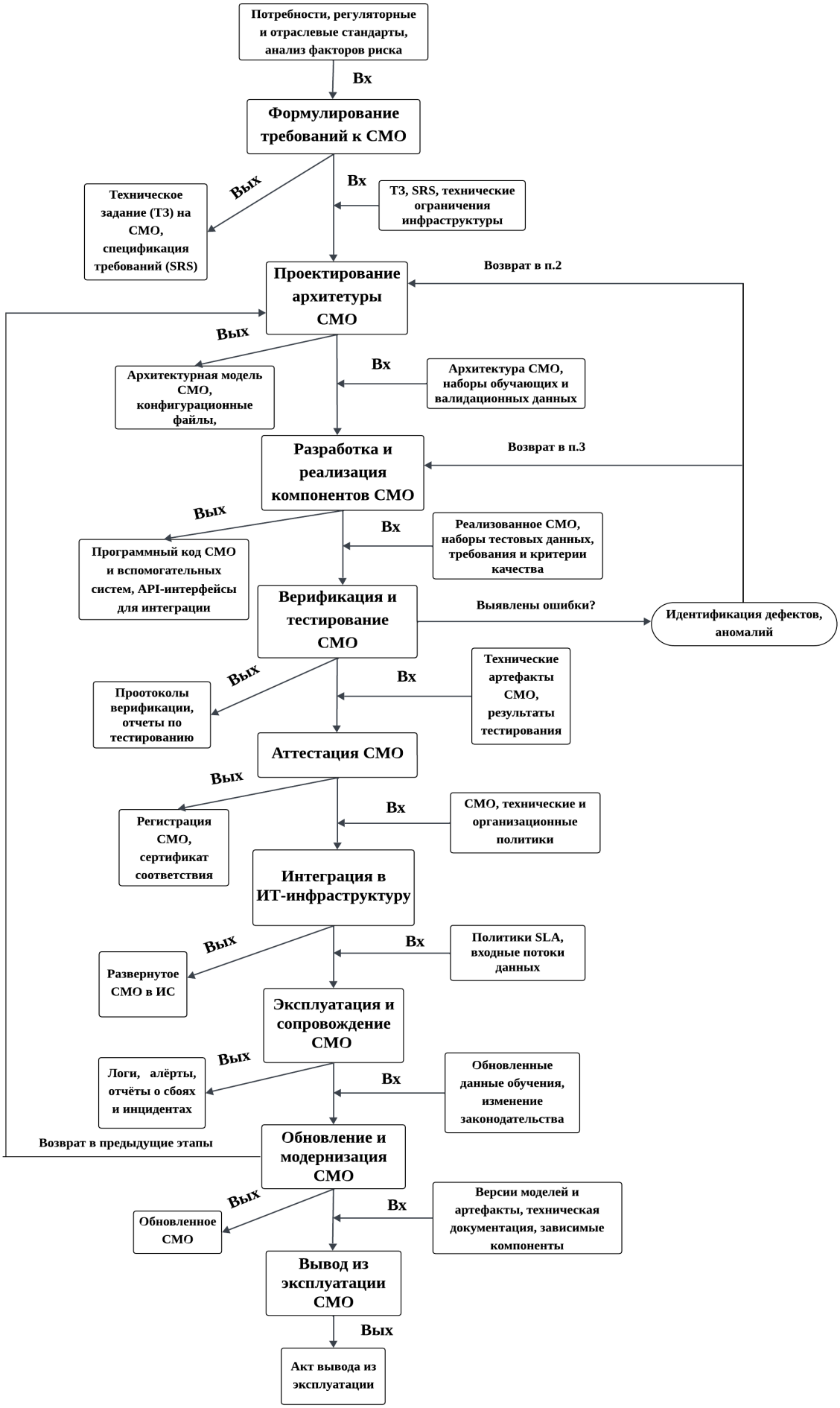


Рисунок 3 – Жизненный цикл СМО

Первоначальный этап жизненного цикла СМО ориентирован на систематизацию и анализ требований заказчика к разрабатываемому СМО. В процессе учитываются нормативные требования, регуляторные и отраслевые стандарты, а также проводится идентификация рисков, связанных с внедрением и использованием СМО в конкретной ИАС. Результатом становится формализованная совокупность требований, охватывающая функциональные, технические и правовые аспекты. Входными данными на этом этапе служат потребности заказчика, требования регуляторов, стандарты и идентифицированные риски. Выходные данные включают техническое задание (ТЗ) и спецификацию требований («Software Requirements Specification», SRS [60]), которые передаются на следующий этап — проектирование архитектуры СМО.

Проектирование архитектуры СМО. На основе полученных ТЗ и SRS осуществляется разработка архитектурной модели СМО с учетом имеющихся технических мощностей и особенностей действующей ИТ-инфраструктуры. В рамках данного этапа выявляются архитектурные компоненты, проектируются интерфейсы, форматы взаимодействующих данных, а также формулируются требования к обучающим и валидационным выборкам. Особое внимание уделяется обеспечению совместимости архитектуры с ИАС заказчика и требованиям масштабируемости. Входными данными выступают ТЗ, спецификация требований и технические ограничения. В качестве выходных данных формируется архитектура СМО, включая схемы, описания компонентов и конфигурационные файлы, которые становятся основой для реализации СМО и ее дальнейшей интеграции.

Разработка и реализация компонентов СМО. На данном этапе реализуются программные компоненты СМО в соответствии с утвержденной архитектурой. Выполняется создание алгоритмов машинного обучения, модулей предобработки и постобработки данных, API-интерфейсов и других вспомогательных элементов. Разработка охватывает весь стек программных средств, обеспечивающих функциональность модели и возможность интеграции с внешними сервисами. Входными данными являются архитектура СМО, конфигурационные файлы и выборки данных, предназначенные для обучения и валидации. Выходные данные

включают программный код СМО, программные интерфейсы и модули, подготовленные к последующему тестированию и верификации.

Верификация и тестирование СМО. Целью указанного этапа является проверка соответствия реализованного СМО ранее установленным требованиям. Осуществляется запуск СМО на заранее подготовленных тестовых выборках (в изолированной среде), проводится анализ точности, устойчивости, производительности и других критически важных метрик. При выявлении отклонений или нестабильной работы модели происходит возврат к этапу реализации или архитектурного проектирования для устранения недостатков. Входными данными на данном этапе служат программный код СМО, тестовые выборки данных и определенные критерии качества. В результате формируются выходные данные: протоколы тестирования и аналитические отчёты, подтверждающие или опровергающие корректность функционирования СМО.

Аттестация СМО. После успешного прохождения этапа тестирования осуществляется аттестация СМО, подтверждающая его готовность к внедрению в производственную среду. В рамках аттестации проводится аудит программных и технических характеристик, проверка на соответствие нормативным и отраслевым требованиям, оценка уровня безопасности, а также экспертиза полноты и корректности документации. Процедуру аттестации осуществляет специализированный орган по сертификации, аккредитованный Федеральной службой по аккредитации (Росаккредитацией) и действующий под надзором ФСТЭК России. Входными данными выступают отчёты о тестировании, а также артефакты, созданные на предыдущих этапах. Выходные данные включают регистрационные документы, аттестат соответствия

Интеграция в ИТ-инфраструктуру. На данном этапе производится внедрение СМО в ИТ-инфраструктуру. Осуществляется настройка потоков входных и выходных данных, интеграция с существующими ИС, настройка сервисов и учет соглашений об уровне обслуживания (SLA). Входными данными служат сертифицированная версия СМО, а также технические и организационные политики,

регулирующие функционирование ИТ-среды. Результатом становится развернутое в инфраструктуре решение, готовое к эксплуатации в реальных условиях.

Эксплуатация и сопровождение СМО. После развертывания СМО начинает функционировать в рабочей ИАС. На этом этапе осуществляется непрерывный мониторинг работы модели, сбор логов, управление инцидентами и анализ эксплуатационных характеристик. Особое внимание уделяется обнаружению аномалий, нарушений SLA и изменение ключевых метрик. Входными данными являются эксплуатационные данные, SLA и поступающие входные потоки. Выходные данные включают журналы событий, алёрты и отчёты мониторинга, которые служат основой для принятия решений о необходимости модификации или обновления модели.

Обновление и модернизация СМО. В процессе эксплуатации может возникнуть необходимость в обновлении СМО вследствие изменений законодательства, появления новых уязвимостей или ухудшения качества прогнозов развития СМО. Выполняется пересмотр архитектуры, повторное обучение модели, обновление алгоритмов и улучшение функциональности. Этап включает сбор и анализ новых обучающих данных, уточнение параметров и возможная модификация архитектурных решений. Входными данными выступают обновлённые выборки, системные логи и техническая документация. Выходные данные представляют собой обновлённую версию СМО, которая возвращается в цикл эксплуатации.

Вывод из эксплуатации. Завершающим этапом жизненного цикла СМО является его вывод из эксплуатации, осуществляемый при достижении морального устаревания СМО, снижении её эффективности, деградации или принятии решения о замене. Производится фиксация всех зависимостей, демонтаж технических связей, подготовка заключительной документации и формирование акта о выводе из эксплуатации ИАС. Входными данными служат текущая документация и версия модели, а выходные данные включают акт о выводе СМО из эксплуатации и итоги архивирования всех соответствующих артефактов.

Анализ обоих жизненных циклов, как моделей машинного обучения, так и средств машинного обучения, имеет ключевое значение в контексте противодействия

атакам на ИАС, включающие в себя СМО. Приведенные выше жизненные циклы различаются по масштабу, структуре, охватываемым этапам, и лишь их всестороннее понимание позволяет выявлять наиболее уязвимые места ИАС, что способствует выработке эффективных мер противодействия атакам.

Жизненный цикл модели МО фокусируется в первую очередь на научных и аналитических аспектах: постановке задачи, сборе и подготовке данных, выборе функций и алгоритмов, а также на процессе обучения. Хотя эти этапы имеют решающее значение для качества модели, они не охватывают весь спектр процессов, сопровождающих использование модели в реальных условиях. Тем не менее, именно в рамках этого цикла определяются уязвимости, связанные с качеством данных, переподготовкой, заражением и возможностью извлечения конфиденциальной информации из модели (например, инверсия модели, вывод о принадлежности). Таким образом, анализ жизненного цикла модели МО позволяет выявить риски, непосредственно связанные с процессом обучения, структурой модели и ее прогностической функцией.

С другой стороны, жизненный цикл СМО охватывает весь спектр этапов разработки и существования программного продукта, включая этапы: от формализации требований и архитектурного проектирования до развертывания в ИТ-инфраструктуре, эксплуатации и вывода из работы. Она включает в себя методы «DevOps» [61], процедуры «CI/CD» [62], средства контроля безопасности, систему документации и техническую поддержку. СМО как объект представляет собой гораздо более широкое и сложное целевое пространство для атак, поскольку он затрагивает не только модель, но и программные интерфейсы, каналы передачи данных, механизмы ведения журналов, систему управления правами доступа, интеграционные компоненты и пользовательские интерфейсы. То есть, атаки могут быть направлены как на саму модель МО, так и на СМО.

Только при одновременном учете обоих жизненных циклов можно гарантировать комплексную безопасность ИАС, включающих в себя СМО. Анализ моделей МО дает возможность создать защиту на уровне алгоритмов и данных, а анализ СМО обеспечивает безопасность на уровне взаимодействия компонентов,

процессов обслуживания и общей архитектурной целостности. Такая интеграция необходима для разработки многоуровневой системы защиты, способной учитывать специфические угрозы моделей МО и СМО.

Любое СМО основано на архитектурной модели, которая проектирует структуру компонентов, их взаимосвязи, порядок передачи данных, а также механизм развертывания и поддержки моделей. Архитектура задает как функциональные, так и нефункциональные свойства информационной системы, что в дальнейшем идентифицирует потенциальные уязвимости. Базовые архитектурные подходы, такие как монолитный, микросервисный обладают разной степенью устойчивости к атакам. Например, тесное соединение компонентов в монолитных системах способствует высокой производительности, но в тоже время привести к лавинообразному распространению повреждений при выходе из строя одного модуля. В противовес микросервисные архитектуры позволяют локализовать инциденты, временно изолировав пострадавший компонент, но требуют сложной системы управления безопасностью сервисов и их взаимодействием.

1.1.2 Монолитная архитектура средств машинного обучения

Анализ типичных архитектур СМО с точки зрения информационной безопасности позволяет идентифицировать и систематизировать потенциальные атаки, такие как заражение данных, подмена модели, извлечение параметров модели, обход механизма классификации или атаки через интерфейс логического вывода. Многие из этих атак реализуются из-за уязвимых мест на архитектурном уровне, например: незащищенного канала передачи данных, отсутствия контроля доступа между компонентами, недостаточностью проверки на этапе предварительной обработки или чрезмерного доступа к модели через API. Архитектурные уязвимости выступают в качестве одного из ключевых факторов риска при построении и эксплуатации СМО, их игнорирование способно привести к успешной реализации атак, вне зависимости от применяемых алгоритмов машинного обучения или используемых криптографических механизмов защиты. С позиции обеспечения

устойчивости к деструктивным воздействиям, аналитика архитектурных решений позволяет специалистам информационной безопасности формировать комплексную и детализированную модель ИАС, включающей в себя компоненты СМО. Подобная аналитика обеспечивает возможность точной идентификации потенциальных уязвимых точек входа в каждом модуле архитектуры, позволяет определить вероятные векторы атак с учётом характера взаимодействий между компонентами, а также исходных предусловий для реализации компрометирующих действий злоумышленника (включая доступ к обучающим данным, каналам передачи или интерфейсам инференса). На основе полученных данных разрабатываются обоснованные меры защиты, направленные на снижение вероятности реализации целевых атак, минимизацию распространённости атаки на компоненты и повышение общей защищённости архитектурной конфигурации СМО на этапе проектирования и эксплуатации. Рассмотрим наиболее популярные типы архитектур СМО.

Анализ типовых архитектур СМО целесообразно начинать с одной из наиболее распространённой и широко применяемой монолитной архитектуры. Представленная схема на рисунке 4 носит обобщённый и концептуальный характер, поскольку иллюстрирует универсальные структурные и функциональные особенности данного архитектурного типа модели СМО. Такой подход позволяет сформировать общее представление о базовом устройстве монолитной архитектуры без привязки к специфики определенного программного продукта. Это, в свою очередь, обеспечивает возможность абстрагированного анализа ключевых компонентов, их взаимосвязей и потенциальных уязвимостей на уровне архитектурного проектирования. На представленном ниже рисунке выделено восемь наиболее важных и распространенных компонента монолитной архитектуры средств машинного обучения, также девятый модуль, не вводимый в схему, является элементом вывода средства машинного обучения из эксплуатации и проводится по установленным техническим и правовым регламентам организации.

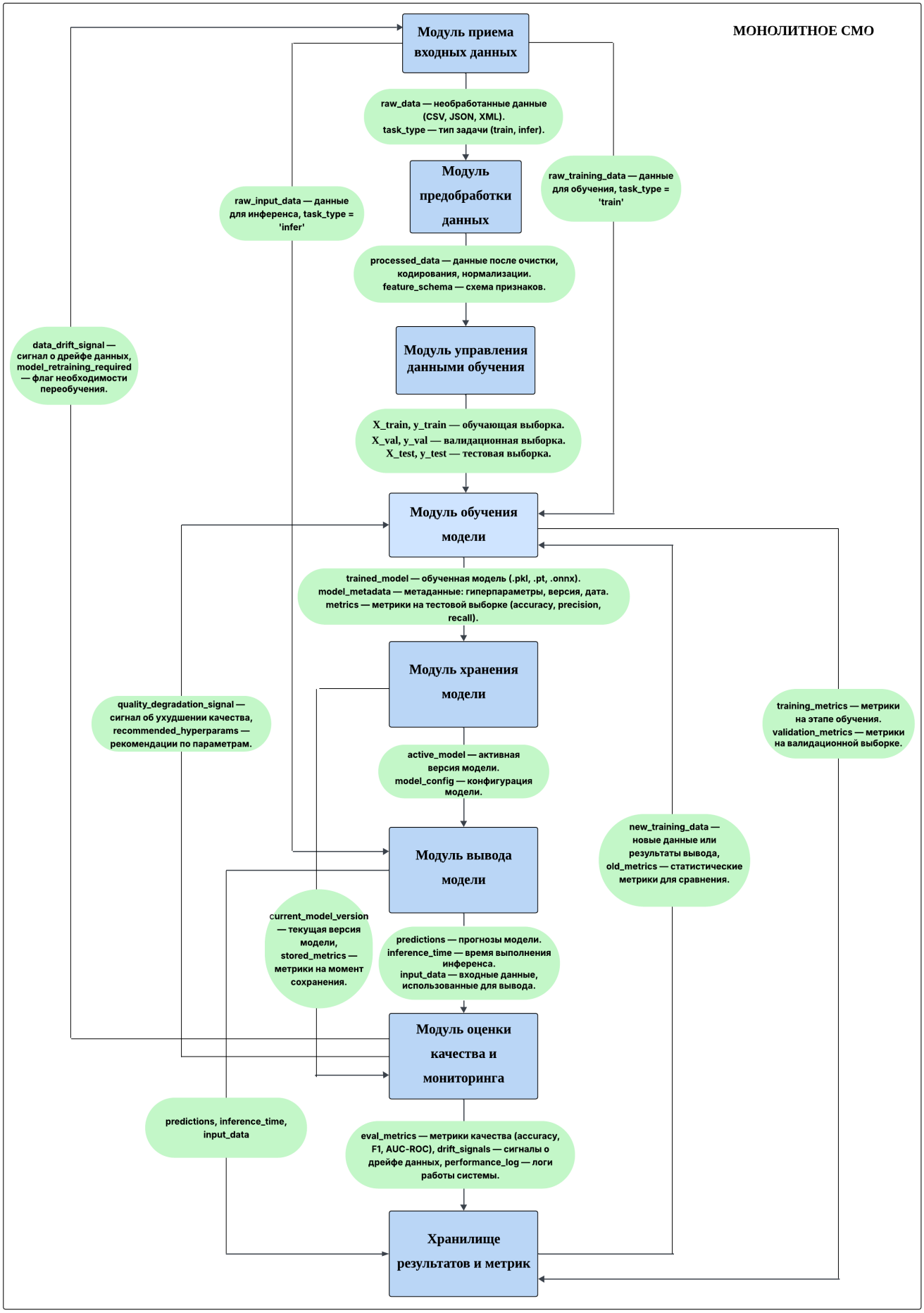


Рисунок 4 – Схема монолитной архитектуры СМО

Представленная выше схема отражает монолитную архитектуру средств машинного обучения, включающую все ключевые этапы жизненного цикла в рамках единой программной среды. Архитектура организована как линейно-циклический процесс, в котором каждый модуль выполняет строго определённую функцию, принимает на вход стандартизированные данные и передаёт результаты в следующий модуль. Такая структура обеспечивает прозрачность, высокую производительность и управляемость всего процесса функционирования СМО.

Модуль приёма входных данных является начальной точкой обработки и отвечает за получение необработанных данных различных форматов (CSV, JSON, XML) из внешних источников. Ключевыми параметрами на этом этапе являются сами данные (raw_data) и тип задачи (task_type), который определяет маршрут их дальнейшей обработки: обучение модели (train) или инференс (infer). В случае задачи предсказания передаются данные для инференса (raw_input_data), а в случае обучения — данные для тренировки модели (raw_training_data).

Далее данные поступают в модуль предобработки данных, который выполняет очистку, нормализацию, кодирование категориальных признаков и иные преобразования, обеспечивающие приведение данных к формату, пригодному для машинного обучения. На выходе модуля формируются обработанные данные (processed_data) и схема признаков (feature_schema), которая описывает структуру вектора свойств. Эти данные служат основой для дальнейшего этапа формирования обучающих выборок.

Следующий компонент — модуль управления данными обучения, получает обработанные данные и разделяет их на три выборки: обучающую (X_train, y_train), валидационную (X_val, y_val) и тестовую (X_test, y_test). Это необходимо для построения модели, подбора гиперпараметров и объективной оценки её суммирующей способности. Далее данные передаются в модуль обучения модели.

Модуль обучения модели выполняет основную задачу построения предсказательной модели. На вход он получает обучающую и валидационную выборки, а на выходе формирует обученную модель в заданном формате (.pkl, .pt, .onnx), а также метаданные (model_metadata) и метрики на тестовой выборке (metrics),

такие как «accuracy», «precision», «recall». Эти артефакты используются для последующего хранения и мониторинга модели.

Сформированная модель и сопутствующая информация передаются в модуль хранения, где выполняется версионирование (выбор активной версии модели). На этом этапе фиксируются конфигурация модели (model_config), активная версия (active_model) и история предыдущих изменений. Этот модуль взаимодействует с модулем вывода модели, предоставляя ему актуальную модель для инференса.

Модуль вывода модели осуществляет применение активной модели к новым входным данным. На вход он получает данные для предсказания (input_data), и выдает прогнозы (predictions), а также информацию о времени выполнения инференса (inference_time). Все предсказания и метаинформация фиксируются и передаются в модуль оценки качества и мониторинга.

Модуль оценки качества и мониторинга играет ключевую роль в отслеживании стабильности и эффективности модели в продуктивной среде. Он получает предсказания, входные данные и временные метки, на основании которых рассчитывает текущие метрики качества (eval_metrics) [63], такие как «accuracy», «F1», «AUC-ROC». Также анализируются признаки деградации качества (quality_degradation_signal) и дрейфа данных (data_drift_signal), при наличии которых формируется сигнал о необходимости переобучения модели (model_retraining_required), а также рекомендации по гиперпараметрам.

Конечным элементом архитектуры выступает хранилище результатов и метрик, где централизованно сохраняются все метрики, версии моделей, сигналы мониторинга (drift_signals, performance_logs) и предсказания. Этот компонент обеспечивает полную прослеживаемость и возможность ретроспективного анализа. В случае получения новых обучающих данных (new_training_data) или изменения входных распределений, старые метрики сравниваются с текущими для выявления отклонений.

Из выше сказанного следует, что каждый модуль системы имеет чётко определённые входные и выходные данные, взаимодействует с соседними модулями по стандартизированным интерфейсам и участвует в замкнутом цикле построения,

развертывания и поддержки модели машинного обучения. Монолитная структура обеспечивает компактность и простоту сопровождения, особенно на начальных этапах внедрения МО в продуктивную среду, но с ростом сложности информационной системы может потребовать перехода к более гибкой микросервисной архитектуре.

1.1.3 Микросервисная архитектура средств машинного обучения

Следующей наиболее распространенной архитектурой является микросервисная. Микросервисная архитектура стала «золотым стандартом» для современных платформ машинного обучения по целому ряду технических и организационных причин. Во-первых, разные этапы реализации СМО потребляют ресурсы по-разному. Потоковая очистка данных требует пропускной способности дисков и сети, обучение моделей — графических процессоров, а онлайн-инференс — минимальной задержки на каждом запросе. Если собрать всё это в один монолит, будет неизбежно происходить перегрузка одних участков системы ресурсами и простаивание других. Также стоит учитывать, что в монолитной архитектуре вывод из строя одного компонента неизбежно приводит к возникновению неисправностей остальных. Разделив же этапы на независимые сервисы, можно каждому подобрать свой идеальный тип узла и масштабировать его ровно тогда, когда это действительно нужно.

Второе основание — «полиглотность» МО-стека. В реальных проектах вместе живут «Python-скрипты», «Spark-джобы» на Scala, «CUDA-ядра» на C++ и лёгкие сетевые сервисы на Go. Микросервисы разрешают каждой технологии пользоваться собственными библиотеками и версиями языка, поскольку запускаются в изолированных контейнерах. Это резко сокращает время на устранение конфликтов зависимостей и упрощает интеграцию.

Третья причина связана со скоростью изменений. Код, отвечающий за сбор данных, обновляется реже, чем алгоритмы и признаки, которые дата-сайентисты экспериментально улучшают чуть ли не каждый день. Микросервисный подход

позволяет выпускать новую модель методом «canary» или «blue-green» [64] без перекомпиляции и перезапуска остальных компонентов. В итоге время простоя стремится к нулю, а среднее время восстановления после сбоя (MTTR) сокращается в разы [65].

Надёжность также выигрывает, сбой в подсистеме подготовки данных не выводит из строя сервис онлайн предсказаний, потому что контуры изолированы. Сетевые оболочки автоматически отключают поврежденный сервис и перенаправляют трафик к здоровым узлам, сохраняя заявленное SLA. Монолит же при аналогичной ошибке может перестать обслуживать пользователей целиком.

Наконец, микросервисы облегчают соответствие законодательным нормативам. Каждый артефакт: данные, признаки, модель, имеет собственную версию и неизменяемый адрес. Это позволяет точно показать регулятору, какие исходные данные и какой код лежали в основе любой конкретной модели и предсказания. Так реализуется полная «прослеживаемость», необходимая для, например, государственных информационных систем.

В совокупности перечисленные выше факторы такие, как разнообразие нагрузок, многосоставной стек технологий, разные скорости развития компонентов, требования к бесперебойности и к аудиту делают микросервисную архитектуру логичным и практически единственным эффективным выбором для построения эффективных средств машинного обучения. Типовая схема микросервисной архитектуры приведена на рисунке 5.

Построение микросервисной архитектуры начинается с сервиса сбора и загрузки данных (Data Ingestion Service), который обеспечивает интеграцию с внешними источниками: API, брокерами сообщений, файловыми хранилищами, а также с базами данных. Входными данными выступают неотсортированные и полуструктурированные потоки, представленные в форматах «JSON», «CSV», «Avro», «Parquet».

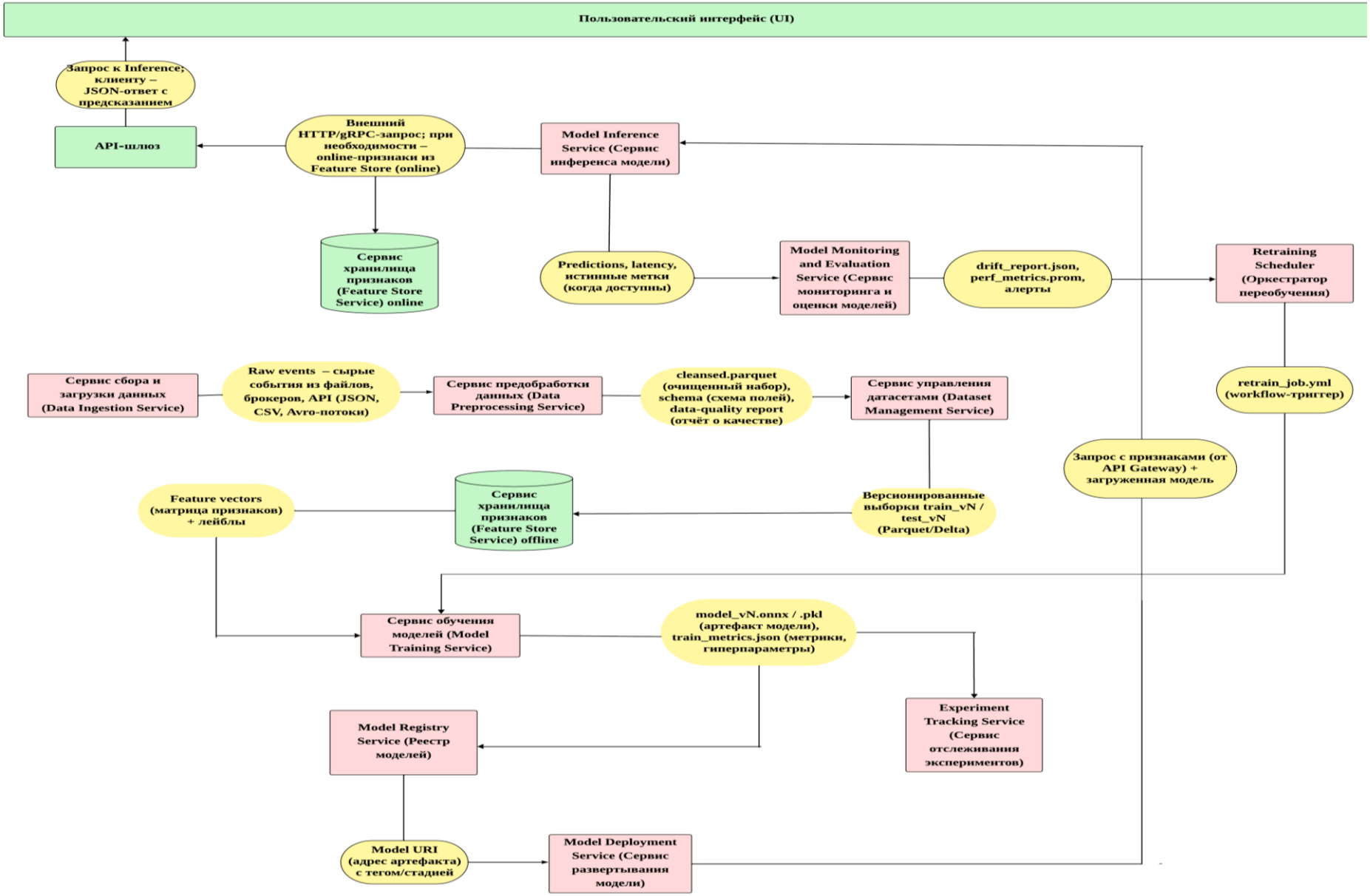


Рисунок 5 – Микросервисная архитектура средтв машинного обучения

Следующим рассматриваемым компонентом является сервис предобработки данных (Data Preprocessing Service), который выполняет очистку, фильтрацию, нормализацию, категоризацию и приведение данных к стандартному виду. Он формирует три ключевых артефакта:

- «cleansed.parquet» — структурированный очищенный набор данных в колоночном формате, пригодный для последующего использования;
- «schema.json» — формальное описание структуры, включающее типы и правила валидации полей;
- «data-quality report» — отчёт, содержащий статистические характеристики данных: процент пропусков, выбросов, дисбаланс классов.

Перечисленные выше данные передаются для обработки в сервис управления датасетами (Dataset Management Service).

«Dataset Management Service» принимает очищенные данные и формирует на их основе версионированные выборки «train_vN.parquet» и «test_vN.parquet» для обучения и тестирования моделей, где vN обозначает номер версии. Эти выборки располагают следующей метаинформацией: временем генерации, источником данных, хэшами и параметрами разделения. Сформированные выборки используются в сервисе хранения признаков (Feature Store Service, offline слой).

«Feature Store (offline)» обрабатывает входные датасеты и генерирует числовые векторы признаков (feature_vectors) и метки (labels). Признаки преобразуются из категориальных и текстовых полей, нормализуются и кодируются в числовую форму. Эти данные служат прямым входом в сервис обучения моделей (Model Training Service).

«Model Training Service» реализует процедуру обучения моделей с учётом указанных гиперпараметров (например, learning_rate, max_depth, batch_size). Входом служат «feature_vectors» и «labels», а на выходе формируется обученная модель: в сериализованном формате «model_vN.onnx», «.pkl»; «train_metrics.json», содержащая показатели качества модели (accuracy, F1, ROC-AUC, logloss) и обладающая журналом параметров запуска. Эти артефакты одновременно передаются в два

микросервиса: в реестр моделей (Model Registry Service) и в сервис отслеживания экспериментов (Experiment Tracking Service).

«Model Registry» служит централизованным хранилищем моделей, управляет версиями, стадиями (development, staging, production) и хранит уникальный адрес модели «model_uri». При запуске модели в продакшен публикуется событие продвижения, активирующее работу сервиса развертывания моделей (Model Deployment Service).

«Deployment Service» извлекает модель по «model_uri», упаковывает её в контейнер и разворачивает в инфраструктуре, публикуя «endpoint» (/predict или /score) для последующего использования в инференсе. Адрес «endpoint» передаётся в сервис инференса модели (Model Inference Service), который, в свою очередь, получает входные данные от API-шлюза (API Gateway).

«API Gateway» выполняет функции маршрутизации и аутентификации запросов пользователей. Если необходимо, он обращается к «Feature Store online» для получения актуальных признаков объекта по идентификатору (например, user_id). Свойства возвращаются в виде онлайнового вектора (массива) и направляются в «Inference Service». Последний загружает модель из «Deployment Service» и производит предсказание, возвращая результат в формате «JSON» обратно через API-шлюз.

Параллельно предсказания, задержки, статус обработки и, при наличии, истинные метки поступают в сервис мониторинга и оценки модели (Model Monitoring and Evaluation Service). Он отслеживает эксплуатационные характеристики модели, вычисляет показатели SLA (latency, throughput, error rate), а также выполняет анализ дрейфа распределений признаков и целевых переменных. В случае обнаружения отклонений формируется «drift_report.json» (структурированный отчет) и «perf_metrics.prom» (файл экспорта метрик), а также направляется алерт в оркестратор переобучения (Retraining Scheduler).

«Retraining Scheduler» запускает новый обучающий цикл, формируя «retrain_job.yml» — конфигурационный манифест, содержащий путь к новым данным, параметры запуска и команду повторного обучения. Этот файл инициирует

повторную работу «Data Preprocessing», «Dataset Management» и «Model Training», замыкая полный автоматизированный жизненный цикл.

Одновременно все конфигурации, параметры и метрики каждого эксперимента регистрируются в сервисе отслеживания экспериментов (Experiment Tracking Service). Он агрегирует данные из «Training», «Monitoring» и «Registry», отображает сравнительные метрики, хранит историю запусков, предоставляет визуализации и позволяет пользователю выбрать лучшую версию модели.

Из всего вышеописанного можно сделать вывод, что описанная архитектура реализует строго типовую схему реального применения микросервисов в средстах машинного обучения. Каждый сервис функционирует независимо, все данные и артефакты версионируются и передаются через стандартные интерфейсы. Это обеспечивает масштабируемость, отказоустойчивость, гибкость и адаптацию к новым данным и требованиям, а также соответствие практикам мониторинга и аудита. Автоматизация переобучения, изоляция компонентов и прослеживаемость делают данную архитектуру идеальной для продуктивного развертывания и сопровождения сложных СМО в ИАС, критичных к точности и воспроизводимости.

1.1.4 «Pipeline» архитектура средств машинного обучения

Архитектура типа «Pipeline», представленная на рисунке 6, отражает современный конвейер построения, внедрения и сопровождения средств машинного обучения и представляет собой целостную реализацию функционала подобной архитектуры. Она основана на принципах модульности, возобновимости и масштабируемости, что делает её достаточно востребованной при построении СМО. Архитектура организована в виде последовательности этапов, каждый из которых реализует определённую функцию в общем процессе разработки модели и взаимодействует с другими компонентами посредством передачи выходных артефактов, таких как файлы данных, модели, метрики и конфигурации.

Первым процессом является сбор и загрузка данных (Data Ingestion). На этом шаге происходит получение исходной информации из внешних источников,

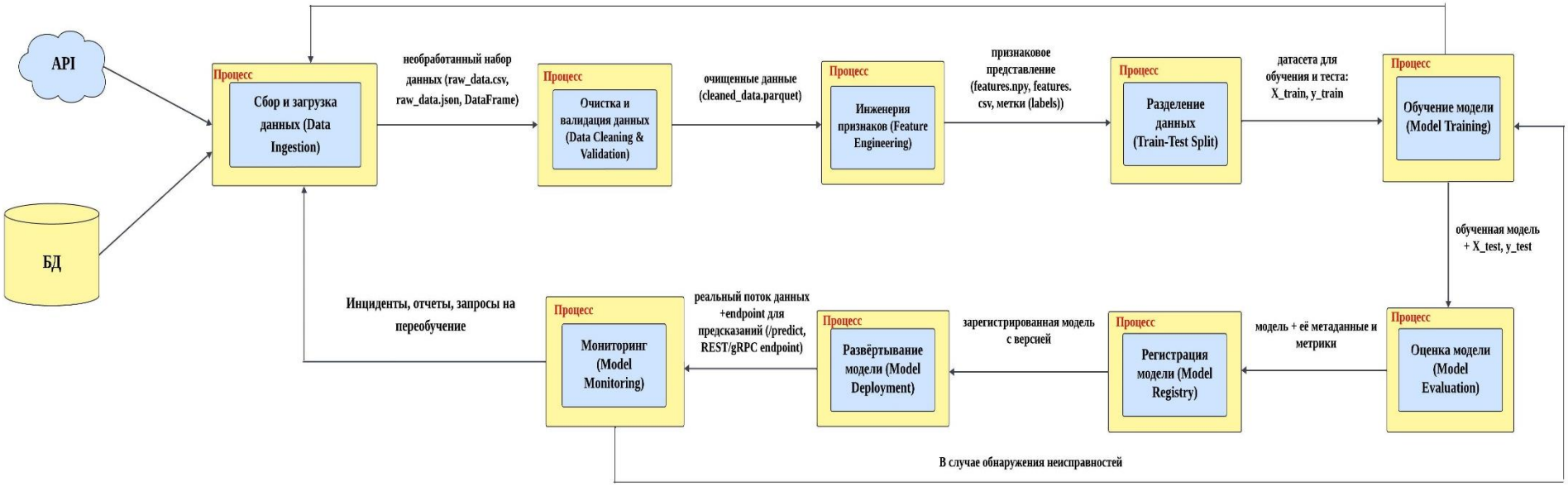


Рисунок 6 – Pipeline-архитектура средств машинного обучения

например, базы данных, «REST API», файловые хранилища или потоки телеметрии. Входными данными для данного блока выступают параметры подключения и структурированные или неструктурированные данные в исходном виде, представляющие собой полную совокупность сведений, необходимых для анализа. Выходом становится агрегированный необработанный набор данных, сохранённый в унифицированном формате (например, «CSV», «JSON» или таблицы в формате «Parquet»), пригодном для дальнейшей предобработки.

Следующий процесс, очистка и валидация данных (Data Cleaning & Validation). Здесь выполняются процедуры устранения шумов, пропусков, дублирующихся строк, а также приведение типов признаков к требуемому виду. Входными данными на этом этапе являются необработанные данные, полученные на предыдущем шаге. На выходе формируется очищенный и валидированный датасет, соответствующий требованиям модели и сохраняющий ключевые закономерности. Кроме того, осуществляется проверка согласованности и корректности данных, в частности, контроль допустимых значений, распределений и схемы данных.

Далее осуществляется инженерия признаков (Feature Engineering) — этап, на котором из структурированных данных извлекаются информативные характеристики. Сюда входит кодирование категориальных признаков, нормализация числовых значений, генерация временных и агрегированных признаков, а также применение доменно-специфичных преобразований. На вход подаются очищенные данные, а на выходе — массив признаков в числовом представлении (матрица признаков) и соответствующие им метки целевой переменной. Эти артефакты обеспечивают возможность использования алгоритмов машинного обучения, которым требуется строгое соблюдение форматов входных данных.

Полученные признаки и метки затем проходят процедуру разделения на обучающую и тестовую выборки (Train-Test Split). Целью данного этапа является разделение датасета на независимые подмножества: обучающее, предназначенное для построения модели, и тестовое, служащее для оценки её обобщающей способности. Входными данными выступают целостные массивы признаков и меток, а на выходе формируются четыре подмножества: «X_train», «X_test», «y_train»,

«y_test». Важным аспектом является сохранение репрезентативности распределения данных в каждой подвыборке, что достигается посредством стратифицированного разбиения или случайной выборки с заданным зерном генератора псевдослучайных чисел.

На этапе обучения модели (Model Training) происходит построение алгоритма машинного обучения, основанного на обучающей выборке. Используемые данные — это признаки и метки обучающей подвыборки. В процессе обучения модель формирует внутреннее представление зависимости между признаками и целевой переменной. Результатом является сериализованная модель (например, в формате .pkl, .joblib или ONNX), содержащая весовые коэффициенты, архитектуру и параметры, необходимые для предсказания новых наблюдений.

Следующим логическим блоком является оценка модели (Model Evaluation). Здесь происходит анализ качества обученного алгоритма на отложенной тестовой выборке. В качестве входа используется предсказание модели на «X_test», которое сравнивается с истинными значениями «y_test». На выходе формируется набор метрик (точность, полнота), а также визуализации (например, матрица ошибок), позволяющие судить о пригодности модели к внедрению. Эти данные критически важны для принятия решений об утверждении модели и её возможном обновлении.

После успешной валидации модель поступает в регистратор моделей (Model Registry) — компонент, отвечающий за централизованное хранение версий моделей, параметров их обучения, а также соответствующих метрик. Входом на этом этапе служит сериализованная модель и её метаданные: гиперпараметры, дата обучения, «ID» эксперимента. На выходе — зарегистрированная сущность модели с уникальной версией, доступная для последующего использования в производственной среде.

Зарегистрированная модель может быть передана в модуль развёртывания (Model Deployment). Здесь осуществляется инкапсуляция модели в сервис (например, REST API или gRPC endpoint), доступный для вызова другими компонентами системы. Входными данными служат: модель, параметры окружения, инфраструктурные конфигурации. На выходе формируется работающий API, либо

микросервис, обеспечивающий предсказания на новых данных в реальном времени или в пакетном режиме.

Финальным элементом архитектуры выступает мониторинг модели (Model Monitoring). Его задача отслеживать производительность и корректность модели в эксплуатации, сравнение фактических и предсказанных значений, выявление сдвигов распределений признаков (data drift) или деградации метрик осуществляется в непрерывном режиме. Входом служит поток эксплуатационных данных и результаты инференса. На выходе формируются отчёты, алерты и сигналы на возможное переобучение модели или её замену.

Все компоненты архитектуры взаимосвязаны посредством передачи выходных артефактов одного блока в качестве входов следующего, образуя строго детерминированную последовательность трансформаций. Такая структура обеспечивает модульность, воспроизводимость и возможность масштабирования. Каждый компонент может быть реализован независимо, при этом изменения в одном модуле минимально влияют на остальные, что соответствует принципам слабой связанности и высокой когезии.

Таким образом, представленная архитектура воплощает лучшие практики построения систем машинного обучения, обеспечивая полный жизненный цикл модели от загрузки и подготовки данных до сопровождения модели в продакшене. Она ориентирована на промышленное применение и может быть эффективно масштабирована и адаптирована под различные бизнес-задачи и инфраструктурные ограничения.

Ключевым преимуществом «Pipeline»-архитектуры является разделение процессов по функциональному признаку, что обеспечивает высокую модульность и переиспользуемость компонентов. В отличие от монолитной архитектуры, где весь процесс, от подготовки данных до развёртывания модели, реализуется в одном программном блоке, «Pipeline» позволяет независимо изменять, масштабировать и отлаживать отдельные этапы без необходимости вмешательства в другие компоненты. Монолитный подход, несмотря на простоту, страдает от низкой гибкости и трудностей в сопровождении при росте объёма задач и данных.

Сравнивая «Pipeline» с микросервисной архитектурой, можно отметить, что обе они используют модульность, но различаются степенью изоляции. Микросервисный подход предполагает реализацию каждого этапа как автономного сетевого сервиса с независимым масштабированием и отказоустойчивостью, что требует более сложной инфраструктуры, но обеспечивает гибкость и устойчивость к сбоям. «Pipeline»-архитектура, в свою очередь, реализуется как строго упорядоченная цепочка процессов в рамках одной системы или контейнерной среды, что делает её оптимальной для средних по сложности проектов с высоким уровнем автоматизации.

Таким образом, представленная архитектура «Pipeline» служит эффективной основой для построения систем машинного обучения, где важна воспроизводимость, прозрачность и контролируемость всех этапов жизненного цикла модели. Она представляет собой середину между простотой монолита и избыточной сложностью микросервисной схемы, делая её предпочтительным выбором в моделях МО, решающих прикладные задачи промышленной аналитики.

1.1.5 Анализ и сравнительная характеристика архитектурных решений средств машинного обучения

Наряду с широко используемыми монолитным, микроархитектурным (микросервисным) и «Pipeline»-ориентированным подходами формируются и активно применяются новые архитектурные парадигмы, каждая из которых решает конкретные задачи в области разработки СМО, моделей, развертывания и масштабирования.

Первой проводится исследование «Serverless»-архитектуры (Function-as-a-Service, FaaS). Архитектура типа «Serverless» основывается на концепции событийно-ориентированного исполнения кода без необходимости в ручном управлении серверами или виртуальными машинами. В данной парадигме функции, реализующие, например, предобработку, инференс или логирование, разворачиваются в облачной среде и автоматически вызываются по заданным событиям. Основные компоненты:

- функции инференса — микрокомпоненты, вызываемые для генерации предсказаний;

- хранилище данных — облачные хранилища (например, Amazon S3, Google Cloud Storage) для размещения входных/выходных артефактов;

- событийные триггеры — механизмы вызова МО-функций при изменении состояния (например, загрузка файла, HTTP-запрос);

- мониторинг и логирование — встроенные средства трекинга вызовов функций и сбора метрик (например, AWS CloudWatch).

Принцип работы: каждая функция (например, predict, preprocess) вызывается по событию (upload файла, поступление запроса от клиента) и исполняется изолированно. Масштабирование происходит автоматически.

Главным преимуществом данной архитектуры является высокая эластичность и автоматическое масштабирование. Она наилучшим образом подходит для систем с нерегулярной или пиково-зависимой нагрузкой. Основным ограничением является невозможность длительных вычислений, что делает её малопригодной для обучения моделей, но возможна для использования проектирования новых СМО, которые имеют более адаптивную структуру.

Следующей будет рационально проанализировать архитектуру на основе потоковой обработки данных (Streaming ML Architecture). Данная архитектура рассчитана на непрерывную обработку и анализ информации в реальном времени, где данные поступают с высокой частотой, а модель должна немедленно реагировать и адаптироваться под новые события. Основные компоненты:

- источник потока (stream source) — датчики, API, очереди сообщений;

- система потоковой обработки — архитектурный компонент, обеспечивающий непрерывный прием, предварительную обработку и передачу входных данных в режиме реального времени для последующего вывода или обучения модели с минимальной задержкой и высокой пропускной способностью;

- оператор МО-инференса — встраиваемая модель, применяющая предсказания к каждой порции входных данных;

- система хранения состояний — база состояний модели, если применяется онлайн-обучение или стохастические методы;

- система визуализации и оповещений — дашборды, уведомления о событиях или аномалиях.

Далее приводится описание базового принципа работы архитектуры на основе потоковой обработки данных. Данные поступают в поток, проходят через серию операторов трансформации и, в конечном итоге, попадают в компонент, где применяется модель для формирования предсказания. Возможна реализация «online learning» через обновление параметров на лету. Идеально подходит для задач мониторинга и рекомендательных систем в реальном времени. Повышенные требования к задержке и отказоустойчивости. Более сложная организация логирования, отладки и мониторинга качества модели.

Также, стоит обратить внимание на не менее важную архитектуру, ориентированную на хранилище признаков (Feature Store-centric Architecture). Центральным компонентом является хранилище признаков, которое обеспечивает единообразие подготовки и использования признаков на всех этапах жизненного цикла модели от обучения до инференса. Основные компоненты:

- «Feature Store» — централизованная система хранения и версионирования признаков (Tecton, Feast);

- «ML pipeline» — обучение моделей с использованием признаков из «Feature Store»;

- «Serving layer» — слой развёртывания, использующий те же признаки в онлайн-инференсе;

- «Metadata registry» — отслеживает версии признаков, источники и зависимости.

В архитектуре, ориентированной на хранилище признаков, выделены следующие подходы к функционированию. Разделение процессов генерации признаков и использования признаков. Признаки могут вычисляться оффлайн (batch) или онлайн (streaming) и синхронно использоваться как в тренировке, так и в

продакшене. Требует тщательной организации версионирования и контроля схемы признаков.

Архитектура на основе «CI/CD». Интеграция методов «DevOps» в модели МО, где архитектура обеспечивает автоматическое тестирование, валидацию, развёртывание и мониторинг моделей по принципам «CI/CD». Основные компоненты:

- «ML CI/CD» пайплайн — инструменты автоматизации обработки больших данных;

- хранилище артефактов — версии моделей, данных, скриптов;

- модули тестирования качества моделей — «unit»-тесты, тесты производительности и «bias»-тестирование;

- инфраструктура развёртывания — контейнеризация (Docker), оркестрация (Kubernetes);

- «Rollback»-механизмы и канареечные релизы — безопасное развёртывание моделей с контролем поведения.

Принцип работы архитектуры на основе «CI/CD» основывается на следующей логике. Каждое изменение в коде или данных инициирует автоматический запуск пайплайна: обучение модели, тестирование, регистрация и развёртывание с мониторингом.

Еще одним обособленным типом построения средств машинного обучения выступает «Гибридная архитектура (Hybrid ML Architectures)».

В основе гибридной архитектуры лежит модульная декомпозиция на ключевые компоненты, каждый из которых реализован в наиболее эффективной для своей задачи архитектурной форме. Так, задачи подготовки данных и обучения моделей часто реализуются в формате pipeline-архитектуры, где последовательные шаги выполняются с учётом зависимостей. Напротив, инференс и внешнее API взаимодействие реализуются как микросервисы или «serverless»-функции, что обеспечивает низкую задержку, гибкое масштабирование и высокую отказоустойчивость. Гибридная архитектура поддерживает быстрые каналы межмодульного взаимодействия, включая синхронные (REST/rpc) и асинхронные

(event queues: Pub/Sub) интерфейсы, адаптированные под характер данных и требуемую скорость передачи. В качестве основного механизма обмена событиями и артефактами используется транспортная прослойка с поддержкой маршрутизации, сериализации и надёжной доставки. Основные компоненты:

- «Pipeline»-ориентированный модуль (Data & Model Pipeline). Данный модуль отвечает за автоматизацию последовательных этапов функционирования СМО: сбор данных, предобработку, генерацию признаков, обучение, валидацию и идентификацию артефактов. Компонент обладает следующими функциями: декларативное описание и планирование задач в DAG-структуре (ориентированный ацикличный граф), управление зависимостями и версионированием данных и моделей, автоматическое повторное выполнение задач при сбое;

- «Feature Store» (Хранилище признаков). Выполняет функцию централизованного хранилища признаков, обеспечивая их согласованность между этапами обучения и инференса. В архитектуре он служит связующим элементом между pipeline и инференс-модулями. Функциональные особенности: генерация и агрегация признаков как в оффлайн-, так и в онлайн-режиме, контроль версий и совместное использование признаков между командами, минимизация «training-serving skew» за счёт унифицированной логики генерации;

- «Inference API» (Микросервис или Serverless-компонент). Модуль инференса отвечает за предоставление модели как сервиса. Он может быть реализован как: контейнеризованный «REST/gRPC» микросервис, «serverless»-функция, запускаемая по запросу. Особенности модуля: масштабирование по запросу или на основе автоскейлинга, разграничение доступа и авторизация через «API Gateway», логирование каждого запроса и времени отклика;

- система оркестрации и планирования (Scheduler & Controller). Компонент отвечает за координацию задач, планирование переобучения моделей, отслеживание состояния пайплайнов и их запуск по событиям. Функции включают: управление задачами по расписанию и по событиям (например, изменение данных, ухудшение метрик модели), контроль зависимостей между компонентами архитектуры, уведомление и реакция на сбои;

- каналы взаимодействия (Communication Layer). Коммуникация между модулями осуществляется с использованием гибких интерфейсов: «REST API» — для синхронного вызова моделей или сервисов, gRPC — для скрытого взаимодействия между сервисами, «Message Queues» для асинхронного взаимодействия, особенно между потоками данных и инференсом. Такой подход позволяет достичь гибкости масштабирования и устойчивости к сбоям, а также реализовать слабо связанную архитектуру;

- унифицированная система логирования и мониторинга (Observability Layer). Для обеспечения прослеживаемости всех событий СМО используется централизованная подсистема мониторинга, включающая: логирование метаданных выполнения, мониторинг метрик модели, аудит и трассировка вызовов между компонентами.

Принцип функционирования архитектуры: гибридная архитектура строится по принципу функционального соответствия задач архитектурным паттернам. Каждая фаза жизненного цикла модели реализуется в том архитектурном стиле, который наилучшим образом соответствует требованиям к масштабируемости, задержки, воспроизводимости и наблюдаемости. Например, оффлайн-обучение и генерация признаков реализуются в виде планируемых «pipeline»-задач, тогда как онлайн-инференс выполняется в микросервисе с низкой невыраженностью. При этом повторно используемые признаки запрашиваются из общего хранилища признаков, а вызовы сервиса сопровождаются централизованным логированием и сбором метрик. Такое построение СМО позволяет эффективно адаптироваться под конкретные прикладные сценарии, снижать инженерные издержки и повышать надёжность МО-систем. Для того, чтобы сделать полный вывод из вышеописанного анализа типовых архитектур СМО, составим сводную таблицу выделенных типов строения, учитывающую плюсы и минусы каждой архитектуры. В таблице 1, представлена краткая информация о рассмотренных архитектурах, выделены их преимущества и недостатки, в том числе приведены основные типы уязвимостей, к которым склонны данные архитектуры и базовые сценарии применения подобных уязвимостей, а также краткая характеристика каждой архитектуры.

Таблица 1. Сравнение типовых архитектур СМО

Архитектура	Описание	Типовые компоненты	Преимущества	Недостатки	Зрелость (распространенность)	Устойчивость к атакам	Основные типы уязвимостей	Сценарии применения	Характеристики
Монолитная архитектура	Вся логика построения и эксплуатации СМО находится в одном приложении (системе)	Обработка данных, обучение модели, интерфейс ввода/вывода, логика оценки модели, единое хранилище данных	Простота разработки и отладки, хорошо подходит для небольших команд и проектов	Трудности масштабирования, слабая модульность, сложность в обновлении	Средняя	Низкая	Внедрение вредоносного кода, отсутствие изоляции компонентов	Малые и средние проекты, прототипирование	Низкая задержка, плохая масштабируемость, сложное сопровождение, плохая воспроизводимость, минимальная автоматизация, низкая гибкость
Микросервисная архитектура	Архитектура с разделением на независимые сервисы, каждый выполняет свою функцию	Сервис обработки данных, сервис обучения, сервис предсказания, служба мониторинга, система коммуникации между сервисами	Масштабируемость, гибкость, независимое развертывание компонентов	Сложность в координации, повышенные требования к инфраструктуре	Высокая	Средняя	Атаки через API, межсервисное взаимодействие, недостатки аутентификации	Крупные распределённые системы, онлайн модели МО	Средняя/низкая задержка, высокая масштабируемость, хорошее сопровождение, хорошая воспроизводимость, автоматизация средняя, высокая гибкость
Pipeline-архитектура	Процесс разрабатывается как цепочка связанных этапов, каждый шаг изолирован	Компонент очистки данных, компонент преобразования признаков, блок обучения, блок валидации, блок деплоя	Упорядоченность процессов, воспроизводимость, прозрачность	Необходимость строгой оркестрации, задержки при последовательной обработке	Высокая	Средняя	Уязвимость отдельных стадий pipeline, перехват данных в промежуточных шагах	Повторяемые и стандартизируемые задачи ML	Средняя задержка, хорошая масштабируемость, хорошее сопровождение, отличная воспроизводимость, высокая автоматизация

Продолжение таблицы 1

Архитектура	Описание	Типовые компоненты	Преимущества	Недостатки	Зрелость (распространенность)	Устойчивость к атакам	Основные типы уязвимостей	Сценарии применения	Характеристики
Pipeline-архитектура									Средняя гибкость
Serverless-архитектура (FaaS)	Логика обрабатывается как отдельные функции, автоматически масштабируется, вызывается по запросу	Функции предсказания, функции обработки событий, триггеры, временное хранилище, логирование	Отличная масштабируемость, минимальные требования к управлению	Ограничение по времени выполнения, холодный старт, сложно отлаживать	Средняя	Низкая	Открытые конечных точки, невозможность контроля окружения	Реактивные задачи, быстрая обработка запросов, автоматизация	Высокая задержка (при холодном старте), отличная масштабируемость, ограниченное сопровождение, плохая воспроизводимость, автоматизация встроенная низкая гибкость
Архитектура потоковой обработки (Streaming ML)	Обработка входных данных и обучение/предсказание в реальном времени	Потоковая очередь, обработчик потоков, компоненты предобработки, окно агрегации, поток предсказания	Обработка в реальном времени, быстрые реакции, работа с изменяющимися данными	Высокая сложность реализации, проблемы с хранением состояния	Средняя	Средняя	Манипуляции с входным потоком, отравление данных, атаки на обработку очередей	Телеметрия	Низкая задержка, высокая масштабируемость, сложное сопровождение, ограниченная воспроизводимость, средняя автоматизация, средняя гибкость
Архитектура на основе потоковой обработки данных (Streaming ML	Централизованное хранилище признаков используется для обучения и предсказания моделей	Хранилище признаков, обработчик признаков, служба доступа, синхронизация с	Повышение согласованности между обучением и инференсом, повторное	Требует точного контроля версий и синхронизации, инфраструктурные затраты	Средняя	Средняя	Компрометация хранилища признаков, несогласованность версий	Продуктовые системы, часто обновляемые модели	Средняя задержка, хорошая масштабируемость, хорошее сопровождение, отличная

Продолжение таблицы 1

Архитектура	Описание	Типовые компоненты	Преимущества	Недостатки	Зрелость (распространенность)	Устойчивость к атакам	Основные типы уязвимостей	Сценарии применения	Характеристики
Architecture)		моделью, система версионирования	использование признаков	Требует точного контроля версий и синхронизации, инфраструктурные затраты	Средняя	Средняя	Компрометация хранилища признаков, несогласованность версий	Продуктовые системы, часто обновляемые модели	Средняя задержка, хорошая масштабируемость, хорошее сопровождение, отличная воспроизводимость, хорошая автоматизация, средняя гибкость
Архитектура на основе CI/CD	Интеграция автоматических процессов тестирования, обучения и развёртывания моделей	Система контроля версий, тестирование моделей, автоматический деплой, мониторинг, система отката	Высокая автоматизация, стабильность, уменьшение ошибок	Высокая сложность настройки, требует зрелости процессов	Высокая	Высокая	Уязвимости в пайплайне поставки, подмена артефактов, инсайдерские угрозы	Крупные компании, продукты с постоянными релизами моделей	Средняя задержка, хорошая масштабируемость, отличное сопровождение, отличная воспроизводимость, отличная автоматизация, средняя гибкость
Гибридные архитектуры	Комбинация нескольких архитектурных подходов для получения максимальной эффективности	Комбинации компонентов из вышеописанных архитектур: микросервисы, функции, пайплайны, потоковая обработка, CI/CD	Гибкость, адаптивность, возможность выбора лучших практик под задачу	Сложность поддержки и мониторинга, требует высокой квалификации	Средняя	Средняя	Комбинированные уязвимости из разных архитектур, сложности безопасности на границах	Крупные масштабируемые системы, системы с различными типами загрузок	Зависит от реализации, гибкая масштабируемость, сложное сопровождение, переменная воспроизводимость, высокая гибкость

Сравнение типичных архитектур МО показывает, что выбор архитектурного подхода напрямую влияет не только на производительность, масштабируемость и гибкость системы, но и на ее устойчивость к информационным угрозам. Каждая архитектура имеет специфические уязвимости, которые необходимо учитывать при проектировании и эксплуатации.

Монолитные архитектуры просты, но уязвимы из-за отсутствия изоляции: атака на один компонент может повлиять на всю систему. Микросервисные архитектуры повышают масштабируемость и управляемость, но требуют безопасного взаимодействия между компонентами, в противном случае возможны атаки через подмену запросов или внедрение данных. Конвейерные архитектуры удобны для воспроизводимости и автоматизации, но они должны защищать промежуточные данные и модели от подмены.

Бессерверные архитектуры (FaaS) эффективны для масштабируемого логического вывода, но подвержены атакам на триггеры событий и утечкам из облачных сред. Для потоковой передачи СМО требуется защита входных потоков в режиме реального времени, в противном случае возможны искажение данных и задержки. Архитектуры, основанные на хранении функциональных возможностей, уязвимы при недостаточном контроле версий и доступе к функциональным данным. Архитектуры «CI/CD» критически зависят от защиты инфраструктуры развертывания, в противном случае возможна замена модели. Гибридные решения сочетают в себе преимущества, но требуют комплексной защиты на всех уровнях.

Понимание архитектуры МО-систем позволяет точно определить, какие компоненты нуждаются в защите (данные, модели, конвейеры, артефакты, API и журналы). Защита включает шифрование, контроль доступа, проверку целостности и детектирование аномалий. Без этого невозможно обеспечить надежность и доверие к результатам работы моделей. Таким образом, грамотный выбор архитектуры с учетом угроз является необходимым условием для безопасного внедрения машинного обучения в критически важные процессы.

1.2 Обзор отечественных и зарубежных ресурсов, описывающих атаки на средства машинного обучения

1.2.1 Анализ нормативно-правовой базы Российской Федерации в области обеспечения информационной безопасности средств машинного обучения

В соответствии с анализом типовых архитектур СМО становится, очевидно, что обеспечение информационной безопасности ИАС, включающих в себя СМО становится одной из самых актуальных задач 2025 года. Связано это с тем, что в Российской Федерации последние два года активно ведется внедрение технологий искусственного интеллекта, фундаментом которого являются средства машинного обучения. Сначала данный тренд начали вводить коммерческие компании, предлагая различные нестандартные продукты, упрощающие жизнь, как обычных людей, так и различных организаций за счет оптимизации монотонной работы. Последний год внедрение добралось и до государственного сектора, модели машинного обучения, такие как различного рода ассистенты, помощники становятся частью государственных информационных систем. С точки зрения рядовых сотрудников данных организаций это становится неплохим бонусом в виде автоматизации определенных задач, требующих единообразного подхода, что освобождает время для более нестандартных и важных вопросов. Получатся, что СМО и ИИ окружают нас повсюду от коммерческих ритейлов до государственных систем.

Коммерческие организации могут относиться не к каждому человеку, а вот с государственным сектором сталкивается каждый, так или иначе. Наиболее показательным является пример здравоохранения, ведь он касается всех граждан РФ. К тому же, наибольшее количество сведений о введение моделей МО и СМО в открытом доступе можно найти именно о государственной информационной системе здравоохранения. В данном государственном элементе идут процессы модернизации внедрения моделей МО и СМО, таких как: системы поддержки принятия врачебных решений, платформы анализа медицинских изображений, анализ и ведение электронных медицинских карт с виртуальными помощниками, системы для лабораторной диагностики. Перечисленные модели МО вносят огромный

положительный вклад в усовершенствование качества обслуживания пациентов. С помощью виртуальных ассистентов врачи проводят осмотр пациентов, а платформа ведет запись и автоматически переводит его в текстовый формат в карточку, подсказывает верную дозу назначаемых препаратов. Врачам рентгенологам и специалистам клинической лаборатории модели МО анализируют снимки и анализы, автоматизировано предлагая варианты диагнозов, что облегчает и ускоряет принятие врачебных решений. В связи с этими нововведениями становится очевидно, что количество врачебных ошибок будет уменьшаться в геометрической прогрессии при правильной эксплуатации СМО и интерпретации полученных данных. Многие продукты СМО проходят апробацию и через пару лет станут, распространены везде не как что-то уникальное, а как данность. В связи с этим понятен полезный вклад СМО, но что насчет негативных оттенков, особенно с точки зрения обеспечения информационной безопасности? Есть ли нормативно-правовые акты, регулирующие правила использования СМО, как учитывать их в модели угроз, как оценивать риски, связанные с их внедрением, как управлять возникающими уязвимостями, на какие отечественные или зарубежные платформы ориентироваться при разработке мер реагирования на атаки, связанные с СМО? Таких вопросов можно задать много, ниже представим полный анализ существующих платформ и нормативно-правовых баз регулирования атак на СМО.

В первую очередь рассмотрим самый фундаментальный документ в области информационной безопасности «Доктрина информационной безопасности Российской Федерации, утвержденная Указом Президента № 646 от 5 декабря 2016 года» [16], представляющий собой основополагающий нормативно правовой акт стратегического характера, регламентирующий принципы, приоритеты и направления государственной политики в области обеспечения информационной безопасности. Целью Доктрины является защита национальных интересов Российской Федерации в информационной сфере, а также обеспечение устойчивого функционирования инфраструктур, критически значимых для государства и общества.

Документ охватывает широкий спектр угроз, включая информационно-психологическое воздействие, деструктивное влияние на критическую информационную инфраструктуру, распространение деструктивной информации, угрозы суверенитету в информационном пространстве, а также риски, связанные с иностранным технологическим доминированием. Особое внимание уделяется необходимости обеспечения технологической независимости, импортозамещения, развития научно-образовательной базы и совершенствования нормативного правового регулирования в области информационной безопасности.

При этом проведённый научно-технический анализ текста Доктрины позволяет сделать вывод о том, что в её текущей редакции отсутствует прямое упоминание систем ИИ и технологий СМО несмотря на то, что на момент принятия документа уже существовали научные и прикладные разработки в данной области. Ни в разделе, посвящённом актуальным угрозам, ни в частях, описывающих направления государственной политики, ИИ и МО не выделены как самостоятельные объекты защиты или источники потенциальных рисков.

Тем не менее, в ряде положений Доктрины содержатся формулировки, которые могут быть интерпретированы как применимые к системам ИИ и МО. В частности, в разделе 2, определяющем основные угрозы информационной безопасности, указано на возможность нарушения функционирования информационно-телекоммуникационных систем, распространения недостоверной информации, а также использования информационных технологий в целях дестабилизации общественно-политической обстановки. Эти положения потенциально охватывают угрозы, возникающие при использовании генеративных моделей, языковых агентов, нейросетевых средств анализа и принятия решений, особенно в контексте их возможного компрометирования (например, путём внедрения вредоносных данных на этапе обучения, отравления модели, использования backdoor).

Также в Доктрине подчёркивается необходимость развития системы прогнозирования и оценки угроз, что может быть расширено до включения моделей угроз для ИИ-систем, методик аудита моделей МО и инструментов верификации

доверия к ИИ-выводам в автоматизированных системах. Однако данный аспект требует нормативного уточнения и развития методологической базы.

Учитывая вышеизложенное, представляется целесообразным рассмотреть возможность внесения в Доктрину следующих дополнений:

- введение в терминологический аппарат понятий «система искусственного интеллекта», «машинное обучение», «средства машинного обучения», «угрозы безопасности ИИ и СМО»;

- включение в перечень актуальных угроз информационной безопасности рисков, связанных с деструктивным воздействием на системы МО, компрометацией обучающих выборок, манипулированием результатами моделей, нарушением целостности алгоритмических механизмов;

- расширение направлений государственной политики за счёт развития отечественных технологий безопасных моделей МО, включая разработку стандартов, процедур сертификации и методов тестирования устойчивости моделей МО к внешним воздействиям;

- формирование международной позиции Российской Федерации в вопросах трансграничной регламентации и противодействия злоупотреблению СМО.

Следовательно, обобщая все вышеизложенное, в действующей редакции Доктрины информационной безопасности Российской Федерации отсутствует прямое упоминание средств машинного обучения и систем искусственного интеллекта как объектов государственной политики в сфере информационной безопасности. Однако развитие указанных технологий требует пересмотра ряда положений Доктрины с целью адаптации её содержания к новым технологическим реалиям и вызовам. Необходимым представляется нормативное закрепление угроз, специфичных для ИИ и СМО, а также разработка соответствующих мер государственной защиты интеллектуальных систем, включающих их технологическую, алгоритмическую и правовую безопасность.

Приказ Федеральной службы по техническому и экспортному контролю от 11 апреля 2025 года № 117 «Об утверждении Требований о защите информации, содержащейся в государственных информационных системах, иных

информационных системах государственных органов, государственных унитарных предприятий, государственных учреждений» (зарегистрирован в Минюсте России 16 июня 2025 года № 82619) [66] устанавливает обязательные для исполнения правила обеспечения информационной безопасности в государственных информационных системах (ГИС) и информационных системах, эксплуатируемых в организациях государственного сектора. Учитывая тенденцию к активному внедрению ИИ-систем и технологий СМО в контур функционирования ГИС, данный нормативный акт подлежит тщательной технической интерпретации на предмет охвата рисков, присущих интеллектуальным технологиям. Анализ положений приказа свидетельствует об отсутствии в его тексте прямых упоминаний терминологии СМО и ИИ-систем, а также терминов, отражающих специфику функционирования таких систем. В документе не рассматриваются угрозы, характерные для компонентов СМО, включая атаки на этапах обучения моделей, манипулирование входными или обучающими данными, внедрение вредоносных параметров в архитектуру моделей МО, а также риски, связанные с несанкционированным переобучением или подменой моделей в продуктивной среде. В то же время приказ носит универсальный характер и, в силу своей правовой структуры, распространяется на любые технические решения, используемые в рамках, ГИС, включая интеллектуальные модули, при условии соответствующего широкого толкования его положений.

В частности, некоторые требования приказа могут быть интерпретированы как потенциально применимые к ИИ и МО. Таким образом, положения, связанные с контролем целостности программного обеспечения, могут быть расширены до проверки стабильности и неизменности весов моделей МО, стабильности архитектурных параметров и безопасности среды выполнения модели. Требования к контролю доступа и идентификации могут быть адаптированы к интеллектуальным агентам, работающим в ГИС от имени пользователей или административных компонентов. Кроме того, элементы, предназначенные для аудита и регистрации событий, с определенной доработкой могут быть использованы для записи действий, связанных с обучением, модификацией и эксплуатацией моделей МО.

В контексте цифровизации государственного сектора и растущей доли алгоритмически администрируемых решений в системах государственного управления существует объективная необходимость в нормативном учете особенностей безопасности компонентов искусственного интеллекта. Чтобы восполнить обнаруженный правовой пробел, представляется целесообразным инициировать включение в структуру приказа положений, непосредственно регулирующих защиту ИИ, СМО в составе ГИС. В частности, это требует нормативного закрепления процедур оценки алгоритмической стабильности моделей, мониторинга переобучения и обновления компонентов, защиты обучающих и валидационных образцов от заражения и подмены данных, а также фиксации и регистрации логики принятия решений, реализуемой инструментами ИИ и СМО.

Особого внимания заслуживает вопрос обоснованности доверия к результатам, генерируемым модулями МО. В связи с этим целесообразно формализовать требование о наличии механизмов интерпретации и отслеживания решений, разрабатываемых интеллектуальными компонентами в автоматическом или полуавтоматическом режиме. Кроме того, необходимо внедрить механизмы мониторинга целостности архитектуры моделей, фиксации источников используемых данных и осуществления внутреннего контроля за жизненным циклом компонентов СМО (включая этапы разработки, тестирования, внедрения и обновления).

Таким образом, несмотря на общий универсальный охват средств защиты, текущая редакция Приказа № 117 не содержит положений, непосредственно регулирующих защиту ИИ и СМО. В контексте системной интеграции искусственного интеллекта в государственные информационные системы существует юридическая и технологическая необходимость в адаптации нормативной базы с целью учета уникальных рисков, характерных для ИАС, включающих в себя СМО. Дополнение приказа положениями, охватывающими аспекты ИИ и СМО, а также средств защиты, обеспечит надлежащий уровень безопасности, устойчивость к внешним воздействиям, а также мониторинг и обоснованность решений, основанных на алгоритмах машинного обучения, что соответствует целям обеспечения

технологического суверенитета и национальной безопасности Российской Федерации. Данный документ должен быть дополнен разделом, связанным с обеспечением защиты информации, циркулирующей в СМО и ИИ, включенных в состав системы ГИС.

Следующим рассмотрим нормативный правовой акт, имеющий ключевое значение в обеспечении информационной безопасности при обработке персональных данных в автоматизированных системах — «Приказ ФСТЭК России от 18.02.2013 № 21 (в редакции от 14.05.2020) «Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных»» [17].

Настоящий приказ подлежит анализу на предмет наличия в нём положений, прямо или косвенно регламентирующих защиту информации в информационных системах персональных данных (ИСПДн), в состав которых включены компоненты ИИ и технологии СМО. Основанием для такого анализа является повсеместная интеграция ИИ и СМО в процессы обработки персональных данных, в том числе с целью автоматизации принятия решений, предиктивной аналитики, биометрической идентификации и интеллектуальной фильтрации данных. Такие компоненты становятся функционально значимыми элементами архитектуры ИСПДн, обрабатывающими персональные данные в обучающих выборках, в процессе инференции, а также в рамках этапов обучения и актуализации модели.

Исследование содержания актуальной редакции приказа ФСТЭК № 21 позволяет однозначно констатировать отсутствие прямого регулирования специфических угроз и технических аспектов защиты информации, циркулирующей в среде функционирования алгоритмов ИИ и МО. Термины «искусственный интеллект», «нейросетевые модели», «обучающая выборка», «вектор признаков», «данные обучающей выборки», «атакующие воздействия на модель» и иные общепринятые в научно-техническом сообществе категории, касающиеся архитектуры систем машинного обучения, в приказе не упомянуты.

Вместе с тем, отдельные положения документа носят общий характер и могут быть интерпретированы как применимые к ИИ и МО-компонентам при условии их

узкого толкования. Так, раздел, регламентирующий меры по контролю целостности программного обеспечения, может быть потенциально распространён на контроль целостности весов моделей МО, структуры слоёв и параметров гиперпараметров в архитектурах типа «CNN», «RNN», «Transformer» и аналогичных. Меры по обеспечению безопасности среды обработки данных (в том числе изоляция, разграничение прав доступа, контроль событий безопасности) можно применить к защите обучающей выборки, валидационных наборов и конфигураций среды машинного обучения (например, окружения, развернутого на GPU- или TPU-инфраструктуре).

Однако приказ не охватывает следующие критически важные аспекты:

- механизмы оценки защищённости моделей к целенаправленной подмене данных обучения и внедрению вредоносных паттернов, приводящих к непредсказуемым или некорректным результатам функции вывода;

- требования к устойчивости моделей, к восстановлению исходных данных по выходным значениям модели или к определению принадлежности персональных данных к обучающему множеству, что создаёт риск несанкционированного раскрытия персональной информации;

- понятие доверенной модели или хранилища эталонных контрольных сумм весов и архитектур, как также не предусмотрена процедура верификации модели при загрузке или дообучении;

- механизмы журналирования событий жизненного цикла модели, в документе не описаны требования к фиксации операций обучения, дообучения, развёртывания и обновления моделей, что делает невозможным аудит действий с ИИ-компонентом при обработке ПДн.

Для приведения приказа № 21 в соответствие с современными техническими реалиями и актуальными угрозами в ИСПДн, содержащих ИИ-компоненты, представляется обоснованным предложить следующие возможные дополнения.

Во-первых, дополнить терминологический аппарат приказа новыми определениями, касающимися специфики информационных систем ИСПДн, включающих в себя компоненты ИИ и СМО.

Во-вторых, в разделе, посвящённом техническим мерам защиты, закрепить обязательность контроля целостности архитектуры моделей и весов, ведения хэш-реестров параметров модели, применения механизмов песочницы или контейнеризации при инференсе, а также разграничения доступа к модели на уровне API-интерфейсов.

В-третьих, в части защиты каналов передачи и хранения информации зафиксировать обязательность защиты обучающих и тестовых выборок при хранении и передаче с использованием криптографических средств, сертифицированных в соответствии с требованиями ФСТЭК и ФСБ России.

В-четвёртых, ввести требования к реализации механизмов интерпретируемости решений, принимаемых ИИ в автоматическом или полуавтоматическом режиме, а также к фиксации обоснования решений в журнале событий безопасности, в целях реализации принципа юридической определённости и возможности обжалования решений.

Таким образом, в текущей редакции Приказа ФСТЭК № 21 отсутствуют положения, прямо регламентирующие меры по защите персональных данных, обрабатываемых информационными системами ИСПДн, включающими в себя компоненты ИИ и СМО. С учётом интенсивного внедрения интеллектуальных алгоритмов в архитектуру ИСПДн, обеспечивающих автоматизацию решений в отношении субъектов персональных данных, существует объективная необходимость нормативного уточнения документа с учётом архитектурных и уязвимых особенностей подобных систем, что позволит устранить правовой пробел и обеспечить адекватную защиту персональных данных в условиях использования адаптивных интеллектуальных технологий.

Указ Президента Российской Федерации от 15 февраля 2024 года № 124 «О развитии искусственного интеллекта в Российской Федерации» [18] представляет собой стратегический нормативно-правовой акт, определяющий государственную политику в сфере создания и внедрения технологий ИИ в целях обеспечения технологической независимости, повышения конкурентоспособности отечественной экономики и реализации научно-технического потенциала. Указ направлен на

создание условий для ускоренного развития и масштабного внедрения ИИ в приоритетные отрасли экономики и государственного управления, а также определяет принципы и механизмы межведомственного взаимодействия и нормативно-правового регулирования в данной области.

Проведённый правовой и научно-технический анализ содержания Указа № 124 позволяет установить, что, несмотря на комплексный характер рассматриваемого документа, в его положениях отсутствует формализованное и терминологически закреплённое внимание к вопросам обеспечения информационной безопасности СМО, являющихся ключевыми технологическими компонентами систем ИИ. Термины, отражающие угрозы, уязвимости, или меры защиты в отношении ИИ и МО, в тексте указа напрямую не представлены. Не урегулированы такие аспекты, как обеспечение целостности обучающих выборок, устойчивость моделей к атакам, надёжность выводов ИИ-систем, или защищённость контуров их функционирования в составе критически важных информационных систем и государственных цифровых платформ.

В то же время, в пункте 2 Указа обозначена задача по обеспечению условий для развития ИИ на основе безопасной цифровой среды, а также указано, что мероприятия должны реализовываться с учётом национальных интересов в области безопасности. Однако формулировка носит обобщённый характер и не раскрывает содержание понятий «безопасная цифровая среда» применительно к ИИ/МО. Также, в рамках реализации указа предусмотрено формирование единого пространства доверия к ИИ-технологиям, однако без детального раскрытия механизмов обеспечения такого доверия с учётом специфики уязвимостей ИИ-компонентов.

Учитывая системную интеграцию средств машинного обучения в решения, предназначенные для обработки чувствительной информации, принятия управленческих решений, мониторинга критической инфраструктуры и оказания государственных услуг, отсутствие прямого нормативного закрепления требований по их защите представляет собой потенциальный правовой пробел в стратегии развития ИИ. МО как технический метод реализации ИИ-систем подвержено ряду специфических угроз, включая: отравление обучающих выборок, инъекционные

воздействия на модели, утечку информации из обученных моделей, а также подмену параметров на этапе инференции. Данные угрозы не охватываются в рамках традиционных подходов к обеспечению кибербезопасности, и требуют отдельного нормативного внимания.

В целях устранения выявленных пробелов и приведения Указа № 124 в соответствие с актуальными угрозами информационной безопасности в сфере ИИ и МО, представляется обоснованным включение следующих положений в структуру документа.

Во-первых, целесообразно включить в основную часть указа отдельный пункт, посвящённый обеспечению информационной безопасности систем ИИ, с формулировкой, предполагающей разработку и внедрение требований по защите компонентов машинного обучения от целевых атак на модели, обучающие выборки и механизмы вывода, а также нормативное закрепление обязательности оценки доверия к алгоритмам.

Во-вторых, необходимо дополнить положения о формировании нормативной базы указанием на разработку национальных стандартов и методических рекомендаций по обеспечению защищённости архитектур СМО, включая аспекты идентификации уязвимостей, процедур сертификации и аудита моделей.

В-третьих, в рамках задач по формированию инфраструктуры доверия к ИИ, рекомендуется установить требования по обеспечению трассируемости, интерпретируемости и проверяемости решений, принимаемых ИИ-системами, особенно в автоматизированных системах поддержки принятия решений государственного и оборонного назначения. Таким образом, в действующей редакции Указа Президента РФ № 124 от 15.02.2024 положения, прямо направленные на обеспечение информационной безопасности средств машинного обучения, отсутствуют. Указ требует нормативного уточнения и расширения с учётом рисков, связанных с технологической уязвимостью обучаемых алгоритмов и моделей МО.

Национальная стратегия развития искусственного интеллекта на период до 2030 года, утвержденная Указом Президента Российской Федерации № 490 от 10 октября 2019 года [19], является стратегическим документом, определяющим

государственные приоритеты в области создания, внедрения и широкомасштабного использования технологий ИИ в целях повышения конкурентоспособности Российской Федерации, обеспечения экономического роста, научно-технического суверенитета и национальной безопасности.

Стратегия определяет основные цели, принципы и направления государственной политики в области ИИ, включая развитие научно-исследовательской и образовательной базы, поддержку отечественных разработчиков, формирование инфраструктуры хранения и обработки данных, совершенствование нормативного регулирования, а также обеспечение доверия к технологиям ИИ. Одним из ключевых положений документа является признание ИИ технологией общего назначения, которая оказывает преобразующее воздействие на ключевые секторы экономики, государственного управления, обороны и безопасности.

С точки зрения информационной безопасности, Стратегия определяет необходимость обеспечения прав и свобод граждан при использовании ИИ, предотвращения дискриминации, а также предотвращения злоупотреблений при автоматизированной обработке информации. В частности, в пункте 7 указывается на приоритетный характер разработки этических норм, стандартов надежности и прозрачности систем ИИ. В то же время документ не дает формализованного определения информационной безопасности для ИИ и его компонентов, а также не раскрывает категории угроз, специфичных для алгоритмов машинного обучения, таких как компрометация модели, отравление обучающих выборок, подмена параметров, обратное проектирование и другие векторы атак, характерные для адаптивных систем.

В то же время средства машинного обучения, как техническая основа подавляющего большинства современных систем искусственного интеллекта, прямо не упоминаются в тексте Стратегии, но упоминаются в рамках концептуальной основы посредством ссылок на анализ данных, самообучающиеся алгоритмы и интеллектуальные методы обработки информации. Таким образом, положения, касающиеся научных исследований, разработки программных решений,

формирования обучающих массивов данных, а также требования к точности, воспроизводимости и управляемости функционирования ИИ, также могут быть отнесены к СМО как элементу архитектуры систем искусственного интеллекта. В Стратегии подчеркивается необходимость создания нормативно-технической базы, обеспечивающей качество и безопасность технологий ИИ, но конкретные меры по защите жизненного цикла моделей машинного обучения, включая этапы генерации, обучения, тестирования, внедрения и эксплуатации, не определены. Аналогичным образом, отсутствуют требования к проверяемости логики модели, защите от вредоносных инъекций данных, исправлению источников обучающих выборок или оценке устойчивости моделей к некорректным воздействиям.

Принимая во внимание вышеизложенное, следует отметить, что «Национальная стратегия развития искусственного интеллекта до 2030 года» излагает лишь общие подходы к обеспечению безопасности, этики и доверия при внедрении технологий искусственного интеллекта, не рассматривая конкретно принципы информационной безопасности СМО. Обоснованным представляется включение в обновленную редакцию Стратегии норм, направленных на обеспечение устойчивости программных компонентов СМО, защиту обучающих данных от подделок и искажений, реализацию механизмов мониторинга корректности работы моделей в реальном времени, а также разработку методов защиты от внешнего вмешательства, включая инъекционные атаки, подмену данных и внедрение вредоносных паттернов в процессе обучения. Только наличие таких норм позволит создать комплексную, системно организованную среду, способную обеспечить надежное и контролируемое функционирование моделей МО на всех этапах их жизненного цикла.

В завершение проведенного анализа представлен сравнительный обзор действующих нормативно-правовых документов, имеющих отношение к вопросам информационной безопасности СМО. В частности, в таблице 2 обобщены существующие регуляторные положения, а также выявлены ключевые пробелы, препятствующие формированию целостной системы обеспечения доверенного функционирования архитектурных компонентов средств машинного обучения.

Таблица 2. Сравнительный анализ ключевой нормативно-правовой базы по обеспечению ИБ СМО

Название нормативно правового акта	Правовая ориентированность на модели МО и СМО	Регулирование защиты архитектуры моделей МО и СМО	Защита обучающих и тестовых выборок модели МО	Учет и анализ специфических угроз ориентированных на модели МО и СМО	Требования к безопасности жизненного цикла модели МО, аудит	Итоговый вывод о нормативно правовом акте
Доктрина информационной безопасности Российской Федерации, утвержденная Указом Президента № 646 от 5 декабря 2016 года	Стратегический документ, носит общий характер, косвенно относится к модели МО и СМО, нормы адресованы информационно-телекоммуникационным системам.	Не регламентируются, закреплены лишь базовые принципы конфиденциальности, целостности и доступности.	Отсутствуют, защита данных трактуется без учёта этапов обучения моделей МО и СМО.	Угрозы, такие как «poisoning», «adversarial input», «backdoor», не рассматриваются, отсутствует концептуальная идея по защите моделей МО и СМО.	Не регламентированы, аудит моделей МО и не предусмотрен.	Доктрина не ориентирована на специфику обеспечения ИБ моделей МО и СМО. Необходимо добавление отдельного раздела под моделей МО и СМО.
Приказ ФСТЭК от 11 апреля 2025 года № 117	Обязателен для ГИС, модели МО и СМО косвенно относятся к ПО или подсистеме. Точное упоминание моделей МО и СМО отсутствует.	Возможна интерпретация СМО как ПО, но отсутствует контроль весов, гиперпараметров и иной специфики моделей МО и СМО.	Нет положений о защите обучающих датасетов моделей МО и СМО.	Механизмы журналирования касаются только конфигураций государственных информационных систем.	Атаки на обучающие выборки, на модельную логику, инъекции параметров и подмены модели МО не идентифицируются.	Данный документ ориентирован на обеспечение защиты информации, циркулирующей в ГИС, не учитывает модель МО и СМО как один из компонентов. Требуется ввести отдельную категорию угроз моделей МО и СМО, предусмотреть меры контроля доверенных моделей и защиту обучающих данных.
Приказ ФСТЭК России от 18.02.2013 № 21 (в редакции от 14.05.2020)	Обязателен для ИСПДн, но не учитывает аспект того, что модель МО и СМО могут быть средствами обработки ПДн.	Отсутствует контроль алгоритмов предобработки, моделей, этапов инференса, и иной узконаправленности обеспечения защиты информации в ИСПДн, имеющих компоненты СМО.	Учитывается лишь защита ПДн при хранении и передаче, отсутствует положения о защите данных, обрабатываемых СМО.	Не рассматриваются угрозы, связанные с моделью МО и СМО.	Не учитывается обеспечение ИБ на каждом этапе жизненного цикла модели МО.	Не рассматривает направление обеспечения ИБ моделей МО и СМО. В технические мероприятия необходимо включить контроль угроз связанных с моделью МО и СМО.

Продолжение таблицы 2

Название нормативно правового акта	Правовая ориентированность на модели МО и СМО	Регулирование защиты архитектуры моделей МО и СМО	Защита обучающих и тестовых выборок модели МО	Учет и анализ специфических угроз ориентированных на модели МО и СМО	Требования к безопасности жизненного цикла модели МО, аудит	Итоговый вывод о нормативно правовом акте
Указ Президента Российской Федерации от 15 февраля 2024 года № 124 «О развитии искусственного интеллекта в Российской Федерации»	Политико-стратегический акт о развитии ИИ, содержит общие принципы развития ИИ, однако не затрагивает вопросы обеспечения ИБ моделей МО и СМО.	Не содержит информации о регулировании защиты архитектуры моделей МО и СМО.	Обучающие выборки не классифицированы как объект защиты, также как и модели МО и СМО не являются объектами защиты.	Не предусматривается оценка стойкости моделей к специализированным атакам, не учитываются угрозы, связанные с моделью МО и СМО.	Не затрагиваются аспекты жизненного цикла и доверия к модели МО и СМО.	Указ не обозревает моделей МО и СМО. Необходимо включить в регуляторную часть указа обязанность разработки норм по обеспечению ИБ моделей МО и СМО, а также оценке специфичных моделей МО.
Национальная стратегия развития искусственного интеллекта на период до 2030 года, утвержденная Указом Президента Российской Федерации № 490 от 10 октября 2019 года	Долгосрочная стратегия, не содержащая норм прямого действия. Не имеет упоминания моделей МО и СМО.	Термины, связанные с МО не раскрыты нормативно.	Не зафиксированы требования к сохранности обучающих данных модели МО.	Нет описания угроз, характерных для моделей МО, и СМО включая атаки на обучение, целостность модели и влияние на прогнозы вредоносных данных.	Отсутствуют требования по защите информации на каждом этапе жизненного цикла модели МО.	В стратегии прямо не упоминаются СМО как техническая основа подавляющего большинства современных систем ИИ. Следует добавить положения о защите моделей МО, обучающих данных, устойчивости к атакам, контроле жизненного цикла.

1.2.2 Обзор отечественных и зарубежных ресурсов, рассматривающих атаки на средства машинного обучения

Далее осуществляется исследование платформ, ведущих учет атак, связанных с моделями МО и СМО, чтобы определить какие ресурсы существуют на текущее время в области регистрации и анализа инцидентов. Ниже приведено их подробное исследование, а также выделены ключевые преимущества и недостатки.

Первым проводится исследование самой актуальной платформы «MITRE ATLAS» [20]. Наиболее популярным на данный момент является ресурс «MITRE ATLAS», спроектированный корпорацией «MITRE» – ведущим разработчиком стандартов в области информационной безопасности и киберугроз. Платформа «MITRE ATLAS» является структурированной базой знаний, предназначенной для описания, классификации и анализа векторов атак в системах, имеющих компоненты машинного обучения. Его основная цель заключается в обеспечении формализованного подхода к моделированию угроз, при котором затрагиваются компоненты систем защиты: архитектура модели, обучающие данные, алгоритмы предварительной обработки и среды выполнения. Платформа предназначена для специалистов по информационной безопасности, специалистов по обработке данных и архитекторов систем ИИ, предоставляя им инструмент для выявления уязвимостей, оценки устойчивости моделей и разработки механизмов защиты.

«MITRE ATLAS» организован по принципу тактико-технической матрицы, аналогичной «MITRE ATT&CK». Каждая строка матрицы отражает определенную тактику, являющуюся высокоуровневой целью злоумышленника, а столбец содержат конкретные техники, основанные на реальных инцидентах и представляющие механизмы реализации атаки. Каждая методика сопровождается описанием способа реализации и приводятся меры по смягчению последствий каждого инцидента. На практике данный ресурс используется для построения моделей угроз, обоснования требований безопасности к системам МО, а также во время тестирования на проникновение.

Преимущества платформы:

- систематизация знаний об атаках, нацеленных на информационные системы, содержащие компоненты МО и СМО;

- интеграция с «MITRE ATT&CK», платформа разработана в соответствии с теми же принципами, что и «ATT&CK», обеспечивая совместимость с существующими инструментами моделирования угроз и управления инцидентами;

- практическая применимость, приведены конкретные примеры атак, реализованных в реальных условиях и на существующих продуктах крупных компаний;

- поддержка разработки мер защиты: содержится не только описание атак, но и рекомендации по созданию систем обнаружения и реагирования, а также смягчающие меры ликвидации последствий.

Выделены следующие ограничения и недостатки:

- ориентация на западную нормативную и прикладную базу: вся структура «MITRE ATLAS» ориентирована на западные стандарты и законодательные нормы, что ограничивает его применимость в Российской Федерации;

- отсутствие строгой формализации рисков: описаны техники и тактики, но не содержится списка уязвимостей, эксплуатируемых в техниках, из-за чего невозможно провести количественную оценку риска и ущерба;

- отсутствие привязки к конкретным фреймворкам, библиотекам, средствам МО, что усложняет автоматизацию оценки безопасности конкретных реализаций.

В совокупности, «MITRE ATLAS» является ключевым инструментом для формализации, анализа и проектирования систем защиты с помощью машинного обучения. Несмотря на некоторые ограничения, платформа представляет большую ценность для специалистов в области ИБ, работающих на стыке с технологиями МО и СМО. Он служит основой для разработки формализованных политик, сценариев атак и анализа угроз ИАС, включающих в свой состав СМО. Однако данная платформа ориентирована на зарубежные тенденции развития ИБ, законодательную базу США, а также не ведет конкретной базы уязвимостей СМО, которая дала бы возможность провести количественную оценку рисков и построить цепочку действий

злоумышленника, но является отличным фундаментом для создания отечественного ресурса контролирования и учета атак на модели МО и СМО.

«OWASP Top 10 Major Language Models» [67]. В контексте развития правового и технического регулирования в области информационной безопасности систем, использующих СМО, формализация угроз, связанных с функционированием моделей МО, в частности, больших языковых моделей LLM (Large Language Model), имеет особое значение. Одним из международных источников, агрегирующих информацию о наиболее значимых угрозах в этой области, является проект «OWASP Top 10 Major Language Models», разработанный в рамках инициативы «Open Worldwide Application Security Project» (OWASP).

Данный проект представляет собой обобщенную классификацию наиболее значимых угроз и уязвимостей, выявленных в ходе анализа практического применения LLM в различных отраслях. Этот список был составлен на основе сочетания экспертных оценок, анализа инцидентов и практик аудита безопасности и отражает наиболее распространенные и критические проблемы, возникающие при проектировании, обучении, эксплуатации и взаимодействии с языковыми моделями. Целью классификации является формирование устойчивых руководящих принципов для специалистов по ИБ, разработчиков и архитекторов систем ИИ при разработке политик безопасности, проектной документации и определении приоритетов технических мер защиты.

«OWASP Top 10» для LLM не является нормативным документом или интегрируемой автоматизированной платформой, но широко используется в международной практике в качестве справочного и методологического пособия. Его структура аналогична другим проектам «OWASP» (в частности, Top 10 для веб-приложений), что обеспечивает преемственность методологий и облегчает интеграцию в существующие процессы оценки, тестирования и аудита безопасности.

Выделены основные преимущества данного подхода:

- доступность и практическая направленность: платформа является общедоступной и ориентирована на разработчиков, технических специалистов и

специалистов по ИБ, обеспечивая высокую прикладную ценность в реальных информационных системах, включающих в себя компоненты СМО;

- унификация угроз: список угроз систематизирован и структурирован, что облегчает его внедрение в стандарты и политики безопасности, включая процедуры оценки рисков, сертификации моделей МО;

- фокусирование на особенностях LLM. В отличие от более обобщенных классификаций угроз, «OWASP Top-10» для LLM ориентирован конкретно на языковые модели, включая виртуальных помощников, что делает его особенно актуальным в свете растущего использования подобных моделей в государственных и коммерческих секторах Российской Федерации;

- обоснованность регулирования. Платформа может быть использована в качестве источника аргументации при разработке нормативных документов, технических спецификаций и требований.

В то же время «OWASP Top-10» для LLM имеет ряд существенных ограничений, которые влияют на его применение в задачах ИБ:

- отсутствие визуальной модели и количественной оценки рисков. Угрозы представлены в текстовом виде без визуальной схемы, что затрудняет интерпретацию пособия, не содержит функционального математического аппарата, что не дает оценить вероятность, риск и ущерб, а, следовательно, не несет серьезной практической ценности по внедрению в существующие информационные системы;

- ограниченная юридическая применимость: являясь неофициальным проектом без статуса стандарта, методика не может лежать в основе национальных и отраслевых нормативных актов;

- недостаточная техническая детализация: «OWASP Top-10» описывает угрозы на уровне абстракции, без привязки к конкретным платформам и продуктам СМО, что затрудняет автоматическую интеграцию в процессы безопасной разработки. Также рассматривается лишь специфичная LLM-модель, и не берутся иные модели, что делает методику неполной и применимой лишь к одному типу МО;

- ориентация на англоязычную аудиторию: отсутствие официального перевода и адаптации на русском языке ограничивает его практическое использование в

российских организациях, по причине неправильной интерпретации англоязычной терминологии.

Исходя из вышеизложенного, можно сказать, что «OWASP Top-10» для LLM является лишь дополнительным источником информации, который можно эффективно использовать при проектировании модели угроз ИАС, включающей в себя СМО, но не несет в себе серьезную практическую применимость к моделям МО и СМО в целом.

База данных «AI Incident Database (Partnership on AI)» [68]. База данных инцидентов с использованием ИИ (AIID) — это публичный реестр инцидентов, связанных с использованием или нарушением работы систем ИИ, включая модели МО и СМО. В отличие от формализованных технических баз данных, таких как «MITRE ATT&CK» или «CVE», «AIID» фокусируется на практических последствиях использования ИИ, включая нарушения конфиденциальности, целостности, доступности, компрометирующие ошибки предсказаний, ненадежные решения (прогнозы), а также случаи атак, манипуляций и сбоев моделей МО.

Платформа структурирует каждый инцидент в соответствии со следующими параметрами:

- идентификатор события и дата;

- описание контекста атаки и задействованных технологий;

- тип затронутой модели (классификаторы, генеративные модели, прогнозирующие модели, большие языковые модели);

- характер инцидента (ошибки алгоритма, внешние манипуляции, предвзятость, целенаправленные атаки);

- последствия (социальные, юридические, технические);

- источники информации и независимые исследования;

- категории затронутых концепций ИИ (например, безопасность, прозрачность, справедливость).

Таким образом, «AIID» является хранилищем инцидентов, связанных с системами ИИ и моделями МО, возникающих по всему миру. Данная платформа-сообщество позволяет обмениваться данными об атаках. Присутствует

пространственная визуализация классификации инцидентов по затрагиваемым сферам жизни общества (услуги проживания и питания, государственное управление, информатизация и коммуникация и др.), а также атаки демонстрируются в виде табличной матрицы, аналогичной «MITRE ATLAS». В разделе «Объекты» приведена статистика большинства известных производителей программного обеспечения СМО по количеству происшествий нарушения безопасности, которые проградуированы по шкале опасности от незначительного до критичного.

Платформа обладает рядом существенных преимуществ:

- широкий охват и комплексность— AIID охватывает как технические, так и социально-правовые аспекты функционирования ИИ, что позволяет всесторонне рассматривать инциденты;

- открытая проверяемая база данных — каждый инцидент сопровождается ссылками на общедоступные источники, что помогает повысить достоверность информации и возможность проведения независимой экспертизы;

- наличие инструментов категоризации и фильтрации — платформа позволяет систематизировать инциденты по отраслям, типам моделей и типу угроз, что удобно для отраслевого анализа (например, в здравоохранении или финансовом секторе);

- практическое значение — база данных инцидентов может быть использована при обучении специалистов, разработке программного обеспечения и оценке необходимости компонентов МО.

С другой стороны, платформа также имеет ряд недостатков, которые существенно влияют на ее использование в области обеспечения защиты моделей МО и СМО:

- отсутствие формализованной типологии угроз AIID не является классификатором в классическом смысле (как MITRE ATLAS), что затрудняет ее интеграцию в функционирующие организационно-правовые регламенты реальных информационных систем;

- внимание акцентировано на последствия, а не механизмы реализации. Большинство инцидентов описываются через призму результатов (ошибка, распознавание, утечка информации), а не технических деталей механизмов атаки;

- ограниченное географическое распространение. Подавляющее большинство публикаций описывает инциденты, происходящие в англоязычных юрисдикциях, включая США и Великобританию, что снижает применимость данной концепции в рамках законодательства Российской Федерации;

- отсутствие правовой принадлежности — AIID не привязан к международным правовым режимам или нормативным документам (например, GDPR, ISO/IEC 27001), что ограничивает использование материалов базы данных при разработке политик безопасности;

- отсутствие примеров эксплуатируемых уязвимостей, в рамках которых возникал инцидент.

Следует отметить, что база данных AIID является уникальным источником доказанных инцидентов, имеющих высокую практическую и научную ценность для анализа угроз в системах МО. Несмотря на отсутствие строго формализованной структуры угроз, AIID эффективно дополняет технические классификаторы, обеспечивая доказательную базу для анализа, регулирования и разработки механизмов защиты, но не является полностью самостоятельно функционирующем ресурсом для противодействия атакам на СМО.

«AI Vulnerability Database (AVID)» [69]. Одним из перспективных проектов, направленных на решение проблемы атак на СМО, является база данных уязвимостей ИИ (AVID), открытая платформа, предназначенная для структурированного учета режимов сбоев, типов ущерба и потенциальных уязвимостей, присущих моделям ИИ, наборам данных и архитектурам СМО и ИИ в целом.

AVID — это база знаний с открытым исходным кодом, которая объединяет информацию о режимах сбоев, связанных с функционированием систем ИИ и МО.

Платформа включает в себя:

- систематизация типов ущерба, который может быть причинен ИИ, как намеренно (атаки), так и в результате ограничений модели, связанных с обучением;

- развернутые данные инцидента (тип системы, область применения, источник сбоя, контекст);

- описания известных уязвимостей, связанных с наборами данных, процедурами обучения, архитектурой и работой модели;

- рекомендации по устранению уязвимостей, включая технические меры и изменения в организационной политике пользования моделей МО;

- AVID используется в качестве аналитического и регулирующего инструмента для обеспечения безопасности СМО.

Преимущества платформы AVID*:*

- функциональная классификация последствий. AVID систематизирует не только технические сбои, но и этические, репутационные ущербы. Это позволяет охватить широкий спектр рисков, связанных с ИИ, в том числе в области защиты персональных данных и избежать социально компрометирующих ошибок в модели;

- модульная структура и расширяемость. На данный момент платформа только начинает свой путь развития, поэтому содержит мало примеров моделей МО, но является модульной и адаптивной, что делает ее применимой к новым классам моделей;

- открытость и машиночитаемость. База данных организована в виде открытой структурированной информации, что позволяет интегрировать ее в процессы разработки CI/CD, а также использовать в сканерах уязвимостей;

- поддержка рейтингов и сравнений. AVID позволяет проводить сравнительный анализ моделей и наборов данных с точки зрения уязвимостей и воздействий, включая показатели ущерба и степень воздействия.

Ограничения и недостатки AVID:

- недостаточное внимание к целенаправленным атакам. В отличие от MITRE ATLAS, платформа построена не на конкретных механизмах атаки, а на последствиях. Это снижает ее применимость в задачах моделирования сценариев атак и разработки регламентов реагирования и ликвидации последствий;

- ограниченная детализация технических механизмов. AVID больше предназначен для системного анализа инцидентов, чем для технического аудита безопасности конкретных реализаций;

- недостаточная стандартизация. Платформа не имеет статуса стандартизированного реестра уязвимостей, что затрудняет ее прямое использование в функционирующих информационных системах;

- отсутствие прямой интеграции с платформами МО. Несмотря на свою машиночитаемую структуру, платформа не предлагает встроенных инструментов для автоматической проверки уязвимостей в моделях МО.

Обобщая все вышеизложенное, платформа AVID представляет собой важный шаг на пути к созданию централизованной базы знаний об атаках на модели МО и СМО. На данный момент, может использоваться в качестве аналитического источника при построении моделей угроз, формирования правил использования моделей МО, а также в организационно-правовых инициативах по обеспечению надежности. Все главные моменты анализируемой информации о ресурсах, рассматривающих атаки на СМО, обобщены в результирующую таблицу 3.

Таблица 3. Сводная таблица о результатах анализа ресурсов, рассматривающих атаки на СМО

Платформа	Наличие уязвимостей	Описание объекта атаки	Механизмы реализации атаки	Последствия атаки	Описание мер реагирования и ликвидации
MITRE ATLAS	Нет, присутствует описание тактик и техник, но не присутствуют идентификаторы уязвимостей.	Да, рассматриваются модели, входные данные, инфраструктура, пайплайны, окружение (обучение, инференс, хранилища).	Да, каждая техника содержит описание, условия применения, предшествующие этапы и зависимости.	Да, указываются прямые и косвенные последствия атак (нарушение целостности модели, искажение вывода, утечка данных, и др.)	Частично, приводятся лишь меры по смягчению последствий атаки.
OWASP Top 10 Major Language Models	Нет, идентификаторы уязвимостей отсутствуют.	Частично, основной фокус на модели LLM, входных и выходных каналах, окружении, пользовательском взаимодействии.	Частично, есть общие описания сценариев эксплуатации, но без полной детализации тактик и техник. Не производит классификацию техник для их общей систематизации.	Да, указываются последствия: утечка, обход ограничений, некорректные решения,	Частично, приводятся общие рекомендации: изоляция окружения, валидация. Не предложены принципы формирования регламентов реагирования и ликвидации

Продолжение таблицы 3

Платформа	Наличие уязвимостей	Описание объекта атаки	Механизмы реализации атаки	Последствия атаки	Описание мер реагирования и ликвидации
OWASP Top 10 Major Language Models				вредоносный вывод.	ввода, логирование, но нет регламентов
AIID	Неформально, платформа не предоставляет типовых описаний уязвимостей, но фиксирует реальные инциденты, часто связанные с эксплуатацией слабостей	Да, описывают атаки на модели, данные, пользовательские интерфейсы, бизнес-логику и систему в целом.	Частично, некоторые записи включают описание атакующих действий, но большинство являются сводками об инцидентах без механизма реализации.	Да, основное внимание уделено последствиям: ущерб, социальные эффекты, технические неполадки, потери репутации и др.	Редко, отдельные записи могут содержать ссылки на меры из бюллетеней производителя, но системных рекомендаций по реагированию не предусмотрено.
AVID	Да, ведет реестр уязвимостей с указаниями идентификаторов.	Да, рассматриваются модели, датасеты, алгоритмы, МО-инфраструктуры, а также взаимодействие с API.	Нет, акцент на типах получаемого ущерба в рамках инцидента. Подробных схем атак почти нет.	Да, последствия классифицированы по уровням: этический, правовой, технический, эксплуатационный, с указанием метрик и описания ущерба.	Частично, приводятся рекомендации по смягчению вреда, но нет регламентов по реагированию и ликвидации последствий инцидента.

Были проанализированы четыре популярные платформы, которые в реальности функционируют на данный момент и периодически обновляются (кроме, OWASP Top 10 Major Language Models), существуют и иные методические пособия и инструкции, но они либо являются совершенно статичными, либо узконаправленные, выпускаемые производителями СМО, поэтому подробно их рассматривать не рационально.

После изучения ресурсов, ведущих учет инцидентов на СМО, логично изложить основной материал, связанный с реальными базами уязвимостей, содержащими актуальные уязвимости, связанные со СМО.

Базы данных уязвимостей являются ключевыми элементами ИБ, обеспечивающими систематизацию, идентификацию и оценку критичности уязвимостей, связанных с жизнедеятельностью программного и аппаратного обеспечения. В контексте средств машинного обучения особый интерес

представляют пять рабочих платформ: «NVD», «CNNVD», «CISA KEV» и БДУ ФСТЭК России. Ниже приведен сравнительный анализ этих систем с учетом поддержки стандарта CPE (Common Platform Enumeration - стандартизированная система идентификации программного обеспечения) и наличия уязвимостей CMO.

База данных уязвимостей NVD (National Vulnerability Database*),* поддерживаемая Национальным институтом стандартов и технологий США (NIST), является дополнением к системе CVE. Она включает идентификаторы, такие как оценки CVSS, ссылки на шаблоны CWE и активное использование стандарта CPE, который обеспечивает точную идентификацию уязвимых компонентов, таких какфреймворки, библиотеки, программные продукты и платформы. Благодаря этому уязвимости CMO формализованы и могут быть отфильтрованы. Несмотря на отсутствие отдельной категории «Средства машинного обучения», в базе данных зарегистрировано около 60-80 уязвимостей, непосредственно связанных со CMO, что делает NVD наиболее структурированной и технически зрелой платформой в данном направлении.

База данных CNNVD (China National Vulnerability Database) [70], разработанная Национальным центром реагирования на компьютерные инциденты Китая (CNCERT/CC), выполняет аналогичные функции NVD и содержит значительное количество уязвимостей, в том числе заимствованных из CVE. Однако архитектура представления данных структурирована: идентификация уязвимых продуктов осуществляется без явного использования CPE, что снижает точность и усложняет автоматизированный анализ. Присутствуют уязвимости CMO, но их можно отфильтровать только вручную или по ключевым словам. Приблизительное количество таких записей составляет 50, но отсутствие открытого API и механизма категоризации ограничивает использование CNNVD в контексте автоматического анализа уязвимостей.

CISA KEV [71]— это каталог уязвимостей, которые используются в реальных атаках, который поддерживается Агентством кибербезопасности и защиты инфраструктуры США (CISA). База данных содержит только те уязвимости, которые активно используются злоумышленниками и требуют оперативного устранения.

Несмотря на то, что CISA KEV основана на системе CVE и косвенно использует CPE через NVD, идентификаторы явно не отображаются в самой платформе. На момент 2025 года в CISA KEV не зарегистрирована ни одна уязвимость, связанная со СМО.

База данных уязвимостей ФСТЭК России является официальным государственным ресурсом, используемым при аттестации, заверении и контроле безопасности ГИС. В отличие от зарубежных аналогов, в базе данных не используются идентификаторы CPE, названия программных продуктов и версий указываются вручную. Однако база данных содержит уязвимости, связанные со СМО, но эти записи не сгруппированы в отдельную категорию, и поиск по ним возможен только по ключевым словам. Общее количество таких уязвимостей составляет около 20-30, в основном на основе данных CVE и информации из бюллетеней поставщиков. Сводная результирующая таблица приведена ниже (Таблица 4).

Таблица 4. Сравнительная таблица баз данных уязвимостей

База данных	Наличие уязвимостей СМО	Использование CPE	Количество новых уязвимостей за первое полугодие 2025 года	Обновляется на 2025 год	Формализованный поиск уязвимостей
NVD	Да	Да	15	Да, но прекращено спонсирование	Да (по CPE, ключевым словам, тегам)
CNNVD	Уязвимости СМО присутствуют, но явно не выделены и не категоризированы. Данные зачастую требуют ручного анализа.	Формат CPE присутствует, но не применяется формально, автоматизированного поиска нет.	10	Да, но с большой задержкой в несколько месяцев	Нет, формализованный поиск по уязвимостям СМО отсутствует. Поиск возможен только ручным анализом описаний уязвимости.
CISA KEV	Нет	Нет	0	Да	Нет поиска по уязвимостям СМО или тегам, связанным с машинным обучением, не предусмотрено.

Продолжение таблицы 4

База данных	Наличие уязвимостей СМО	Использование CPE	Количество новых уязвимостей за первое полугодие 2025 года	Обновляется на 2025 год	Формализованный поиск уязвимостей
БДУ ФСЭК	Частично содержатся записи об уязвимостях СМО, но они не объединены в отдельную категорию.	Нет, не применяет CPE или аналогичные стандартизированные идентификаторы продуктов. Описания проводятся в свободной текстовой форме.	5	Да, но с задержкой в несколько месяцев.	Частично, возможен поиск, по ключевым словам, CWE, но без формализованных тегов или автоматической фильтрации по типу уязвимости или продукту.

Таким образом, можно сделать вывод, что NVD является наиболее зрелой и применимой платформой для анализа уязвимостей СМО, благодаря поддержке системы CPE, структуре данных и возможностям фильтрации, основанным на платформах машинного обучения, но с 16 апреля 2025 года правительство США прекратило ее финансирование, что приостановило активное обновление данных. Базы данных CNNVD и ФСТЭК содержат соответствующие данные, но без классифицируемого подхода к СМО, что требует дополнительных усилий при их использовании. CISA KEV обеспечивает быстрое реагирование на наиболее опасные уязвимости, но текущая версия не распространяется на СМО.

Обобщая, все вышеизложенное из двух подпунктов данного раздела, можно сделать вывод, что в законодательном поле Российской Федерации отсутствует нормативно-правовая база, ориентированная на обеспечение ИБ СМО. В документах, упоминающих ИИ и СМО, рассматриваются лишь аспекты активного развития и построение систем ИИ, но не учитываются вопросы защиты ИС, в которые они будут включены. Совсем отсутствуют отечественные платформы, ведущие исследования специфики защиты ИАС, включающих в себя СМО, не ведется специальный мониторинг возникающих инцидентов, ведь их описание сможет понять масштаб возникновения атак, связанных с МО и предпринять действия для разработки политики обеспечения безопасности СМО.

1.3 Классификация атак на средства машинного обучения

На основании анализа, проведенного в предыдущих подразделах, становится очевидным, что на данный момент абсолютно отсутствует полный ресурс, конкретизирующий специфику атак на СМО, часть ресурсов лишь описывают реальные инциденты, но не приводят ни уязвимостей, ни конкретных механизмов реализации, другие же описывают способы достижения инцидента, но не предлагают методологию реагирования на атаки, нацеленные на СМО, и ликвидацию последствий. В первую очередь, сложность заключается в том, чтобы агрегировать и систематизировать все данные о реальных инцидентах по каким-либо признакам. Поэтому на сегодняшний день остро стоит вопрос классификации атак на СМО. Ввиду большого ареала распространения технологии, вполне логично, что одним из классификаторов выступает объект защиты. Как отмечают исследователи компании «Сбер» [72], основными объектами при реализации атак на СМО являются: модель МО, программное обеспечение и инфраструктура. Детальная классификация объектов защиты при реализации компьютерных атак на информационные системы, включающие в себя средства машинного обучения, представлены на рисунке 7.

Ввиду того, что реализация атак на средства МО зачастую связана с эксплуатацией уязвимостей программного обеспечения, можно выделить следующие два параметра классификации: механизм реализации атаки, который непосредственно связан со способами эксплуатации уязвимости, и тип ущерба, характеризующегося последствиями реализации атаки.

Как было установлено ранее, в основе классификации атак по механизмам их реализации лежит такой параметр уязвимостей как способ их эксплуатации. Определение механизма зачастую может позволить администраторам безопасности оперативно отреагировать на реализуемую атаку, что, несомненно, позволит свести наносимый системе ущерб к минимальным значениям.

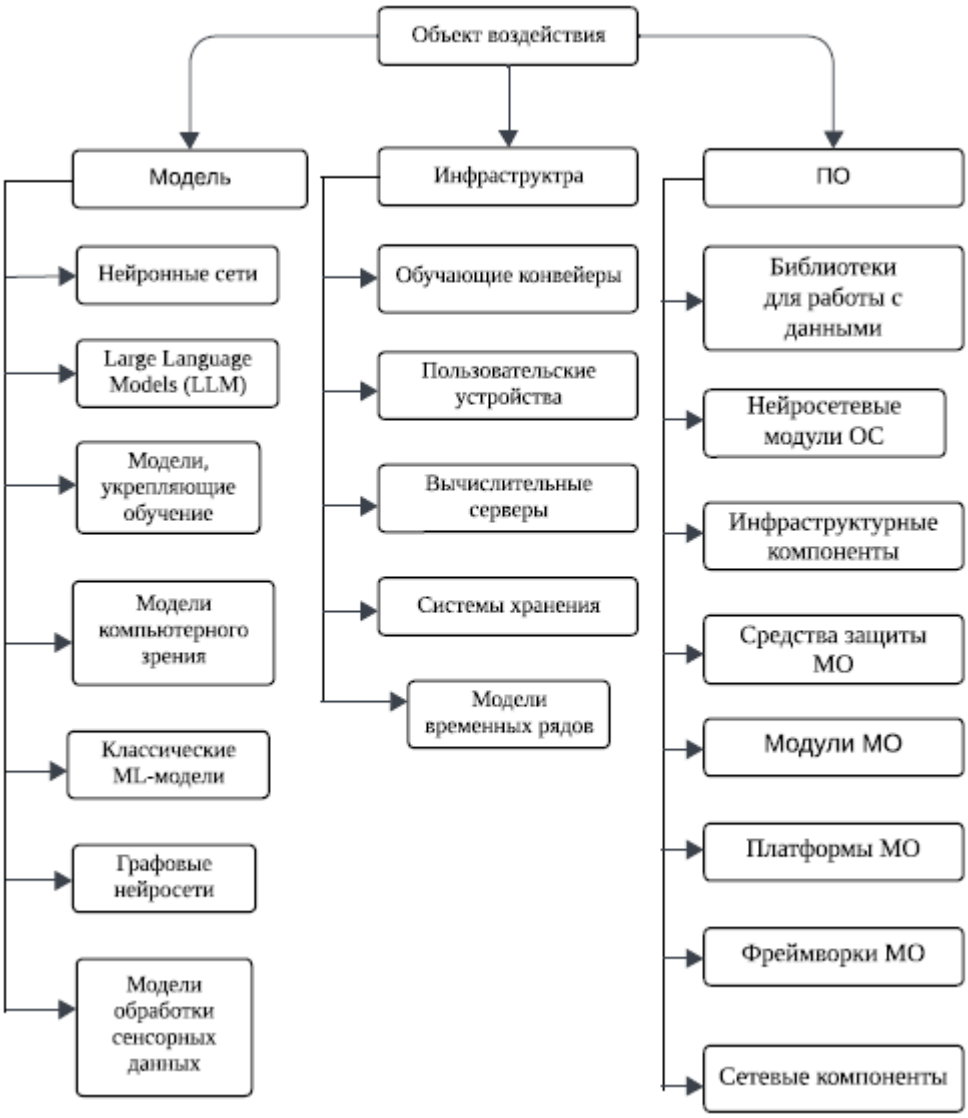


Рисунок 7– Классификация объектов воздействия атак на средства машинного обучения

Классификация атак на средства машинного обучения по механизмам их реализации представлена на рисунках 8 и 9. Изложенная классификация, структурирует известные и потенциальные пути воздействия на СМО по механизмам реализации и их подмеханизмам (конкретным техническим приёмам). Такая двухуровневая структура позволит построить систематизированную базу атак на СМО, которая будет основой для проведения оценки рисков и выработки мер противодействия подобным атакам.

Далее приведено исследование механизма реализации «Нарушение механизмов аутентификации».

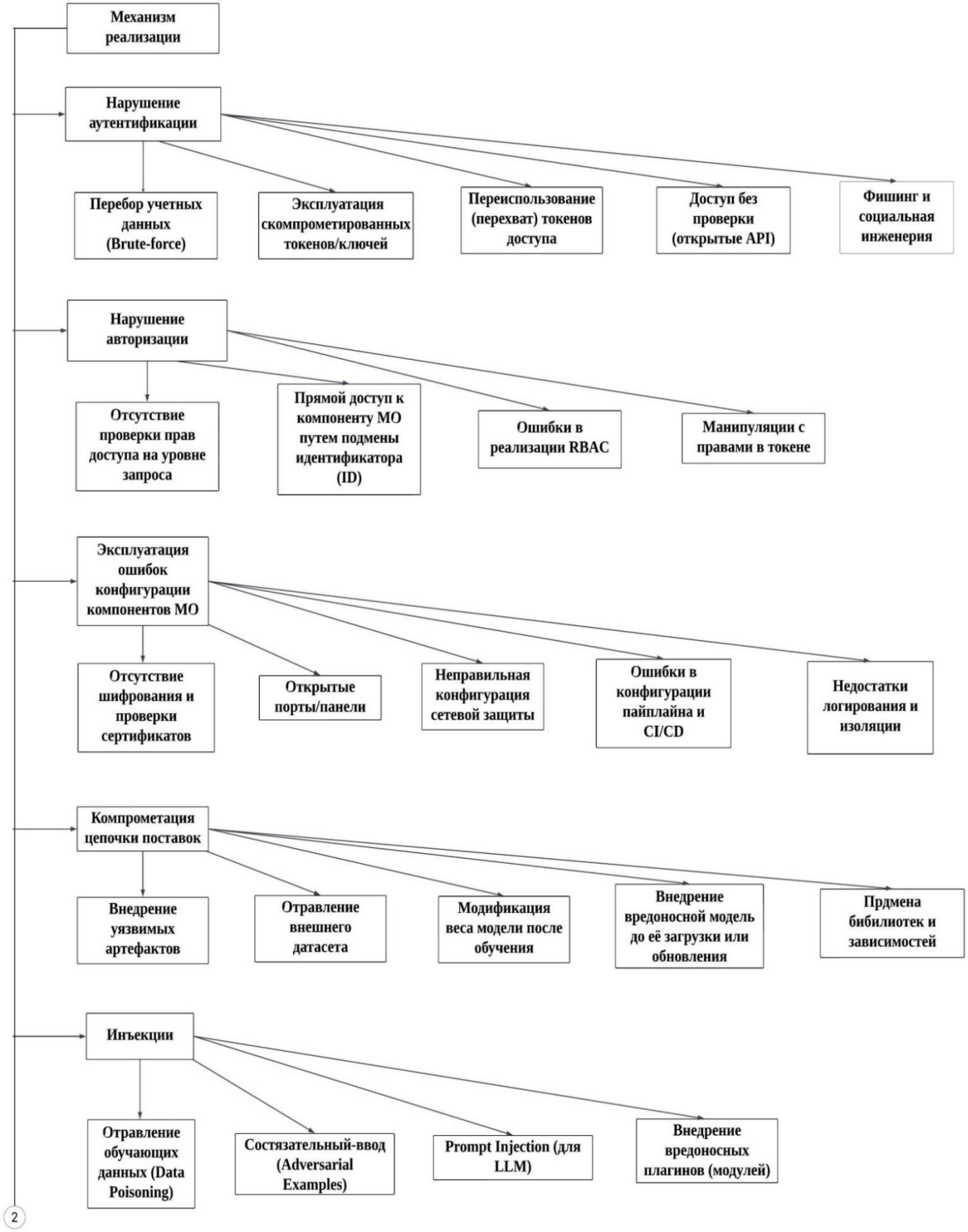


Рисунок 8 - Классификация механизмов реализации атак на средства машинного обучения, часть 1

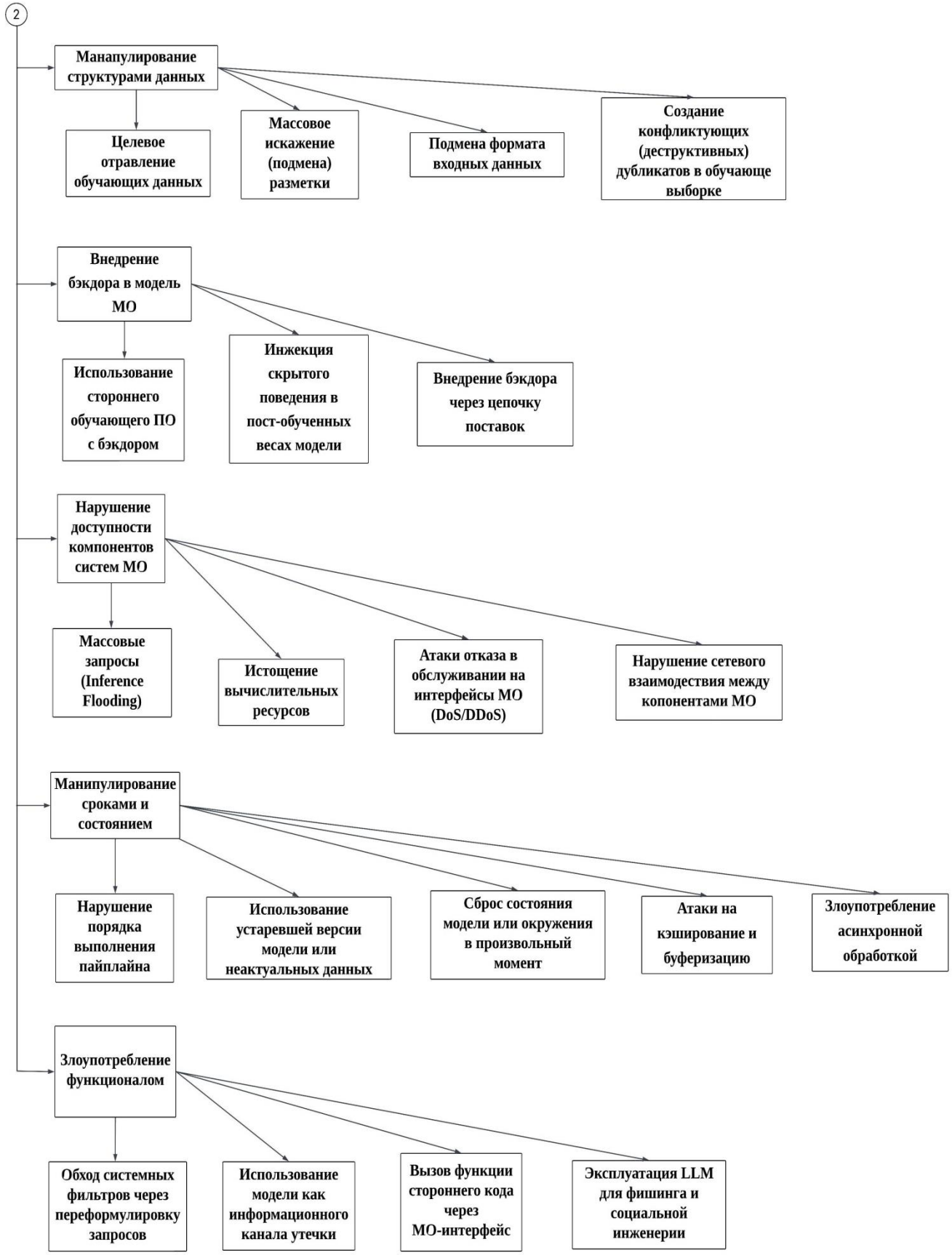


Рисунок 9 - Классификация механизмов реализации атак на средства машинного обучения, часть 2

Первый блок механизмов охватывает ситуации, в которых злоумышленник получает несанкционированный доступ за счёт обмана или взлома механизма аутентификации пользователей. Наиболее распространённые подтипы могут включать в себя:

- перебор учётных данных (Brute-force): использование автоматизированных средств (словарей) подбора логина и пароля;

- эксплуатация скомпрометированных токенов и ключей: применение ранее утекших данных или перехваченных секретов доступа;

- повторное использование токенов: атаки, применяющие перехваченные токены, которые не были удалены после завершения;

- доступ через открытые API: использование интерфейсов, не защищённых (или слабо защищенных) механизмами проверки подлинности;

- фишинг и социальная инженерия: получение доступа к системе путём манипулирования психикой пользователя.

Атаки, реализованные первым механизмом, создают предпосылки для последующего внедрения и компрометации модели МО. Вторым наиболее популярным механизмом реализации атак на СМО выступает «Нарушение механизмов авторизации». Данный механизм включает атаки, в которых нарушитель эксплуатирует слабости в логике разграничения прав доступа:

- отсутствие проверки прав в API-запросах: доступ к функциям без надлежащей проверки на уровне контроллеров;

- подмена идентификатора объекта: прямой доступ к критически важным ресурсам модели путём подмены параметров запроса;

- ошибки в настройке RBAC: некорректная реализация ролевой модели доступа;

- манипуляции с правами внутри токена: подмена или расширение полномочий за счёт изменений в «JSON Web Token» (JWT);

Атаки данного механизма могут позволить атакующему получить доступ к конфиденциальным данным, логам модели или административной панели управления.

Третьим по популярности злоумышленников является механизм реализации «Эксплуатация ошибок конфигурации компонентов СМО». Механизм направлен на использование уязвимостей, связанных с неправильной настройкой элементов инфраструктуры:

- отсутствие (или недостаточное) шифрования (TLS/SSL) и проверок сертификатов: делает возможную дальнейшую реализацию атак типа «человек посередине»;

- открытые панели и незакрытые порты: позволяют получить свободный доступ к компонентам и средствам модели МО;

- ошибочная настройка межсетевых экранов и ACL: делает компоненты видимыми из публичной сети;

- уязвимости CI/CD и пайплайнов: ошибки в скриптах деплоя, использование переменных окружения без защиты;

- недостаточная изоляция и логирование: несанкционированные действия злоумышленника могут остаться незамеченными и распространиться на иные компоненты модели МО и полностью ее парализовать;

- ошибки конфигурации компонентов СМО: часто при развёртывании новых элементов в системах не производится настройка конфигурации, соответствующая функционирующей системы, а остается по умолчанию.

Следующим выделим механизм реализации, являющийся специфичным и ориентированным на модели МО и СМО «Компрометация цепочки поставок». Один из наиболее опасных механизмов, при котором атака закладывается ещё до ввода модели в эксплуатацию:

- внедрение уязвимых артефактов: загрузка преднамеренно слабозащищённых моделей, конфигураций, контейнеров;

- отправка поддельного датасета: злоумышленник подменяет набор данных, включая вредоносные элементы;

- модификация весов модели «post-training»: вмешательство в «checkpoint»-файл;

- интеграция вредоносной модели (закладки) в процессе загрузки: подмена объекта в момент деплоя;

- подмена библиотек и зависимостей: приводит к внедрению вредоносного кода, который может содержаться в компрометирующей библиотеке и осуществляет саботаж работы модели МО.

Пятой по частоте встречающихся механизмов реализации атак на средства машинного обучения выступает «Инъекции». Инъекционные атаки сложны для обнаружения и позволяют получить контроль над выводом модели без нарушения её внешней логики. Механизм инъекций охватывает различные способы внедрения вредоносного содержимого в данные и команды:

- «Data Poisoning»: внедрение искажённых примеров в обучающую выборку;

- «Adversarial Examples»: генерация объектов, вызывающих неправильные предсказания;

- «Prompt Injection»: манипуляции с входными инструкциями в LLM для обхода ограничений;

- инъекция плагинов и модулей: загрузка вредоносных расширений в окружение исполнения модели.

Следующим механизмом реализации атак на СМО злоумышленником выделен тип «Манипулирование структурами данных». Относится к случаям, когда нарушитель изменяет структуру входных или обучающих данных без нарушения их структуры:

- подмена меток (Label flipping): приводит к некорректной функции потерь;

- скрытая подмена содержимого при сохранении структуры: вредоносный объект сохраняет имя и размер;

- модификация схемы данных: изменение порядка колонок, формата или вложенности;

- создание деструктивных дубликатов: вставка конфликтующих записей с разными метками.

Атаки этого класса сложны для детектирования средствами валидации и нарушают фундаментальную корректность обучающих выборок.

Достаточно часто распространенным механизмом определяется «Нарушение доступности компонентов СМО». Целью атак данной категории является выведение из строя отдельных компонентов или всей системы:

- flooding-запросы к API: перегрузка интерфейса модели массовыми обращениями;

- истощение ресурсов (CPU, GPU, RAM): спровоцированные тяжёлыми запросами;

- DoS/DDoS-атаки: классические сетевые воздействия на точки входа;

- нарушение сетевого взаимодействия: подмена DNS, сбои discovery в микросервисах.

Такие атаки реализуются как напрямую, так и через злоупотребление функциональностью LLM и генеративных моделей.

Также, стоит обратить внимание на достаточно интересный и сложно-реализуемый механизм «Манипулирование состоянием и временем». Механизмы реализации атак на СМО, основанные на манипулировании состоянием и временем, представляют собой вмешательство в управление жизненным циклом модели с целью искажения результатов ее функционирования. Типичные причины включают преждевременный запуск логического вывода до завершения этапов обучения или предварительной обработки данных, использование устаревших версий модели и образцов, а также целенаправленный сброс среды выполнения в критический момент. Атаки на кэши и механизмы буферизации, особенно в распределенных или асинхронных конфигурациях, могут привести к ошибкам в логике модели, которые не сопровождаются внешними признаками сбоя. Такие воздействия нарушают предсказуемость поведения и могут использоваться как для маскировки вторжений, так и для дестабилизации системы.

Злоупотребление функциональностью. Механизм злоупотребления функциональностью основан на использовании разрешенных интерфейсов и предоставляемых функций модели в целях, противоречащих ее назначению или политике безопасности. Примеры включают обход фильтрации путем переформулировки запросов, генерацию ответов с утечкой конфиденциальной

информации, выполнение стороннего кода при наличии уязвимостей API и использование моделей (особенно LLM) для создания фишинговых или манипулятивных сообщений. Эти атаки осуществляются без явного нарушения прав доступа и часто не обнаруживаются системами обнаружения, что делает их особенно опасными в открытых или полуоткрытых МО-сервисах. Эффективное противодействие требует комплексного подхода: от контекстной фильтрации до контроля логики выполнения и оценки выходных данных.

Определив тип ущерба, наступающего вследствие реализации атаки, становится возможно грамотно сформировать перечень мер, направленных на ликвидацию последствий. Основой для этой классификации служит Банк данных угроз безопасности информации ФСТЭК России [11]. Классификация атак на средства машинного обучения по последствиям представлена на рисунках 10 и 11.

Одной из ключевых групп последствий является утечка информации, которая может повлиять как на сами обучающие выборки, так и на метаинформацию о процессе обучения, архитектуре и параметрах модели. Разглашение таких данных создает предпосылки для посягательств на частную жизнь, интеллектуальную собственность, а также может привести к несанкционированному воспроизведению модели третьими лицами.

Вторая важная категория — это нарушения функционирования модели, включая ее деградацию, сбои в работе вычислительных ресурсов и генерацию недостоверных результатов, в частности, так называемые галлюцинации в больших языковых моделях. Эти эффекты напрямую влияют на надежность и предсказуемость поведения модели в производственной среде и, как правило, обнаруживаются уже на этапе эксплуатации, когда устранение последствий становится дорогостоящим и сложным. В классификации особое внимание уделяется несанкционированному сбору информации, который реализуется посредством систематического вызова API, синтаксического анализа и агрегирования ответов моделей и может привести как к краже интеллектуальной собственности, так и к сбору конфиденциальных пользовательских данных. Существенным ущербом также является распространение

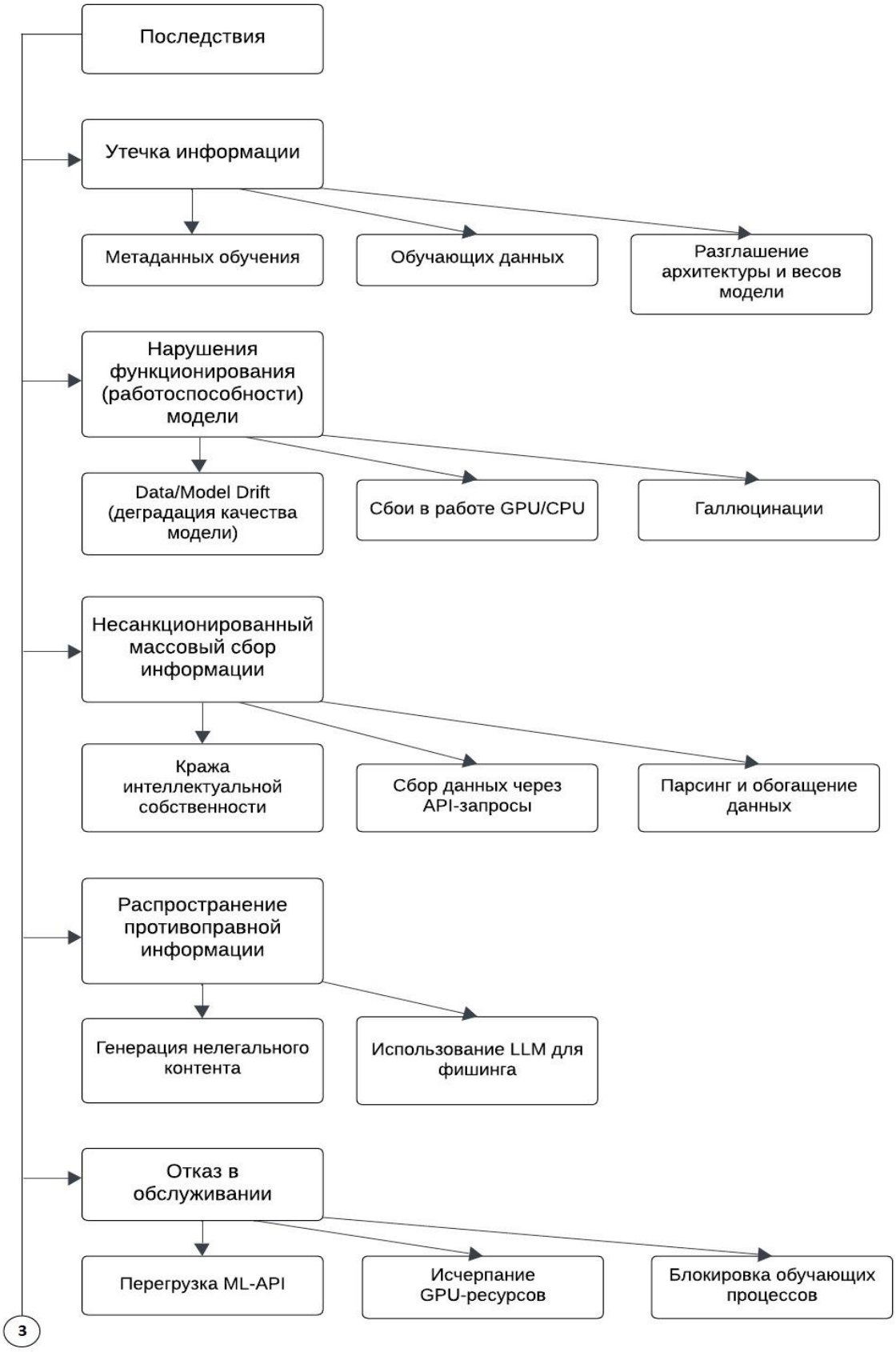


Рисунок 10 - Классификация последствий реализации атак на средства машинного обучения, часть 1

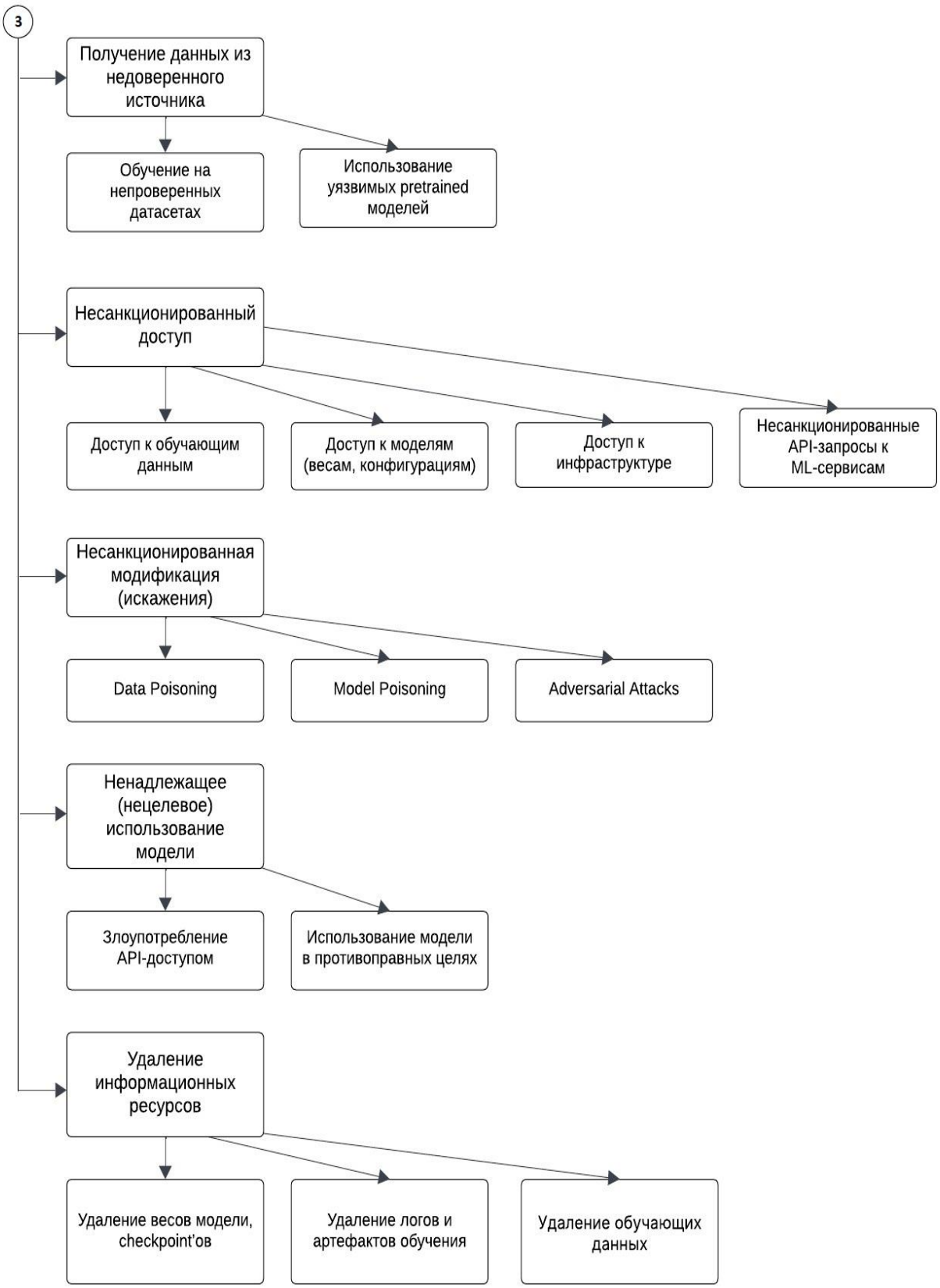


Рисунок 11 - Классификация последствий реализации атак на средства машинного обучения, часть 2

незаконного или вредоносного контента, который может быть создан с использованием модели намеренно или в обход систем фильтрации.

Это включает фишинг, создание вредоносных инструкций, нарушение авторских прав и применение модели в задачах социальной инженерии.

Наконец, классификация охватывает сценарии отказа в обслуживании, которые возникают из-за перегрузки API, истощения вычислительных ресурсов или приостановки обучения. Также рассматриваются потери, связанные с получением данных из ненадежных источников, несанкционированным, злоупотреблением функциональностью API и даже удалением критически важных ресурсов, таких как веса моделей, данные обучения или журналы регистрации.

Распределение последствий по таким областям позволяет не только определить наиболее критические сценарии воздействия, но и определить приоритеты ответных мер. Такая структура может служить основой для оценки рисков (например, AIVSS), построения моделей угроз, а также для разработки архитектуры защитных механизмов, учитывающей не только факт атаки, но и ее потенциальное влияние на стабильность, целостность и надежность о системе машинного обучения.

Таким образом, определив такие параметры уязвимости как способ и последствие её эксплуатации и тип уязвимого программного обеспечения, становится возможно описать множество реализуемых атак в отношении информационных систем, включающих в себя средства машинного обучения. В результате анализа такого множества администратор безопасности сможет грамотно и адекватно сформировать перечень мер по предотвращению, обнаружению, реагированию на компьютерные атаки и ликвидации последствий из реализации.

2 Методическое обеспечение для формирования сценариев атак на средства машинного обучения и риск-анализ процессов их реализации

2.1 Построение множества сценариев атак на средства машинного обучения

В результате данного исследования были проанализированы атаки на средства машинного обучения, в том числе использовалось специально разработанное программное обеспечение для поиска уязвимостей, которые может эксплуатировать злоумышленник на каждом этапе реализации техники атаки. Удалось выделить двадцать семь групп сценариев атак, а далее было определено несколько тысяч конкретных сценариев атак для каждой группы. На основе данной работы построен невзвешенный граф множества сценариев атак на СМО, представленный на рисунке 12. Данный граф может быть интерпретирован как своеобразная «карта» возможных действий злоумышленника, отражающая различные траектории (техники), по которым может развиваться атака в зависимости от целей противника. Использование подобной модели позволяет своевременно выявлять и блокировать действия нарушителя на ранних этапах атаки, до наступления критических последствий. Кроме того, технология обеспечивает возможность предварительной идентификации наиболее приоритетных сценариев атак, характерных для конкретной информационной автоматизированной системы, что способствует повышению эффективности мер защиты.

Построенный граф сценариев атак отражает не только возможные траектории действий злоумышленника в информационной автоматизированной системе (ИАС), включающей компоненты машинного обучения, но и структурные особенности реальной архитектуры защищаемой среды. Такой граф выполняет роль своеобразной "карты" поведения атакующего, отображая, по каким техникам возможны переходы в зависимости от используемых уязвимостей и целей атаки. При этом наличие или отсутствие связей между техниками в графе имеет важное прикладное значение с точки зрения информационной безопасности.

Отсутствие связи между рядом техник объясняется тем, что в условиях конкретной ИАС не все уязвимости поддаются эксплуатации. Это может быть

связано как с техническими ограничениями самой системы, так и с архитектурными особенностями защиты. В частности, в системах, использующих компоненты машинного обучения, могут применяться контейнерные среды исполнения, аппаратная изоляция (например, использование TPU или специализированных GPU), а также микросегментация и контроль межсервисного взаимодействия. Все эти меры существенно снижают вероятность развития атаки от одной техники к другой. Например, даже при успешной реализации одной техники злоумышленник может не иметь возможности перейти к следующему этапу из-за отсутствия нужных условий среды или доступа к определённым компонентам.

Кроме того, эксплуатация уязвимостей в области машинного обучения часто требует специфических подходов и инструментов. Техники атак, направленные на подмену обучающих данных, генерацию «adversarial examples» или проведение «model inversion», имеют ограниченное взаимодействие с классическими техниками, такими как эскалация привилегий или горизонтальное перемещение по сети. Это также обуславливает отсутствие переходов между соответствующими узлами графа.

Важным аспектом при построении графа атак и его интерпретации является количественная оценка риска, связанного с эксплуатацией конкретных уязвимостей. Для этого в современных системах управления уязвимостями применяются различные оценочные модели, включая:

– CVSS 3.1 [74] — базовая система оценки критичности уязвимостей;

– CVSS 4.0 [75] — обновлённая версия с учётом эксплуатационной среды и контекста;

– EPSS (Exploit Prediction Scoring System) [76] — предиктивная модель, оценивающая вероятность эксплуатации;

– AIVSS (AI Vulnerability Scoring System) [77] — специализированный калькулятор для уязвимостей в системах с ИИ и машинным обучением.

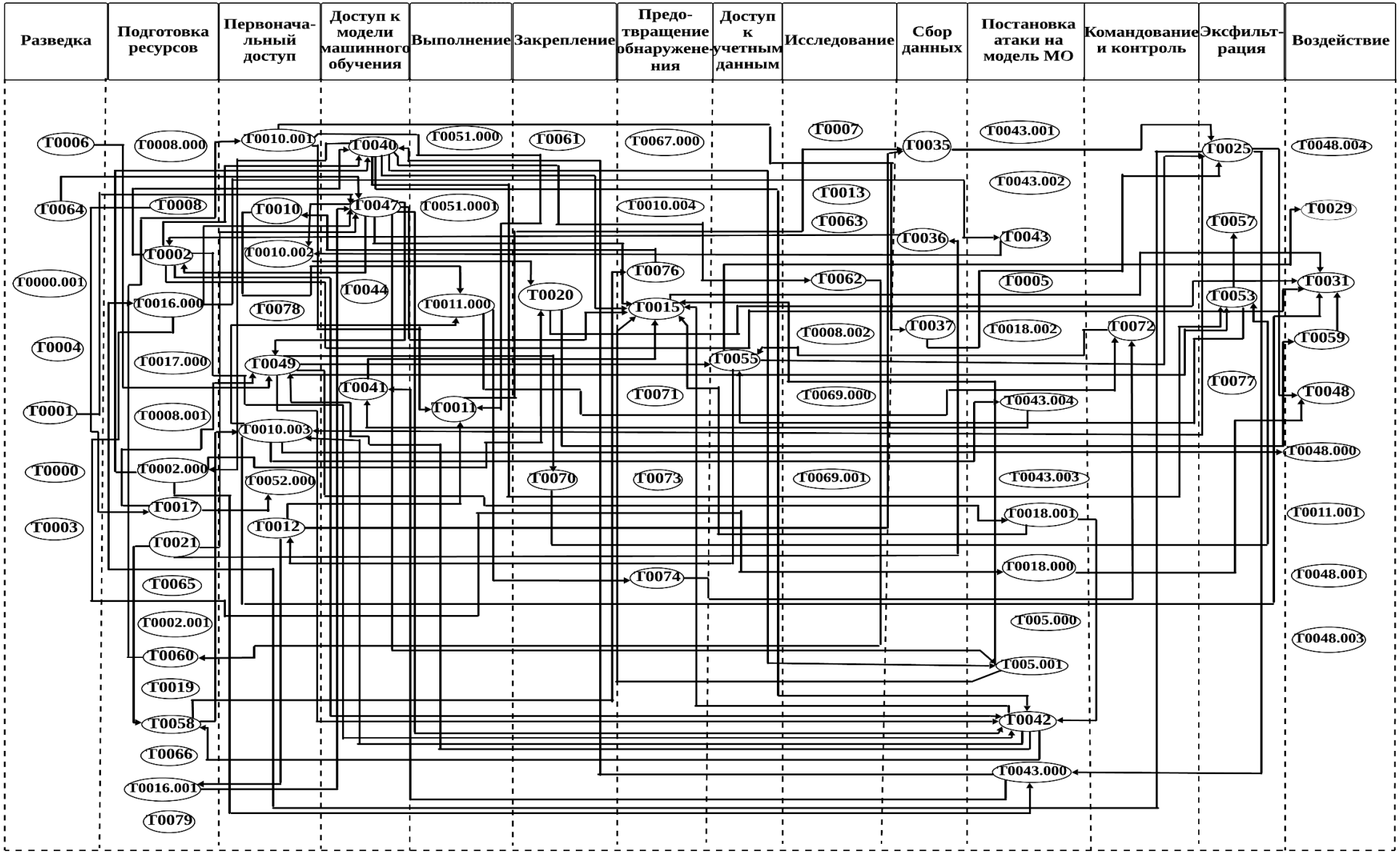


Рисунок 12 – Граф множества сценариев

Результаты анализа показывают, что ряд техник в графе опирается на уязвимости, которые, по совокупной оценке, вышеуказанных калькуляторов имеют низкий уровень критичности. Соответственно, такие техники при последующих расчетах риска демонстрируют минимальную вероятность реализации. Это снижает их практическую значимость при моделировании целостных атакующих сценариев и объясняет отсутствие переходов к другим техникам. Фактически, такие узлы графа являются изолированными не только по топологическим, но и по риск-аналитическим причинам. Структура графа сценариев атак формируется под влиянием как архитектурных ограничений защищаемой ИАС, так и объективной оценки эксплуатационного риска. Комплексный учёт этих факторов позволяет более точно отражать потенциальные пути развития атаки, выделять приоритетные векторы угроз, а также формировать эффективные стратегии реагирования и защиты в условиях использования средств машинного обучения.

Ниже приведены двадцать семь групп сценариев атак на СМО, сформированных на основе реальных инцидентов информационной безопасности и включающих в себя техники, изображенные на графе. Некоторые группы сценариев имеют лишь 2-3 техники, это связанно с тем, что некоторые сценарии были усечены по причине отсутствия уязвимостей для перехода из одной техники в другую, фактически это присутствие уязвимостей «нулевого дня», разработчики и базы данных уязвимостей не знают о их существовании, но злоумышленники, гипотетически нашедшие слабое место, могут активно эксплуатировать данную уязвимость. По этой причине не имеется возможности оценить ущерб, вероятность и риск реализации с подобными уязвимостями, следовательно, в риск-анализе рационально не брать в расчет данные техники и уязвимости, поэтому первоначально будет приведен полный граф группы и усеченный, после поиска уязвимостей. Усеченный граф имеет зарегистрированные уязвимости, поэтому несет реальную угрозу ИАС, включающую в себя СМО.

Группа сценариев атаки №1 «Компрометация LLM-ассистентов для финансового обмана через инъекцию контента и манипуляцию результатами поиска»:

T0006 → T0049 → T0035→ T0055 → T0025→ T0010.003.

Группа сценариев атаки №2 «Обход обнаружения C&C-трафика через атаки на модель глубокого обучения средствами состязательных примеров»:

Полный граф: T0000.001 → T0049 → T0005→ T0043.003 → T0042 → T0015;

Усеченный граф: T0049 → T0042 → T0015.

Группа сценариев атаки №3 «Манипулирование DGA-доменами для обхода систем на основе МО»:

Полный граф: T0000→T0002→T0017.000→T0043.001→T0042→T0015;

Усеченный граф: T0002 → T0042 → T0015.

Группа сценариев атаки №4 «Манипуляция обучающими данными в системах анализа вредоносного ПО»:

T0016.000 → T0043 → T0010.002 → T0020.

Группа сценариев атаки №5 «Зеркальное проникновение: подмена лиц в системах аутентификации»:

T0016.001 → T0016.000 → T0021→ T0047 → T0015.

Группа сценариев атаки №6 «Манипуляции и репликации моделей машинного перевода через API и публичные данные»:

T0002.000 → T0040 → T0005.001 → T0015 → T0031.

Группа сценариев атаки №7: «Нарушение безопасности ML-инфраструктуры из-за неправильной настройки и контроля доступа»:

T0021 → T0036 → T0002 → T0031.

Группа сценариев атаки №8 «Атаки на модели фильтрации спама с использованием прокси-моделей»:

Полный граф:

T0063 →T0047 →T0005.001 →T0043.002 →AML.T0015;

Усеченный граф:

T0047 → T0005.001→ T0015.

Группа сценариев атаки №9 «Атаки на целостность моделей разговорных агентов через обучение с подкреплением вредоносным контентом»:

T0047 → T0010.002 → T0020 → T0031.

Группа сценариев атаки №10 «Комбинированная атака на модель ИИ с доступом к API и прямой эксфильтрацией»:

T0012 → T0035 → T0025 → T0043.000 → T0040 → T0042 → T0015.

Группа сценариев атаки №11 «Модификация моделей ИИ в мобильных приложениях с внедрением управляющих бэкдоров»:

T0018.001 → T0042 → T0010.003 → T0043.004 → T0041 → T0015.

Группа сценариев атаки №12 «Оптические атаки на модели идентификации в физической среде»:

T0012 → T0040 → T0002.000 → T0043.000 → T0041 → T0015.

Группа сценариев атаки №13 «Обход облачных моделей ИИ в антивирусной защите»:

T0001 → T0047 → T0002.000 → T0042 → T0015.

Группа сценариев атаки №14 «Злоупотребление доверенными источниками в поставках ML-библиотек»:

T0010.001 → T0037 → T0025.

Группа сценариев атаки №15 «Компрометация LLM-приложения через инъекцию подсказок и выполнение сгенерированного кода»:

T0001 → T0047 → T0042 → T0049 → T0053 → T0055 → T0029.

Группа сценариев атаки №16 «Исполнение в облаке: атака через интерактивные окружения»:

T0010.001 → T0012 → T0011 → T0035 → T0025 → T0048.

Группа сценариев атаки №17 «Компрометация цепочки поставок моделей искусственного интеллекта через отравление весов LLM»:

T0018.000 → T0042 → T0058 → T0010.003 → T0031.

Группа сценариев атаки №18 «Атаки через поддельные зависимости и ложные пакеты, вызванные галлюцинациями больших языковых моделей»:

T0040 → T0062 → T0060 → T0010.001 → T0011.001.

Группа сценариев атаки №19 «Самораспространяющиеся атаки на системы генерации с расширенным контекстом (RAG)»:

Полный граф: T0040 → T0051.000 → T0053 → T0051.001 → T0061 → T0057 → T0048.003;

Усеченный граф: T0040 → T0053 → T0057.

Группа сценариев атаки №20 «Отравление данных в масштабе сети: атаки с разделением представления»:

Полный граф: T0002.000 → T0008.002 → T0020 → T0019 → T0059 → T0031

Усеченный граф: T0002.000 → T0020 → T0059 → T0031.

Группа сценариев атаки № 21 «Неправомерный доступ к подключаемым модулям через инжектированный промпт»:

Полный граф: T0064 → T0047 → T0069.000 → T0069.001 → T0066 → T0065 → T0049 → T0068 → T0070 → T0071 → T0051.001 → T0053 → T0067.000 → T0048.000

Усеченный граф: T0064 → T0047 → T0049 → T0070 → T0053.

Группа сценариев атаки № 22 «Атака через поддельные учетные записи в репозиториях моделей»:

T0021 → T0058 → T0010.003 → T0011.000 → T0074 → T0072 → T0055 → T0025 → T0016.000 → T0018.000 → T0048.

Группа сценариев атаки № 23 «Атака на жизненный цикл модели МО через уязвимые контейнерные реестры»:

T0049 → T0018.000 → T0018.001 → T0015.

Группа сценариев атаки № 24 «Непрямая инъекция подсказок и эксфильтрация данных через доверенные каналы визуализации:

Полный граф: T0065 → T0008 → T0017 → T0049 → T0051.001 → T0077 → T0048.003;

Усеченный граф: T0008 → T0017 → T0049.

Группа сценариев атаки № 25 «Кража и монетизация LLM-ресурсов через облачные среды»:

T0049 → T0055 → T0012 → T0016.001.

Группа сценариев атаки № 26 «Эксплуатация десериализации моделей ИИ для удалённого выполнения кода»:

T0058 → T0076 → T0010 → T0011.000 → T0072.

Группа сценариев № 27: T0002(CVE-2023-3765) → T0016(CVE-2024-1879) → T0017(CVE-2017-16066) → T0015(CVE-2024-2928) → T0049(CVE-2023-39660) → T0053(CVE-2024-1560) → T0070(CVE-2019-10844) → T0054(CVE-2024-2057) → T0055(CVE-2018-7577) → T0037(CVE-2024-31583) → T0036(CVE-2020-15206) → T0035(CVE-2024-23752) → T0018(CVE-2024-5452) → T0057(CVE-2025-47277) →T0059(CVE-2023-39659) → T0029(CVE-2025-47777) → T0031(CVE-2024-25723).

В следующем разделе будет построена модель для каждой группы сценариев и рассмотрены наиболее критичные сценарии из каждой группы, имеющие высокий риск реализации и наибольший ущерб. А также определены предусловия для перехода злоумышленника из одной техники в другую для наиболее критичного сценария по каждой группе.

2.2 Оценка риска реализации наиболее критичных сценариев атак по каждой выделенной группе сценариев

Так как в результате исследования в выделенных группах насчитываются тысячи сценариев реализации атак, будут рассмотрены наиболее показательные примеры, демонстрирующие эффективность разработанного методического обеспечения.

Риск-оценка соответствующих выделенных сценариев атак производится с использованием ниже представленного математического аппарата.

Оценка вероятности успешной реализации уязвимости по формуле (1).

$$P_{ij} = \frac{\overline{k_i}}{\sum_{j=1}^{n} \overline{k_{ij}}}, \quad (1)$$

где p_{ij} - вероятность реализации атаки i-м вектором на j-ую уязвимость, k_i - оценка критичности i-й уязвимости, n – общее количество уязвимостей.

Оценка ущерба атаки вычисляется по формуле (2).

$$u_{ij} = 1 - (1 - u_{к})(1 - u_{д})(1 - u_{ц}), \quad (2)$$

где u_{ij} - ущерб реализации атаки i-m вектором на j-ую уязвимость, $u_{к}$, $u_{ц}$, $u_{д}$ - воздействие на конфиденциальность, целостность, доступность.

Из оценок (1) и (2) риск рассчитывается по формуле (3).

$$Risk_{ij} = p_{ij} u_{ij}. \quad (3)$$

Оценка критичности уязвимости выстраивается с помощью использования четырех калькуляторов: CVSS 3.1, CVSS 4.0, EPSS, AIVSS. Если первые три калькулятора являются достаточно распространенными и универсальными для оценки любых уязвимостей, то калькулятор AIVSS используется конкретно для оценки уязвимостей средств машинного обучения и учитывает специфику данной направленности, вводя специализированные метрики, например: MR (надежность модели), DS (чувствительность данных), DC (критичность решения), LL (уязвимости жизненного цикла), AA (подверженность методам состязательных атак). Ниже более подробно приведем описание калькулятора AIVSS.

AIVSS стремится устранить ограничения традиционных моделей оценки уязвимостей, таких как CVSS, которые не учитывают специфические особенности архитектур и угроз в ИАС, включающих в себя СМО, и систем ИИ. К таким особенностям могут относиться: зависимость от данных и моделей, возможность атаки во время обучения, неустойчивость к вмешательству в процесс вывода, угрозы, связанные с манипулированием функциями, и ограниченная воспроизводимость. В отличие от универсальных систем оценки уязвимостей, AIVSS включает метрики, охватывающие этапы сбора данных, обучения модели, проверки достоверности, развертывания и логического вывода. Это важно, поскольку уязвимости могут возникать как на этапе подготовки данных, так и во время работы модели. AIVSS учитывает угрозы, связанные с заражением данных, внедрением помех и изменениями в распределении. Эти типы атак характерны только для систем,

включающих в себя СМО, но практически не рассматриваются в CVSS, также включает категории уязвимостей, связанных с архитектурой модели, утечкой информации о модели (инверсия модели, извлечение) и способностью модели к атакам с помощью градиентных методов (например, примеры состязательности).

Специфичные метрики калькулятора AIVSS, агрегируются следующей формулой (4).

$$AISM = [MR \times DS \times EI \times DC \times AD \times AA \times LL \times GV \times CS] \times MCM, \quad (4)$$

где MR (Надежность модели) - оценивает устойчивость системы к враждебным атакам и ухудшению качества СМО; DS (Чувствительность данных) - оценивает риски, связанные с конфиденциальностью, целостностью и происхождением данных, используемых системой ИИ, моделью МО или СМО; EI (Этические последствия) - учитывает потенциальные предубеждения, проблемы прозрачности, подотчетности и влияния на общество; DC (Критичность принятия решений) - измеряет потенциальные последствия неправильных или злонамеренных решений, принимаемых системой; AD (адаптивность) - оценивает способность системы адаптироваться к меняющимся угрозам и поддерживать безопасность с течением времени; AA (Защита от агрессивных атак) - оценивает подверженность системы различным методам агрессивных атак; LL (Уязвимости жизненного цикла) - рассматривает риски безопасности на разных этапах жизненного цикла системы искусственного интеллекта, GV (Управление и валидация) - оценивает наличие и эффективность механизмов управления и процессов валидации, CS (Cloud Security Alliance LLM Taxonomy) - устраняет конкретные угрозы для LLM в облачных средах в соответствии с таксономией угроз CSA LLM; MCM - коэффициент, который корректирует оценку показателей, специфичных для моделей МО или СМО, в зависимости от сложности проектируемой системы (в диапазоне от 1,0 для простых моделей до 1,5 для очень сложных моделей).

Также стоит обратить внимание, что калькулятор AIVSS поддерживает контекстно-зависимую оценку рисков, что позволяет адаптировать его к различным

типам сред ИИ, моделей МО и СМО: от классификаторов изображений до языковых моделей и систем рекомендаций. AIVSS представляет собой важный инструмент в развитии методов обеспечения безопасности ИАС, включающих в себя СМО. Благодаря тому, что в нем основное внимание уделяется особенностям архитектур СМО и угрозам, он позволяет проводить более точную оценку рисков, соответствующую контексту машинного обучения, по сравнению с универсальными калькуляторами оценки критичности уязвимостей.

Также в данном риск-анализе будет использоваться дополнительная формула (5) вероятности для уязвимостей, которые имеют эксплойт.

$$p_i = \frac{k_i\,(1 + \alpha)}{\sum_{i=1}^{n} k_i\,(1 + \alpha)}, \tag{5}$$

где $\alpha = \{0{,}91; 0{,}94; 0{,}97; 1\}$ в соответствии с метрикой Exploit Code Maturity (E) CVSS v 3.1 для уровней Unproven (U - недоказанный), Proof-of-Concept (POC/P – подтвержденный концепцией), Functional (F – функциональный), High (H – высокий уровень).

В приведенной выше формуле введен добавочный коэффициент для оценки вероятности реализации уязвимость атакующим в средствах машинного обучения α, соответствующий показателю зрелости кода эксплойта (E) из CVSS версии 3.1. Использование этой метрики рационально, поскольку она отражает зрелость и доступность инструментов эксплуатации (эксплойтов), что существенно влияет на вероятность атаки. Коэффициент α увеличивает вес уязвимостей, для защиты от которых существуют готовые, проверенные или широко распространенные эксплойты, поскольку использование таких уязвимостей требует от злоумышленника меньших затрат и технических условий. Это отражает практическую тенденцию: наличие эксплойта значительно повышает вероятность того, что уязвимость будет использована при реальной атаке, по сравнению с уязвимостью, которая требует создания нового или неподтвержденного кода. Добавление коэффициента α дает возможность количественно оценить степень оперативной готовности, повышая

точность оценки рисков за счет учета практической доступности средств атаки, что особенно важно в контексте сложных и уязвимых к подмене данных или вмешательству в СМО.

Математический аппарат был сформирован, далее будет осуществляться непосредственный риск-анализ наиболее критичных сценариев по каждой из выделенных групп.

Для 1 группы определены предусловия злоумышленника, которые он должен получить в рамках действий одной техники, чтобы иметь возможность перейти в другую (Таблица 5). Это необходимо знать для того, чтобы понимать кого спектра будет пытаться искать атакующий уязвимости в системе.

Таблица 5. Предварительные условия для перехода в технику для группы сценариев №1

Предварительные условия	Техника	Последствия
LLM-сервис доступен по внешнему адресу (например, открыты порты TCP 443/80, 8443); WAF отключён или работает в режиме monitor-only, или имеет неверно настроенные правила; отсутствует rate-limiting на discovery-запросы.	T0006: Активное сканирование	Карта открытых портов, версий веб-фреймворков, списков эндпоинтов и обнаруженных CVE; идентифицирована уязвимая точка входа.
Подтверждённая уязвимость в публичном эндпоинте; получены данные о параметрах запроса для delivery payload.	T0049: Эксплуатация приложений с публичным доступом	Неавторизованный доступ к API LLM-модели или к контейнеру с моделью; возможность отправлять несанкционированные промпты и перезаписывать системные инструкции, конфигурации.
Привилегированный или контейнерный доступ к файловой системе, сервису хранилища модели, обучающих данных.	T0035: Сбор артефактов МО	Изъяты веса модели, токены, файл промпт-инжекции, журналы запросов-ответов; получен инсайд о поведении модели и потенциальных ответах.
Логи и артефакты содержат строки подключения, переменные окружения, кеш аутентификации	T0055: Доступ к незащищённым учётным данным	Извлечены API-ключи облачного векторного поиска, токены OAuth, административные учетные данные; обеспечена эскалация прав и долговременный скрытый доступ
Наличие чувствительных данных модели и действительных учётных сведений; открыт исходящий трафик.	T0025: Эксфильтрация через киберсредства	Артефакты и учётные данные переданы на внешние хосты; утрата конфиденциальности, предпосылки к массовым фишинговым или мошенническим кампаниям с использованием скомпрометированной LLM.

Для группы сценариев №1 определен наиболее критичный сценарий атаки: T0006(CVE-2023-2617) → T0049(CVE-2023-39660) → T0035(CVE-2024-23752) → T0055(CVE-2018-7577) → T0025(CVE-2023-6014). Модель сценария продемонстрирована на рисунке 13. Проведена оценка критичности выявленных уязвимостей (Таблица 6), а следующим этапом на основании данных из таблицы 6 рассчитана вероятность эксплуатации данного сценария, сумма ущербов и риск (Таблица 7).

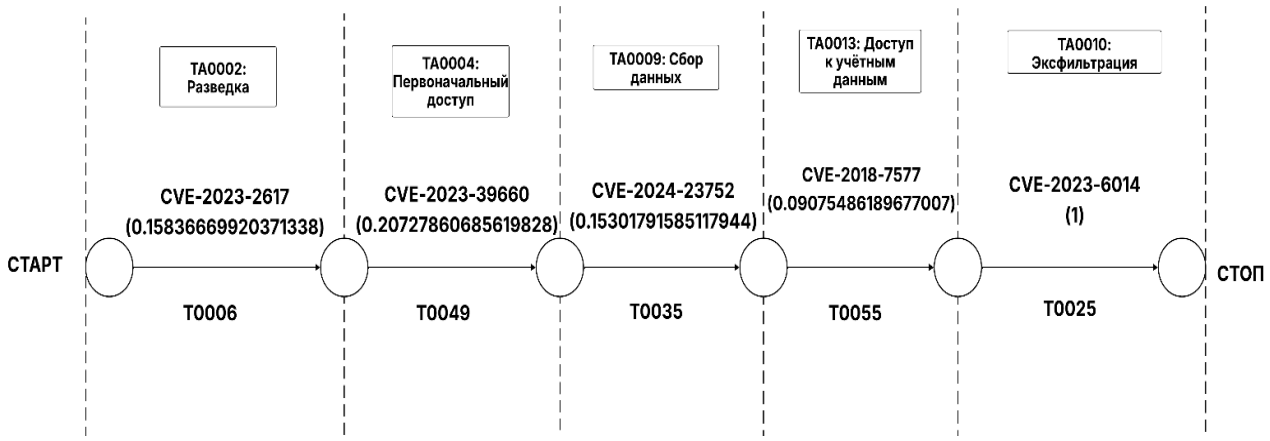


Рисунок 13 – Модель сценария №1 с наибольшим риском

Таблица 6. Критичность уязвимостей для сценария с наибольшим риском для группы №1

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0006: Активное сканирование	CVE-2023-2617	5.3	6.9	0.4	0.3733750625	0.5541382403461
T0049: Эксплуатация приложений с публичным доступом	CVE-2023-39660	9.8	9.3	0.63	0.3949690625	0.862090588368319
T0035: Сбор артефактов МО	CVE-2024-23752	9.8	9.3	0.505	0.3861490625	0.84846896947103
T0055: Доступ к незащищённым учётным данным	CVE-2018-7577 (Есть эксплойт)	8.1	7	0.166	0.174190375	0.693248036587888
T0025: Эксфильтрация через киберсредства	CVE-2023-6014	9.8	9.3	0.842	0.2130730625	0.913969395164871

Таблица 7. Оценка риска для сценария с наибольшим риском для группы №1

Произведение вероятностей	Сумма ущербов	Риск
0,000456	3.5750	0,00163

Также в таблицах 8 и 9 приведены сценарии для данной группы с наибольшим ущербом, схема представлена на рисунке 14.

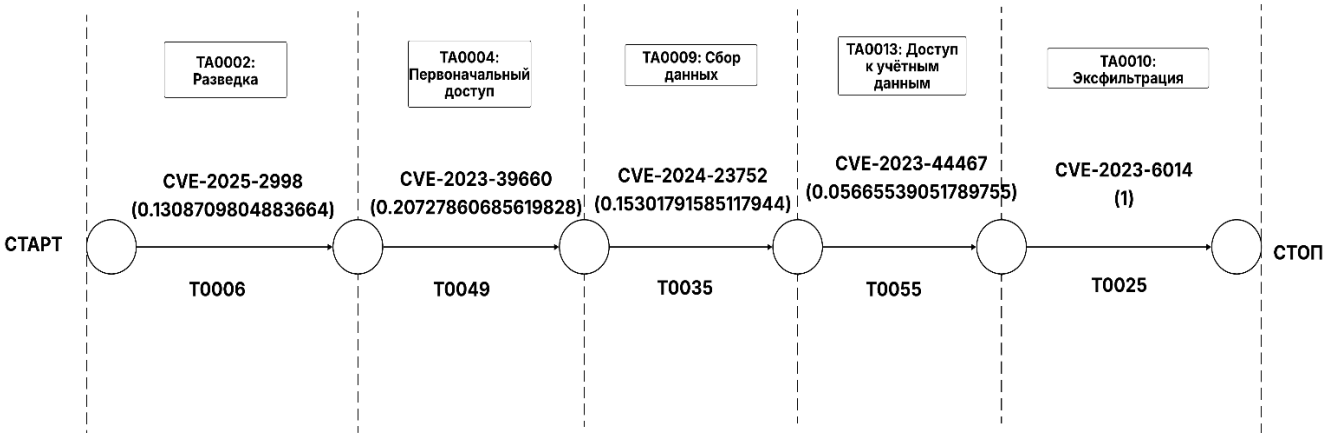


Рисунок 14 – Сценарий с наибольшим ущербом для группы №1

Таблица 8. Критичность уязвимостей для сценария с наибольшим ущербом для группы №1

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0006: Активное сканирование	CVE-2025-2998	5.3	4.8	0.19	0.181502125	0.449640302643542
T0049: Эксплуатация приложений с публичным доступом	CVE-2023-39660	9.8	9.3	0.63	0.3949690625	0.862090588368319
T0035: Сбор артефактов МО	CVE-2024-23752	9.8	9.3	0.505	0.3861490625	0.84846896947103
T0055: Доступ к незащищённым учётным данным	CVE-2023-44467	9.8	9.3	0.109	0.3418270625	0.89536574207962
T0025: Эксфильтрация через киберсредства	CVE-2023-6014	9.8	9.3	0.842	0.2130730625	0.913969395164871

Таблица 9. Оценка риска для сценария с наибольшим ущербом для группы №1

Произведение вероятностей	Сумма ущербов	Риск
0.00023516969563573947	3.9880	0.000937856746195329

Для группы сценариев №1 с помощью специально разработанного программного обеспечения было сформировано 1972 сценария, наиболее критичный сценарий имеет $Risk = 0{,}00163$, а наиболее ущербный сценарий имеет сумму ущербов U = 3.9880. На рисунках 15-19 представлены уязвимости, которые эксплуатируются в рамках первой группы сценариев по техникам с их единичными вероятностями реализациями.

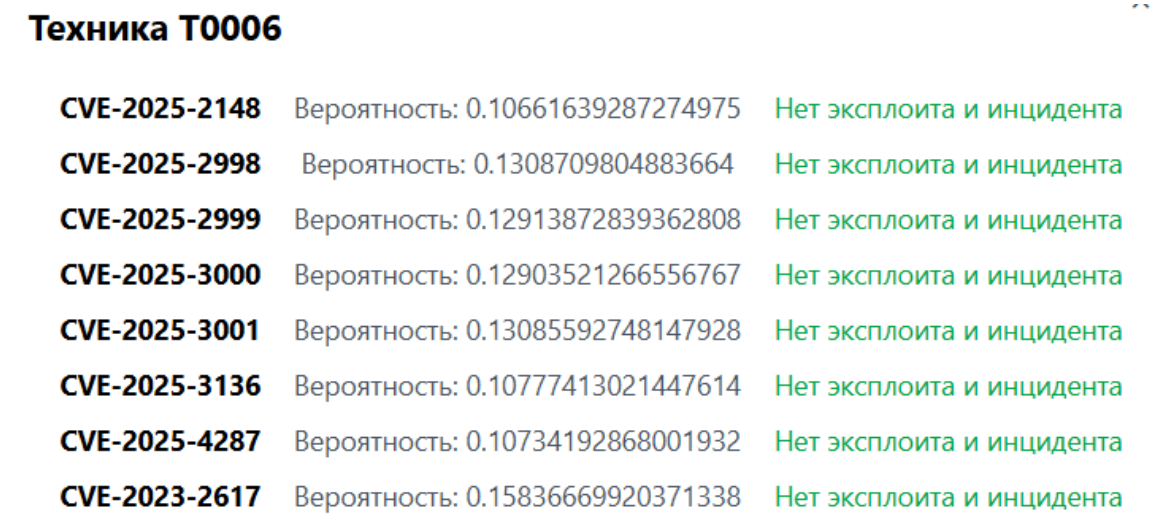


Рисунок 15 – Уязвимости, эксплуатируемые в рамках перехода из техники T0006 в T0049 для группы №1

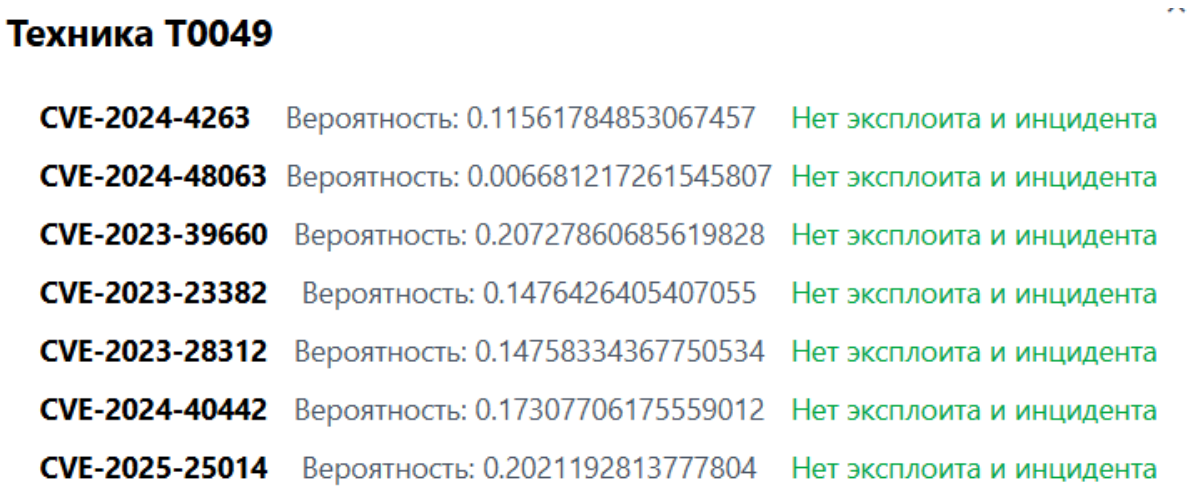


Рисунок 16 – Уязвимости, эксплуатируемые в рамках перехода из техники T0049 в T0035 для группы №1

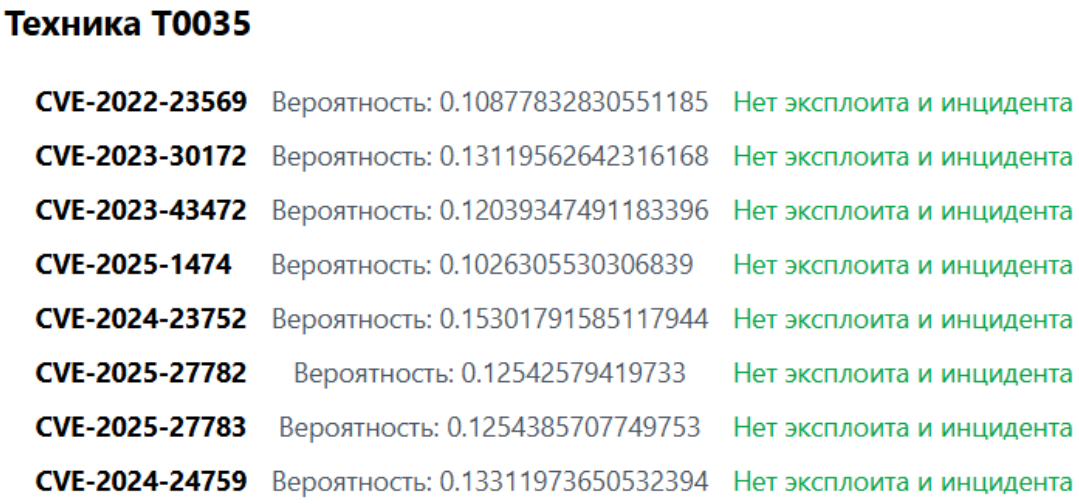


Рисунок 17 - Уязвимости, эксплуатируемые в рамках перехода из техники T0035 в T0055 для группы №1

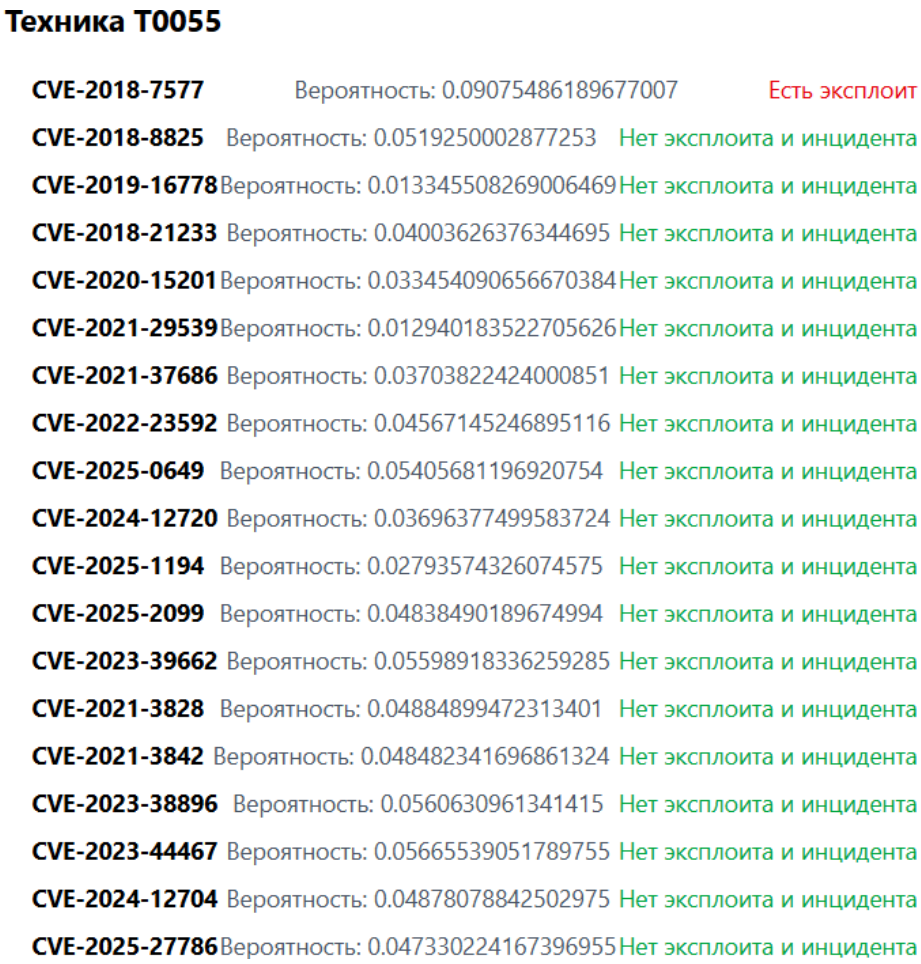


Рисунок 18 - Уязвимости, эксплуатируемые в рамках перехода из техники T0055 в T0025 для группы №1

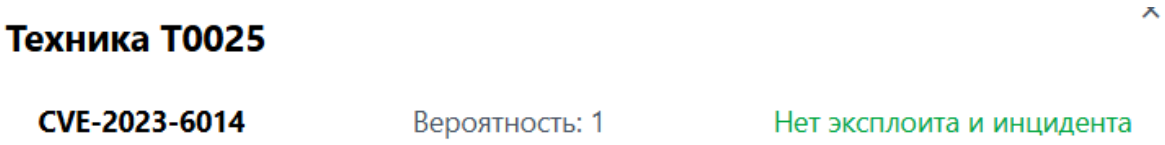


Рисунок 19 – Уязвимости, эксплуатируемые в рамках перехода из техники T0025 в конец атаки, для группы №1

Для 2 группы также определены предусловия злоумышленника, которые он должен получить в рамках действий одной техники, чтобы иметь возможность перейти в другую (Таблица 10).

Таблица 10. Предварительные условия для перехода в технику для группы сценариев №2

Предварительные условия	Техника	Последствия
1) Наличие слабостей (например, ошибок конфигурации, отсутствия механизмов аутентификации или наличие уязвимых версий компонентов) в программных интерфейсах общедоступных веб-приложений или API, взаимодействующих с компонентами модели МО. 2) Отсутствие или неэффективная реализация механизмов контроля доступа, фильтрации входных данных и межсервисной аутентификации.	T0049: Недостатки в общедоступных приложениях	1) Неавторизованный удалённый доступ к элементам инфраструктуры МО, включая входные точки сбора данных, интерфейсы API модели или вспомогательные сервисы. 2) Возможность внедрения вредоносных данных или манипулирования запросами к модели, что создаёт условия для искажения выводов и обхода модели. 3) Получение частичной или полной информации об архитектуре модели.
1) Имеется доступ к системе или её компонентам, обеспеченный через эксплуатацию уязвимостей. 2) Наличие возможности передачи тестовых или модифицированных входных данных в модель. 3) Отсутствие правил SIEM-системы, реагирующих на попытки некорректного использования модели.	T0042: Подтверждение эффективности атаки	1) Подтверждения успешного обхода политики безопасности или изменения поведения модели. 2) Определение устойчивых параметров модели МО, позволяющих манипулировать предсказаниями. 3) Нахождение злоумышленником факта уязвимости модели к определенному типу обхода.
1) Подтверждено, что модель уязвима к специфическим входным воздействиям, выявлены устойчивые векторы обхода. 2) Получен доступ к интерфейсу модели и механизму генерации ответов. 3) Отсутствует эффективная проверка входных данных (например, механизмов нормализации, фильтрации, контекстной валидации).	T0015: Обход модели МО	1) Нарушение конфиденциальности, целостности, доступности модели МО путём обхода механизма принятия решений. 2) Деградация качества предсказаний модели и генерация недостоверных или компрометирующих результатов. 3) Возможность последующего использования искажённых решений модели для реализации, более сложно выстроенных атак.

Для группы сценариев №2 определен наиболее критичный сценарий атаки: T0049(CVE-2023-39660) → T0042(CVE-2025-3121) → T0015(CVE-2024-2928), модель сценария с наибольшим риском, представлена на рисунке 20.

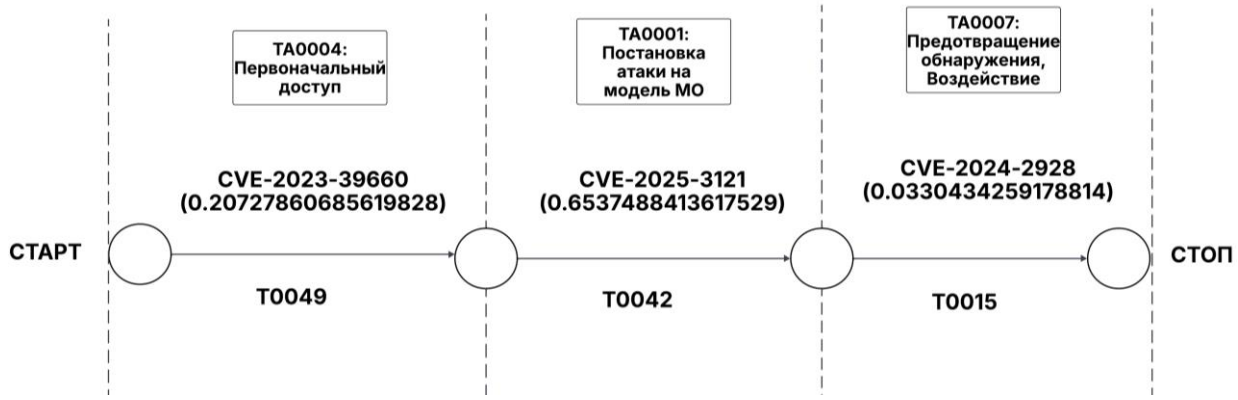


Рисунок 20 – Модель сценария №2 с наибольшим риском

Проведена оценка критичности выявленных уязвимостей (Таблица 11), и на основании данных из таблицы 11 рассчитана вероятность эксплуатации данного критичного сценария, сумма ущербов и риск (Таблица 12).

Таблица 11. Критичность уязвимостей для сценария с наибольшим риском для группы №2

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0049: Недостатки в общедоступных приложениях	CVE-2023-39660	9.8	9.3	0.63	0.3949690625	0.862090588368319
T0042: Подтверждение эффективности атаки	CVE-2025-3121	3.3	4.8	0.19	0.262886125	0.366457433675535
T0015: Обход модели МО	CVE-2024-2928 (Есть эксплойт)	7.5	8.7	0.90397	0.2672590625	0.837918792956813

Таблица 12. Оценка риска для сценария с наибольшим риском для группы №2

Произведение вероятностей	Сумма ущербов	Риск
0,00447765348510732	1.5750	0,00705230423904403

Также представлен наиболее ущербный сценарии для группы № 2, модель, которого приведена на рисунке 21 данные о результатах расчетов приведены в таблицах 13 и 14.

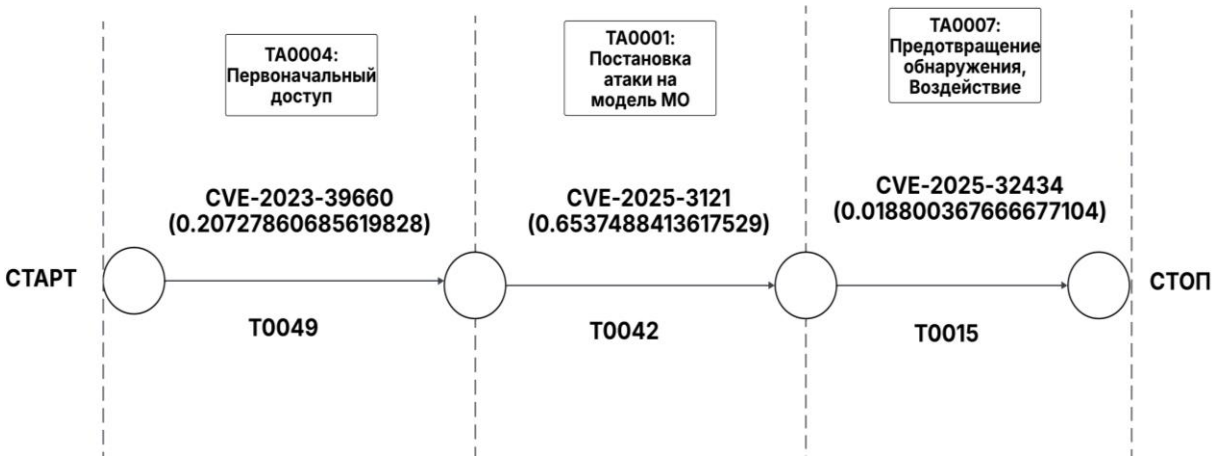


Рисунок 21 – Сценарий с наибольшим ущербом для группы №1

Таблица 13. Критичность уязвимостей для сценария с наибольшим ущербом для группы №2

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0049: Недостатки в общедоступных приложениях	CVE-2023-39660	9.8	9.3	0.63	0.3949690625	0.862090588368319
T0042: Подтверждение эффективности атаки	CVE-2025-3121	3.3	4.8	0.19	0.262886125	0.366457433675535
T0015: Обход модели МО	CVE-2025-32434	0.0	9.3	0.407	0.0	0.770792071802543

Таблица 14. Оценка риска для сценария с наибольшим ущербом для группы №2

Произведение вероятностей	Сумма ущербов	Риск
0,00254760302437167	1.9500	0,00496782589752475

Для группы сценариев №2 сформировано 182 сценария, наиболее критичный сценарий имеет $Risk = 0{,}007052304239044 03$, а наиболее ущербный сценарий сумму ущербов U = 1.9500.

На рисунках 20-24 представлены уязвимости, которые эксплуатируются в рамках второй группы сценариев по техникам с их единичными вероятностями реализациями.

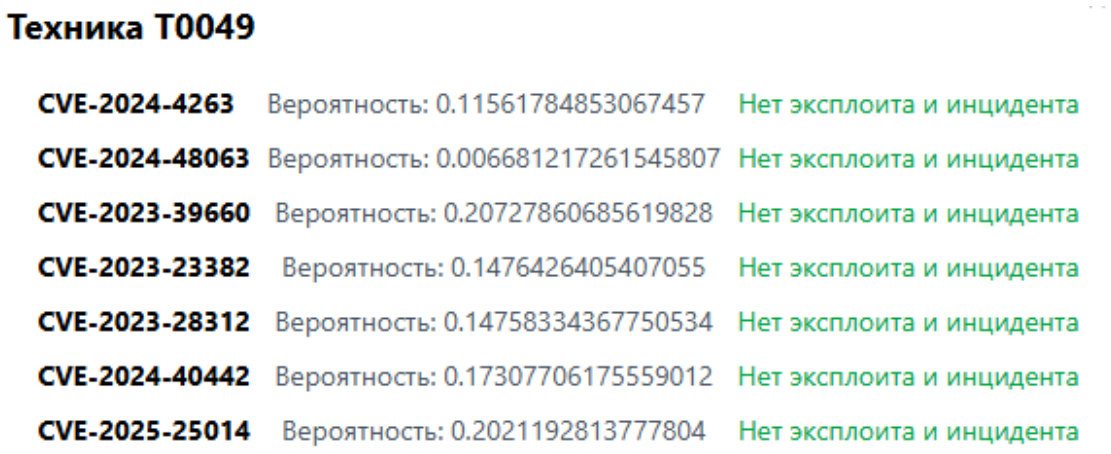


Рисунок 22 - Уязвимости, эксплуатируемые в рамках перехода из техники T0049 в T0042 для группы №2

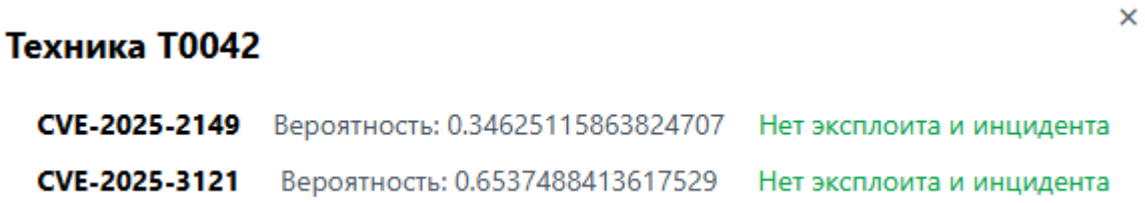


Рисунок 23 - Уязвимости, эксплуатируемые в рамках перехода из техники T0042 в T0015 для группы №2

Наибольшее число возможных уязвимостей, эксплуатируемых в рамках критичного сценария группы №2, выделяется в рамках перехода из техники T0015 в завершающий этап реализации сценария. Также в рамках данной техники присутствует две уязвимости, имеющие эксплойт, а значит данные слабости самые легкие в исполнении для злоумышленника, так как требуют наименьших ресурсов.

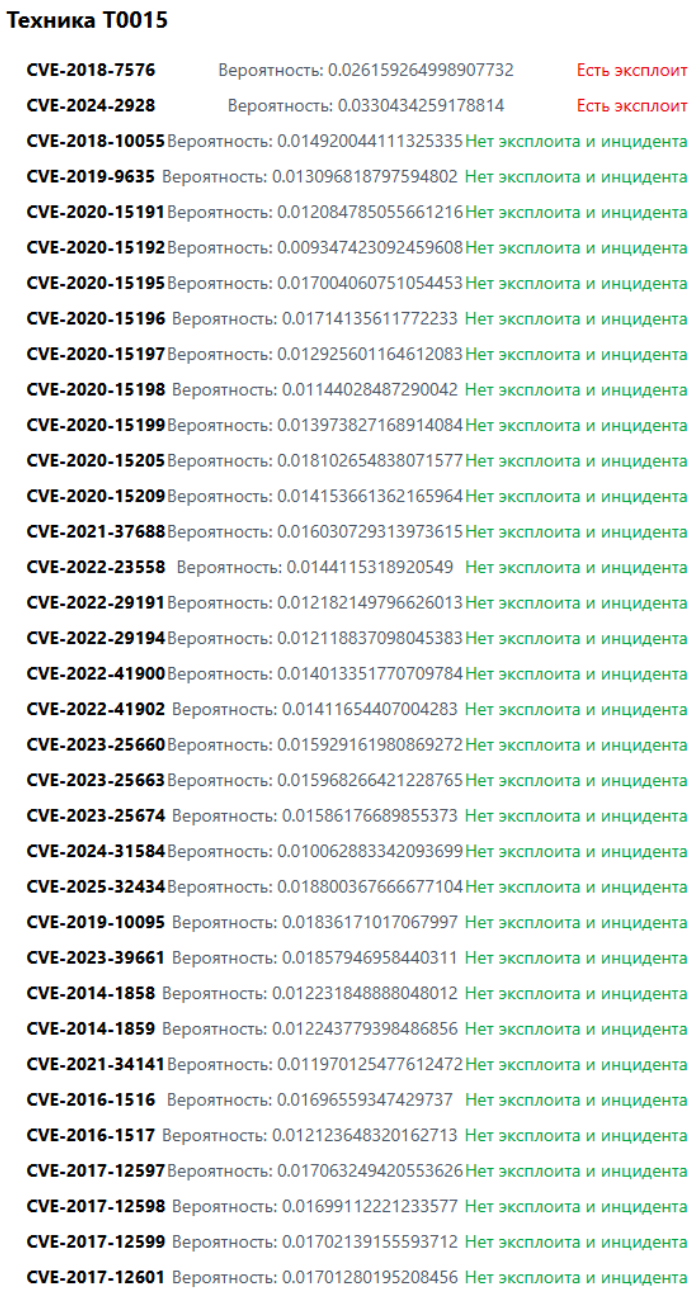


Рисунок 24 - Уязвимости, эксплуатируемые в рамках перехода из техники T0015 в конец атаки, для группы №2

Для группы сценариев №3 сформулированы предусловия злоумышленника, которые он должен получить в рамках действий одной техники, чтобы иметь возможность перейти в другую (Таблица 15).

Таблица 15. Предварительные условия для перехода в технику для группы сценариев № 3

Предварительные условия	Техника	Последствия
1) Наличие доступа к системным компонентам, содержащим артефакты МО (например, директории с моделью, логами обучения, весами, параметрами архитектуры). 2) Отсутствие эффективной изоляции модели, контроля доступа к данным и механизмов шифрования артефактов. 3) Успешная эксплуатация стороннего интерфейса доступа к данным или компонентов, выполняющих инференс.	T0002: Получение артефактов МО	1) Извлечение параметров модели (весовые коэффициенты, архитектура, гиперпараметры), обучающих данных или метаданных (журналы, конфигурации). 2) Получение знаний о внутренней логике модели, используемых функциях активации и структурах входных и выходных данных. 3) Создание основы для проведения целенаправленных атак, включая примеры атак и обход прогнозов.
1) Подтверждено, что модель уязвима к специфическим входным воздействиям, выявлены устойчивые векторы обхода. 2) Получен доступ к интерфейсу модели и механизму генерации ответов. 3) Отсутствует эффективная проверка входных данных (например, механизмов нормализации, фильтрации, контекстной валидации).	T0015: Обход модели МО	1) Нарушение конфиденциальности, целостности, доступности модели МО путём обхода механизма принятия решений. 2) Деградация качества предсказаний модели и генерация недостоверных или компрометирующих результатов. 3) Возможность последующего использования искажённых решений модели для реализации, более сложно выстроенных атак.
1) Имеется доступ к системе или её компонентам, обеспеченный через эксплуатацию уязвимостей. 2) Наличие возможности передачи тестовых или модифицированных входных данных в модель. 3) Отсутствие правил SIEM-системы, реагирующих на попытки некорректного использования модели.	T0042: Подтверждение эффективности атаки	1) Подтверждения успешного обхода политики безопасности или изменения поведения модели. 2) Определение устойчивых параметров модели МО, позволяющих манипулировать предсказаниями. 3) Нахождение злоумышленником факта уязвимости модели к определенному типу обхода.

Для группы сценариев №3 наиболее критичным сценарием атаки является: T0002(CVE-2023-3765) → T0015(CVE-2024-2928) → T0042(CVE-2025-3121), модель которого представлена на рисунке 25.

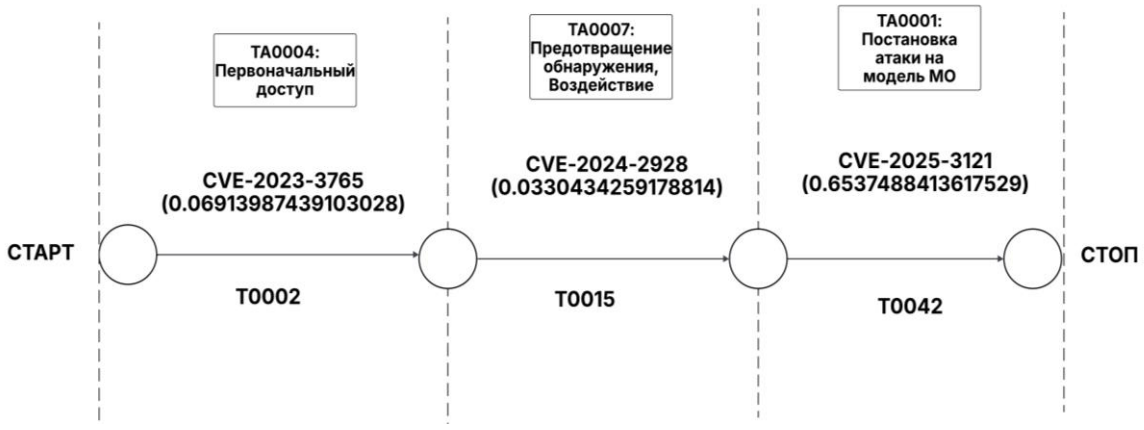


Рисунок 25 - Модель сценария №3 с наибольшим риском

Проведена оценка критичности выявленных уязвимостей (Таблица 16), а на основании данных из таблицы 16 рассчитана вероятность эксплуатации данного критичного сценария, сумма ущербов и риск (Таблица 17).

Таблица 16. Критичность уязвимостей для сценария с наибольшим риском для группы №3

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0002: Получение артефактов МО	CVE-2023-3765 (Есть эксплойт)	9.8	9.3	0.63	0.3949690625	0.862090588368319
T0015: Обход модели МО	CVE-2024-2928 (Есть эксплойт)	3.3	4.8	0.19	0.262886125	0.366457433675535
T0042: Подтверждение эффективности атаки	CVE-2025-3121	3.3	4.8	0.19	0.262886125	0.366457433675535

Таблица 17. Оценка риска для сценария с наибольшим риском для группы №3

Произведение вероятностей	Сумма ущербов	Риск
0.0018294686373859623	1.5750	0.0028814131038828903

Для группы сценариев №3 наиболее ущербным сценарием атаки является: T0002(CVE-2023-3765) → T0015(CVE-2025-32434) → T0042(CVE-2025-3121), модель которого представлена на рисунке 26.

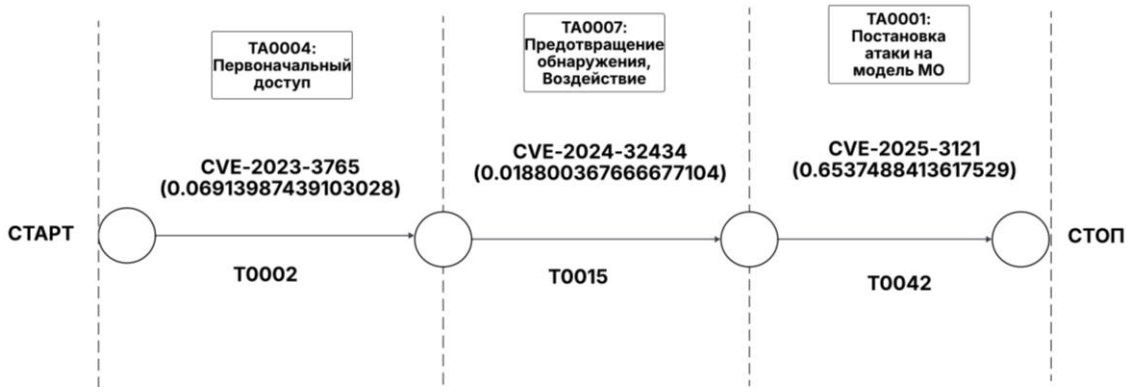


Рисунок 26 - Модель сценария №3 с наибольшим ущербом

Расчеты для сценария с наибольшим ущербом, приведены в таблицах 18 и 19.

Таблица 18. Критичность уязвимостей для сценария с наибольшим ущербом для группы №3

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0002: Получение артефактов МО	CVE-2023-3765 (Есть эксплойт)	9.8	9.3	0.63	0.3949690625	0.862090588368319
T0015: Обход модели МО	CVE-2025-32434	0.0	9.3	0.407	0.0	0.770792071802543
T0042: Подтверждение эффективности атаки	CVE-2025-3121	3.3	4.8	0.19	0.262886125	0.366457433675535

Таблица 19. Оценка риска для сценария с наибольшим ущербом для группы №3

Произведение вероятностей	Сумма ущербов	Риск
0.0010408933717401935	1.9500	0.0020297420748933773

В результате, для группы 3 было обнаружено 598 сценариев, из которых наиболее критичный сценарий имеет $Risk = 0.0028814131038828903$, а сценарий с наибольшим ущербом U = 1.9500.

На основе анализа групп сценариев № 2 и № 3 было установлено, что отдельные группы сценариев демонстрируют идентичные или сходные показатели риска и потенциального ущерба. В то же время были выявлены случаи использования повторяющихся техник и уязвимостей, что указывает на высокую степень совпадения между соответствующими сценариями атак. Это обстоятельство, в свою очередь, обусловлено исходной структурой сценариев, в которых предусмотрено наличие либо теоретических уязвимостей, которые не были подтверждены фактической эксплуатацией, либо уязвимостей, которые не обеспечивают практическую достижимость переходов между техниками в рамках сформированных графов атак.

В частности, группы сценариев №4, №5, №6, №8, №14, №19, №23, №24 и № 25 характеризуются ограниченным количеством переходов (3-4), минимальной вариативностью в развитии атакующих действий, а также частичной или полной принадлежностью к более сложным и расширенным сценарным группам. Кроме того, эти группы полагаются в первую очередь на уязвимости нулевого дня, что значительно снижает применимость их детального анализа рисков в рамках практико-ориентированного моделирования атак.

Учитывая вышеизложенное, расширенный анализ этих групп считается нецелесообразным из-за их ограниченной информативности, отсутствия практической применимости для построения реалистичных компромиссных маршрутов, а также дублирования информации, уже предоставленной при анализе более значимых и взаимосвязанных сценариев. Далее рассмотрены критичные сценарии с наибольшим риском.

Продолжен риск-анализ дальнейших выделенных групп сценариев. Для группы сценариев №7 обозначены предусловия злоумышленника, которые он должен приобрести в рамках действий одной техники, чтобы иметь возможность перейти в другую (Таблица 20).

Таблица 20. Предварительные условия для перехода в технику для группы сценариев № 7

Предварительные условия	Техника	Последствия
1) Отсутствие контроля доступа к хранилищам или каталогам, содержащим обучающие и тестовые наборы данных. 2) Публикация данных в открытых источниках без надлежащей анонимизации или ограничения доступа. 3) Отсутствие механизма хэширования и цифровых отпечатков пальцев для контроля целостности данных.	T0002.000: Получение артефактов МО: Наборы данных	1) Злоумышленник получает полный или частичный доступ к исходным данным, используемым для обучения модели. 2) Возможность анализировать распределение признаков, семантические характеристики классов и структуру входных данных модели. 3) Подготовка основы для создания точной копии модели и атак, использующих чувствительность модели к структуре данных.
1) Имеются знания об используемых форматах ввода и характеристиках обучающего дистрибутива. 2) Отсутствует аутентификация или реализованы небезопасные механизмы доступа к API модели. 3) Отсутствует защита от чрезмерных или последовательных запросов (ограничение скорости, защита от спуфинга, анализ шаблонов запросов).	T0040: Доступ к API модели МО	1) Получение доступа к интерфейсу модели логического вывода в режиме реального времени. 2) Возможность массовой отправки входных данных и сбора ответов модели. 3) Формирование обучающей выборки на основе пар ввода-вывода для создания прокси-модели.
1) Наличие набора входных данных и соответствующих ответов целевой модели, собранных через API. 2) Отсутствие механизмов защиты от извлечения модели. 3) Была сформирована достаточная выборка для приблизительного описания поведения целевой модели.	T0005.001: Создание прокси-модели машинного обучения: Обучение прокси-модели с помощью репликации	1) Построение замещающей модели, воспроизводящей логику предсказаний целевой модели. 2) Упрощение атак, включая обход модели и генерацию примеров атак. 3) Возможность тестирования атак на модели МО в изолированной среде, прежде чем применять к реальной модели.
1) Наличие доступа к прокси-модели, которая точно соответствует поведению целевой модели.	T0015: Обход модели МО	1) Нарушение корректного функционирования модели путем предоставления специально разработанных входных данных.

Продолжение таблицы 20

Предварительные условия	Техника	Последствия
2) Были выявлены уязвимые векторы входных данных, вызывающие искажение прогноза. 3) Нет мер для защиты от конкурирующих примеров или контекстной фильтрации входных данных.	T0015: Обход модели МО	2) Получение искаженных или вредоносных прогнозов, которые могут повлиять на бизнес-логику или поведение систем. 3) Возможность использования обходного пути в качестве основы для последующего воздействия на модель.
1) Обнаружены неконтролируемые изменения в поведении модели, вызванные внешними воздействиями. 2) Отсутствие механизмов проверки целостности модели (например, проверка контрольных сумм весов, мониторинг отклонений в поведении). 3) Модель подвержена атакам через внешние интерфейсы или замену компонентов.	T0031: Нарушение целостности модели МО	1) Намеренное изменение структуры или параметров модели с целью саботажа, снижения точности или внедрения вредоносной логики. 2) Потеря уверенности в результатах логического вывода, риски сбоя системы в критических задачах. 3) Угроза компрометации цепочки связанных систем на основе решений модели.

Для группы сценариев №7 наиболее критичным сценарием атаки является: T0002.000 (CVE-2022-41910) → T0040 (CVE-2025-27776) → T0005.001(CVE-2020-15203) → T0015 (CVE-2024-2928) → T0031 (CVE-2024-25723), модель которого представлена на рисунке 27. В таблице 21 приведены нормализованные оценки критичностей уязвимостей и выведена среднеквадратичная по каждой, а также в таблице 22 представлены результаты расчетов вероятности, суммы ущербов и риск.

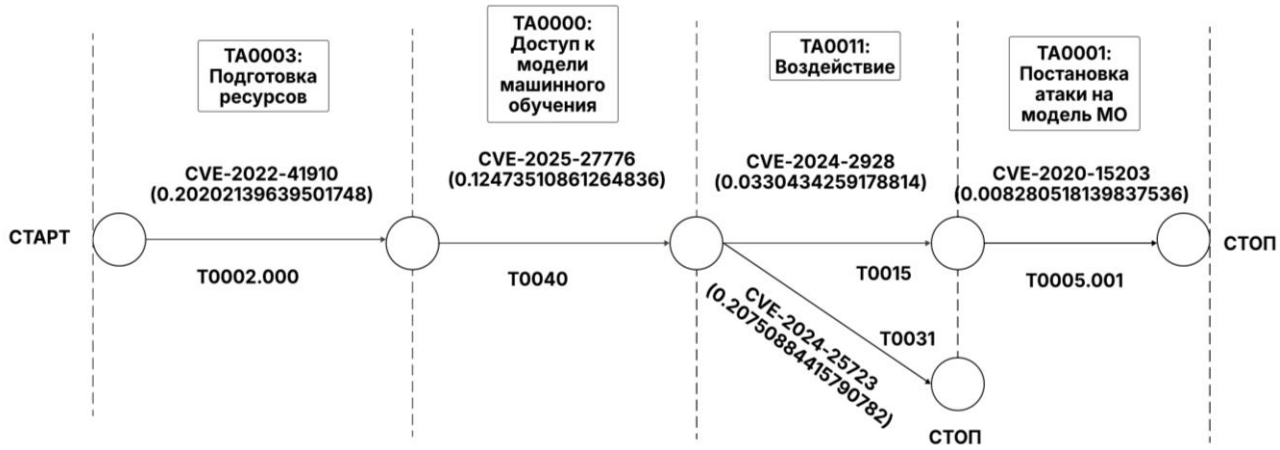


Рисунок 27 – Модель сценария с наибольшим риском для группы сценариев № 7

Также в таблице 21 указаны уязвимости, имеющие эксплойт, а следовательно, являются наиболее приоритетными для атакующего.

Таблица 21. Критичность уязвимостей для сценария с наибольшим риском для группы №7

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0002.000: Получение артефактов МО: Наборы данных	CVE-2022-41910 (Есть эксплойт)	4.8	5.7	0.97	0.1809614	0.734277172166618
T0040: Доступ к API модели МО	CVE-2025-27776	3.3	4.8	0.19	0.262886125	0.366457433675535
T0005.001: Создание прокси-модели машинного обучения: Обучение прокси-модели с помощью репликации	CVE-2020-15203 (Есть эксплойт)	7.5	8.7	0.36	0.3319030625	0.720300307391254
T0015: Обход модели МО	CVE-2024-2928 (Есть эксплойт)	7.5	8.7	0.90397	0.2672590625	0.837918792956813
T0031: Нарушение целостности модели МО	CVE-2024-25723 (Есть эксплойт)	8.8	8.7	0.90183	0.339130375	0.873407250902154

Таблица 22. Оценка риска для сценария с наибольшим риском для группы №3

Произведение вероятностей	Сумма ущербов	Риск
0.0000014307549949920538	2.3750	0.000003398043113106 1276

Расчеты для сценария с наибольшим ущербом и модель (Рисунок 28), приведены в таблицах 23 и 24.

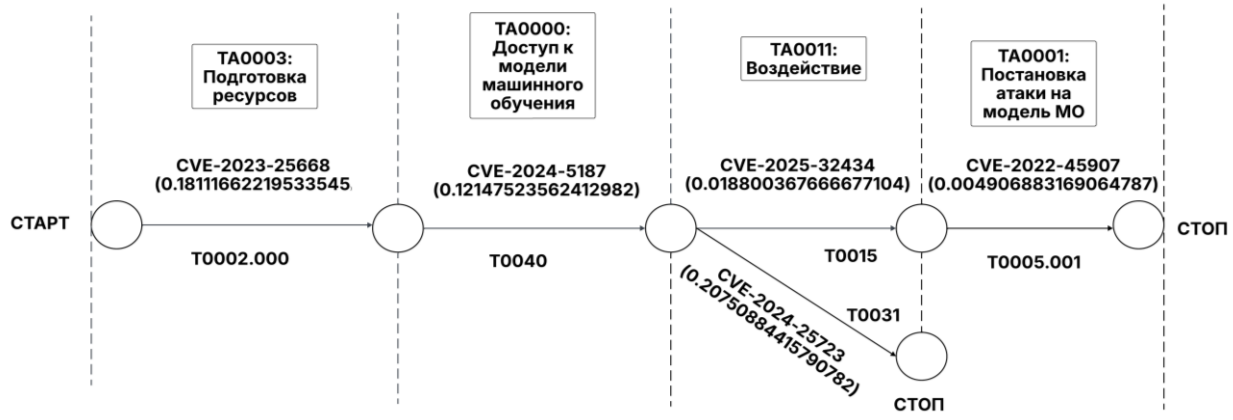


Рисунок 28 – Модель сценария с наибольшим ущербом для группы сценариев № 7

Таблица 23. Критичность уязвимостей для сценария с наибольшим ущербом для группы №7

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0002.000: Получение артефактов МО: Наборы данных	CVE-2023-25668	9.8	9.3	0.2873	0.3691390625	0.854530500026796
T0040: Доступ к API модели МО	CVE-2024-5187	8.8	8.6	0.716	0.352330375	0.81401351716438
T0005.001: Создание прокси-модели машинного обучения: Обучение прокси-модели с помощью репликации	CVE-2022-45907	9.8	9.3	0.234	0.4085290625	0.861259334468788
T0015: Обход модели МО	CVE-2025-32434	0.0	9.3	0.407	0.0	0.770792071802543
T0031: Нарушение целостности модели МО	CVE-2024-25723 (Есть эксплойт)	8.8	8.7	0.90183	0.339130375	0.873407250902154

Таблица 24. Оценка риска для сценария с наибольшим ущербом для группы №7

Произведение вероятностей	Сумма ущербов	Риск
0.000004211673845632559	4.3750	0.000018426073074642444

На рисунках 29 - 32 приведены все уязвимости, эксплуатируемые в рамках перехода из одной техники в другую с учетом единичных вероятностей перехода, для группы сценариев №7.

Наибольшее количество уязвимостей выделено в рамках перехода из техники T0040 в технику T0015 (девять уязвимостей), а также из техники T0015 в технику T005.001 (присутствует несколько уязвимостей с эксплойтом, что ставит их в приоритетность использования злоумышленником в рамках реализации сценария, и, следовательно, повышает вероятность их эксплуатации).

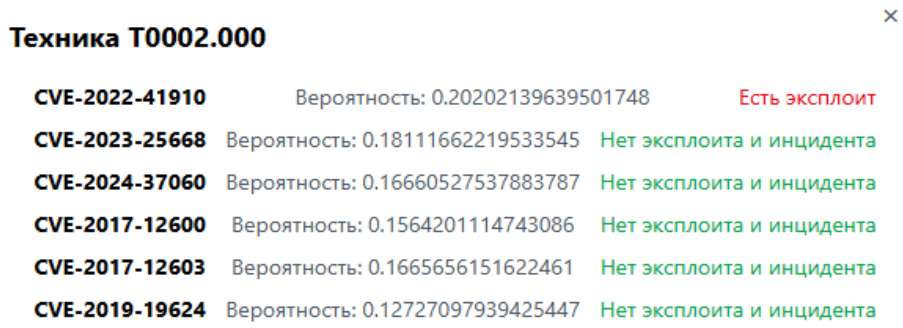


Рисунок 29 –Уязвимости, эксплуатируемые в рамках перехода из техники T0002.000 в T0040 для группы №7

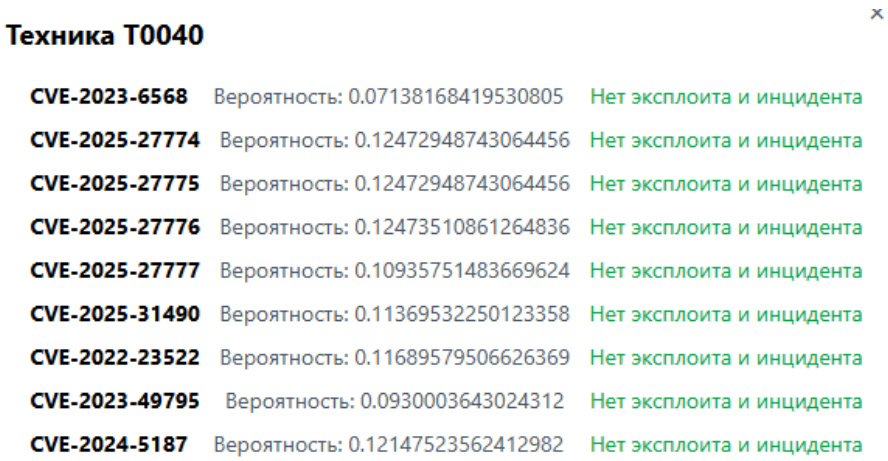


Рисунок 30 - Уязвимости, эксплуатируемые в рамках перехода из техники T0040 в T0015 для группы №7

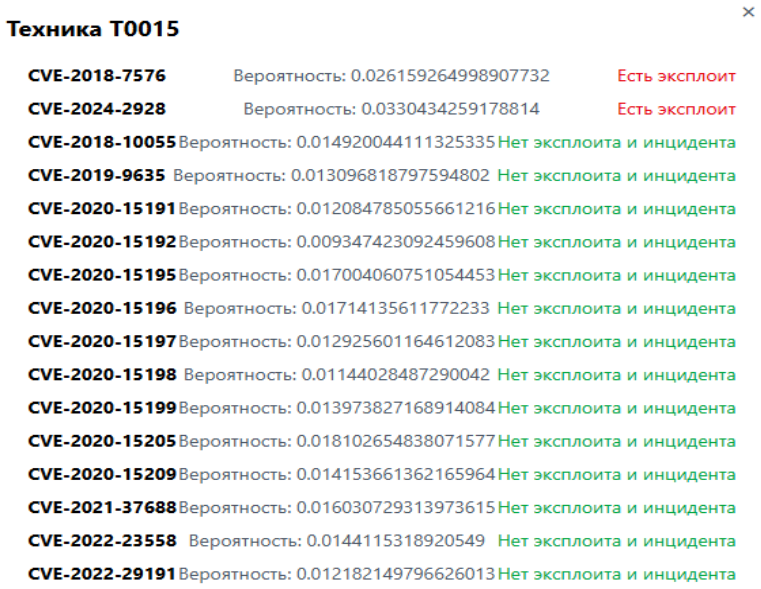


Рисунок 31 - Уязвимости, эксплуатируемые в рамках перехода из техники T0015 в T0005.001 для группы №7

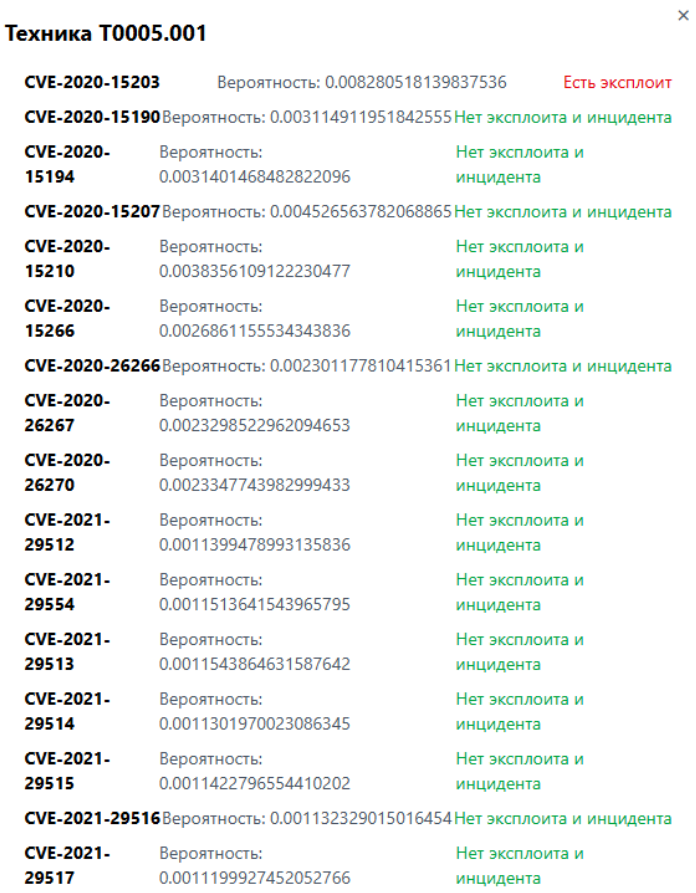


Рисунок 32 - Уязвимости, эксплуатируемые в рамках перехода из техники T0005.001 в конец атаки для группы №7

В результате, для группы 7 было обнаружено 2000 сценариев, из которых наиболее критичный сценарий имеет $Risk = 0.00000339804311310612 76$, а сценарий с наибольшим ущербом U = 4.3750.

Для группы сценариев №9 обозначены предусловия злоумышленника, которые он должен приобрести в рамках действий одной техники, чтобы иметь возможность перейти в другую (Таблица 25). Подобное выделение предварительных условий облегчит деятельность специалиста ИБ по поиску уязвимостей, так как благодаря подобному анализу сценария предоставляется возможность сузить ареал поиска слабостей, за счет четкого понимания каких действий и результатов должен добиться злоумышленник для выстраивания атаки.

Таблица 25. Предварительные условия для перехода в технику для группы сценариев № 9

Предварительные условия	Техника	Последствия
1) Отсутствие механизмов проверки подлинности и целостности входящих данных на этапе обучения модели. 2) Использование внешних, неподтвержденных поставщиков обучающих выборок (например, наборы данных с открытым исходным кодом). 3) Отсутствие процедуры сертификации цепочки поставок, включая цифровую подпись, контроль версий и сопоставление хэшей.	T0010.002: Компрометация цепочки поставок МО: данные	1) Введение поддельных или модифицированных обучающих данных злоумышленником на этапе проектирования или интеграции модели. 2) Нарушение валидности и корректности исходной обучающей выборки. 3) Формирование предпосылок для скрытого отравления данных или деградации модели на этапе обучения.
1) Получение доступа к сервису, использующему скомпрометированную модель, через открытый или защищенный API, пользовательский интерфейс или интеграционный шлюз. 2) Отсутствие механизма контроля типов и источников входных данных, предоставляемых модели. 3) Отсутствие механизмов обнаружения атакующих моделей взаимодействия (например, ограничение скорости, фильтрация признаков атакующей активности клиента).	T0047: Доступ к продукту или сервису, использующему МО	1) Возможность предоставления контролируемых данных модели в производственной среде. 2) Возможность постепенного внедрения вредоносных данных, которые могут быть повторно использованы в цикле активного обучения модели (если включено онлайн-обучение). 3) Расширение зоны действия атаки до уровня бизнес-логики сервиса.
1) Вредоносные данные могут быть переданы модели в процессе ее обучения или переподготовки (например, через пользователей, сенсорные данные, логи клиентов). 2) Модель настроена на непрерывное или периодическое обновление на основе пользовательских данных (онлайн-обучение, обучение с обратной связью, федеративное обучение). 3) В потоке обучения отсутствуют механизмы контроля качества, семантической фильтрации и обнаружения аномалий.	AML.T0020: Отравление обучающих данных	1) Введение специально разработанных записей в обучающий набор данных, направленных на изменение логики классификации или регрессии. 2) Возможность искажения границ принятия решений моделью без генерирования очевидных ошибок. 3) Повышение вероятности успешной реализации последующих атак на целостность модели.
1) Модель обучена или переобучена на вредоносных, отравленных данных. 2) Отсутствие механизмов контроля целостности модели (весов хэширования, мониторинга метрик, мониторинга поведения при выводе). 3) Выявлены систематические отклонения в логике прогнозов, которые не соответствуют исходным данным.	AML.T0031: Нарушение целостности модели МО	1) Нарушение корректности и надежности модели, включая ее архитектурную структуру, веса и внутренние зависимости. 2) Модель становится непредсказуемой в условиях эксплуатации, потенциально вредоносной или контролируемой злоумышленником. 3) Угроза сбоя системы в критических ситуациях (например, медицинская диагностика, автономное вождение, финансовые рекомендации).

Сценарий для группы № 9 с наибольшим риском: T0047 (CVE-2020-9480) →T0010.002 (CVE-2019-6446) → T0020 (CVE-2020-13092) →T0031 (CVE-2024-25723), модель которого изображена на рисунке 33, расчеты приведены в таблицах 26, 27.

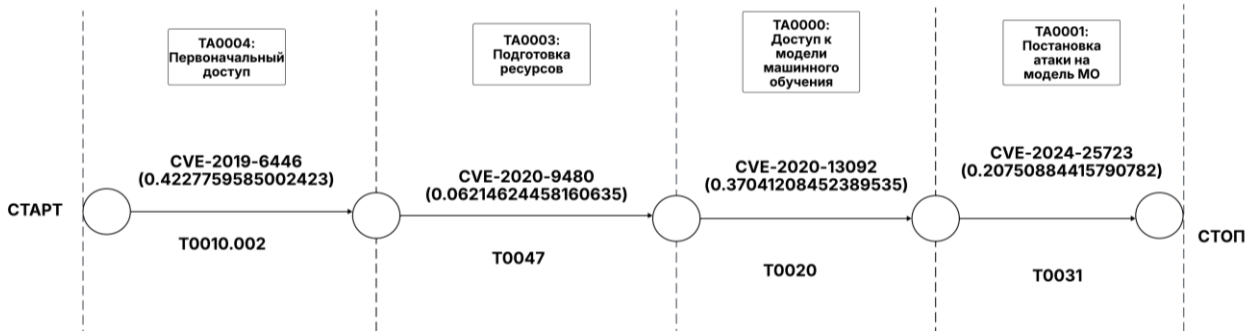


Рисунок 33– Сценарий из группы № 9 с наибольшим риском и ущербом

Таблица 26. Критичность уязвимостей для сценария с наибольшим риском для группы №9

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0010.002: Компрометация цепочки поставок МО: данные	CVE-2019-6446	9.8	9.3	0.57542	0.3354250625	0.856516629672852
T0047: Доступ к продукту или сервису, использующему МО	CVE-2020-9480 (Есть эксплойт)	9.8	9.3	0.8098	0.3336970625	0.901575217706473
AML.T0020: Отравление обучающих данных	CVE-2020-13092	9.8	9.3	0.912	0.3395590625	0.930755617673241
AML.T0031: Нарушение целостности модели МО	CVE-2024-25723 (Есть эксплойт)	8.8	8.7	0.90183	0.339130375	0.873407250902154

Таблица 27. Оценка риска для сценария с наибольшим ущербом для группы №9

Произведение вероятностей	Сумма ущербов	Риск
0.002019514291931326	3.5000	0.0070683000217596405

Приведенный выше сценарий является как с наиболее высоким риском, так и с наибольшим ущербом. В группе сценариев № 9 выделено 666 сценариев, из них самый критичный сценарий имеет $Risk = 0.0070683000217596405$ и наибольший ущерб U = 3,5000.

Проведя анализ группы сценариев №12, становится возможным определить предварительные условия для перехода от одной технике к другой (Таблица 28).

Таблица 28. Условия перехода злоумышленника из одной техники в другую для группы сценариев №12

Предварительные условия	Техника	Последствия
1) Наличие скомпрометированных или украденных учетных данных, полученных с помощью фишинга, брутфорса или из взломанных баз данных. 2) Отсутствие механизма многофакторной аутентификации. 3) Повышенные права для украденной учетной записи или отсутствие разграничения привилегий (RBAC).	T0012: Использование существующих учетных записей	1) Авторизованный доступ к инфраструктуре МО от имени доверенного лица. 2) Возможность маскировки под легитимную деятельность. 3) Расширение периметра атаки за счет доступа к API, хранилищам артефактов и логам.
1) Использование авторизованной учетной записи с правами доступа к API. 2) Отсутствие ограничений на использование API (ограничение скорости, поведенческий контроль, сегментация доступа). 3) API модели МО предоставляют доступ к результатам логического вывода и метаинформации.	T0040: Доступ к API модели МО	1) Возможность интерактивного взаимодействия с моделью в продуктивной среде. 2) Сбор данных о реакции модели на различные входные значения. 3) Создание основы для анализа границ принятия решений моделью и генерации атакующих входных данных.
1) Имеются данные о поведении модели и возможности контролируемого взаимодействия с API. 2) Отсутствуют механизмы обнаружения атакующих шаблонов. 3) Известны слабые зоны модели.	T0015: Обход модели МО	1) Нарушение корректности прогнозов модели путем предоставления специально разработанных входных данных. 2) Возможность генерировать ложные тревоги или подавлять критические предупреждения. 3) Основа для создания состязательных примеров.
1) Доступ к журналам, логам, весам моделей, структуре и другим компонентам. 2.) Отсутствие шифрования, контроля доступа или цифровой подписи для хранения артефактов. 3) Модель развернута в неизолированной среде с прямым доступом к файловой системе.	T0035: Сбор артефактов МО	1) Получение ключевых компонентов модели: весов, архитектуры, функций, вспомогательных скриптов. 2) Повышение эффективности атак за счет глубокого анализа внутренней структуры модели. 3) Создание условий для генерации состязательных примеров с полным знанием модели.
1) Наличие доступа к API и артефактам модели. 2) Собрана статистика по реакции модели на различные входные данные. 3) Применена генерация атакующих запросов, которые изменяют выходные значения модели.	T0042: Подтверждение эффективности атаки	1) Подтверждено, что обход модели эффективен (прогнозы искажены). 2) Определены стабильные векторы атаки, пригодные для использования в продуктивной среде. 3) Созданы условия для оптимизации входных данных для атаки.
1) Доступ к внутренней структуре модели, включая градиенты, веса и уровень активации. 2) Проведен предварительный анализ эффективности атак на входы. 3) Отсутствуют механизмы защиты от градиентных атак (например, состязательное обучение, градиентная маскировка).	T0043.000: Создание состязательных данных: оптимизация образцов при доступе на уровне «белого ящика»	1) Создание высокоэффективных состязательных примеров, которые могут обойти даже защиту модели. 2) Возможность точечного манипулирования результатами моделирования. 3) Повышение риска масштабного внедрения атакующих примеров в продуктивной среде.

Продолжение таблицы 28

Предварительные условия	Техника	Последствия
1) Завершено формирование входных данных для целенаправленной атаки. 2) Модель дает искаженные прогнозы без запуска защитных механизмов. 3)Отсутствие протоколирования, фильтрации или инструментов DLP при выводе данных.	T0025: Эксфильтрация через программные средства	1) Утечка конфиденциальных данных (веса моделей, реакции на ключевые входные данные, внедрения) через интерфейсы приложений или API. 2) Возможность отображения примеров атак, используемых для повторных атак в других системах. 3) Угроза компрометации бизнес-логики и интеллектуальной собственности.

Группа сценариев №12 имеет следующий сценарий с наибольшим риском: T0012(CVE-2024-49375) → T0040(CVE-2025-27776) → T0015(CVE-2024-2928) → T0035(CVE-2024-23752) → T0042(CVE-2025-3121) → T0043.000(CVE-2024-39705) → T0025(CVE-2023-6014), модель представлена на рисунке 34, расчеты приведены в таблицах 29 и 30.

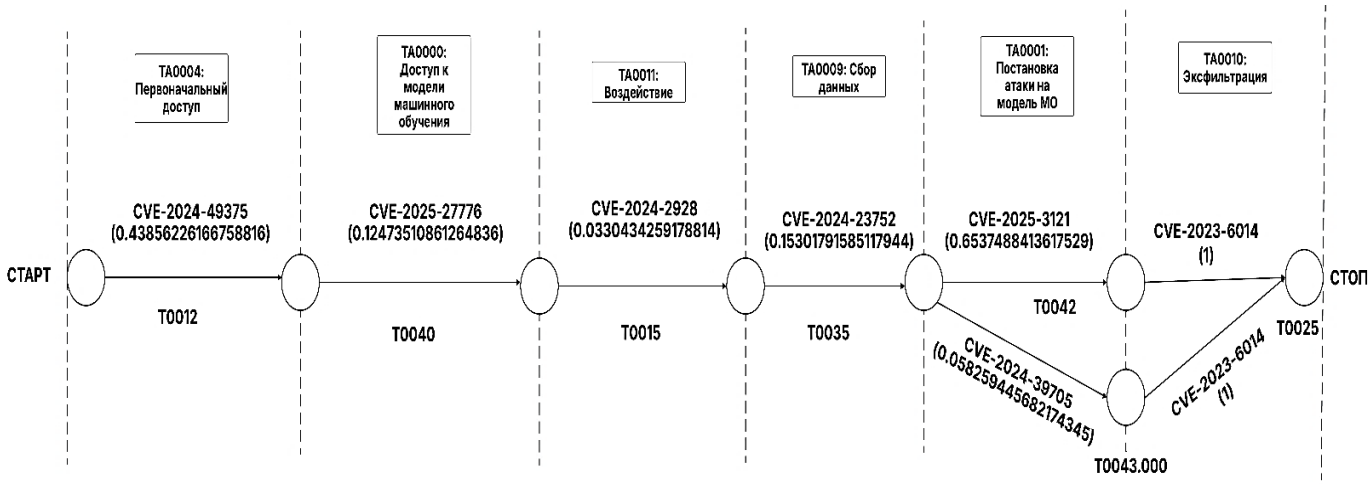


Рисунок 34 – Сценарий с наибольшим риском для группы №12

Таблица 29. Критичность уязвимостей для сценария с наибольшим риском для группы №12

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0012: Использование существующих учетных записей	CVE-2024-49375	9.0	9.5	0.549	0.175970625	0.833490484559682
T0040: Доступ к API модели МО	CVE-2025-27776	8,9	8,8	0.2873	0.3691390625	0.854530500026796

Продолжение таблицы 29

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0015: Обход модели МО	CVE-2024-2928 (Есть эксплойт)	7.5	8.7	0.90397	0.2672590625	0.837918792956813
T0035: Сбор артефактов МО	CVE-2024-23752	9.8	9.3	0.505	0.339130375	0.84846896947103
T0042: Подтверждение эффективности атаки	CVE-2025-3121	3.3	4.8	0.19	0.262886125	0.366457433675535
T0043.000: Создание состязательных данных: оптимизация образцов при доступе на уровне «белого ящика»	CVE-2024-39705	9.8	9.3	0.1484	0.2716390625	0.886120263332381
T0025: Эксфильтрация через программные средства	CVE-2023-6014	9.8	9.3	0.842	0.2130730625	0.913969395164871

Таблица 30. Оценка риска для сценария с наибольшим риском для группы №12

Произведение вероятностей	Сумма ущербов	Риск
0.000010534758845660852	4.2000	0.00004424598715177558

Наиболее же ущербный сценарий: T0012(CVE-2024-49375) → T0040(CVE-2024-5187) → T0015(CVE-2025-32434) → T0035(CVE-2024-23752) → T0042(CVE-2025-3121) → T0043.000(CVE-2024-39705) → T0025(CVE-2023-6014), представлен на рисунке 35, критичности уязвимостей и результаты вычислений приведены в таблицах 31, 32.

Таким образом, для группы №12 было сконфигурировано 20000 сценариев, выявлен сценарий с наибольшим риском, равным $Risk = 0.00004424598715177558$ и сценарий с наибольшим ущербом U = 5.4500.

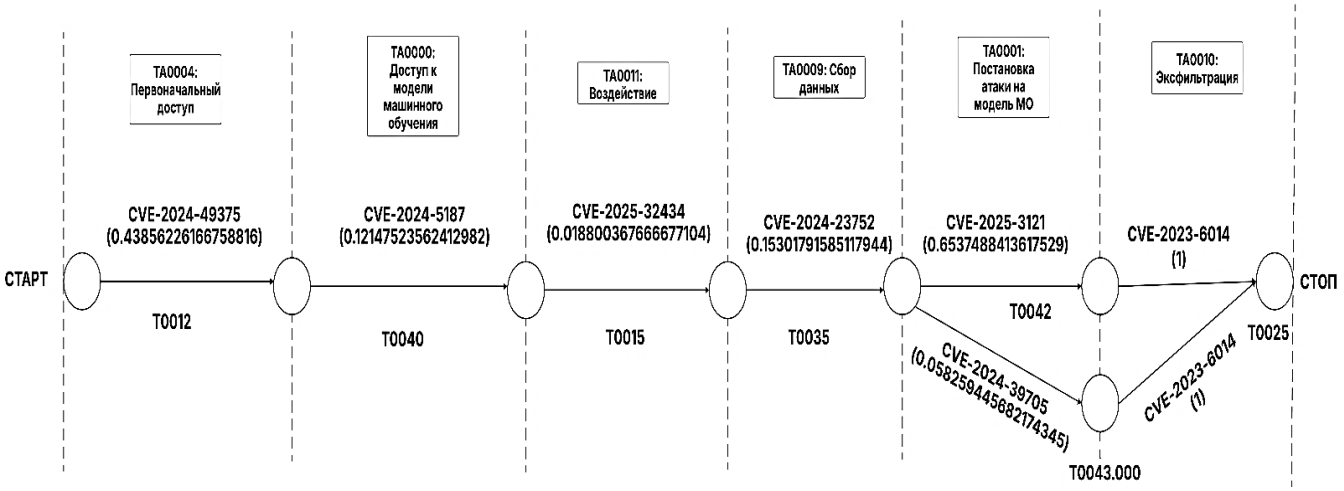


Рисунок 35 – Сценарий с наибольшим ущербом для группы №12

Таблица 31. Критичность уязвимостей для сценария с наибольшим ущербом для группы №12

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0012: Использование существующих учетных записей	CVE-2024-49375	9.0	9.5	0.549	0.175970625	0.833490484559682
T0040: Доступ к API модели МО	CVE-2024-5187	8.8	8.6	0.716	0.352330375	0.81401351716438
T0015: Обход модели МО	CVE-2025-32434	0.0	9.3	0.407	0.0	0.770792071802543
T0035: Сбор артефактов МО	CVE-2024-23752	9.8	9.3	0.505	0.339130375	0.84846896947103
T0042: Подтверждение эффективности атаки	CVE-2025-3121	3.3	4.8	0.19	0.262886125	0.366457433675535
T0043.000: Создание состязательных данных: оптимизация образцов при доступе на уровне «белого ящика»	CVE-2024-39705	9.8	9.3	0.1484	0.2716390625	0.886120263332381
T0025: Эксфильтрация через программные средства	CVE-2023-6014	9.8	9.3	0.842	0.2130730625	0.913969395164871

Таблица 32. Оценка риска для сценария с наибольшим ущербом для группы №12

Произведение вероятностей	Сумма ущербов	Риск
0.00000583720456362275	5.4500	0.00003181276487174399

Проведен анализ группы сценариев №18. В результате становится возможным определить предварительные условия для перехода от одной технике к другой (Таблица 33).

Таблица 33. Условия перехода злоумышленника из одной техники в другую для группы сценариев №18

Предварительные условия	Техника	Последствия
1) Обнаружены уязвимости в общедоступном приложении модели МО (например, XSS, SQL, небезопасные API). 2) Отсутствует сегментация сетевого взаимодействия между внешним интерфейсом и инфраструктурой МО. 3) Возможность обхода механизма аутентификации.	T0049: Недостатки в общедоступных приложениях	1) Получен несанкционированный доступ к элементам инфраструктуры модели МО, включая сервисы логического вывода и данные конфигурации. 2) Взаимодействие с моделью через интерфейсы, которые не предназначены для внешнего доступа.
1) Доступ к интерфейсу продукта или сервиса, использующего модель МО, был получен путём эксплуатации слабостей веб-приложения. 2) Существует прямой или промежуточный канал связи с API модели, который позволяет отправлять запросы на сервер и получать ответы. 3) Механизмы защиты на уровне API отсутствуют или неэффективны (нет ограничения скорости, аутентификации, ведения журнала).	T0047: Доступ к продукту или сервису, использующему МО	1) Получен стабильный канал взаимодействия с моделью в продуктивной среде. 2) Злоумышленник может выбирать входные данные и анализировать поведение модели, формируя репрезентативную выборку ответов. 3) Открыт доступ к вспомогательной информации (заголовкам, метаданным, структуре запроса).
1) Во время взаимодействия с сервисом были обнаружены открытый учетные данные, хранящиеся в файлах конфигурации или логах. 2) Полученные данные включают ключи доступа к модели или токены административного доступа. 3) Секретные механизмы хранения не используются.	T0055: Незащищенные учетные данные	1) Злоумышленник получает авторизованный доступ к внутренним сервисам МО. 2) Расширен уровень привилегий, что позволяет проводить атаки с повышенной точностью и получать доступ к диагностическим функциям. 3) В будущем появляется возможность протестировать устойчивость модели к целенаправленным воздействиям.
1) Доступ к модели МО был получен с правами авторизованного клиента, включая возможность подачи пользовательских данных на вход. 2) Модель не имеет защиты от повторных запросов с изменяющимися параметрами. 3) Поведение модели отслеживается с помощью возвращаемых показателей (достоверность, вероятности классов, эвристические теги).	T0042: Подтверждение эффективности атаки	1) Подтверждены уязвимости в логике прогнозирования модели: выявлены входные данные, которые вызывают неверные или непредсказуемые реакции. 2) Получен сценарий воздействия, который подходит для замены или обхода системы защиты. 3) Злоумышленник может использовать точку входа в модель как средство внедрения вредоносного кода.

Продолжение таблицы 33

Предварительные условия	Техника	Последствия
1) Вектор атаки, полученный в результате анализа ответов модели, используется для реализации модифицированного плагина LLM, интегрированного с моделью МО. 2) Плагин использует недостаточную изоляцию между плагинами и ядром модели, обходя ограничения доступа. 3) В системе не реализованы механизмы проверки цифровых подписей, песочницы или поведенческого контроля плагинов.	T0053: Компрометация плагина LLM	1) Внедрённый плагин осуществляет подмену данных или модификацию логики обработки запросов, перенаправляя входы к атакующим шаблонам. 2) Созданы условия для неконтролируемой генерации нагрузки на систему. 3) Фактически установлен контролируемый агент в контуре модели.
1) Взломанный плагин LLM может инициировать создание массивных или ресурсоемких запросов к модели. 2) Отсутствует механизм защиты от перегрузки. 3) Модель работает в режиме единичного экземпляра без резервного копирования или изоляции критически важных компонентов.	T0029: Отказ в обслуживании модели МО	1) Ухудшение производительности или полный отказ в обслуживании модели из-за превышения допустимой нагрузки. 2) Потеря доступности инференс-сервиса для легитимных пользователей. 3) Потенциальное нарушение соглашения об уровне обслуживания и сбои в работе бизнес-процессов, зависящих от модели МО.

Сценарий с наибольшим риском для группы №18: T0049(CVE-2023-39660) → T0047(CVE-2020-9480) → T0055(CVE-2018-7577) → T0042(CVE-2025-3121) → T0053(CVE-2024-1560) → T0029(CVE-2025-47777), модель которого изображена на рисунке 36.

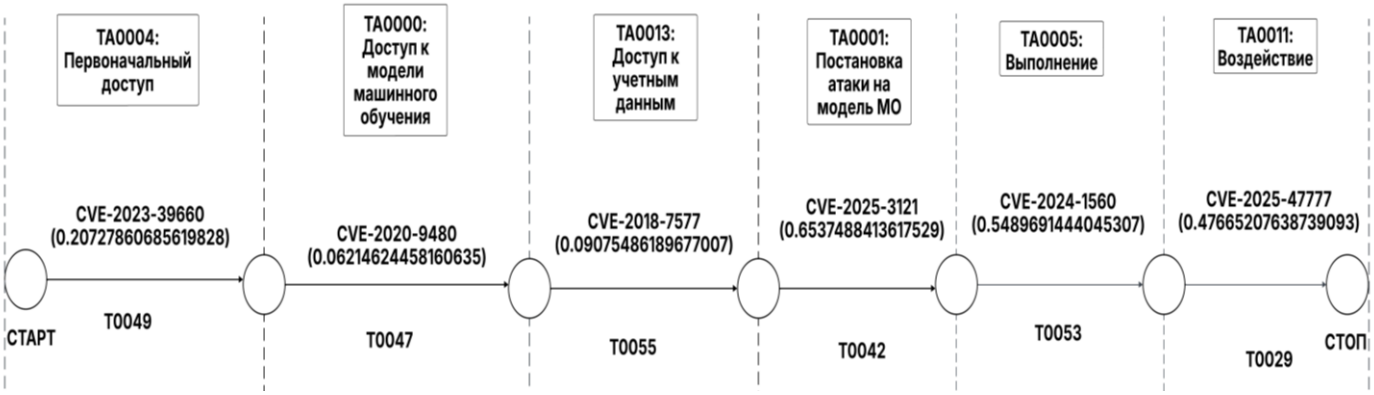


Рисунок 36 - Модель сценария с наибольшим риском для группы № 18

Результаты риск-анализа с наибольшим риском для группы сценариев № 18 представлен в таблицах 34 и 35.

Таблица 34. Критичность уязвимостей для сценария с наибольшим риском для группы №18

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0049: Недостатки в общедоступных приложениях	CVE-2023-39660	9.8	9.3	0.63	0.3949690625	0.862090588368319
T0047: Доступ к продукту или сервису, использующему МО	CVE-2020-9480 (Есть эксплойт)	9.8	9.3	0.8098	0.3336970625	0.901575217706473
T0055: Незащищенные учетные данные	CVE-2018-7577 (Есть эксплойт)	8.1	7.0	0.166	0.174190375	0.693248036587888
T0042: Подтверждение эффективности атаки	CVE-2025-3121	3.3	4.8	0.19	0.262886125	0.366457433675535
T0053: Компрометация плагина LLM	CVE-2024-1560	8.1	7.2	0.3	0.223030375	0.682932219983322
T0029: Отказ в обслуживании модели МО	CVE-2025-47777	7.5	8.7	0.90397	0.2672590625	0.837918792956813

Таблица 35. Оценка риска для сценария с наибольшим риском для группы №18

Произведение вероятностей	Сумма ущербов	Риск
0.00021957790836821397	4.3250	0.0009496744536925255

Данный сценарий из группы № 18 также является и наиболее ущербным. Таким образом наиболее критичный сценарий имеет риск $Risk = 0.0009496744536925255$ и ущерб U = 4.3250.

Для группы № 20 определены предусловия для перехода злоумышленника из одной техники в другую, выделенные в рамках проведенного анализа сценария (таблица 36).

Таблица 36. Условия перехода злоумышленника из одной техники в другую для группы сценариев №18

Предварительные условия	Техника	Последствия
1) Система допускает автоматическую или не регламентирующую регистрацию новых пользователей без проверки источника и целей. 2) Процедуры проверки личности, антибот-фильтрации и контроля аномалий не были реализованы. 3) Зарегистрированный аккаунт получает чрезмерные или неконтролируемые права в среде МО.	T0021: Создание учетных записей	1) Злоумышленник создал валидную учетную запись в системе, действующую под видом законного пользователя. 2) Данная запись может быть использована для неправомерной загрузки артефактов, взаимодействия с моделью и доступа к инфраструктуре. 3) Закладывается фундамент для внедрения вредоносных компонентов в систему МО.
1) Полученная учетная запись используется для загрузки артефактов. 2) Система не проверяет безопасность и целостность пользовательских компонентов (отсутствует проверка цифровой подписи, статический анализ, песочница). 3) Загружаемые артефакты интегрируются в конвейер или используются в последующих вызовах модели.	T0011.000: Выполнение с участием пользователя: небезопасные артефакты машинного обучения	1) Артефакты, содержащие вредоносный код или намеренно искаженную логику, внедряются в систему МО. 2) Злоумышленник получает возможность выполнять произвольные операции при активации артефактов. 3) Получен локальный доступ к внутренним структурам модели или сервисам.
1) Во время запуска вредоносных артефактов злоумышленник получает доступ к файлам конфигурации, среде выполнения и переменным окружения. 2) Обнаружены незашифрованные или незащищенные учетные данные (токены, пароли, API-ключи). 3) Функции безопасности не применяются или отключены.	T0055: Незащищенные учетные данные	1) Компрометация действующих учётных данных для доступа к МО-сервисам, хранилищам данных или конвейерам обучения. 2) Возможность повышения привилегий и подмены доверенных компонентов. 3) Подготовка условий для внедрения отравленных данных в обучение модели.
1) Собранные или достоверные данные используются для запуска обучения модели в инфраструктуре (например, через API). 2) Загрузка ошибочных данных обучения, включая целевые шаблоны бэкдоров. 3) Отсутствуют механизмы контроля качества данных, фильтрации аномалий или отслеживания происхождения данных.	T0018.000: Создание бэкдора в модели машинного обучения: обучение модели на отравленных данных	1) Модель обучается или переобучается на отравленных данных с внедрением бэкдора (триггеров для генерации прогнозов по заранее заданному шаблону). 2) Целостность логики прогнозов модели нарушается при наличии специфических входных данных. 3) Модель становится инструментом злоумышленника, управляемым извне.
1) Реализованная модель бэкдора работает в продуктивной среде, где можно инициировать определенные входные данные и получать контролируемые ответы. 2) Модель не фильтрует подозрительные запросы и не регистрирует аномалии. 3) Система имеет выходные данные (API, CLI, отчеты), которые позволяют отображать содержимое или поведение модели.	T0025: Эксфильтрация через программные средства	1) Экспортируются чувствительные данные (веса модели, результаты на специфических входах, скрытые метки). 2) Сведения о модели или поведении могут быть использованы для репликации или целевой атаки на аналогичную систему. 3) Канал эксфильтрации может быть скрыт в стандартных запросах или ответах.
1) Модель с бэкдором используется для создания компрометирующих прогнозов или несанкционированных операций. 2) Продуктивная среда не ограничивает типы задач, запускаемых моделью, и обеспечивает доступ к внешним API или файловым системам. 3) Модель работает как вычислительный агент, а не контролируется администратором.	T0048: Неправомерное использование системы для достижения внешних эффектов	1) Модель используется злоумышленником для запуска внешних операций, включая взаимодействие с внешними API, генерацию вредоносного контента и сбор данных. 2) Система МО используется в качестве инструмента для более направленной атаки. 3) Потеря контроля над поведением модели и неправильное использование инфраструктуры.

Сценарий, имеющий наиболее высокий риск: T0021(CVE-2022-36022) →T0011.000(CVE-2017-12852) →T0055(CVE-2018-7577) → T0025(CVE-2023-6014) →T0018.000(CVE-2024-1880) →T0048(CVE-2023-38860) представлен на рисунке 37, также в таблице 37 представлены нормализованные критичности уязвимостей, эксплуатируемые в рамках данного сценария, а в таблице 38 показаны расчеты вероятность реализации данного сценария, ущерб и риск.

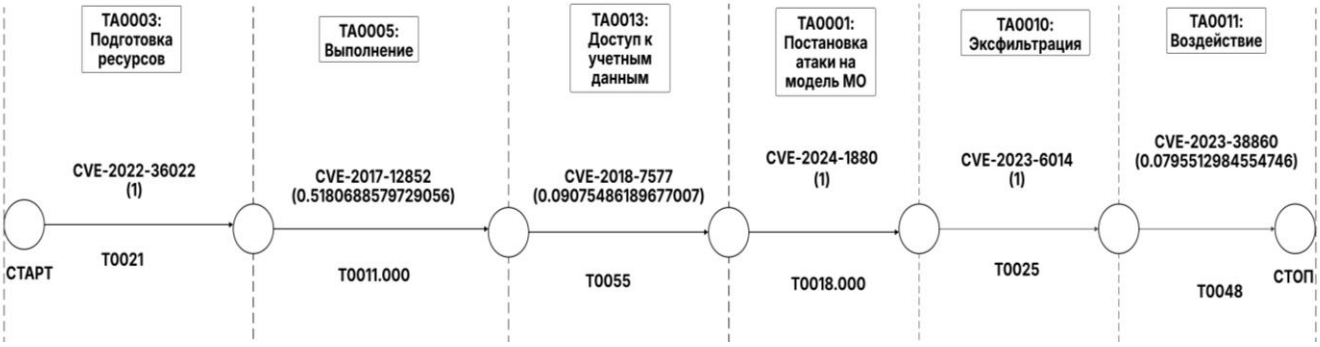


Рисунок 37 – Наиболее критичный сценарий для группы № 20, имеющий наибольший риск и ущерб

Таблица 37. Критичность уязвимостей для сценария с наибольшим ущербом для группы №20

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0021: Создание учетных записей	CVE-2022-36022	5.3	6.9	0.62	0.2455870625	0.612479041944177
T0011.000: Выполнение с участием пользователя: небезопасные артефакты машинного обучения	CVE-2017-12852	7.5	8.7	0.212	0.1836310625	0.737520759607476
T0055: Незащищенные учетные данные	CVE-2018-7577 (Есть эксплойт)	8.1	7.0	0.166	0.174190375	0.693248036587888
T0018.000: Создание бэкдора в модели машинного обучения	CVE-2024-1880	7.8	8.5	0.304	0.223208125	0.727802009554432

Продолжение таблицы 37

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0025: Эксфильтрация через программные средства	CVE-2023-6014	9.8	9.3	0.842	0.2130730625	0.913969395164871
T0048: Неправомерное использование системы для достижения внешних эффектов	CVE-2023-38860	9.8	9.3	0.1361	0.3031390625	0.888426983348294

Таблица 38. Оценка риска для сценария с наибольшим риском для группы №20

Произведение вероятностей	Сумма ущербов	Риск
0.003740284692050209	4.5750	0.015241660120104604

Таким образом, для группы сценариев №20 выделен наиболее критичный сценарий, имеющий $Risk = 0.015241660120104604$ и ущерб U = 4.5750.

Следующим этапом проведен анализ сценария с наибольшим количеством переходов, данный сценарий имеет достаточно низкий риски, но показывает более детализированный подход к прослеживанию действий злоумышленника, но данный сценарии из группы 27 имеет наибольший ущербы по сравнению со всеми остальными выделенными группами.

Для группы сценариев №27 выделен следующий наиболее критичный сценарий с наибольшим риском и ущербом: T0002(CVE-2023-3765) → T0016(CVE-2024-1879) → T0017(CVE-2017-16066) → T0015(CVE-2024-2928) → T0049(CVE-2023-39660) → T0053(CVE-2024-1560) → T0070(CVE-2019-10844) → T0054(CVE-2024-2057) → T0055(CVE-2018-7577) → T0037(CVE-2024-31583) → T0036(CVE-2020-15206) → T0035(CVE-2024-23752) → T0018(CVE-2024-5452) → T0057(CVE-2025-47277) →T0059(CVE-2023-39659) → T0029(CVE-2025-47777) → T0031(CVE-2024-25723), модель представлена на рисунке 38.

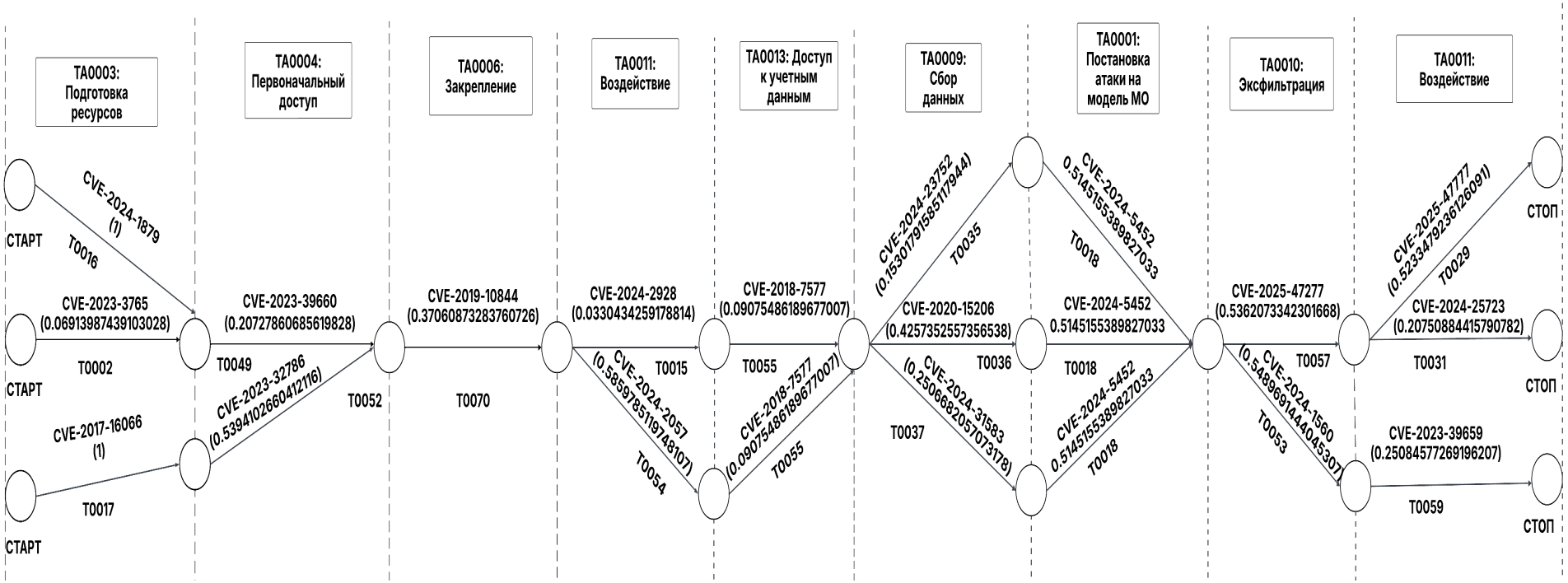


Рисунок 38 – Модель наиболее критичного сценария для группы № 27

Таблица 39. Критичность уязвимостей для сценария с наибольшим ущербом для группы №27

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0002: Получение артефактов МО	CVE-2023-3765 (Есть эксплойт)	10.0	10.0	0.9279	0.27515259375	0.968309103237041
T0017: Разработка собственных средств атаки МО	CVE-2017-16066	7.5	8.7	0.212	0.1836310625	0.737520759607476
T0016: Подготовка необходимых программных средств	CVE-2024-1879	8.8	8.6	0.157	0.252490375	0.800773720712385
T0049: Недостатки в общедоступных приложениях	CVE-2023-39660	9.8	9.3	0.3949690625	0.862090588368319	0.727802009554432
T0052: Фишинг	CVE-2023-32786	9.8	9.3	0.63	0.3949690625	0.862090588368319
T0070: Отравление RAG	CVE-2019-10844	9.8	9.3	0.363	0.3590890625	0.848174843211431
T0015: Обход модели МО	CVE-2024-2928 (Есть эксплойт)	8.1	7.0	0.166	0.174190375	0.693248036587888
T0054: LLM Джейлбрейк	CVE-2024-2057	6.3	5.3	0.39	0.396430375	0.523055523037339
T0055: Незащищенные учетные данные	CVE-2018-7577 (Есть эксплойт)	8.6	8,1	0.166	0.174190375	0.693248036587888
T0035: Сбор артефактов МО	CVE-2024-23752	9.8	9.3	0.505	0.3861490625	0.84846896947103
T0036: Данные из информационных хранилищ	CVE-2020-15206 (Есть эксплойт)	9.8	9.3	0.505	0.339130375	0.84846896947103
T0037: Данные из локальных систем	CVE-2024-31583	7.8	8.4	0.56	0.199916125	0.740002668792152
T0018: Создание бэкдора в модели машинного обучения	CVE-2024-5452	9.8	9.3	0.38186	0.3248890625	0.848483884379964
T0053: Компрометация плагина LLM	CVE-2024-1560	8.1	7.2	0.3	0.223030375	0.682932219983322

Продолжение таблицы 39

Техника	Уязвимость	CVSS 3.1	CVSS 4.0	EPSS	AIVSS	Среднеквадратичная
T0057: Утечка данных LLM	CVE-2025-47277	7,5	7.5	0.99	0.2088445	0.838563542918832
T0029: Отказ в обслуживании модели МО	CVE-2025-47777	7,5	7.5	0.99	0.2088445	0.838563542918832
T0031: Нарушение целостности модели МО	CVE-2024-25723	8.8	8.7	0.90183	0.339130375	0.873407250902154
T0059: Нарушение целостности набора данных	CVE-2023-39659	9.8	9.3	0.1201	0.2931190625	0.893742136899433

Таблица 40. Оценка риска для сценария с наибольшим риском для группы №27

Произведение вероятностей	Сумма ущербов	Риск
0,000000000149703342240	13.4880	0,000000020191986801 28

Таким образом, данный сценарий из всех выделенных групп имеет наибольший ущерб, равный U = 13, 4880, а риск является достаточно небольшим $Risk = 0{,}000000020191986801 28$.

На основании всего вышеизложенного можно сказать, что были рассмотрены одни из самых показательных примеров из выделенных групп, демонстрирующие эффективность разработанной методики, проанализированы сценарии с наибольшим риском и с наибольшим ущербом. В дальнейшем, данное исследование может быть положено в основу формирования новых сценариев, представленное множество сценариев не является исчерпывающем и должно проводиться активное дополнение, многие выделенные группы не являются полными на текущий момент по причине того, что не все слабости публикуются в открытом доступе, в следствие чего многие сценарии были урезаны в следствие отсутствия или невозможности применимости уязвимостей для перехода из одной техники в другую.

3 Организационно-правовое обеспечение противодействия атакам на средства машинного обучения

3.1 Меры реагирования и ликвидация последствий для наиболее критичных сценариев атак на средства машинного обучения

Во втором разделе данного исследования был построен граф множества сценариев и выделены наиболее возможные группы сценариев. Проведен риск-анализ групп и определены наиболее критичные сценарии, имеющий высокий риск реализации и ущерб. В результате из них были выделены группы сценариев, насчитывающее более трех переходов из одной техники в другую и имеющие либо наибольший риск, либо наибольший ущерб, данные сценарии были исследованы более тщательно и подробно. Следующим, логично завершающим этапом, становится разработка мер реагирования и ликвидации последствий для наиболее критичных сценариев атак на СМО, рассматриваемых в предыдущем разделе работы.

Классификация мер противодействия атакам – это процесс систематизации и группировки различных методов и технологий, используемых для защиты информационных систем от атак. Эта классификация позволяет лучше понять разнообразие подходов к обеспечению безопасности и эффективно применять их для защиты пользователей от угроз. Меры противодействия атакам могут быть классифицированы по различным критериям. К ним относятся организационно-правовые, технические, базовые и компенсирующие меры.

Организационно-правовые меры – это комплекс правил, положений и процедур, которые устанавливаются в организации для обеспечения безопасности информации. Эти меры направлены на предотвращение утечки данных, несанкционированного доступа к информации, а также на защиту от вредоносных программ и других угроз. Они включают в себя политику ИБ, процедуры и инструкции, меры доступа, контроль внутри организации ответственным подразделением ИБ. Контролируется работа сотрудников, имеющих допуск в информационную систему, а также порядок хранения и уничтожения секретных материалов.

Технические меры – это специальные методы и инструменты, которые используются для защиты информации от несанкционированного доступа, утечки или повреждения данных. Они включают в себя следующие методы: шифрование данных, аутентификацию, авторизацию, контроль доступа, создание электронной цифровой подписи для подтверждения личности пользователя. Для передачи данных используются специальные защищенные каналы связи. Отмечается время доступа пользователей в информационную систему, используются пароли и секретные метки. Вход в систему усложняется введением двухфакторной аутентификацией.

В ходе исследования были выработаны базовые и компенсирующие меры. Базовые состоят из организационных и технических мер. Компенсирующие меры – это меры безопасности, которые принимаются для смягчения рисков и компенсации уязвимостей в системе информационной безопасности. Эти меры могут включать в себя использование дополнительных уровней шифрования, усиление полномочий доступа к данным, регулярное обновление программного обеспечения, мониторинг сетевого трафика. Компенсирующие меры помогают уменьшить вероятность возникновения компьютерных атак и защищают информацию от утечек, несанкционированного доступа и других угроз. Они также обеспечивают дополнительный уровень защиты в случае нарушения безопасности или уязвимости в основных системах. Таким образом, классификация мер является важным шагом при анализе уязвимостей. С их помощью специалисты в области информационной безопасности могут минимизировать риски воздействия на систему.

При выработке базовых мер следует учитывать оценку критичности уязвимостей. Требуется рассматривать, каким образом злоумышленник воздействует на систему и какое влияние он оказывает на конфиденциальность, целостность и доступность. В ходе работы было выявлено, что для всех исследуемых уязвимостей ПО машинного обучения базовой мерой является обновление уязвимого программного обеспечения. Далее приведем разработанный регламент для сценариев атаки из группы №1 (таблица 41-42), остальные же меры представлены в приложении А.

Таблица 41. Базовые и компенсирующие меры для наиболее критичного сценария группы №1

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
TA0002: Разведка	T0006: Активное сканирование	CVE-2025-2998	- Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга (сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. - Установление процедуры еженедельного мониторинга наличия обновлений и установки безопасных и актуальных версий программного обеспечения (Руководство по мониторингу ведений об уязвимостях); - Внедрение методики тестирования обновления программного обеспечения. - Создание и внедрение руководства по устранению уязвимостей (включая уязвимости СМО).	Обновить фреймворк машинного обучения PyTorch до актуальной версии 2.7.1. Установка обновления должна происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	- Внедрение политики идентификации и аутентификации, которая регулирует аспекты: обязательного присвоения учётной записи пользователю организации; смена учётных данных в случае выявления факта их компрометации. - Утверждение парольной политики, включающей в себя: определение ответственных лиц за исполнение политики; положение об использовании паролей; требования к обеспечению парольной защиты учетных записей; порядок применения временных паролей. - Отключение (удаление) неиспользуемых учётных записей пользователей. - Смена учётных данных по умолчанию согласно установленному графику (не реже одного раза в три месяца).	- Минимизация пользовательских привилегий путем настройки СЗИ. - Ограничение возможности запуска уязвимого ПО пользователями с низкими привилегиями. - Настройка механизма разграничения доступа (RBAC) для объектов ClusterProvision; - Ограничение возможности выполнения системных вызовов «недоверенной» программой. - Ограничение возможности записи в директорию с установленными пакетами только разработчиков и администраторов. - Использование замкнутой (изолированной) программной среды для работы с файлами из недостоверных источников либо для запуска тестовых МО-задач. - Эксплуатация средств контроля целостности для отслеживания конфигурационных изменений системы. - Использование средств обнаружения и предотвращения вторжений (IDS/IPS) для выявления и реагирования на попытки эксплуатации уязвимости, например, на повышенную чувствительность к ошибкам 404 (Not Found), особенно если они поступают с нестандартных или подозрительных IP-адресов.

Продолжение таблицы 41

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
TA0004: Первоначальный доступ	T0049: Эксплуатация приложений с публичным доступом	CVE-2023-39660	- Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга (сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. - Установление процедуры еженедельного мониторинга наличия обновлений и установки безопасных и актуальных версий программного обеспечения (Руководство по мониторингу сведений об уязвимостях); - Внедрение методики тестирования обновления программного обеспечения. - Создание и внедрение руководства по устранению уязвимостей (включая уязвимости СМО).	Обновить Gaberiele Venturi pandasai v.0.8.0 до актуальной версии. Установка обновления должна происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	- Внедрение политики идентификации и аутентификации, которая регулирует аспекты: обязательного присвоения учётной записи пользователю организации. - Смена учётных данных в случае выявления факта их компрометации. - Утверждение парольной политики, включающей в себя: определение ответственных лиц за исполнение политики; положение об использовании паролей; требования к обеспечению парольной защиты учетных записей; порядок применения временных паролей. - Политика сетевой сегментации и доступа по «белым спискам» IP + запрет доступа из внешнего Интернета. - Ограничение доступа неизвестных пользователей с помощью белых/чёрных списков IP-адресов.	- Использование межсетевого экрана уровня приложений (WAF) для фильтрации HTTP/HTTPS-трафика. - Использование IDS/IPS для обнаружения и предотвращения попыток эксплуатации уязвимости. - Сегментирование сети путем организации доступа DMZ для публичного веб-сервиса pandas-ai. - Стартовый запуск библиотеки в изолированной программной среде (контейнер, песочница). - Ограничение запуска уязвимого ПО пользователями с недостаточными привилегиями. - Запрет возможности выполнения системных вызовов «подозрительной» программой. - Ограничение возможности записи в директорию с установленными пакетами. - Использование средств контроля целостности для отслеживания изменений конфигурации и пакетов; - Использование виртуальных машин для работы с файлами/вводом из неизвестных источников.
TA0009: Сбор данных	T0035: Сбор артефактов МО	CVE-2024-23752	- Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга (сканирования) и оценки	Обновить Pandas-ai до версии 1.5.17 и выше. Установка обновления должна происходить только из доверенных источников и	- Внедрение политики идентификации и аутентификации, которая регулирует аспекты: обязательного присвоения	- Отключение механизма анонимной аутентификации для доступа к платформе; - Использование двухфакторной (многофакторной)

Продолжение таблицы 41

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
TA0009: Сбор данных	T0035: Сбор артефактов МО	CVE-2024-23752	уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. - Внедрение регламента тестирования обновлений программного обеспечения.	лишь после оценки всех сопутствующих рисков.	учётной записи пользователю организации. - Смена учётных данных в случае выявления факта их компрометации. - Утверждение парольной политики, включающей в себя: определение ответственных лиц за исполнение политики; положение об использовании паролей; требования к обеспечению парольной защиты учетных записей, порядок применения временных паролей. - Регламент разграничения прав доступа к средствам машинного обучения. - Использование «белого» списка IP-адресов (ограничение доступа из внешних сетей).	аутентификации. - Настройка механизма разграничения доступа (RBAC). - Сегментирование сети и размещение сервиса в DMZ. - Использование WAF для фильтрации HTTP/HTTPS-трафика; - Настройка IDS/IPS для выявления и блокирования попыток эксплуатации уязвимости путем отслеживания сетевого трафика. - Запуск программного обеспечения в замкнутой (изолированной) среде; - Минимизация пользовательских привилегий и ограничение записи в каталог пакетов при помощи настройки дискреционного и мандатного доступа.
TA0013: Доступ к учётным данным	T0055: Доступ к незащищённым учётным данным	CVE-2023-44467	- Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга (сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. - Установление процедуры еженедельного мониторинга наличия	Обновление фреймворка LangChain до актуальной версии 0.3.25. Установка обновления должна происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	- Внедрение политики идентификации и аутентификации, которая регулирует аспекты: обязательного присвоения учётной записи пользователю организации; смена учётных данных в случае выявления факта их компрометации. - Утверждение парольной политики, включающей в себя: положение об использовании паролей; требования к минимально длине пароля.	- Использование межсетевого экрана уровня приложений (WAF) для фильтрации HTTP/HTTPS-трафика. - Использование IDS/IPS для обнаружения и предотвращения попыток эксплуатации уязвимости. - Ограничение доступа по «белым спискам» IP-адресов, запрет доступа по неизвестным адресам; - Сегментирование сети и размещение сервиса в DMZ.

Продолжение таблицы 41

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
ТА0013: Доступ к учётным данным	Т0055: Доступ к незащищённым учётным данным	CVE-2023-44467	наличия обновлений и установки безопасных и актуальных версий программного обеспечения (Руководство по мониторингу сведений об уязвимостях). - Внедрение методики тестирования обновления программного обеспечения. Создание и внедрение руководства по устранению уязвимостей (включая уязвимости СМО).		- Внедрение политики идентификации и аутентификации, которая регулирует аспекты: обязательного присвоения учётной записи пользователю организации. - Смена учётных данных в случае выявления факта их компрометации. - Утверждение парольной политики, включающей в себя: определение ответственных лиц за исполнение политики; положение об использовании паролей; требования к обеспечению парольной защиты учетных записей; порядок применения временных паролей, порядок процедуры экстренной смены учетных данных при подозрении на компрометацию. - Стандарт безопасной разработки программного обеспечения.	- Использование замкнутой (изолированной) программной среды. - Ограничение возможности выполнения системных вызовов «неизвестной» программой. - Запрет возможности записи в директорию с установленными пакетами пользователя, не имеющего должностных полномочий на данное действие. - Настройка механизма разграничения доступа (RBAC) к серверам МО. - Разграничение правд доступа путем настройки в СЗИ мандатного и дискреционного доступа.
ТА0010: Эксфильтрация	Т0025: Эксфильтрация через кибересредства	CVE-2023-6014	- Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга (сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц.	Обновление платформы машинного обучения MLflow до актуальной версии 3.1.0. Установка обновления должна происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	- Внедрение политики идентификации и аутентификации, которая регулирует аспекты: обязательного присвоения учётной записи пользователю организации; смена учётных данных в случае выявления факта их компрометации.	- Включение механизма аутентификации на уязвимых устройствах. - Отключение механизма анонимной аутентификации для доступа к платформе. - Использование двухфакторной аутентификации.

Продолжение таблицы 41

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
TA0010: Эксфильтрация	T0025: Эксфильтрация через киберсредства	CVE-2023-6014	- Установление процедуры еженедельного мониторинга наличия обновлений и установки безопасных и актуальных версий программного обеспечения (Руководство по мониторингу сведений об уязвимостях); - Внедрение методики тестирования обновления программного обеспечения. - Создание и внедрение руководства по устранению уязвимостей (включая уязвимости СМО).		- Утверждение парольной политики, включающей в себя: определение ответственных лиц за исполнение политики; положение об использовании паролей; требования к обеспечению парольной защиты учетных записей; порядок применения временных паролей, порядок процедуры экстренной смены учетных данных при подозрении на компрометацию. - Стандарт безопасной разработки программного обеспечения. - Использование «белого» списка IP-адресов / ограничение доступа из внешних сетей.	- Настройка взаимного TLS или VPN при удалённом доступе представляющего собой реализацию защищённого канала связи с двусторонней аутентификацией на основе сертификатов или туннелирования трафика с шифрованием и контролем доступа. - Использование IDS/IPS для обнаружения и предотвращения попыток эксплуатации уязвимости. - Ограничение доступа из внешних сетей (Интернет) и/или размещение сервиса в DMZ.

Таблица 42. Меры противодействия для наиболее критичного сценария атаки из группы №1 по техникам

Тактика	Техника	Меры реагирования	Меры ликвидации последствий	Превентивные меры
TA0002: Разведка	T0006: Активное сканирование	Поскольку система защиты информации не может влиять на действия нарушителя до его внедрения в систему и до его непосредственного взаимодействия с ней, то на данной тактике меры реагирования не применимы.	Поскольку система защиты информации не может влиять на действия нарушителя до его внедрения в систему и до его непосредственного взаимодействия с ней, то на данной тактике меры ликвидации последствий не применимы.	1) Логическое разделение вычислительных узлов, хранилищ данных и компонентов управления СМО на изолированные подсети с политикой «без использования по умолчанию»; 2) Настройка межсетевого экрана (WAF) прикладного уровня на блокирование характерных признаков автоматического сканирования (массовый перебор портов, попытки доступа к API); 3) Сокрытие лишней сетевой информации (стандартных портов, ICMP-ответов) для уменьшения возможности обнаружения злоумышленником слабых мест системы; 4) Развёртывание имитационно-ловушечной подсистемы раннего обнаружения (honeynet для СМО).
TA0004: Первоначальный доступ	T0049: Эксплуатация приложений с публичным доступом	1) Использование SIEM-систем для централизованного мониторинга попыток эксплуатации уязвимости. 2) Корреляция телеметрии СМО в централизованной системе мониторинга: внезапные всплески количества сбоев, нестандартные сетевые вызовы, признаки несанкционированного доступа к весовым файлам модели. 3)Удалённая проверка подлинности установленного экземпляра (контроль целостности) и автоматическое отключение доступа к ресурсам при расхождении контрольных сумм.	1) Экстренный выпуск исправленной версии с принудительным обновлением пользователей и отзывом подписи скомпрометированного пакета; 2) Генерация нового ключевого материала (сертификатов подписи, токенов доступа к репозиториям модели) и отзыв старых ключей. 3) Проведение форензического анализа изменённых артефактов модели, пересборка компонетов модели и обновление набора обучающих данных. 4) Внесение выявленных методик модификации в базу инцидентов, расширение правил проверки целостности и обновление локальных	1) Криптографическая подпись и контроль целостности исполняемых пакетов, библиотек и весовых файлов моделей до размещения в открытых репозиториях. 2) Исключение отладочных артефактов и уязвимых зависимостей путём статического и динамического анализа исходного кода и сторонних модулей. 3) Применение механизмов сокрытия и шифрования модели для затруднения извлечения и модификации весов. 4) Предварительная проверка каждого релиза через локальную систему безопасности.

Продолжение таблицы 42

Тактика	Техника	Меры реагирования	Меры ликвидации последствий	Превентивные меры
			нормативных документов по безопасности разработки. фиксируемую в системе управления изменениями.	5) Настройка минимально необходимых разрешений приложений и запрет экспортируемых компонентов, не требуемых для функционирования модели.
TA0009: Сбор данных	T0035: Сбор артефактов МО	1) Настройка следующих правил SIEM-системы: выявление и оповещение в случаях резкого роста выгрузки данных, частые запросы к .pt / .csv, доступ из неизвестной подсети; 2)Настройка на WAF правил автоблокировки: при подозрительной активности отправляем IP-адрес в черный список, блокировка учетной записи IAM; 3) Оповещение ИБ-отдела об инциденте.	1) Обновление ключей и токенов доступа к репозиторию артефактов, открытые сессии сбрасываются. 2) Переобучение модели или перезапуск (новая версия, другой хэш, новые ключи). 3) Проверка целостность кода и пакетов — удаление всех неподписанных или изменяемых данных. 4) Расширение правил SIEM и DLP с учётом новой схемы утечки. 5) Документирование инцидента и обновление внутренних инструкций: кто ответственен, какие шаги обязательны, какие риски добавились, есть ли пострадавшее ПО.	1) Шифрование хранилищ моделей и датасетов при помощи криптографических алгоритмов; ключи необходимо хранить в защищённом модуле. 2) Регулировать доступ к артефактам строго по ролям и минимально необходимым правам. 3) Размещать репозиторий в изолированном сегменте сети с политикой «deny all». 4) Оснащать каждую модель хэшем и водяным знаком; проверять их при каждом обращении. 5) Настроить DLP-систему на блокировку передачи файлов типа *.pt, *.onnx, крупных CSV/Parquet.
TA0013: Доступ к учётным данным	T0055: Доступ к незащищённым учётным данным	1) В средствах обнаружения и предотвращения вторжений (IDS/IPS) задать триггеры на множественные обращения к файлам id_rsa, .key, credentials (данные файлы хранят приватные ключи либо токены, обеспечивающие аутентификацию и шифрование). 2) Автоматизированная изоляция вычислительной среды: контейнер или виртуальная машина переводится в режим read-only; исходящий трафик фильтруется правилом «доверенная подсеть — DROP».	1) Полная ротация сертификатов (паролей, API-токенов, сертификатов) с публикацией обновлённого списка отозванных сертификатов. 2) Восстановление поврежденных компонентов модели МО из резервных копий, и обновление аутентификационных данных к ним. 3) Все бинарные и скриптовые файлы сверяются с эталонными хэш-значениями, объекты без подтверждённой подписи удаляются. 4) Обновление сигнатур и шаблонов обнаружения секретов в SIEM-	1) Внедрение централизованной системы управления секретами: все пароли, API-токены и закрытые ключи передаются вычислительным узлам по протоколу однократной выдачи с ограничением времени жизни, исходный ключевой материал размещается в аппаратном модуле защиты. 2) Криптографическая защита конфигурационных данных: файлы, содержащие параметры подключения к хранилищам данных или службам модели, шифруются алгоритмами, сертифицированными ФСТЭК,

Продолжение таблицы 42

Тактика	Техника	Меры реагирования	Меры ликвидации последствий	Превентивные меры
		3) Немедленный отзыв скомпрометированных секретов. Хранилище аннулирует выданные токены, активные сессии прерываются.	системах на основании полученных данных об инциденте.	хранение в открытом виде исключается. 3) Автоматический контроль цепочки поставки: в конвейер сборки включён анализ кода и образов на наличие секретов, при обнаружении выпуск блокируется. 4) Ротация ключей и принцип минимальных привилегий: постоянные секреты меняются по расписанию, каждая сервисная учётка ограничена строго необходимыми правами.
TA0010: Эксфильтрация	T0025: Эксфильтрация через киберсредства	1) Настройка IDS/IPS-правил: обнаружение резкого всплеска upload-трафика, попыток туннелирования по нестандартным портам, отправки файлов, совпадающих с DLP-сигнатурами. 2) Автоматическая изоляция узла-нарушителя: перевод интерфейса в VLAN-карантин, файловой системы — в режим read-only, обрыв активных соединений. 3) Немедленный отзыв криптографических ключей, токенов, задействованных в подозрительной сессии, принудительный разрыв TLS-сеансов. 4) Использование средств контроля целостности.	1) Полная смена сертификатов (паролей, API-токенов, сертификатов) с публикацией обновлённого списка отозванных сертификатов. 2) Проверка целостности программной среды и конфигураций: проверка контрольных сумм всех исполняемых файлов, скриптов, библиотек и конфигураций средствами СЗИ контроля целостности. 3) Восстановление репозиториев из доверенных резервных копий с верификацией цифровых подписей и контрольных сумм. 4) Удаление файлов с несовпадающими контрольными суммами и восстановление их предыдущих копий из сервера резервного копирования; 5) Дополнение политик DLP, SIEM, WAF и IDS с учётом выявленных векторов: все выявленные методы эксфильтрации добавляются в сигнатурные базы и правила корреляции.	1) Сетевое сегментирование и изоляция подсистем хранения артефактов МО: вычислительные узлы, на которых размещаются модели, обучающие выборки, лог-файлы и метаданные, должны быть размещены в логически изолированном сегменте сети с политикой «отказ по умолчанию» (default deny). 2) Применение криптографической защиты каналов передачи артефактов МО. 3) Внедрение системы предотвращения утечек информации (DLP). 4) Ограничение скорости исходящего трафика и контроль аномалий. 5) Встраивание цифровых идентификаторов в модели и датасеты.

3.2 Методическое обеспечение для управления уязвимостями информационных автоматизированных систем (ИАС), включающих в себя средства машинного обучения

3.2.1 Модель процесса управления уязвимостями средств машинного обучения

В связи с глубоким анализом атак, нацеленных на ИАС, включающих в себя СМО, очевидным фактом становится то, что реализация атак сводится к эксплуатации уязвимостей. Следовательно, в качестве эффективной меры ликвидации выступает разработка методического обеспечения для управления уязвимостями СМО.

В качестве нормативной основы для построения такой методики используется Методический документ "Руководство по организации процесса управления уязвимостями в органе (организации)", утверждённый ФСТЭК России 17 мая 2023 года [71]. Несмотря на то, что данный документ имеет универсальную направленность и не учитывает специфические особенности СМО, он служит методологическим базисом для построения специализированных процедур, адаптированных под контекст ИАС, с включёнными средствами машинного обучения. Учитывая отсутствие в текущем нормативном поле специализированных руководств по управлению уязвимостями СМО, данный документ следует рассматривать как отправную точку для последующей модификации и детализации процедур в отношении специфики угроз и уязвимостей, присущих СМО.

Разрабатываемая методика (Рисунок 39) представляет собой семиэтапную модель управления уязвимостями, интегрированную в общий цикл обеспечения информационной безопасности ИАС. Она опирается на принцип непрерывного процесса управления, охватывающего полный жизненный цикл выявления, анализа, устранения и контроля уязвимостей в компонентах системы, включая модели МО, данные, механизмы вывода (инференса) и сопутствующую инфраструктуру.

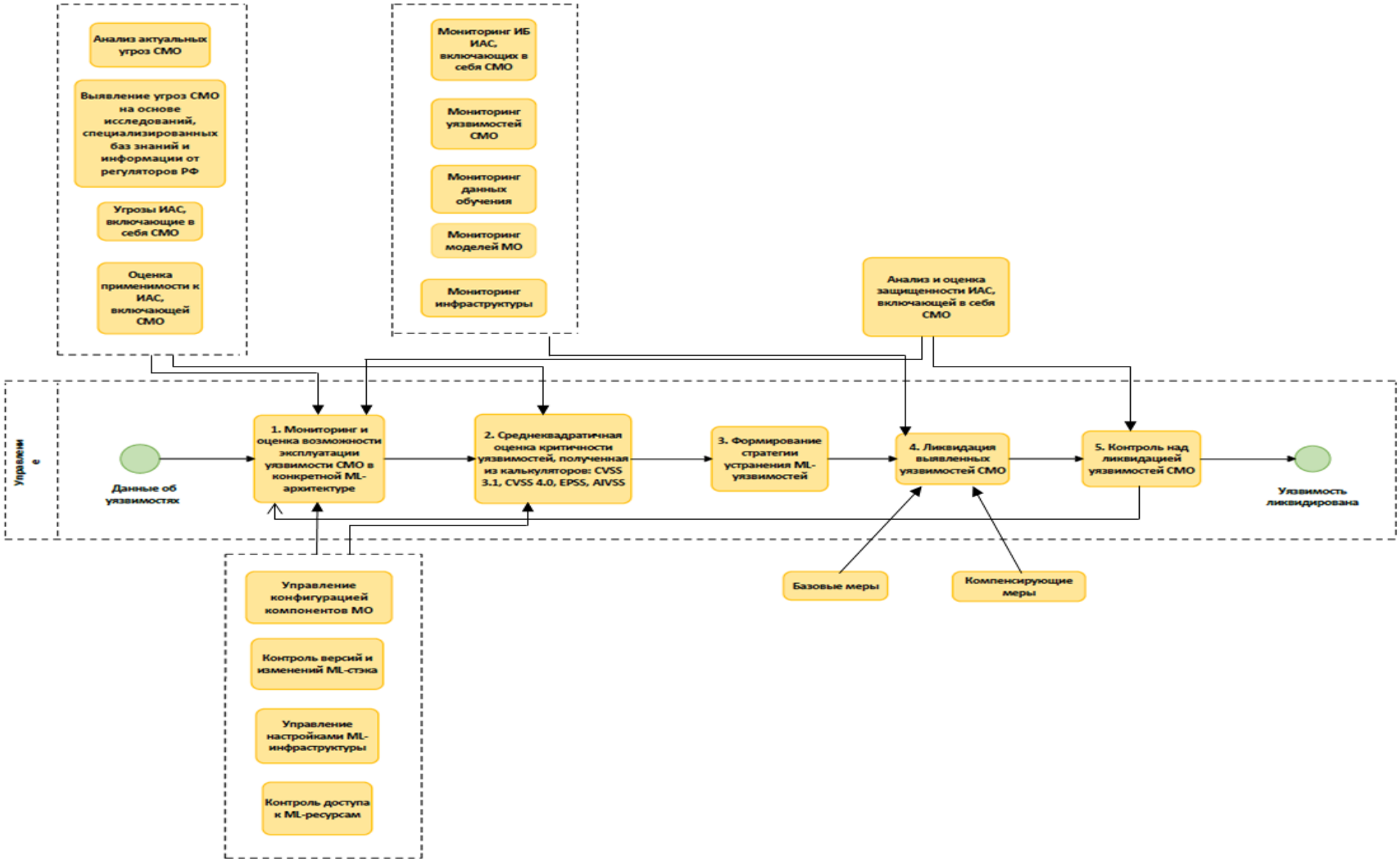


Рисунок 39 – Схема процесса управления уязвимостями СМО

Первым этапом методики выступает идентификация угроз, которая основывается на многофакторном анализе информации из различных проверенных источников. В рамках этого этапа осуществляется систематическое изучение специализированных баз уязвимостей, включая БДУ ФСТЭК, NVD (National Vulnerability Database), НКЦКИ (национальный координационный центр по компьютерным инцидентам), OVALdb [78] и CNNVD. Анализ дополняется мониторингом бюллетеней поставщиков программных решений, публикаций регуляторных органов (например, профильных структур Правительства РФ), а также оценкой существующих инцидентов, зафиксированных в отношении систем, основанных на машинном обучении. Особое внимание уделяется анализу взаимодействия МО-компонентов с другими подсистемами, включая источники данных, управляющие подсистемы и каналы обмена, что позволяет сформировать целостную модель угроз с учётом каскадных эффектов. На следующем этапе реализуется непрерывный мониторинг состояния безопасности, выполняемый средствами многоуровневого контроля. Объектами наблюдения являются целостность и функциональная корректность моделей, истинность и репрезентативность обучающих и валидационных данных, производительность ключевых вычислительных узлов, состояние хранилищ, API-интерфейсов и транспортной среды. Для обработки полученной телеметрии используются инструменты интеллектуального анализа, включая системы обнаружения аномалий, механизмы корреляции событий и системы предиктивной аналитики, что позволяет в режиме реального времени фиксировать потенциальные признаки эксплуатации уязвимостей или несанкционированного вмешательства.

Третий этап включает оценку уязвимостей с использованием стандартизированных методик. В частности, применяются Common Vulnerability Scoring System (CVSS) версий 3.1 и 4.0 для универсального ранжирования уязвимостей, а также более специализированные метрики, такие как Exploit Prediction Scoring System (EPSS) и AI Vulnerability Scoring System (AIVSS), ориентированные на оценку рисков в МО-среде. На основании совокупной оценки формируется приоритетный план реагирования, включающий мероприятия по патчингу,

обновлению компонентов, устранению конфигурационных ошибок и переобучению моделей.

Четвёртым этапом выступает управление конфигурацией, направленное на обеспечение устойчивости и управляемости МО-инфраструктуры. В рамках этого направления реализуется централизованное администрирование конфигурационными параметрами, контроль версий компонентов, защита от нежелательных изменений и автоматизированное развертывание безопасных виртуальных машин. Использование принципов ролевого доступа (RBAC), сегментирование полномочий и обязательное применение шифрования как при хранении, так и при передаче данных служат дополнительными уровнями защиты от атак, направленных на компрометацию компонентов СМО.

Представленная методика позволяет формировать целостную систему управления уязвимостями, ориентированную на специфические риски и особенности систем, использующих машинное обучение. Её применение в ИАС способствует переходу от реактивной модели реагирования к проактивному управлению безопасностью, обеспечивая снижение вероятности успешной реализации атак за счёт своевременной идентификации и устранения уязвимостей на всех уровнях архитектуры. Система защиты включает два взаимодополняющих уровня. Базовые меры охватывают регулярное обновление ПО. Компенсирующие меры предусматривают использование систем обнаружения вторжений (IDS/IPS), антивирусной защиты и веб-приложений (WAF), что обеспечивает защиту от сложных целевых атак.

Все компоненты системы тесно интегрированы и взаимодействуют по принципу замкнутого цикла. Данные об угрозах определяют параметры мониторинга, результаты которого используются для оценки защищенности и разработки корректирующих мер. Постоянный контроль эффективности реализованных мер безопасности позволяет оперативно адаптировать систему к изменяющимся угрозам.

Представленный подход обеспечивает комплексную защиту ИАС с компонентами машинного обучения, соответствуя современным требованиям информационной безопасности и нормативным стандартам. Гибкая методика

позволяет эффективно противодействовать как известным, так и новым киберугрозам, минимизируя риски при сохранении производительности защищаемых систем.

3.2.2 Мониторинг уязвимостей и оценка их применимости в информационных автоматизированных системах (ИАС), включающих в себя средства машинного обучения

Этап «Мониторинг уязвимостей и оценка их применимости в ИАС, включающих СМО» является критически важной частью процесса управления уязвимостями в ИАС, использующих технологии машинного обучения (Рисунок 40). Ниже приведено поэтапное описание действий, выполняемых на данном этапе, с указанием их назначения, содержания и результатов.

«Сбор исходной информации о компонентах СМО и МО-инфраструктуре». Процесс начинается с формирования запроса сведений о компонентах машинного обучения, включая модели, пайплайны и используемые датасеты. Эти данные необходимы для составления полной картины архитектуры МО-инфраструктуры и последующего анализа возможных угроз. Далее выполняется анализ угроз, специфичных для компонентов машинного обучения, с учетом их уязвимостей и архитектурных особенностей. Результатом является формирование перечня уязвимых объектов, потенциально подверженных эксплуатации.

Следующим шагом данного этапа является «Управление конфигурацией и жизненным циклом компонентов МО». Параллельно осуществляется управление конфигурацией и жизненным циклом МО-компонентов, в ходе которого производится актуализация сведений о текущем состоянии МО-инфраструктуры. Это необходимо для обеспечения согласованности данных и точного определения состава элементов, находящихся в эксплуатации состава ИАС.

«Мониторинг источников и анализ уязвимостей». На следующем этапе проводится сбор информации о внутренних МО-модулях и пайплайнах, анализируются базы данных уязвимостей, такие как NVD и БДУ

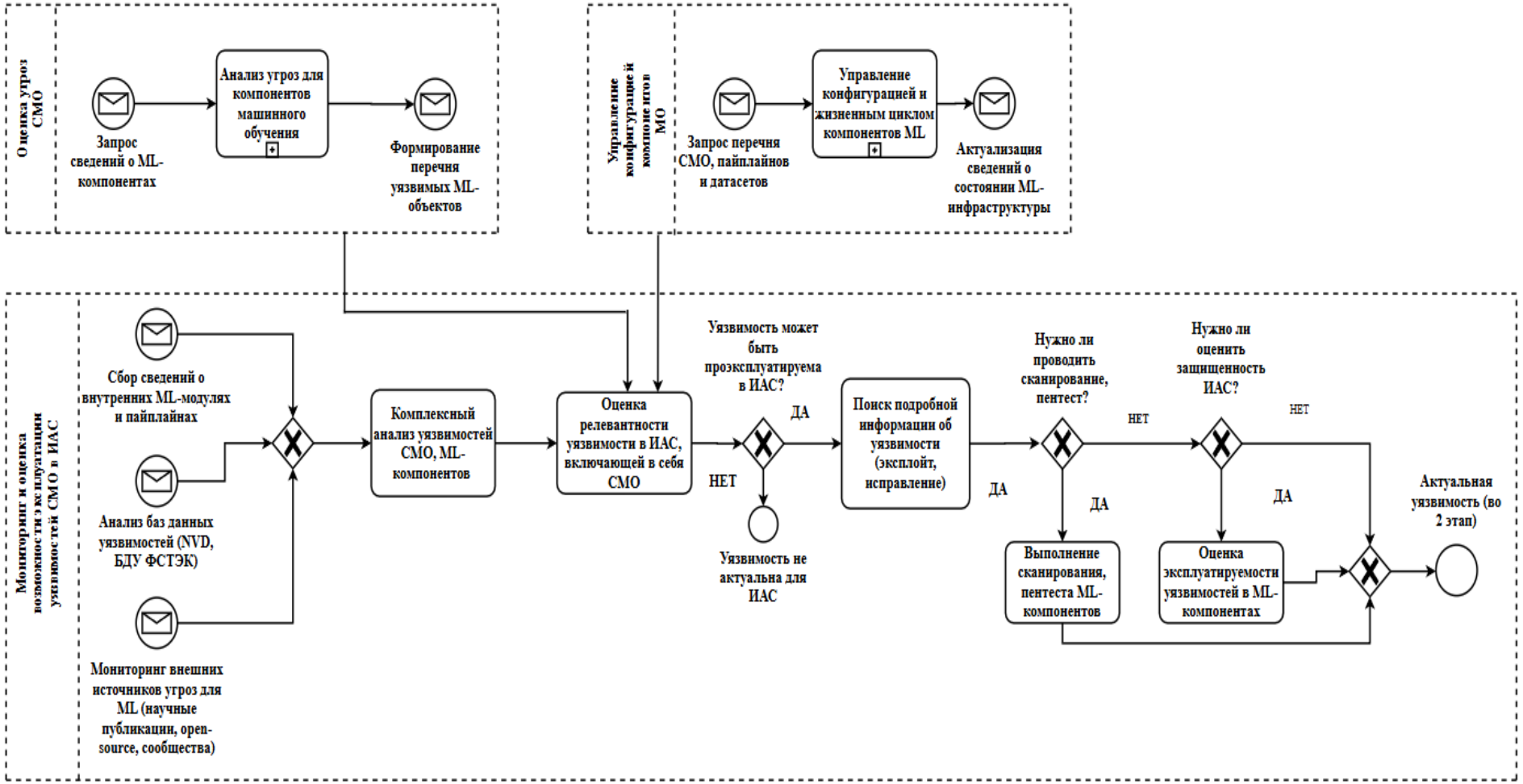


Рисунок 40 - Мониторинг уязвимостей и оценка их применимости в ИАС, включающих СМО

ФСТЭК, а также осуществляется мониторинг внешних источников угроз (научные публикации, open-source сообщества). Данная информация служит основой для комплексного анализа уязвимостей СМО и МО-компонентов, направленного на выявление потенциально опасных и критичных уязвимостей.

«Оценка релевантности и возможности эксплуатации уязвимостей в ИАС». После получения сведений об уязвимостях выполняется их оценка на предмет релевантности применительно к конкретной ИАС. На этом этапе определяется, применима ли уязвимость к условиям функционирования ИАС и может ли она быть потенциально использована злоумышленником. Если уязвимость не может быть эксплуатирована, она исключается из дальнейшего анализа как неактуальная.

«Изучение возможности эксплуатации и принятие решения о действиях». Для уязвимостей, потенциально применимых в ИАС, осуществляется поиск дополнительной информации: наличие эксплойтов, исправлений, уровней критичности. После этого принимается решение о необходимости проведения активного тестирования — сканирования или пентеста. Если такие меры необходимы, они выполняются в отношении МО-компонентов. Результаты пентеста и сканирования позволяют перейти к следующему шагу — оценке эксплуатируемости выявленных уязвимостей.

«Финальная оценка актуальности уязвимости». Заключительным этапом является оценка степени защищенности ИАС, которая определяется по результатам анализа, сканирования, тестирования и исследования уязвимостей. Если уязвимость подтверждается как актуальная, она переходит в следующий этап управления уязвимостями (этап 2), где разрабатываются и внедряются меры по устранению или снижению риска её эксплуатации.

Таким образом, данный этап позволяет системно выявить, оценить и классифицировать уязвимости в МО-компонентах с учетом специфики их использования в ИАС. Это обеспечивает проактивное управление рисками, связанными с безопасностью машинного обучения, и создает основу для последующих шагов по снижению потенциального ущерба от киберугроз.

3.2.3 Оценка уязвимостей средств машинного обучения

Этап оценки уязвимостей СМО в рамках процесса управления уязвимостями в ИАС представляет собой комплексную процедуру анализа актуальных уязвимостей, выявленных на предыдущем этапе, с целью определения их степени критичности, потенциального воздействия на МО-инфраструктуру и ИАС в целом, а также последующего формирования стратегии реагирования. Данный этап включает ряд логически взаимосвязанных шагов, каждый из которых выполняет специфическую аналитическую функцию (Рисунок 41).

«Сбор сведений о подверженных уязвимостям МО-компонентах». Первоначально осуществляется систематизация и детализация информации об МО-компонентах, для которых ранее были выявлены актуальные уязвимости. На данном шаге уточняются архитектурные и конфигурационные особенности компонентов (например, тип модели, структура пайплайна, используемое ПО и фреймворки), подтверждается принадлежность компонентов к контексту ИАС и проверяется их текущее состояние на предмет подверженности уязвимостям. Результатом является расширенный набор данных, позволяющий осуществить дальнейшую риск-ориентированную оценку.

Далее происходит переход на шаг «Оценка риска эксплуатации уязвимостей в МО», включающий качественный и количественный анализ риска эксплуатации выявленных уязвимостей. Оцениваются условия эксплуатации, уровень привилегий, необходимый для реализации атаки, возможности удаленного доступа, потенциальное наличие эксплойтов и другие факторы, влияющие на вероятность эксплуатации. Оценка проводится как экспертными методами, так и с привлечением автоматизированных средств (например, статических и динамических анализаторов). Результатом является классификация уязвимостей по уровню эксплуатационного риска: от низкого до критического.

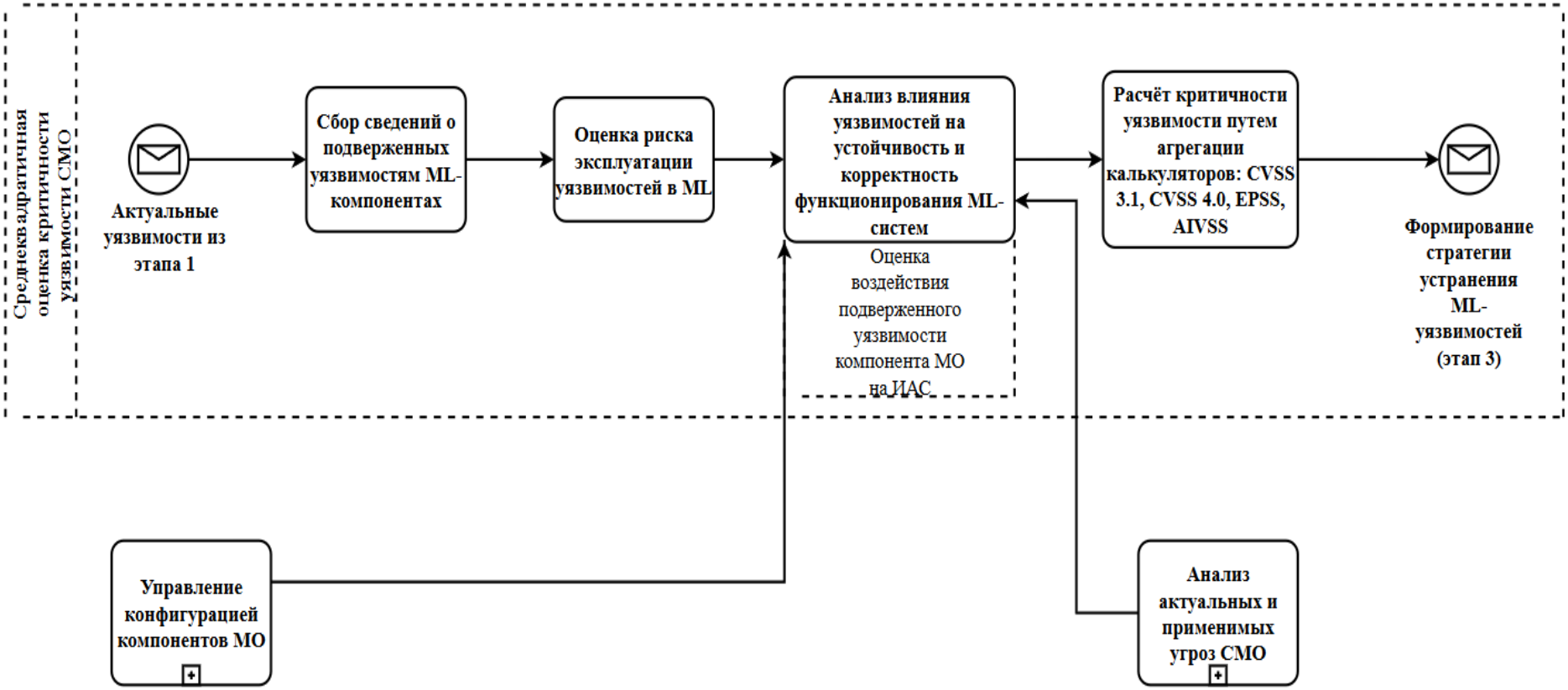


Рисунок 41 - Оценка уязвимостей СМО

Следующим выступает шаг «Анализ влияния уязвимостей на устойчивость и корректность функционирования МО-систем». На данном этапе осуществляется моделирование воздействия уязвимостей на жизненный цикл и функциональную корректность МО-систем. В частности, рассматриваются возможные последствия на этапах обучения, валидации, инференса и обновления модели. Оценивается потенциальное снижение устойчивости к шуму, рост ошибок классификации, возможность внедрения закладок (backdoor), манипуляция входными или выходными данными и другие последствия. Дополнительно выполняется оценка воздействия уязвимых компонентов на всю ИАС, включая межкомпонентные связи и уровень критичности задач, решаемых уязвимыми модулями.

Одним из самых решающих и важных шагов является «Расчёт критичности уязвимости путём агрегации результатов различных калькуляторов». Суммарная оценка критичности уязвимостей формируется путём агрегирования данных из различных калькуляторов оценки, включая CVSS 3.1, CVSS 4.0, EPSS, а также специализированный калькулятор AIVSS, ориентированный на особенности уязвимостей в МО. Используемая агрегирующая методика позволяет учесть как эксплуатационную опасность, так и потенциальный ущерб от воздействия на МО-компоненты. Результатом этапа становится формализованная метрика критичности, выраженная в числовом и категориальном виде.

«Формирование стратегии устранения МО-уязвимостей». Финальной задачей рассматриваемого этапа является передача результатов в блок стратегического управления уязвимостями (этап 3), где на основе полученных метрик разрабатываются конкретные меры реагирования — от устранения уязвимости и обновления компонентов до реализации компенсирующих механизмов или переноса функциональности. Это обеспечивает обоснованное принятие решений по снижению риска для ИАС.

Поддерживающие процессы: управление конфигурацией и анализ угроз. Параллельно основному процессу ведется управление конфигурацией компонентов машинного обучения, что обеспечивает актуальность и достоверность информации о программно-аппаратной базе. Также выполняется анализ актуальных и применимых

угроз СМО, что позволяет уточнять параметры угроз модели и адаптировать критерии оценки уязвимостей в зависимости от актуального ландшафта угроз.

Таким образом, этап оценки уязвимостей СМО представляет собой структурированный и воспроизводимый процесс, направленный на всестороннюю оценку эксплуатационной и функциональной значимости уязвимостей МО-компонентов в составе ИАС.

3.2.4 Методика определения приоритетов устранения уязвимостей средств машинного обучения

На этапе управления уязвимостями средств машинного обучения в ИАС реализуется методика определения приоритетов устранения уязвимостей, представляемая в виде структурированной блок-схемы (Рисунок 42). Ниже приводится последовательное пояснение всех шагов данной схемы.

Первоначально осуществляется выявление уязвимостей, обнаруженных в результате процедур сканирования и проведения тестов на проникновение (пентестов). Эти уязвимости могут затрагивать различные компоненты МО-систем, включая данные, модели, программные библиотеки и окружение исполнения. Полученные данные поступают на анализ в рамках процесса определения этапности реагирования на выявленные уязвимости компонентов машинного обучения.

На следующем этапе производится выбор стратегии и методов нейтрализации уязвимостей МО. Это включает оценку характера угрозы, возможного воздействия на функционирование ИАС, и определение допустимого временного окна реагирования. После чего осуществляется классификация инцидента и формулируются мероприятия по ликвидации, если уязвимость признаётся критической.

Если критическая оценка подтверждает значимость уязвимости, то осуществляется оперативное инициирование базовых мер защиты средствами системы мониторинга и управления безопасностью СМО. В противном случае применяется подход с определением типа защитных мер, включая внедрение

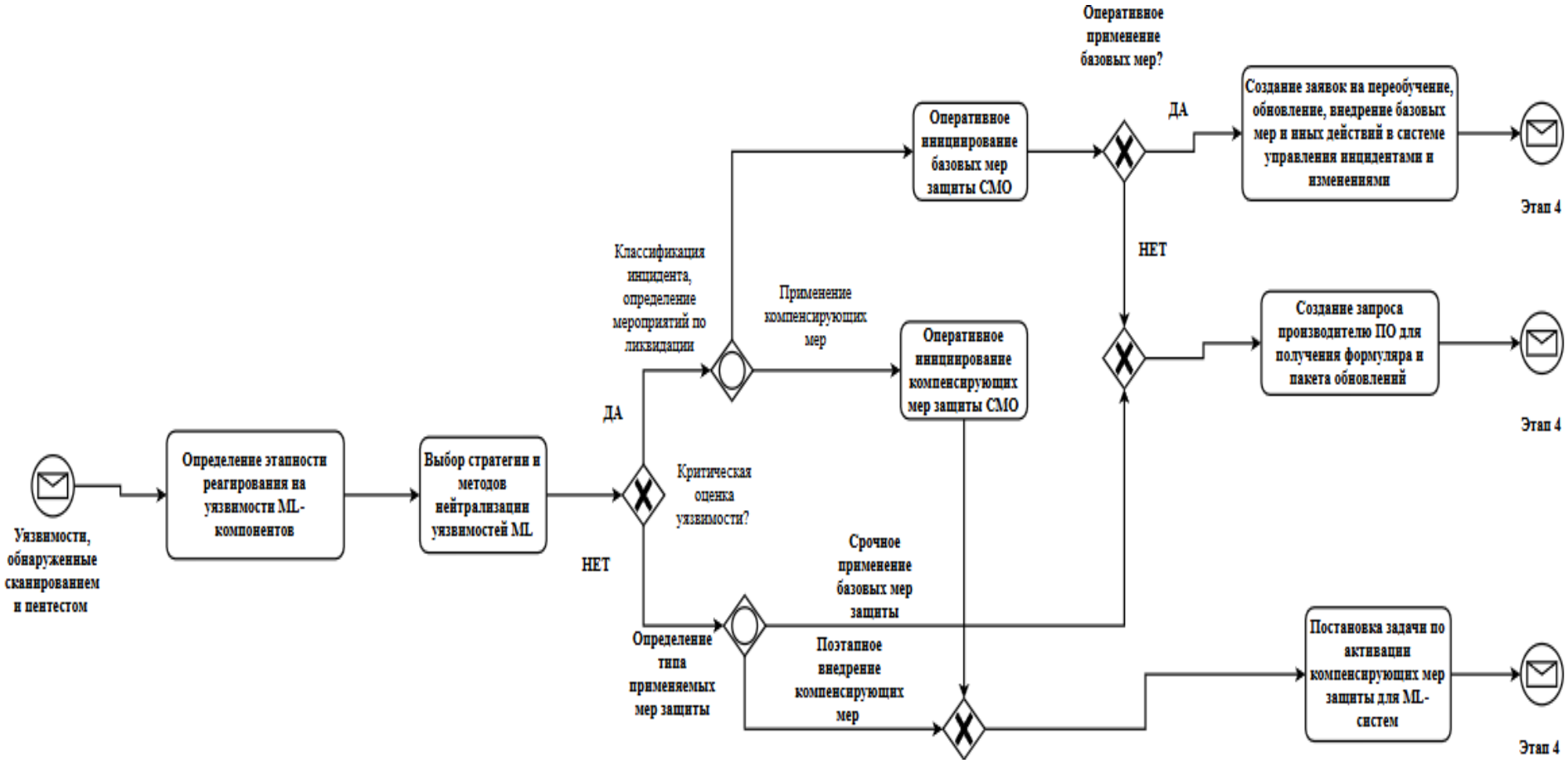


Рисунок 42 – Методика определения приоритетов устранения уязвимостей

базовых механизмов или последовательную реализацию компенсирующих мер.

Параллельно с этим, в случае невозможности применения базовых мер защиты, инициируется процесс применения компенсирующих мер, которые затем активируются СМО. Далее вновь проверяется возможность оперативного применения базовых мер. Если это возможно, формируется заявка на переобучение, обновление и внедрение базовых мер с дальнейшей регистрацией этих действий в системе управления инцидентами и изменениями.

В случае невозможности такого обновления формируется запрос вендору программного обеспечения на получение соответствующих формуляров и пакетов обновлений. Если и это недоступно, инициируется задача по активации компенсирующих мер защиты для МО-систем с целью временного нивелирования уязвимости до внедрения основного решения.

На завершающих этапах все мероприятия документируются, формируются отчёты, а также проводится итеративная валидация применённых мер на предмет их эффективности, с последующим возвращением в исходную точку при необходимости корректировки стратегии реагирования.

3.2.5 Устранение уязвимостей средств машинного обучения

Этап устранения уязвимостей в контексте обеспечения безопасности ИАС, включающих средства машинного обучения (СМО), представляет собой систематизированный процесс исправления обнаруженных уязвимостей в МО-компонентах с последующим внедрением обновлённых моделей в рабочую среду. Целью данного этапа является минимизация эксплуатационных рисков и обеспечение безопасности ИАС при сохранении требуемого уровня производительности (Рисунок 43).

Данный этап начинается с шага «Инициация процесса устранения уязвимости». Процесс начинается с формирования запроса на обновление или переобучение МО-модели. Запрос, может быть, следующих типов:

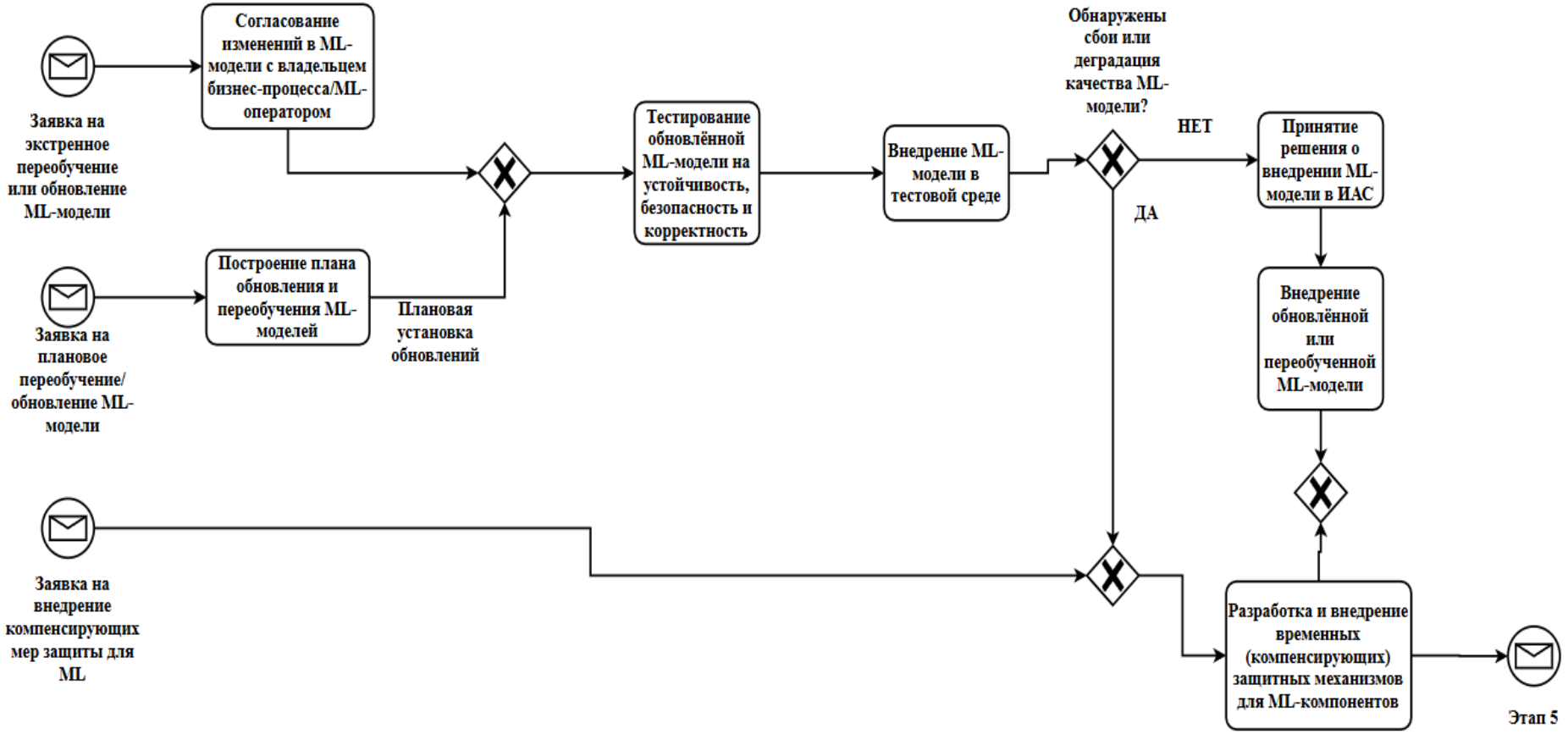


Рисунок 43 – Устранение уязвимостей СМО

- «Экстренный», если выявлена критическая уязвимость, требующая немедленного вмешательства;

- «Плановый», когда изменения связаны с регулярным техническим обслуживанием либо улучшением модели;

- «Запрос на компенсирующие меры», в случае необходимости временной защиты до устранения основной уязвимости.

Результатом данного шага является формализация задачи по устранению уязвимости с последующим согласованием с владельцем бизнес-процесса или МО-оператором.

«Согласование изменений с заинтересованными сторонами». На этом этапе происходит согласование предлагаемых изменений в МО-модели с владельцем бизнес-процесса и МО-оператором. Владелец бизнес-процесса оценивает влияние изменений на ключевые показатели эффективности (KPI), а МО-оператор проверяет техническую реализуемость и соответствие требованиям безопасности.

Итогом является получение решения о целесообразности внесения изменений — либо одобрение, либо отказ от их внедрения.

Далее осуществляется переход на шаг «Разработка плана обновления и переобучения модели». Если изменения утверждены, формируется детализированный план, включающий:

- определение сроков всех этапов работ (подготовка, тестирование, внедрение);

- выбор подходящей методологии обновления (например, переобучение на новых данных, модификация параметров, изменение архитектуры);

- организацию необходимых ресурсов (вычислительных мощностей, специалистами, инструментами).

Результатом является утверждённый план, обеспечивающий структурированный подход к обновлению модели.

«Тестирование обновлённой модели». Перед внедрением обновлённая модель проходит комплексное тестирование по трём основным направлениям:

- устойчивость к атакам;

- безопасность, в части защиты данных, взаимодействия с другими компонентами системы, а также предотвращения несанкционированного доступа;

- корректность функционирования, оцениваемая на тестовых наборах данных.

Модель, успешно прошедшая все тесты, допускается к следующему этапу. В противном случае осуществляется возврат к доработке.

«Развёртывание модели в тестовой среде». Обновлённая модель МО внедряется в тестовую среду, имитирующую рабочее окружение ИАС. Проводится настройка конфигурации, а также мониторинг ключевых характеристик: производительности, стабильности, безопасности. Результатом данного этапа является подтверждение готовности модели к работе в реальных условиях.

«Мониторинг и анализ отклонений». После внедрения в тестовую среду осуществляется анализ метрик качества и выявление возможных аномалий. Цель — обнаружение признаков деградации модели или нестабильного поведения. При выявлении проблем выполняется возврат к предыдущим этапам для устранения недостатков. В случае положительных результатов модель допускается к финальному внедрению.

«Принятие решения о внедрении в рабочую среду». На данном шаге принимается решение о переводе модели в продуктивную эксплуатацию. Все заинтересованные стороны (владельцы бизнес-процессов, МО-операторы, администраторы ИАС) подтверждают готовность модели и согласуют порядок внедрения, включая выбор времени и методов обеспечения непрерывности работы системы.

«Финальное внедрение модели». Обновлённая модель разворачивается в рабочем окружении. Производится переключение на новую версию модели с минимальными перебоями в функционировании системы. Результатом является интеграция актуальной модели МО в ИАС с устранёнными уязвимостями.

«Временные защитные меры». В случаях, когда устранение уязвимости требует значительных затрат ресурсов или времени, допускается внедрение компенсирующих механизмов: дополнительных слоёв контроля доступа, фильтрации, мониторинга,

временных ограничений доступа к уязвимым компонентам системы. Цель — обеспечение временной защиты до завершения полного устранения уязвимости.

Этап устранения уязвимостей является критически важным элементом жизненного цикла управления безопасностью МО-компонентов ИАС. Он включает в себя инициацию процесса, согласование, планирование, тестирование, развёртывание и финальное внедрение, а также возможное применение временных защитных мер. Комплексный характер данного этапа позволяет обеспечить как устойчивость системы к внешним воздействиям, так и надёжность функционирования обновлённых моделей в условиях реальной эксплуатации.

3.2.6 Проектирование и внедрение компенсирующих мер защиты для моделей машинного обучения

Данный этап представляет собой систематизированный процесс разработки и реализации компенсирующих мер, направленных на минимизацию рисков, связанных с эксплуатацией уязвимостей в моделях машинного обучения (МО), интегрированных в ИАС (Рисунок 44). Эти меры могут носить как временный, так и постоянный характер, в зависимости от характера угрозы и приоритетов безопасности системы. Основной целью этапа является обеспечение устойчивости МО-моделей к потенциальным атакам, снижение последствий выявленных уязвимостей и повышение общего уровня защищённости.

Первоначальным шагом в данном этапе выступает «Инициирование процедуры внедрения компенсирующих мер». Процесс начинается с получения запроса на внедрение компенсирующих мер. Инициирующий фактор может быть различным: срочная необходимость в предотвращении атак, плановое усиление защиты или реакция на выявленные уязвимости. На этом этапе формируется задача на проектирование защитных

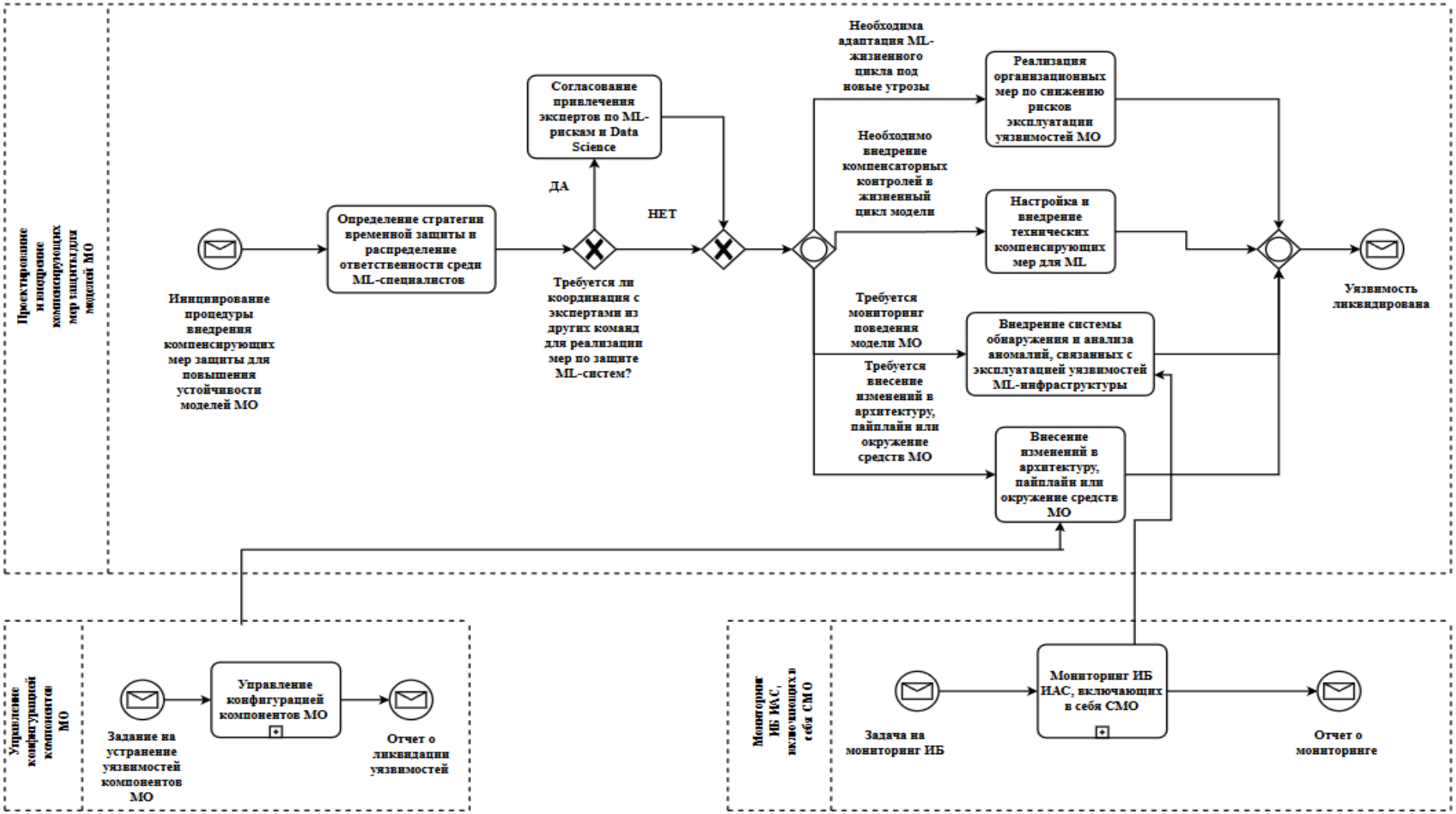


Рисунок 44 – Схема проектирования и внедрения компенсирующих мер защиты для моделей МО

механизмов, подлежащая обязательному согласованию с заинтересованными сторонами.

«Формирование стратегии временной защиты и распределение ответственности». Следующим шагом является выработка стратегии реагирования. Определяется тип компенсирующих мер (технические, организационные или комбинированные), устанавливаются сроки действия (временные или постоянные), а также осуществляется распределение ролей и обязанностей среди специалистов по МО. Результатом этапа является документированная стратегия внедрения, включающая перечень действий и ответственных лиц.

Далее осуществляется переход на шаг «Привлечение экспертов по МО-рискам и «Data Science»». При необходимости на этапе планирования согласовывается участие узкопрофильных специалистов. Это может включать экспертов по рискам в сфере машинного обучения для проведения детального анализа угроз или специалистов по Data Science — для модификации алгоритмов или данных. В случае необходимости координации с другими направлениями (например, безопасность или ИТ-инфраструктура), формируется расширенная рабочая группа.

Не менее важным элементом этапа является «Адаптация жизненного цикла модели под актуальные угрозы». Для обеспечения устойчивости модели к новым типам атак проводится ревизия текущего жизненного цикла разработки и эксплуатации МО. При выявлении несоответствий требованиям безопасности, жизненный цикл дополняется или модифицируется, включая корректировку процессов разработки, тестирования, валидации и мониторинга.

Один из самых важных элементов «Внедрение контрольных точек в жизненный цикл». Дополнительные контрольные точки могут быть внедрены на различных стадиях жизненного цикла модели. Это включает автоматическое сканирование кода, тестирование на устойчивость к атакующим воздействиям, а также интеграцию мониторинговых решений для наблюдения за моделью в реальном времени. Такие меры повышают надежность процессов и снижают вероятность незамеченного воздействия.

«Настройка и реализация технических компенсирующих мер». На данном этапе реализуются конкретные технические меры защиты. Включаются технологии защиты данных (например, шифрование, дифференциальная конфиденциальность), механизмы устойчивости модели к атакам (defensive distillation, input gradient masking и др.), а также меры по защите инфраструктуры: усиление контроля доступа, фильтрация трафика, DDoS-защита.

«Внедрение системы обнаружения и анализа аномалий». Для своевременного реагирования на угрозы осуществляется внедрение системы мониторинга и анализа аномалий. Она обеспечивает постоянное наблюдение за качеством работы модели и техническими параметрами системы. Механизмы автоматизированного реагирования (например, отключение компонентов, переключение на резервные системы) позволяют оперативно ограничить или пресечь развитие атаки.

«Изменения в архитектуре, пайплайнах и окружении». При выявлении архитектурных или инфраструктурных причин уязвимостей проводится доработка архитектуры модели, переработка пайплайнов обработки данных, а также модернизация вычислительного окружения. Могут быть внедрены меры изоляции компонентов (например, sandboxing), повышение устойчивости моделей за счёт архитектурных решений и оптимизация рабочих процессов.

«Реализация организационных компенсирующих мер». Технические меры сопровождаются организационными изменениями. Внедряются внутренние стандарты безопасности, усиливаются правила управления доступом, а также проводится обучение персонала, взаимодействующего с МО-моделями. Это обеспечивает формирование устойчивой культуры безопасности и снижает вероятность угроз, связанных с человеческим фактором.

«Постоянный мониторинг поведения модели». После внедрения всех запланированных мер осуществляется постоянный мониторинг модели. Осуществляется сбор и анализ показателей её производительности, проводится аудит логов и событий. Сформированная отчётность позволяет убедиться в корректной работе системы и своевременно выявлять возможные отклонения.

И наконец происходит переход на «Финальное устранение уязвимости». Завершающим этапом является подтверждение эффективности реализованных мер. Выполняется итоговая оценка состояния защищённости системы, анализируются данные мониторинга, тестируются все внесённые изменения. После подтверждения ликвидации уязвимости система продолжает функционировать в защищённом режиме.

Этап «Проектирование и внедрение компенсирующих мер защиты для моделей МО» представляет собой критически важную часть методики управления уязвимостями в интеллектуальных автоматизированных системах. Комплексный подход, сочетающий технические, архитектурные и организационные меры, позволяет минимизировать вероятность успешной атаки, обеспечить непрерывность функционирования модели и создать устойчивую к угрозам эксплуатационную среду. Последовательное выполнение всех шагов данного этапа обеспечивает системное и надёжное реагирование на уязвимости, возникающие в процессе жизненного цикла моделей машинного обучения.

3.2.7 Контроль устранения уязвимостей средств машинного обучения

Этап контроля устранения уязвимостей СМО, интегрированных в ИАС, представляет собой процесс систематической проверки эффективности реализации мероприятий по ликвидации ранее выявленных уязвимостей (Рисунок 45). Основной целью данного этапа является подтверждение того, что угрозы были устранены, а функционирование системы осуществляется в безопасном и устойчивом режиме. Ниже приведено поэтапное описание процедур, входящих в данный процесс.

«Инициация контроля устранения уязвимостей». На начальном шаге производится фиксация информации о завершении мероприятий по устранению уязвимости. Ответственные лица подтверждают реализацию корректирующих действий. После этого инициируется процедура контроля, которая предполагает запуск задач по верификации эффективности применённых мер.

Результатом данного этапа является формирование задачи на контроль устранения уязвимости, определяемой в рамках выбранного метода проверки.

«Выбор метода верификации эффективности устранения уязвимости». На следующем этапе осуществляется анализ характера уязвимости, включая её потенциальную критичность и сложность, с целью выбора оптимального метода контроля. Возможны следующие подходы: проведение экспертной оценки (аудита) устойчивости и корректности работы модели машинного обучения или использование автоматизированных инструментов тестирования и сканирования.

Выбранный метод должен обеспечивать объективную верификацию того, что уязвимость устранена и система функционирует в рамках допустимых параметров безопасности.

«Периодическая переоценка устойчивости модели». Если для контроля выбран метод экспертной оценки, реализуется периодическая переоценка устойчивости модели. В рамках этого процесса анализируется стабильность работы модели при различных условиях, проводится имитация потенциальных атак (например, adversarial attacks), а также осуществляется проверка корректности прогнозных значений и логики принятия решений.

Результатом этапа становится заключение о текущем уровне устойчивости модели к воздействиям и подтверждение её корректного функционирования после устранения уязвимости.

«Запуск автоматизированного тестирования и сканирования». В случае выбора автоматизированного подхода реализуются процедуры тестирования с использованием специализированных программных инструментов, ориентированных на проверку безопасности ML-компонентов. Тестируются не только непосредственно модель, но также связанные с ней элементы: данные, пайплайны, инфраструктура. По завершении тестирования формируются детализированные отчёты, содержащие информацию об обнаруженных

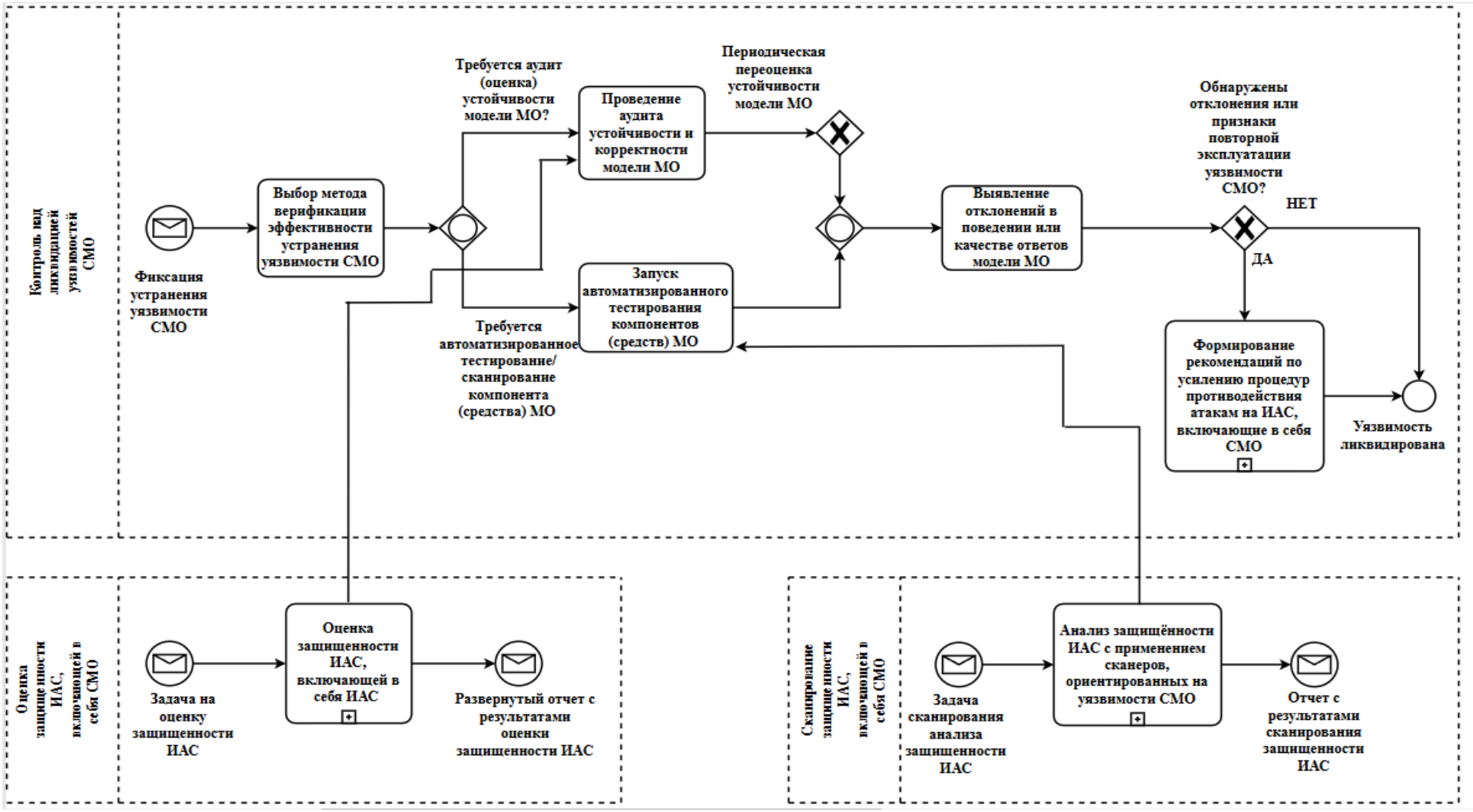


Рисунок 45 – Схема контроля устранения уязвимостей СМО

уязвимостях или подтверждающие их отсутствие.

«Анализ отклонений в поведении и качестве ответов модели». На основе результатов контрольных мероприятий проводится комплексный анализ поведения модели. Сравниваются метрики качества до и после внесения изменений, выполняется мониторинг логов и поиск аномалий, оценивается вероятность повторного возникновения уязвимостей. На этом этапе определяется, достигнут ли требуемый уровень безопасности, и выявляются возможные отклонения, свидетельствующие о неполном устранении уязвимости.

«Формирование рекомендаций по усилению безопасности ИАС». Если в ходе анализа обнаружены признаки повторной эксплуатации уязвимости или недостаточной защищённости, разрабатываются дополнительные рекомендации. Проводится анализ причин возникновения проблем, формируются предложения по внедрению дополнительных технических и организационных мер, направленных на повышение уровня безопасности. Также уточняются и совершенствуются процессы мониторинга и управления уязвимостями. Результатом данного этапа становится набор конкретных рекомендаций для усиления защиты ИАС и повышения устойчивости СМО.

«Подтверждение успешного устранения уязвимости». На завершающем этапе, при отсутствии признаков остаточных или повторно возникающих уязвимостей, формируется официальное заключение об успешности устранения уязвимости. Все выполненные действия и полученные результаты подлежат документированию и архивированию для обеспечения трассируемости и последующего анализа. Фиксация положительного результата свидетельствует о том, что СМО возвращена в безопасное состояние, и эксплуатация ИАС может продолжаться без дополнительного риска.

Таким образом, этап «Контроль устранения уязвимостей СМО» является критически важным элементом общей методики управления уязвимостями в ИАС. Он включает в себя последовательность формализованных процедур — от инициации контроля и выбора методов верификации до анализа результатов и формирования дополнительных рекомендаций. Его реализация позволяет обеспечить достоверную

проверку эффективности устранения уязвимостей и подтверждение надёжности функционирования средств машинного обучения в условиях потенциальных угроз информационной безопасности.

На основании вышеизложенного можно сделать обоснованный вывод о том, что методика управления уязвимостями ИАС, включающих в свой состав средства машинного обучения СМО, представляет собой один из ключевых организационно-нормативных элементов в системе обеспечения ИБ организаций, использующих интеллектуальные технологии. В условиях усложнения архитектурных решений и увеличения степени автономности решений, основанных на МО, такая методика обеспечивает формализацию процессов выявления, анализа, устранения и контроля уязвимостей, возникающих как в программно-аппаратной инфраструктуре, так и в логике функционирования самих моделей. Без наличия специализированной методики не представляется возможным реализовать полноценное и эффективно масштабируемое управление уязвимостями, поскольку подразделения ИБ остаются без чётко определённых регламентов, разграничения ответственности и процедурного описания всех этапов работы с уязвимыми компонентами. Особенно критичным это становится при интеграции СМО, так как данные компоненты обладают рядом специфических характеристик.

С учётом того, что средства машинного обучения до настоящего времени остаются слабо охваченной областью в действующих нормативно-методических актах в сфере информационной безопасности, возникает объективная необходимость разработки и внедрения специализированного документа, регламентирующего управление их уязвимостями. Такой документ должен учитывать как архитектурные особенности СМО, так и характерные векторы атак, присущие системам с искусственным интеллектом, а также требования к мониторингу, оценке риска и обеспечению доверия к результатам обработки. Только при наличии целостной, формализованной и адаптированной методики возможно обеспечить надёжную защиту ИАС с элементами СМО от актуальных и перспективных киберугроз.

ЗАКЛЮЧЕНИЕ

Данное исследование, выполненное в рамках выпускной квалификационной работы, направлено на решение проблем, связанных с повышение защищенности ИАС, включающих в себя средства МО, за счет оценки и регулирования рисков.

В порядке разрешения выявленного противоречия между возрастающим темпом внедрения средств машинного обучения в коммерческий и государственный сектор Российской Федерации и отсутствием нормативно правовой базы, осуществляющей классификацию атак на машинное обучение, удалось провести глубокий анализ типовых архитектур средств машинного обучения и построить классификацию атак на средства машинного обучения, обладающую следующей новизной, практической ценностью и теоретической значимостью:

- впервые разработана комплексная классификация атак на средства машинного обучения, учитывающая направленность реализации инцидентов на объект воздействия (модель МО, программное обеспечение и инфраструктура), механизм реализации и последствия;

- сформированная комплексная классификация атак на средства машинного обучения позволяет структурировать процессы мониторинга и анализа инцидентов в ИАС, обеспечивает методологическую базу для создания специализированных средств защиты МО-компонентов, формирует основу для разработки отраслевых стандартов и нормативных документов, ориентированных на законодательство Российской Федерации;

- разработанная комплексная классификации атак на средства машинного обучения систематизирует и расширяет теоретические представления о спектре угроз безопасности для ИАС, включающих в себя МО, формализует таксономию атак с учетом особенностей архитектуры современных МО-систем, создает концептуальную основу для разработки новых моделей угроз в области ИИ-безопасности.

В порядке разрешения выявленного противоречия между необходимостью системного управления рисками в ИАС, включающих в себя СМО, и отсутствием

специализированной методики их оценки удалось разработать методическое обеспечение для формирования сценариев атак на средства машинного обучения и выработать методику риск-анализа, учитывающую специфику средств машинного обучения и обладающую следующей новизной, практической ценностью и теоретической значимостью:

- впервые построен граф множество сценариев атак на СМО, а также разработана методика оценки рисков для ИАС, включающих в себя СМО, учитывающая наличие эксплойтов у эксплуатируемых злоумышленником уязвимостей, что приближает количественную оценку рисков к истинным значениям;

- разработанная специализированная методика оценки рисков предоставляет инструментарий для комплексного аудита безопасности ИАС, позволяет автоматизировать процессы идентификации и каталогизации уязвимостей, формирует основу для создания систем поддержки принятия решений по управлению рисками;

- созданный узконаправленный инструментариий оценки рисков разрабатывает новые методологические подходы к формализации описания уязвимостей СМО, создает теоретическую модель многофакторной оценки рисков для ИАС, расширяет научные представления о механизмах управления рисками в условиях применения МО.

В порядке разрешения выявленного противоречия между потребностью в оперативном реагировании на инциденты в ИАС, включающих в себя СМО, и отсутствием методик и инструментов для своевременного выявления и устранения уязвимостей в системах МО спроектировано методическое обеспечение для управления уязвимостями информационных автоматизированных систем (ИАС), включающих в себя средства машинного обучения, обладающая следующей новизной, практической ценностью и теоретической значимостью:

- впервые предлагается методическое обеспечение для выявления и устранения уязвимостей в системах МО, включая политику управления уязвимостями СМО;

- разработанное методического обеспечения защиты СМО предоставляет готовые алгоритмы действий при выявлении уязвимостей, сокращает время

реагирования на инциденты безопасности, позволяет тиражировать лучшие практики защиты в различных отраслях Российской Федерации;

- сформированное методического обеспечения защиты МО-систем создает новые принципы построения систем защиты ИАС с МО-компонентами, развивает методологию оперативного реагирования на инциденты, формирует теоретические основы для разработки защитных механизмов нового поколения информационной безопасности.

Таким образом, представленное в выпускной квалификационной работе информационное и методическое обеспечение противодействия атакам на средства машинного обучения представляет собой прикладной инструмент, ориентированный на практическое применение в сфере обеспечения информационной безопасности СМО. Оно обладает потенциалом к интеграции в процессы формирования официальных нормативно-правовых актов, регламентов и методик, направленных на управление уязвимостями в системах, использующих технологии машинного обучения. Учитывая динамичное развитие данной области и появление новых векторов угроз, результаты проведённого исследования обладают высокой научной значимостью и могут служить основой для последующих научных изысканий. Дальнейшее развитие предложенных подходов в рамках научных работ позволит расширить теоретическую и прикладную базу в области безопасности СМО, что особенно актуально в условиях стремительного распространения СМО в ГИС и коммерческом секторе нашей страны.

СПИСОК ЛИТЕРАТУРЫ

1 Эпидемии в телекоммуникационных сетях / Остапенко [и др.]; [под ред. чл.–корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 1). – Текст: непосредственный.

2 Атакуемые взвешенные сети / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 2). – Текст: непосредственный.

3 Социальные сети и деструктивный контент / Остапенко [и др.]; [под ред. чл.–корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 3). – Текст: непосредственный.

4 Социальные сети и риск-мониторинг / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2019. – 284 с. (Серия «Теория сетевых войн»; вып. 4). – Текст: непосредственный.

5 Социальные сети и психологическая безопасность / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2020. – 284 с. (Серия «Теория сетевых войн»; вып. 5). – Текст: непосредственный.

6 Сетео-информационная эпидемиология / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2021. – 284 с. (Серия «Теория сетевых войн»; вып. 6). – Текст: непосредственный.

7 Картография защищаемого киберпространства / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2022. – 372 с. (Серия «Теория сетевых войн»; вып. 7). – Текст: непосредственный.

8 Организационно-правовая защита сетей / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2023. – 228 с. (Серия «Теория сетевых войн»; вып. 8). – Текст: непосредственный.

9 Автоматизированный атлас кибератак / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2025. – 188 с. (Серия «Теория сетевых войн»; вып. 9). – Текст: непосредственный.

10 2024 Информационно-аналитическая справка по результатам мониторинга внедрения решений в сфере искусственного интеллекта в приоритетных отраслях экономики Российской Федерации по итогам 1-го полугодия 2024 года, НЦРИИ. - Электрон. дан. - Режим доступа: https://ai.gov.ru/knowledgebase/vnedrenie-ii/2023_informacionno-analiticheskaya_spravka_po_rezulytatam_monitoringa_vnedreniya_resheniy_v_sfere_iskusstvennogo_intellekta_v_prioritetnyh_otraslyah_ekonomiki_rossiyskoy_federacii_po_itogam_2023_goda_ncrii/. - Текст: электронный.

11 Федеральная служба государственной статистики. - Электрон. дан. - Режим доступа: https://rosstat.gov.ru/. - Текст: электронный.

12 Результаты работы Группы Сбер по МСФО за 2024 год. - Электрон. дан. - Режим доступа: https://www.sberbank.com/ru/investor-relations/groupresults/results_of_work_on_ifrs_q42024#:~:text=%D0%A7%D0%B8%D1%81%D1%82%D0%B0%D1%8F%20%D0%BF%D1%80%D0%B8%D0%B1%D1%8B%D0%BB%D1%8C%20%D0%A1%D0%B1%D0%B5%D1%80%D0%B0%20%D0%B7%D0%B0%2012,%D0%BC%D0%B5%D0%B6%D0%B4%D1%83%D0%BD%D0%B0%D1%80%D0%BE%D0%B4%D0%BD%D1%8B%D0%BC%D0%B8%20%D1%81%D1%82%D0%B0%D0%BD%D0%B4%D0%B0%D1%80%D1%82%D0%B0%D0%BC%D0%B8%20%D1%84%D0%B8%D0%BD%D0%B0%D0%BD%D1%81%D0%BE%D0%B2%D0%BE%D0%B9%20%D0%BE%D1%82%D1%87%D0%B5%D1%82%D0%BD%D0%BE%D1%81%D1%82%D0%B8%20(%D0%9C%D0%A1%D0%A4%D0%9E). - Текст: электронный.

13 Актуальные киберугрозы: II квартал 2024 года. - Электрон. дан. - Режим доступа: https://www.ptsecurity.com/ru-ru/research/analytics/aktualnye-kiberugrozy-ii-kvartal-2024-goda/. - Текст: электронный.

14 Актуальные киберугрозы: III квартал 2024 года. - Электрон. дан. - Режим доступа: https://www.ptsecurity.com/ru-ru/research/analytics/aktualnye-kiberugrozy-iii-kvartal-2024-goda/. - Текст: электронный.

15 Group-IB. - Электрон. дан. - Режим доступа: https://www.group-ib.com/products/business-email-protection/?etext=2202.FUlgG2dE4-

148TUl6VouTMHFEsl4BnDp6Q7GDz_0QErrhopd1xEIo9WXZ5an5P-Fandpb2pud3RveWtiYnJwYg.898f49a3780b4c08db9a1d00a6e4af896d41c806. - Текст: электронный.

16 Указ Президента РФ от 5 декабря 2016 г. № 646 «Об Утверждении Доктрины информационной безопасности Российской Федерации». - Электрон. дан. - Режим доступа: https://base.garant.ru/71556224/. - Текст: электронный.

17 Приказ ФСТЭК России № 21 от 14.03.2013. - Электрон. дан. - Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/prikazy/prikaz-fstek-rossii-ot-18-fevralya-2013-g-n-21. - Текст: электронный.

18 Указ Президента РФ № 124 от 15.02.2024 "О развитии искусственного интеллекта в Российской Федерации". - Электрон. дан. - Режим доступа: http://www.kremlin.ru/acts/bank/50326. - Текст: электронный.

19 Национальная стратегия развития ИИ на период до 2030 года утверждена Указом Президента РФ от 10.10.2019 №490. - Электрон. дан. - Режим доступа: http://www.kremlin.ru/acts/bank/44731. - Текст: электронный.

20 MITRE ATLAS. - Электрон. дан. - Режим доступа: https://atlas.mitre.org/. - Текст: электронный.

21 NIST NVD. - Электрон. дан. - Режим доступа: https://nvd.nist.gov/. - Текст: электронный.

22 БДУ ФСТЭК. Электрон. дан. - Режим доступа: https://bdu.fstec.ru/threat. - Текст: электронный.

23 Приостановка спонсирования NVD, анализ экспертов. - Электрон. дан. - Режим доступа: https://www.securitylab.ru/analytics/558492.php. - Текст: электронный

24 Остапенко Г.А. Совершенствование организационно-правового обеспечения информационной безопасности предприятия: формирование риск-ландшафта сетевых атак / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Ю. Пекло // Информация и безопасность. 2023. - Т. 26. Вып. 2. - С. 203-210. – Текст: непосредственный.

25 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения

безопасности организации (часть I) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.С. Кривошеин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 329-340. – Текст: непосредственный.

26 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть II) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 329-340. – Текст: непосредственный.

27 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть III) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 341-358. – Текст: непосредственный.

28 Остапенко А.Г. Проектная деятельность: научно-методическое развитие в направлении внедрения средств искусственного интеллекта для обеспечения организационно-правовой защиты корпоративных сетей / А.Г. Остапенко, Д.В. Щербакова, А.А. Остапенко, Д.А. Нархов // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 447-454. – Текст: непосредственный.

29 Остапенко Г.А. Нейросетевые задачи и компетенции проектной деятельности по созданию защищённых автоматизированных информационных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность. 2023. - Т. 26. Вып. 4. - С. 579-586. – Текст: непосредственный.

30 Остапенко Г.А. Методики регламентации обеспечения информационной безопасности атакуемых автоматизированных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность.2023. - Т.26.Вып. 4.- С.597-602. – Текст: непосредственный.

31 Пекло А.Ю. Атаки типа "сетевая разведка": риск-ландшафт и частная политика информационной безопасности предприятия / А.Ю. Пекло, Г.А. Остапенко, Д.В. Щербакова, А.А. Остапенко // Информация и безопасность. 2023. - Т. 26. Вып. 2. - С. 235-246. – Текст: непосредственный.

32 Остапенко А.Г. Направление совершенствования нормативно-правового обеспечения объектов информатизации на основе риск-анализа их кибербезопасности/ А.Г. Остапенко, Д.В. Щербакова, Д.А. Нархов, Ю.В. Макаров, А.С. Кривошеин // Информация и безопасность.2022. - Т.25.Вып. 4. - С.593-598. – Текст: непосредственный.

33 Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 231-238. – Текст: непосредственный.

34 Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам/ Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 239-246. – Текст: непосредственный.

35 Остапенко Г.А. Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей/ Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Н.Н. Корвяков [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 219-230. – Текст: непосредственный.

36 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. - Т. 27. Вып. 1. - С. 7-30. – Текст: непосредственный.

37 Хромых С.А. Сетевые атаки на уровне приложений: риск-ландшафт и частная политика информационной безопасности предприятия / С.А. Хромых, Г.А. Остапенко, Д.В. Щербакова, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. Вып. 2. С. 261-276. – Текст: непосредственный.

38 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 31-54. – Текст: непосредственный.

39 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 319-336. – Текст: непосредственный.

40 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, Д.С. Печкин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 337-378. – Текст: непосредственный.

41 Остапенко Г.А. Использование средств искусственного интеллекта в ходе исследовательского и учебного процессов при подготовке специалистов по защите информации / Г.А. Остапенко, А.О. Калашников, А.Г. Остапенко, Е.А. Москалева, Д.О. Карпеев, О.В. Поздышева, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 389-400. – Текст: непосредственный.

42 Остапенко А.А. Методики и алгоритмы риск-анализа успешности реализации массированных кибератак / А.А. Остапенко // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 401-420. – Текст: непосредственный.

42 Остапенко А.Г. Картографирование киберпространства и защита информации / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. С. 89-106.

43 Остапенко А.Г. Картографирование киберпространства и обеспечение информационной безопасности / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. С. 115-128. – Текст: непосредственный.

44 Остапенко Г.А. Матричная формализация целеполагания и результативности проектной деятельности в сфере защиты информации и информационной безопасности / Г.А. Остапенко, В.И. Белоножкин, Н.И. Баранников, А.А. Остапенко, А.Г. Краснобородкин, Т.Ю. Мирошниченко // Информация и безопасность. 2022. Т. 25. Вып. 4. С. 475-484. – Текст: непосредственный.

45 Смирнов В.В. Кибератаки вида "анализ целевого объекта": риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / В.В. Смирнов, А.П.

Васильченко, А.А. Остапенко, А.В. Гречишкин, С.С. Куликов, Д.Н. Рахманин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 273-284. – Текст: непосредственный.

46 Жидков Э.И. Кибератаки вида "социальная инженерия": риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / Э.И. Жидков, А.П. Васильченко, А.А. Остапенко, А.С. Кольцов, Е.А. Шварцкопф, А.С. Щеголеватых // Информация и безопасность. 2024. Т. 27. No 2. С. 285-298.

47 Сердечный А.Л. Риск-анализ и прогнозирование частоты и ущербности компьютерных атак / А.Л. Сердечный, А.С. Маликова, А.Г. Остапенко, М.Е. Волкова, Д.А. Нархов, А.Н. Бартенев. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 159-178. – Текст: непосредственный.

48 Архипова К.В. Автоматизированная информационная система моделирования эпидемических процессов, порожденных саморазмножающимися и мутирующими вредоносами / К.В. Архипова, А.А. Остапенко, В.В. Сафронова, В.Ю. Остапенко, Ю.Г. Пастернак // Информация и безопасность. 2022. Т. 25. No 3. С. 349-366. – Текст: непосредственный.

49 Остапенко Г.А. Киберполигон как проект управления информационными рисками / Г.А. Остапенко, В.И. Белоножкин, А.А. Остапенко, М.Е. Волкова // Информация и безопасность. 2023. Т. 26. No 1. С. 9-16. – Текст: непосредственный.

50 Остапенко Г.А. Разработка архитектуры киберполигона для повышения качества и результативности учебного процесса в исследовании атак на информационные системы и сети / Г.А. Остапенко, С.С. Куликов, А.В. Коноплин, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. No 1. С. 101-108. – Текст: непосредственный.

51 Остапенко А.Г. Методические основы проектной деятельности при выполнении научно-исследовательской работы студентами специалитета в сфере обеспечения информационной безопасности / А.Г. Остапенко, А.С. Пахомова, Д.А. Нархов, А.А. Остапенко, А.И. Шеншин // Информация и безопасность. 2023. Т. 26. No 2. С. 169-176. – Текст: непосредственный.

52 Остапенко А.Г. Научно-технические результаты и перспективы реализации проекта "безопасный интернет" / А.Г. Остапенко, И.А. Боков, А.А. Остапенко, Н.М. Лантюхов, Т.Ю. Мирошниченко, С.В. Лихобабин, С.Д. Трубицын // Информация и безопасность. 2021. Т. 24. No 2. С. 287-296. – Текст: непосредственный.

53 Сердечный А.Л. Метод информационно-картографического анализа активности группировок хактивистов / А.Л. Сердечный, А.Г. Остапенко // Информация и безопасность. 2023. Т. 26. No 4. С. 587-596. – Текст: непосредственный.

54 Остапенко А.Г. Сетевая вирусология: прогнозирование развития двувирусных эпидемических процессов в сетях. / А.Г. Остапенко, Е.В. Зарочинцев, .А. Остапенко, К.В. Сибирко, В.В. Сафронова, П.Д. Федоров. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 203-222. – Текст: непосредственный.

55 Остапенко А.Г. Картографические модели процессов диффузии вредоносов в сетевом киберпространстве. / А.Г. Остапенко, А.Л. Сердечный, А.А. Остапенко, С.С. Куликов. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 281-286. – Текст: непосредственный.

56 Остапенко А.Г. Научно-технические результаты и перспективы реализации проекта «Безопасный интернет». / А.Г. Остапенко, И.А. Боков, А.А. Остапенко, Н.М. Лантюхов, Т.Ю. Мирошниченко, С.В. Лихобабин, С.Д. Трубицын. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 287-296. – Текст: непосредственный.

57 Кобцев О.Е. Сетевые атаки компьютерными вирусами: риск-ландшафт / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, В.Г. Юрасов, Д.С. Печкин // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 55-66. – Текст: непосредственный.

58 Кобцев О.Е. Сетевые атаки компьютерными вирусами: частная политика и регламенты информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, Ю.Г. Пастернак, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 67-80. – Текст: непосредственный.

59 Кобцев О.Е. Сетевые атаки компьютерными вирусами: частные инструкции информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, В.И.

Белоножкин, К.А. Разинкин, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 81-90. – Текст: непосредственный.

60 How to Write an SRS Document (Software Requirements Specification Document). Электрон. дан. - Режим доступа: https://www.perforce.com/blog/alm/how-write-software-requirements-specification-srs-document. - Текст: электронный.

61 Методы DevOps в разработке программного обеспечения. Электрон. дан. - Режим доступа: https://efsol.ru/promo/devops-methods/. - Текст: электронный.

62 CI/CD. Электрон. дан. - Режим доступа: https://blog.skillfactory.ru/glossary/ci-cd/. - Текст: электронный.

63 Метрики качества работы моделей машинного обучения: как их понимать и использовать. Электрон. дан. - Режим доступа: https://webiomed.ru/blog/metriki-kachestva-raboty-modelei/. - Текст: электронный.

64 Blue-Green и Canary деплойменты в микросервисах. Электрон. дан. - Режим доступа: https://habr.com/en/companies/otus/articles/754422/. - Текст: электронный.

65 MTBF, MTTR, MTTA и MTTF. Электрон. дан. - Режим доступа: https://www.atlassian.com/ru/incident-management/kpis/common-metrics. - Текст: электронный.

66 Приказ Федеральной службы по техническому и экспортному контролю от 11 апреля 2025 года № 117 «Об утверждении Требований о защите информации, содержащейся в государственных информационных системах, иных информационных системах государственных органов, государственных унитарных предприятий, государственных учреждений». Электрон. дан. - Режим доступа: http://publication.pravo.gov.ru/document/0001202506170011. - Текст: электронный.

67 OWASP Top 10 Major Language Models. Электрон. дан. - Режим доступа: https://owasp.org/www-project-top-10-for-large-language-model-applications/. Электрон. дан. - Текст: электронный.

68 AI Incident Database. Электрон. дан. - Режим доступа: https://incidentdatabase.ai/. - Текст: электронный.

69 AVID. Электрон. дан. - Режим доступа: https://www.avid.com/. - Текст: электронный.

70 CNNVD. Электрон. дан. - Режим доступа: https://www.cnnvd.org.cn/. - Текст: электронный.

71 CISA KEV. Электрон. дан. - Режим доступа: https://www.cisa.gov/known-exploited-vulnerabilities-catalog/. - Текст: электронный.

72 Сбер Модель угроз. Электрон. дан. - Режим доступа: https://www.sberbank.ru/ru/person/kibrary/experts/new_metodicheskie-materialy-kiberbezopasnosti-opyt-sbera_1744705783601. - Текст: электронный.

73 CVSS 3.1. Электрон. дан. - ежим доступа: https://bdu.fstec.ru/calc31. - Текст: электронный.

74 CVSS 4.0. Электрон. дан. - Режим доступа: https://www.first.org/cvss/v4-0/. Текст: электронный.

75 EPSS. Электрон. дан. - Режим доступа: https://www.first.org/epss/. - Текст: электронный.

76 AIVSS. Электрон. дан. - Режим доступа: https://vineethsai.github.io/aivss/. - Текст: электронный.

77 Методический документ "Руководство по организации процесса управления уязвимостями в органе (организации)". Электрон. дан. - Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/spetsialnye-normativnye-dokumenty/metodicheskij-dokument-ot-17-maya-2023-g. - Текст: электронный.

78 OVALdb. Электрон. дан. - Режим доступа: https://www.altx-soft.ru/ovaldb/. - Текст: электронный.

ПРИЛОЖЕНИЕ А

Таблица А1. Базовые и компенсирующие меры для наиболее критичного сценария группы №2

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
TA0004: Первоначальный доступ	T0049: Недостатки в общедоступных приложениях	CVE-2023-39660	- Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга (сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. - Внедрение регламента тестирование обновлений программного обеспечения.	Обновить Gaberiele Venturi pandasai v.0.8.0 до актуальной версии. Установка обновления должна происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	- Внедрение политики идентификации и аутентификации, которая регулирует аспекты: обязательного присвоения учётной записи пользователю организации; смена учётных данных в случае выявления факта их компрометации. - Утверждение парольной политики, включающей в себя: определение ответственных лиц за исполнение политики; положение об использовании паролей; требования к обеспечению парольной защиты учетных записей; порядок применения временных паролей. - Политика сетевой сегментации и доступа по «белым спискам» IP + запрет доступа из внешнего Интернета. - Организация DMZ для публичного веб-сервиса pandas-ai. - Ограничение доступа недоверенных	- Использование межсетевого экрана уровня приложений (WAF) для фильтрации HTTP/HTTPS-трафика. - Использование IDS/IPS для обнаружения и предотвращения попыток эксплуатации уязвимости; - Ограничение доступа по «белым спискам» IP-адресов / сегментирование сети. - Запуск библиотеки в изолированной программной среде (контейнер, песочница). - Ограничение запуска уязвимого ПО пользователями с высокими привилегиями. - Ограничение возможности выполнения системных вызовов «недоверенной» программой. - Ограничение возможности записи в директорию с установленными пакетами. - Использование средств контроля целостности для отслеживания изменений конфигурации и пакетов. - Использование SIEM-систем для централизованного мониторинга попыток эксплуатации.

Продолжение таблицы А1

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
ТА0004: Первоначальный доступ	Т0049: Недостатки в общедоступных приложениях	CVE-2023-39660			пользователей с помощью белых/чёрных списков.	- Использование замкнутой программы среды для работы с файлами (вводом) из подозрительных источников.
ТА0001: Постановка атаки на модель МО	Т0042: Подтверждение эффективности атаки	CVE-2025-3121	- Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга (сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. - Установление процедуры еженедельного мониторинга наличия обновлений и установки безопасных и актуальных версий программного обеспечения. - Внедрение регламента тестирование обновлений программного обеспечения.	Обновить фреймворк машинного обучения PyTorch до актуальной версии 2.7.1. Установка обновления должна происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	- Внедрение политики идентификации и аутентификации, которая регулирует аспекты: обязательного присвоения учётной записи пользователю организации; смена учётных данных в случае выявления факта их компрометации. - Политика ограниченного доступа к средствам исполнения компонентов МО. - Процедура доверенной подготовки и загрузки моделей МО. - Регламент мониторинга и реагирования на попытки запуска неавторизованных JIT-моделей. - Регламент действий при локальном инциденте, в том числе раздел, касающийся компрометации памяти. - Внедрение политики безопасной разработки продуктов. - Использование процедуры изоляции вычислительных сред СМО с уязвимыми компонентами.	- Ограничение возможности запуска уязвимого ПО пользователями с высокими привилегиями. - Ограничение возможности выполнения системных вызовов «недоверенной» программой. - Использование средств контроля целостности для отслеживания изменений конфигурации системы. - Использование систем обнаружения и предотвращения вторжений (IDS/IPS) для отслеживания паттернов подозрительной сетевой активности. - Ограничение возможности подключения сторонних внешних съёмных носителей информации путем настройки правил СЗИ; - Использование замкнутой программной среды (песочницы) для запуска компонентов, использующих небезопасные вызовы JIT-интерпретатора. - Настройка антивирусного программного обеспечения для сканирования загружаемых FlatBuffer-файлов;

Продолжение таблицы А1

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
ТА0001: Постановка атаки на модель МО	Т0042: Подтверждение эффективности атаки	CVE-2025-3121				- Ограничение прав доступа СЗИ к директории с установленным ПО, путем настройки мандатного доступа. - Сегментирование сети и изоляция узлов, выполняющих уязвимые компоненты МО.
ТА0007: Предотвращение обнаружения, Воздействие	Т0015: Обход модели МО	CVE-2024-2928	- Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга (сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. - Установление процедуры еженедельного мониторинга наличия обновлений и установки безопасных и актуальных версий программного обеспечения. - Внедрение регламента тестирование обновлений программного обеспечения.	Обновить платформу управления жизненным циклом машинного обучения Mlflow до актуальной версии 3.1.0. Установка обновления должна происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	- Регламент по ограничению доступа к уязвимым компонентам из внешних сетей, в случае возникновения инцидента. - Инструкция по проверке и ограничению разрешений файловой системы на рабочих узлах СМО. - Методика валидации входных параметров URI при развертывании моделей МО. - Использование процедуры изоляции компонентов СМО с уязвимостями. - Политика безопасной настройки и эксплуатации платформ МО с веб-интерфейсом. - Ограничение доступа к уязвимому программному обеспечению с применением «белых списков» IP-адресов. - Ограничение доступа к платформе из внешних сетей (Интернет).	- Настройка межсетевого экрана уровня приложений (WAF) для фильтрации HTTP/HTTPS-запросов; - Сегментирование сети для ограничения доступа к уязвимому ПО из других подсетей. - Использование SIEM-систем для отслеживания попыток эксплуатации уязвимости. - Использование систем обнаружения и предотвращения вторжений (IDS/IPS). - Ограничение возможности обработки уязвимым ПО запросов, содержащих вредоносные заголовки. - Использование антивирусного ПО с функцией контроля веб-ресурсов. - Настройка «замкнутой программной среды» к продуктам, над которыми ведется активная разработка и тестирование функционала. - Ограничение прав файловой системы и прав пользователей mlflow-сервиса.

Таблица А2. Меры противодействия для наиболее критичного сценария атаки из группы №2 по техникам

Тактика	Техника	Меры реагирования	Меры ликвидации последствий	Превентивные меры
TA0004: Первоначальный доступ	T0049: Недостатки в общедоступных приложениях	1)Настройка IDS/IPS для обнаружения обращений к известным уязвимым ресурсам, либо аномальных HTTP-паттернов. 2) Использование межсетевого экрана уровня приложений для автоматической блокировки IP-источников с признаками атакующего поведения. 3) Изоляция уязвимого узла путем переключения на VLAN, временного отключения общедоступного интерфейса и перехода в режим только для чтения. 4) Уведомление должностных лиц, ответственных за информационную безопасность СМО, запись инцидента в журнал SIEM-системы.	1) Проведение технического анализа серверов, на которых расположены уязвимые компоненты СМО, включая дампы сетевых пакетов, хешей и контрольные суммы файлов, системные логи, состояние учетных записей пользователей. 2) Обновление данных аутентификации и авторизации (токены API, пароли, сертификаты), использовавшихся в публичных интерфейсах модели. 3) Установка обновлений или вывод из эксплуатации уязвимого ПО и библиотек, включая устаревшие зависимости. 4) Пересоздание виртуальной машины, контейнера или среды на основе проверенной резервной копии.	1) Разделение публичных и внутренних сервисов СМО с помощью DMZ, сегментирования и межсетевого экранирования. 2) Проведение регулярного мониторинга новых уязвимостей используемых СМО из проверенных баз уязвимостей: бюллетени вендоров, НКЦКИ, БДУ ФСТЭК, OVALdb, NVD, CNNVD, с последующим сканированием и устранением уязвимостей. 3) Ограничение сетевого доступа по IP географическим признакам (геофильтрация) к компонентам МО, имеющим внешние интерфейсы. 4) Обязательная аутентификация и авторизация доступа к интерфейсам сервисов МО, включая API-интерфейсы, консоли моделей и оркестрационные панели. 5) Внедрение процедуры управления обновлениями программного обеспечения, библиотек, фреймворков, с периодичностью не менее одного раза в неделю.
TA0001: Постановка атаки на модель МО	T0042: Подтверждение эффективности атаки	1) Настройка средств обнаружения и предотвращения вторжений (IDS/IPS) на уровне API-запросов (например, искажение входных данных, идентичные последовательные запросы, перебор паролей). 2) Ведение журнала всех входных параметров и метаданных вызовов моделей, включая IP, токен,	1) Замена поврежденной версии модели с последующим обновлением параметров, архитектуры или структуры входных данных. 2) Обновление данных аутентификации и авторизации (токены API, пароли, сертификаты), использовавшихся в публичных интерфейсах модели.	1) Ограничение доступа к API инференса модели с обязательной аутентификацией, авторизацией и контролем частоты запросов. 2) Скрытие архитектурных и поведенческих характеристик модели в ответах API. 3) Регламентированный доступ к весам модели и обучающим выборкам (включая запрет на экспорт из производственной среды без

Продолжение таблицы А2

Тактика	Техника	Меры реагирования	Меры ликвидации последствий	Превентивные меры
		геолокацию, заголовки, время отклика и тип ответа. 3) Сигнатурный и поведенческий анализ запросов с использованием SIEM-системы с возможностью мгновенного уведомления о превышении пороговых значений (по количеству, структуре или отклонению от нормы). 4) Временная блокировка или запрет ответов API в случае подозрительной активности (например, отказа в выдаче логинов).	3) Создание отчета об инциденте, который включает проверку источника атаки, последовательность действий, оценку ущерба и предложения по корректировке модели угроз. 4) Расширение ограничений и обновление правил обнаружения вредоносных запросов в IDS IPS. 5) Реализация режима работы API после атаки (например, временное отключение вывода вероятности, возврат "обобщенного" ответа).	разрешения отдела информационной безопасности). 4) Внедрение механизма отпечатков запросов (дактилоскопия запроса) с целью идентификации подозрительных запросов, содержащих признаки несогласованного тестирования модели
TA0007: Предотвращение обнаружения, Воздействие	T0015: Обход модели МО	1) Интеграция правил поведенческого анализа в систему мониторинга SIEM, которые фиксируют нестандартную активность модели: массовые ошибки классификации, неожиданное распределение ответов. 2) Реализация механизма уведомления при получении входных данных, характеризующихся высокой степенью отклонения от обучающего распределения (системы мониторинга МО-инференса). 3) Использование средств оркестрации для временного ограничение доступа к модели из внешних интерфейсов до завершения анализа и доработки.	1) Повторное обучение или переподготовка модели на основе расширенного тренировочного набора, включающего фиксированные примеры атак. 2) Проверка СЗИ целостности компонентов логического вывода сверка с эталонными хэш-суммами и цифровыми подписями. 3) Обновление правил в DLP, WAF и IDS/IPS на основании выявленного паттерна обхода. 4) Документирование SIEM-системой инцидента обхода, анализ его сценария, и корректировка системы реагирования. 5) Использование межсетевого экрана (WAF) или VPN для временного ограничения доступа к модели из внешних интерфейсов до завершения устранения инцидента.	1) Ограничение доступа к API логического вывода и журналам принятия решений модели с реализацией минимизации утечки информации о внутренних механизмах RBAC. 2) Использование детекторов аномалий и проверка нетипичных характеристик входных данных перед их вводом в модель. 3) Применение процедуры нормализации, фильтрации и проверки правильности входных данных (конвейер предварительной обработки входных данных) перед вводом в модель. Преобразование входных данных в согласованный формат.

Таблица А3. Базовые и компенсирующие меры для наиболее критичного сценария группы №3

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
ТА0004: Первоначальный доступ	Т0002: Получение артефактов МО	CVE-2023-3765	- Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга (сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. - Установление процедуры еженедельного мониторинга наличия обновлений и установки безопасных и актуальных версий программного обеспечения. - Внедрение регламента тестирование обновлений программного обеспечения.	Обновить MLflow Prior до актуальной версии 3.1.0. Установка обновления должна происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	- Политика ограничения публикации уязвимых компонентов СМО в открытых сетях. - Процедура анализа входных параметров и URI-путей в web-приложениях МО. - Регламент контроля обращений к URI и структуре пути в web-интерфейсах платформ машинного обучения. - Политика безопасной настройки и эксплуатации платформ МО с веб-интерфейсом.	- Использование межсетевого экрана уровня приложений (WAF) для фильтрации HTTP/HTTPS-трафика, фильтрации пользовательских запросов. - Ограничение доступа из внешних сетей (Интернет). - Ограничение доступа к уязвимому ПО с использованием схемы доступа по «белым спискам. - Сегментирование сети для ограничения доступа к уязвимому компоненту из других подсетей; - Использование систем обнаружения и предотвращения вторжений (IDS/IPS). - Использование SIEM-систем для отслеживания попыток эксплуатации уязвимости. - Использование замкнутой программной среды для работы с файлами, полученными из недоверенных источников. - Ограничение возможности записи в директорию с установленными пакетами. - Настройка списка контроля доступа (ACL) к директориям установки ПО.
ТА0007: Предотвращение	Т0015: Обход модели МО	CVE-2024-2928	- Внедрение политики управления уязвимостями, включающей в себя этапы	Обновить платформу управления жизненным циклом машинного	- Регламент по ограничению доступа к уязвимым компонентам из внешних	- Использование межсетевого экрана уровня приложений

Продолжение таблицы А3

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
обнаружения, Воздействие			мониторинга (сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. - Установление процедуры еженедельного мониторинга наличия обновлений и установки безопасных и актуальных версий программного обеспечения. - Внедрение регламента тестирование обновлений программного обеспечения.	обучения Mlflow до актуальной версии 3.1.0. Установка обновления должна происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	сетей, в случае возникновения инцидента. - Инструкция по проверке и ограничению разрешений файловой системы на рабочих узлах СМО. - Методика валидации входных параметров URI при развертывании моделей МО. - Использование процедуры изоляции компонентов СМО с уязвимостями. - Политика безопасной настройки и эксплуатации платформ МО с веб-интерфейсом. - Ограничение доступа к уязвимому программному обеспечению с применением «белых списков» IP-адресов.	(WAF) для фильтрации HTTP/HTTPS-запросов. - Сегментирование сети для ограничения доступа к уязвимому ПО из других подсетей. - Использование SIEM-систем для отслеживания попыток эксплуатации уязвимости. - Использование систем обнаружения и предотвращения вторжений (IDS/IPS). - Ограничение доступа к платформе из внешних сетей (Интернет). - Ограничение возможности обработки уязвимым ПО запросов, содержащих вредоносные заголовки (например, x-middleware-subrequest). - Использование антивирусного ПО с функцией контроля веб-ресурсов; - Использование «замкнутой программной среды» при развертывании новых компонентов МО. - Ограничение прав файловой системы и прав пользователей mlflow-сервиса.
TA0001: Постановка атаки на модель МО	T0042: Подтверждение эффективности атаки	CVE-2025-3121	Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга	Обновить фреймворк машинного обучения PyTorch до актуальной версии 2.7.1. Установка обновления должна	- Внедрение политики идентификации и аутентификации, которая регулирует аспекты	- Ограничение возможности запуска уязвимого программного обеспечения пользователями с высокими привилегиями; - Ограничение возможности

Продолжение таблицы А3

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
ТА0001: Постановка атаки на модель МО	Т0042: Подтверждение эффективности атаки	CVE-2025-3121	(сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. Установление процедуры еженедельного мониторинга наличия обновлений и установки безопасных и актуальных версий программного обеспечения. Внедрение регламента тестирование обновлений программного обеспечения.	происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	обязательного присвоения учётной записи пользователю организации. - Смена учётных данных в случае выявления факта их компрометации. - Политика ограниченного доступа к средствам исполнения компонентов МО. - Процедура доверенной подготовки и загрузки моделей МО. - Регламент мониторинга и реагирования на попытки запуска неавторизованных JIT-моделей. - Регламент действий при локальном инциденте, в том числе раздел, касающийся компрометации памяти. - Внедрение политики безопасной разработки продуктов. - Использование процедуры изоляции вычислительных сред СМО с уязвимыми компонентами.	выполнения системных вызовов программой, установленной из неподтвержденных источников. - Использование средств контроля целостности для отслеживания изменений конфигурации системы. - Использование систем обнаружения и предотвращения вторжений (IDS/IPS). - Ограничение возможности подключения недоверенных внешних съёмных носителей информации. - Использование замкнутой программной среды для запуска компонентов, использующих небезопасные вызовы JIT-интерпретатора. - Использование антивирусного ПО для проверки загружаемых файлов. - Ограничение прав доступа к директории с установленным ПО. - Сегментирование сети и изоляция узлов, выполняющих уязвимые компоненты МО. - Использование SIEM-систем для отслеживания попыток выполнения подозрительных операций в рамках компонент.

Таблица А4. Базовые и компенсирующие меры для наиболее критичного сценария группы №7

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
TA0003: Подготовка ресурсов	T0002.000: Получение артефактов МО: Наборы данных	CVE-2022-41910	- Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга (сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. - Установление процедуры еженедельного мониторинга наличия обновлений и установки безопасных и актуальных версий программного обеспечения (Руководство по мониторингу ведений об уязвимостях); - Внедрение методики тестирования обновления программного обеспечения. - Создание и внедрение руководства по устранению уязвимостей (включая уязвимости СМО).	Обновить библиотеку машинного обучения TensorFlow до актуальной версии 2.19.0. Установка обновления должна происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	- Организация DMZ для публичного веб-сервиса. - Процедура анализа входных параметров и URI-путей в web-приложениях МО. - Методика валидации входных параметров URI при развертывании моделей МО.	- Ограничение возможности запуска уязвимого программного обеспечения пользователями с высокими привилегиями. - Использование замкнутой программной среды для работы с файлами, полученными из компрометирующих источников. - Ограничение возможности выполнения системных вызовов «неизвестной» программой. - Использование систем обнаружения и предотвращения вторжений (IDS/IPS). - Использование средств контроля целостности для отслеживания изменений конфигурации системы. - Ограничение доступа к директории с установленными пакетами TensorFlow. - Сегментирование сети для ограничения доступа к уязвимому ПО из других подсетей. - Использование антивирусного программного обеспечения для проверки библиотек и скриптов TensorFlow на предмет наличия ВПО. - Ограничение возможности записи в директорию с установленными пакетами.
TA0000: Доступ к модели	T0040: Доступ к API модели МО	CVE-2025-27776	- Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга	Обновить инструмент Applio для преобразования голоса до версии 3.2.7 и выше.	- Регламент обработки подозрительных URL-параметров и заголовков в МО-интерфейсах;	- Использование межсетевого экрана уровня приложений (WAF) для

Продолжение таблицы А4

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
машинного обучения			(сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. - Установление процедуры еженедельного мониторинга наличия обновлений и установки безопасных и актуальных версий программного обеспечения (Руководство по мониторингу ведений об уязвимостях); - Внедрение методики тестирования обновления программного обеспечения. - Создание и внедрение руководства по устранению уязвимостей (включая уязвимости СМО).	Установка обновления должна происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	- Инструкция по контролю записей и файлов, создаваемых в процессе инференса и загрузки моделей. - Методика обработки и отклонения подозрительных загрузок моделей на основании сигнатур и структуры.	фильтрации HTTP/HTTPS-трафика. - Ограничение доступа из внешних сетей к интерфейсам, задействованным в загрузке моделей. - Фильтрация заголовков и тела запросов с подозрительными параметрами. - Сегментирование сети и запрет взаимодействия уязвимого компонента с внутренними ресурсами (например, базами данных, API, хранилищами моделей). - Использование систем обнаружения и предотвращения вторжений (IDS/IPS) для блокировки подозрительных сетевых вызовов. - Настройка ACL на директории хранения моделей и временных файлов.
TA0001: Постановка атаки на модель МО	T0005.001: Создание прокси-модели машинного обучения: Обучение прокси-модели с помощью репликации	CVE-2020-15203	- Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга (сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. - Установление процедуры еженедельного мониторинга наличия обновлений и установки	Обновить библиотеку машинного обучения TensorFlow до актуальной версии 2.19.0. Установка обновления должна происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	- Внедрение политики идентификации и аутентификации, которая регулирует аспекты: обязательного присвоения учётной записи пользователю организации; смена учётных данных в случае выявления факта их компрометации. - Политика ограниченного доступа к средствам исполнения компонентов МО.	- Изоляция компонентов TensorFlow в замкнутой среде исполнения (sandbox, контейнер). - Ограничение возможности обработки непроверенных входных данных, передаваемых в API TensorFlow. - Фильтрация входных параметров на уровне промежуточного API или сетевого шлюза. - Контроль целостности СЗИ компонентов TensorFlow и

Продолжение таблицы А4

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
ТА0001: Постановка атаки на модель МО	Т0005.001: Создание прокси-модели машинного обучения: Обучение прокси-модели с помощью репликации	CVE-2020-15203	безопасных и актуальных версий программного обеспечения (Руководство по мониторингу ведений об уязвимостях); - Внедрение методики тестирования обновления программного обеспечения. - Создание и внедрение руководства по устранению уязвимостей (включая уязвимости СМО).		- Процедура доверенной подготовки и загрузки моделей МО.	пользовательских скриптов через хеш-суммы и цифровые подписи. - Ограничение доступа к сервисам, использующим уязвимую версию TensorFlow, на уровне сетевого сегмента (VLAN, firewall).
ТА0011: Воздей-ствие	Т0015: Обход модели МО	CVE-2024-2928	- Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга (сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. - Установление процедуры еженедельного мониторинга наличия обновлений и установки безопасных и актуальных версий программного обеспечения. - Внедрение регламента тестирование обновлений программного обеспечения.	Обновить платформу управления жизненным циклом машинного обучения Mlflow до актуальной версии 3.1.0. Установка обновления должна происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	- Ограничение доступа из внешних сетей (Интернет). - Ограничение доступа к платформе по «белым спискам» IP-адресов. - Внедрение политики идентификации и аутентификации, которая регулирует аспекты: обязательного присвоения учётной записи пользователю организации; смена учётных данных в случае выявления факта их компрометации.	- Использование WAF для фильтрации HTTP/HTTPS-трафика (блокировка URL, содержащих, нестандартные пути, абсолютные ссылки). - Настройка IDS/IPS для реагирования на попытки обхода каталогов. - Сегментирование сети для изоляции уязвимого ПО (mlflow размещается в сегменте без доступа к чувствительным хостам, например, без доступа к локальной файловой системе хоста). - Ограничение прав доступа к файловой системе (ACL) для веб-интерфейсов (исключение доступа к критичным путям (/etc, /home, /root, /var/lib/mlflow) при запуске веб-сервиса).

Продолжение таблицы А4

Тактика	Техника	Уязвимость	Базовые меры		Компенсирующие меры	
			Организационно-правовые	Технические	Организационно-правовые	Технические
ТА0011: Воздей-ствие	Т0031: Нарушение целостности модели МО	CVE-2024-25723	- Внедрение политики управления уязвимостями, включающей в себя этапы мониторинга (сканирования) и оценки уязвимостей, устранения уязвимостей, назначение ответственных должностных лиц. - Установление процедуры еженедельного мониторинга наличия обновлений и установки безопасных и актуальных версий программного обеспечения. - Внедрение регламента тестирование обновлений программного обеспечения.	Обновить ZenML Server в пакете машинного обучения ZenML до актуальной версии 0.46.7. Установка обновления должна происходить только из доверенных источников и лишь после оценки всех сопутствующих рисков.	- Ограничение привилегий учетной записи по умолчанию и деактивация неиспользуемых учетных записей. - Управление доступом на уровне URL с разделением административного и пользовательского API. - Настройка политики блокировки за превышение количества вызовов API.	- Ограничение доступа к API только из доверенных источников с применением фильтрации IP или сегментации сети. - Фильтрация всех входящих запросов REST на уровне шлюза WAF/API. - Использование систем IDS/IPS для обнаружения нетипичных запросов REST на активацию пользователя. - Изоляция сервиса ZenML в отдельной виртуализированной или контейнерной среде, при тестовом разворачивании в системе.